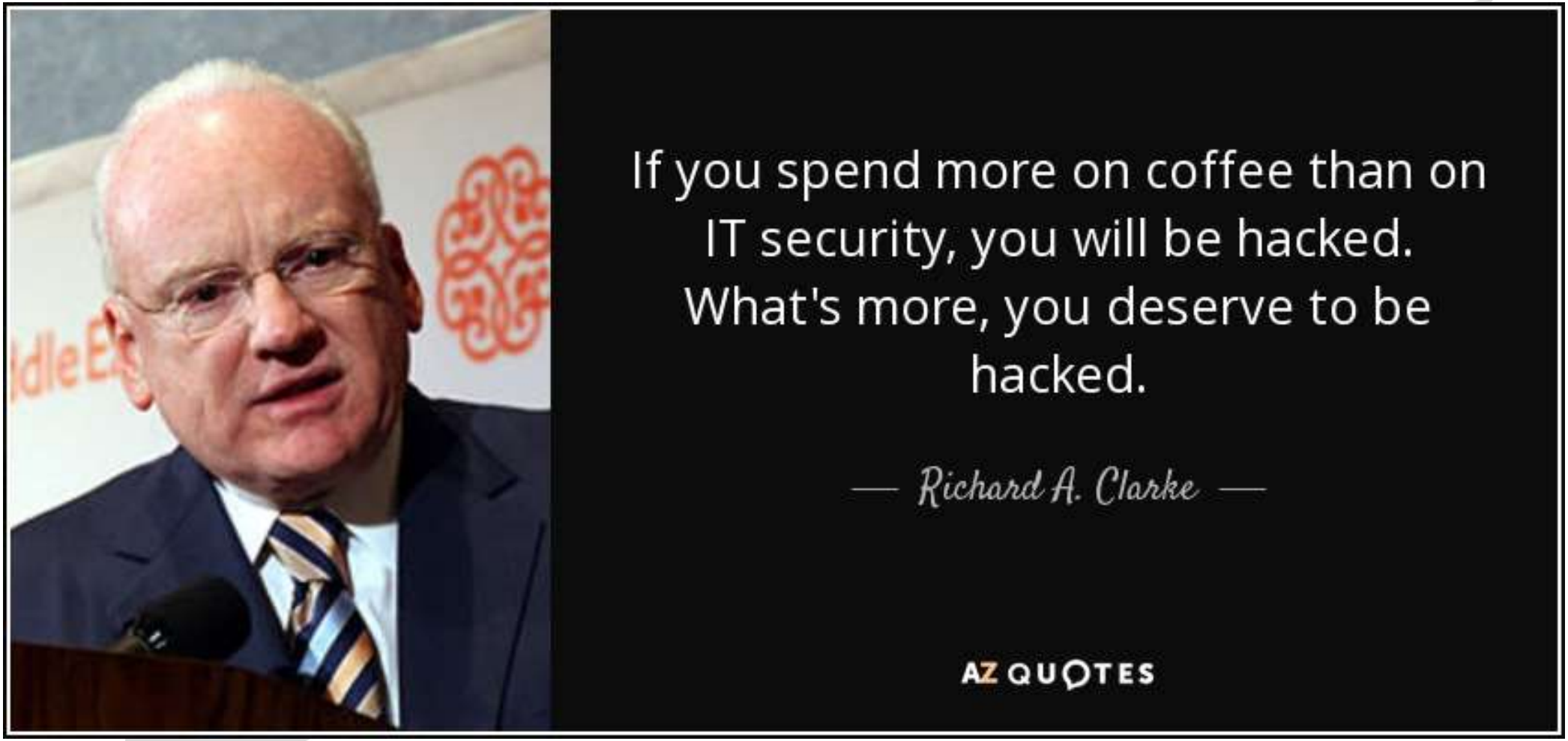
Wprowadzenie

- 0. …
- 1. Haking
- 2. Programy destrukcyjne
- 3. Zagrożenia, Podatności, Ataki
- 4. Cyberbezpieczeństwo
- 5. Kilka porad jako podsumowanie

Where is the problem ???

0.
Richard A. Clarke (2002)



0.
John Chambers (2015)

BwSK

T.Łukaszewski

0.

THE H@CK SUMMIT

5/12/2020 ONLINE

Attacks of the Industry: A View into the Future of Cybersecurity

Paula Januszkiewicz
CEO, Founder
CQURE

THE H@CK SUMMIT

BWSK

T.Łukaszewski

0.
hasła

THE H@CK SUMMIT

Here comes the 1st issue...

#1: PATHETIC PASSWORDS

15%

IN APPROXIMATELY 15% OF PHYSICAL SECURITY TESTS PERFORMED AT CLIENT SITES WRITTEN PASSWORDS WERE FOUND ON AND AROUND USER WORKSTATIONS

THE MOST COMMON CORPORATE PASSWORD IS Password1 BECAUSE IT JUST BARELY MEETS THE MINIMUM COMPLEXITY REQUIREMENTS OF ACTIVE DIRECTORY FOR LENGTH, CAPITALIZATION AND NUMERICAL FIGURES

COURE

THE H@CK SUMMIT

BwSK

T.Łukaszewski

0.
podglądacz

THE H@CK SUMMIT

#2: PEEPING ROM

WORKERS SURVEYED THAT SAY THEY HAVE BEEN ABLE TO SNEAK A PEEK AT A CO-WORKER'S OR STRANGER'S WORK STATION IN THE WORKPLACE OR A PUBLIC PLACE

71%

ONE IN THREE WORKERS LEAVE THEIR COMPUTERS LOGGED ON TO NETWORK RESOURCES AND UNLOCKED WHEN THEY ARE AWAY FROM THEIR DESK

26.4% *OF MALWARE* IS KEY LOGGER OR APPLICATION-SPECIFIC — WHICH OFTEN REQUIRES DETAILED KNOWLEDGE OF OR PHYSICAL ACCESS TO A TARGETED SYSTEM

THE H@CK SUMMIT

BWSK

T.Łukaszewski

0.
podrzucony pendrive

THE H@CK SUMMIT

#3: USB STICK UP

60% OF USERS WHO FIND RANDOM USB STICKS IN A PARKING LOT WILL PLUG THEM INTO THEIR COMPUTERS

ADD THE COMPANY LOGO, AND THAT NUMBER INCREASES TO 90%

35% OF USERS REPORT HAVING EXPERIENCED A VIRUS INFECTION THROUGH A USB DEVICE

THE H@CK SUMMIT

BwSK

T.Łukaszewski

0.
phishing

THE H@CK SUMMIT

#4: PHISH BITING

69% OF IT SECURITY PROS SAY THEY COME ACROSS PHISHING MESSAGES THAT GET PAST SPAM FILTERS

27% OF IT ORGANIZATIONS HAVE TOP EXECUTIVES OR PRIVILEGED USERS WHO HAVE FALLEN FOR MALICIOUS EMAIL ATTACKS

USERS TRAINED IN AVOIDING PHISHING AND SCAM EMAILS FELL FOR THESE MALICIOUS EMAILS *42% LESS* THAN THOSE WITHOUT TRAINING

COURE

THE H@CK SUMMI

BWSK

T.Łukaszewski

0.
pozostawienie (smartfona)

BWSK

T.Łukaszewski

0.

łączenie się z niezaufanym wifi

THE H@CK SUMMIT

#6: HOOKING UP WITH ANOTHER MAN'S WI-FI

BY 2015, THE NUMBER OF WIFI HOTSPOT DEPLOYMENTS WILL INCREASE BY 350%

ONLY 18 PERCENT OF USERS USE A VPN TOOL WHEN ACCESSING PUBLIC WI-FI

FBI

THE FBI RECENTLY RELEASED AN ALERT TO TRAVELERS WARNING AGAINST AN UPTICK IN MALWARE PASSED OFF AS SOFTWARE UPDATES ON HOTEL INTERNET CONNECTIONS

THE H@CK SUMMIT

BwSK

T.Łukaszewski

0.
zbytnia „towarzyskość”

THE H@CK SUMMIT

#7: A LITTLE TOO SOCIAL

67% OF YOUNG WORKERS THINK CORPORATE SOCIAL MEDIA POLICIES ARE OUTDATED

70% REGULARLY IGNORE IT POLICIES

52% OF ENTERPRISES HAVE SEEN AN INCREASE OF MALWARE INFECTIONS DUE TO EMPLOYEES' USE OF SOCIAL MEDIA

THE H@CK SUMMIT

Haking

WŁÓŻ MONETĘ, PODNIEŚ
MIKROTELEFON, PO UZYSKANIU
SYGNAŁU CENTRALI
WYBIERZ ŻĄDANY NUMER
1
ZŁOTY
1 2 3 4 5 6 7 8 9 0

Haking
narodziny hakingu

Haking

Pomysłowy sposób wykorzystania sprzętu do nowych zastosowań

- Pod koniec lat 50-tych klub modelarza kolejowego przy MIT otrzymał stare oprzyrządowanie telefoniczne
- Stworzyli system, który pozwalał operatorom na zdalne sterowanie różnymi elementami przez „wdzwanianie się”

[Hacking sztuka penetracji]

Haking
phreaking

Phreaking (*phone* + *freak*)
Włamania do sieci telefonicznej

- Gwizdek dodawany do płatków śniadaniowych Cap'n Crunch generował dźwięk 2600Hz, sterujący elektromechaniczną centralą telefoniczną
- Nowe centrale elektroniczne – również były podatne na „*atakl*"
- Sterowanie obu typami central - **kolorowe pudełka** (emitują specjalne tony lub wprowadzają fizyczne zmiany w obwodach telefonicznych)

Haking
phreaking – kolorowe pudełka

Kolorowe pudełka

- red box – wybieracz tonowy cyfrowo generujący dźwięki – po przebudowie można było symulować dźwięk ćwierćdolarówek wrzucanych do automatu
- blue box – pozwalało na prowadzenie rozmów międzymiastowych (ton 2600Hz)
- dayglo box – pozwalało na korzystanie z linii telefonicznej sąsiada
- aqua box – uniemożliwiało ustalenie przez FBI trasy połączenia telefonicznego
- mauve box – pozwalało na podsłuchiwanie linii telefonicznej
- chrome box – kontrolowało sygnały w linii telefonicznej

Współczesny haking

- 1983: FBI aresztuje grupę nastolatków, 414 oskarżonych o włamanie do około 60 komputerów
- 1984: Powstaje kwartalnik *2600: The Haker Quarterly*
- 1985: Powstaje czasopismo *Phrack*

- 2000: Atak na Yahoo, Amazon, eBay, CNN
- 2010: WikiLeaks: wyciek poufnej korespondencji dyplomatycznej
- 2017: Petya ransomware i straty około 10mld $

Haking
Kevin Mitnick (Condor) 1963

- Najbardziej znany haker świata
- Condor – przyjął taki pseudonim po obejrzeniu filmu „Trzy dni Condora”, ponieważ widział analogie między położeniem bohatera a swoim

[en.wikipedia.org]

Haking
Kevin Mitnick (Condor)

- Jako dziecko włamywał się do szkolnego systemu komputerowego.
- W 1981, mając 17 lat, wraz z kolegami włamał się do komputerów firmy **Pacific Bell**. Skazany na 3 miesiące w zakładzie poprawczym.
- 1983 – 6 miesięcy za włamanie do **ARPAnetu**
- 1987 – 36 miesięcy (w zawieszeniu) za włamanie do **SCO**
- 1988 włamanie do laboratorium **Palo Alto** – próba zdobycia kodu źródłowego systemu VMS. 12 miesięcy.
- Od 1989 uciekał przed FBI (bał się niesprawiedliwego wyroku). Aresztowany w 1995, skazany w 1999, zwolniony w styczniu 2000 roku, do stycznia 2003 roku zakaz używania sprzętu komputerowego i urządzeń elektronicznych

Haking
Robert Tappan Morris 1965

- Twórca pierwszego robaka (1988)
- Ph.D. na Harvardzie (1999)
- Profesor MIT (od 1999)

[en.wikipedia.org]

Haking
Robert Tappan Morris

- Syn szefa informatyków w NSA

- W 1988 będąc doktorantem na Uniwersytecie Cornell, zajmował się błędami w systemach 4 BSD Unix i stworzył program, który wykorzystując wykryte błędy w mechaniźmie przesyłania poczty potrafił mnożyć się w tych systemach. Program miał mnożyć się w sposób ograniczony ale wskutek błędu programisty nie zadziałało ograniczenie
- Program zablokował ponad 6000 komputerów
- Program nazwano "**worm**"

Haking
Kevin Poulsen (Dark Dante) 1965

- Otrzymał najwyższy wyrok sądowy w historii hackingu

[en.wikipedia.org]

Haking
Kevin Poulsen (Dark Dante)

- Pierwszy haker oskarżony o szpiegostwo (listopad 1989)
- 24-hours hacker: w dzień expert od zabezpieczeń, nocą włamywał się do systemów rządowych
- Przez 17 miesięcy unikał aresztowania. W tym czasie szlifował umiejętności zdobywania nagród w konkursach radiowych
- W 1990 roku przejął wszystkie linie telefoniczne stacji KIIS-FM w Los Angeles. Sto druga osoba dzwoniąca po zagraniu odpowiedniej sekwencji utworów miała otrzymać samochód Porsche. Był 102-gi
- 11 kwietnia 1991 roku został ujęty na nocnych zakupach w supermarkecie. Został rozpoznany przez sprzedawcę. Sprzedawca był fanem programu Unsolved Mysteries, w którym kilka dni wcześniej przedstawiono Poulsena jako przestępcę

Haking
polscy eksperci: Michal Zalewski 1981

http://lcamtuf.coredump.cx/

- Od połowy lat 90-tych uczestniczy w projekcie Bugtraq
- W roku 2000 dostał pracę w firmie BindView w USA
- W roku 2003 wraca do Polski – Polska Telefonia Cyfrowa
- W roku 2010 zaczyna pracować dla Google
- W roku 2018 przechodzi do Snapchat
- Autor książek „Cisza w sieci”, „Splątana sieć”, „Practical Doomsday: A User’s Guide to the End of the World”

Haking
polscy eksperci: Gynvael Coldwind

http://gynvael.coldwind.pl/

Michał Składnikiewicz

- Pracował jako reverse engineer/pentester
- Od 2010 pracuje w Zurychu dla Google
- Członek zespołu Dragon Sector (najlepszy na świecie w 2018)
- Autor książek „Zrozumieć oprogramowanie” oraz „Praktyczna inżynieria wsteczna”

Haking
podział hakerów

W zależności od stwarzanego niebezpieczeństwa hakerów (crackerów, intruzów, włamywaczy, napastników, wandali, przestępców) można podzielić na następujące kategorie:

- eksperci do spraw bezpieczeństwa
- przypadkowi włamywacze
- osoby poszukujące wrażeń (np. studenci)
- hobbyści
- włamywacze-kryminaliści
- szpiedzy przemysłowi
- niezadowoleni pracownicy (tzw. **wróg wewnętrzny**)

BwSK

Programy destrukcyjne

Programy destrukcyjne
wprowadzenie

Programy destrukcyjne (ang.*malware, malicious software*)

- Cel:
  - nękanie użytkowników
  - zdobywanie/niszczenie danych
  - zarabianie pieniędzy
- Podział:
  - **Wirusy**
  - **Robaki**
  - **Konie trojańskie**
  - **Ransomware**
- Botnet – zainfekowane komputery kontrolowane przez hakerów

BwSK

Programy destrukcyjne
wirusy

Wirus

- Koncepcja samopowielających się programów – John von Neuman, Teoria i organizacja skomplikowanych automatów, 1949 rok
- W połowie lat 70. tych w systemie operacyjnym Tenex stworzony został program **The Creeper**, który sam się rozprzestrzeniał w sieci. Do zwalczania go administratorzy napisali program **The Reeper**, uważany za pierwszy w historii **program antywirusowy**
- Do 1983 roku wirusy były sprawą czysto teoretyczną i poza środowiskami akademickimi fascynowały jedynie niektórych autorów powieści science fiction.

Programy destrukcyjne
robaki

Robak (ang. worm)

- Jest bardzo podobny do wirusa. Różnica: **może rozpowszechniać się samodzielnie**
- Ponadto jego celem jest przenoszenie się z **komputera** na **komputer**, nie zaś z pliku na plik
- Większość obecnego malware'u należy do klasy robaków
- Włamują się one do systemów wykorzystując **słabe punkty** w oprogramowaniu

Programy destrukcyjne
robaki – cyfrowa broń

Operacja **Olympic Games**

- (2010) **Stuxnet** atakował systemy sterowania irańskich instalacji nuklearnych – czasowo unieruchomił 1000 z 5000 wirówek do oczyszczania uranu
- (2011) **Duqu** - blokada prac nad uruchomieniem elektrowni atomowej
- (2012) **Flame** - cyberszpieg
- (2012) **Gauss – trojan** bankowy

Programy destrukcyjne
konie trojańskie

Koń trojański (**trojan**)

- Program, który wydaje się realizować pożądane i pożyteczne funkcje, lecz realizujący funkcje nieznane jego użytkownikowi
- Działa bardzo podstępnie i bardzo trudno określić dokonaną przez nich skalę zniszczeń (penetracji systemu)
- Celem jest ujawnienie istotnych informacji o systemie, na którym został uruchomiony lub doprowadzenie do pokonania zabezpieczeń

Programy destrukcyjne
ransomware

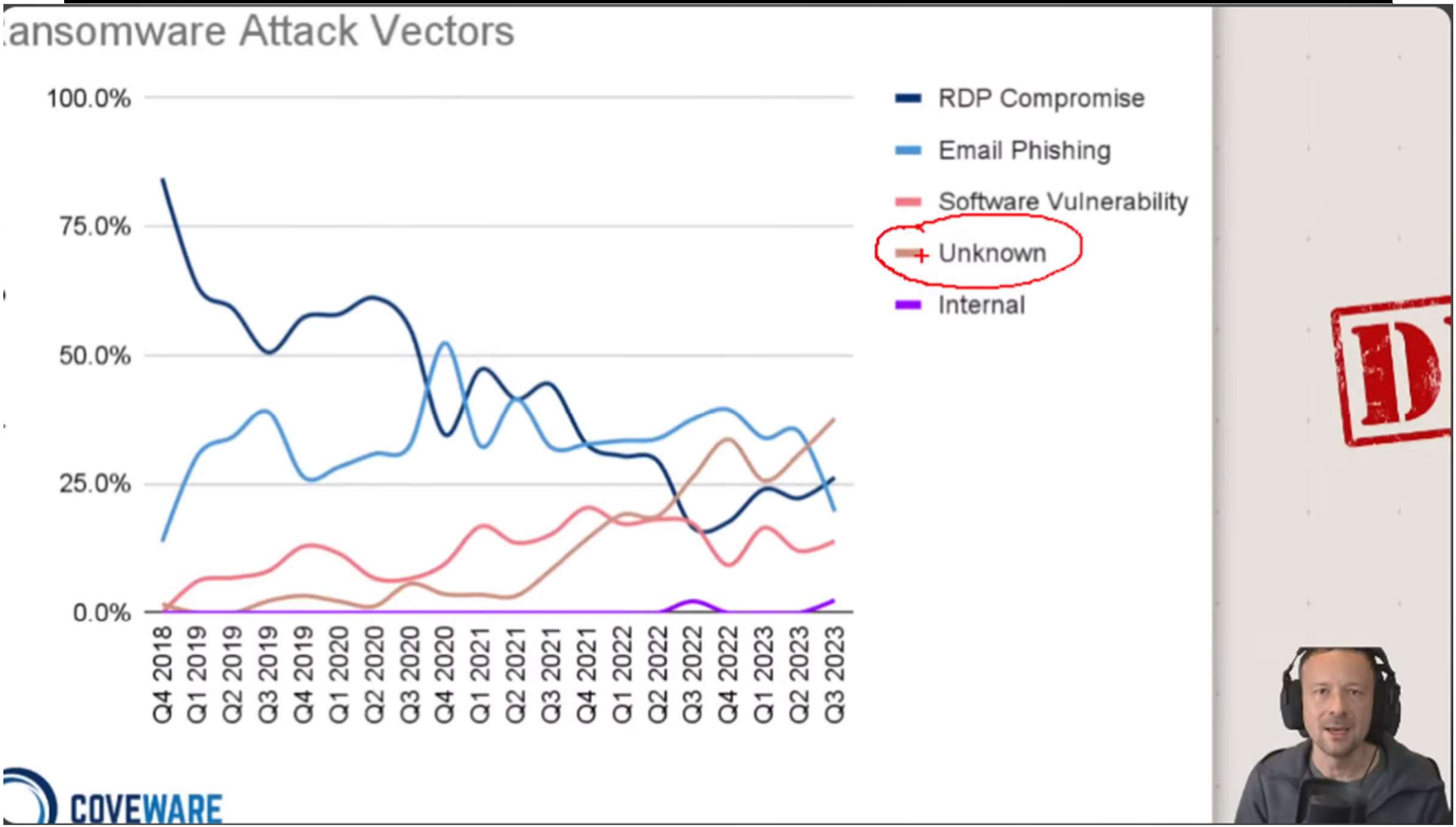
Ransomware

- Program, który po zainstalowaniu na komputerze ofiary **blokuje komputer** lub **szyfruje pliki** (wszystkie lub wybrane) a następnie żąda okupu (ang. ransome), najczęściej w kryptowalucie bitcoin. Takie pobieranie okupu znacznie utrudnia zidentyfikować autora ataku.
- Zagrożenie dotyczy też użytkowników smartfonów
- Model biznesowy RaaS – Ransomware as a Service – twórca oprogramowania pobiera prowizję od osób „korzystających” z oprogramowania

BwSK

T.Łukaszewski

Programy destrukcyjne
ransomware



Programy destrukcyjne
ransomware – przykłady

14.05.2017 WannaCry - W jednej chwili dziesiątki tysięcy komputerów na całym świecie zostało zaszyfrowanych

BwSK
T.Łukaszewski

Programy destrukcyjne
ransomware – przykłady

27.06.2017 Petya – Zaatakował instytucje na Ukrainie >12k komputerów (banki, operatorzy, narodowi dostawcy energii, setki firm prywatnych). Kilka firm z Polski przyznało się do bycia ofiarą ataku.

Programy destrukcyjne
ransomware – przykłady

27.06.2017 Petya – „atak na dostawcę”

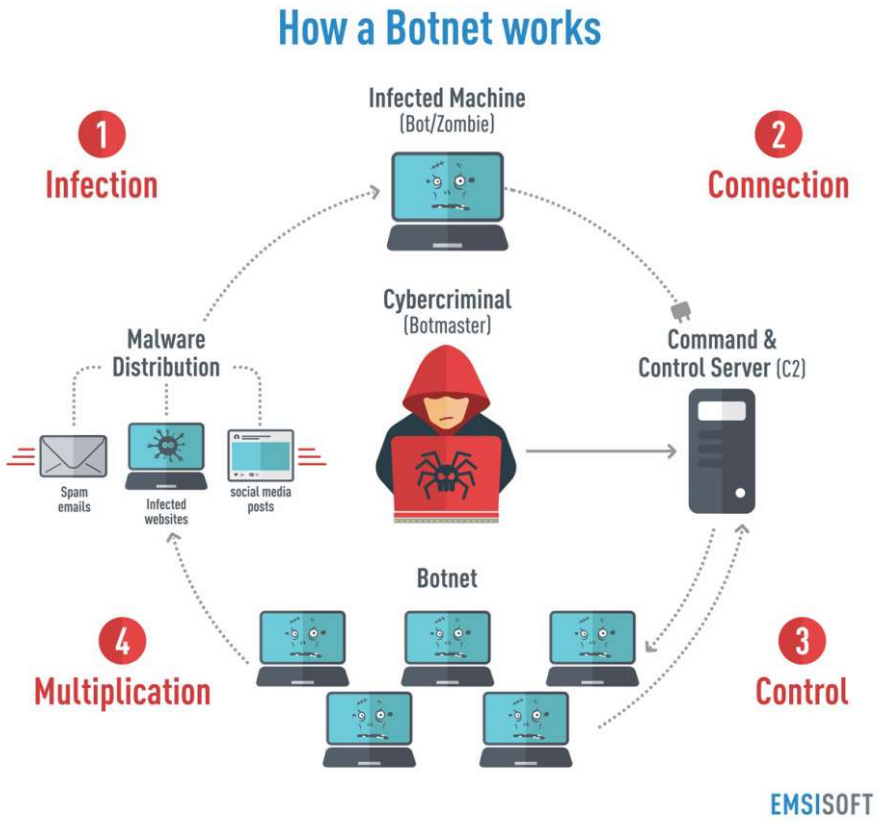
- Ustalono źródło ataku na Ukrainie: ktoś podmienił **aktualizację** oprogramowania do rozliczeń podatkowych na złośliwą wersję (ślady wskazują, że firma dostarczająca oprogramowanie miała **przejętą infrastrukturę** około 75 dni wcześniej)

- W Polsce kilka tygodni wcześniej Antywirusy blokowały nieudaną aktualizację Płatnika.

Programy destrukcyjne
botnet

Botnet

- grupa komputerów zainfekowanych szkodliwym oprogramowaniem (np. robakiem) pozostającym w ukryciu przed użytkownikiem i pozwalającym jego twórcy na sprawowanie zdalnej kontroli nad wszystkimi komputerami



Programy destrukcyjne
mobile

Samsung/Google Pixel

Sekurak 2023

Google Project Zero – osiemnaście 0-day podatności w Exynos Modem

Ciche infekowanie telefonów m.in. S22, S23, M33, M12, A71, A53, A33

Zaleca się wyłączenie WiFi calling oraz Voice over LTE

Programy destrukcyjne
USB – klawiatura

BwSK

T.Łukaszewski

Programy destrukcyjne

USB – przechwytywanie/usuwanie plików

securitum

USB RUBBER DUCKY

$49.99

Imagine plugging in a seemingly innocent USB drive into a computer and installing backdoors, exfiltrating documents, or capturing credentials.

With a few well crafted keystrokes anything is possible. If only you had a few minutes, a photographic memory and perfect typing accuracy.

The USB Rubber Ducky injects keystrokes at superhuman speeds, violating the inherent trust computers have in humans by posing as a keyboard.

Inventing keystroke injection in 2010, the USB Rubber Ducky became the must-have pentest tool. With a covert design and simple "Ducky Script" language, this bad USB infiltrates systems and imaginations the world over.

USB RUBBER DUCKY DELUXE $49.99

HOTPLUG ATTACK COMBO KIT ~~$199.99~~

1 ADD TO CART

0111001100001

Programy destrukcyjne
ile to kosztuje

securitum

Ransomware z punktu widzenia szeregowego pracownika

- ✓firma padła w jakieś 40 minut
- ✓kilka dni niepewności co dalej i kiedy będą wypłaty
- ✓duuuuuużo jeżdżenia po biurach w całej europie
- ✓niemalże cała infrastruktura była stawiana od zera
- ✓bardzo długo zajmowało odzyskiwanie rzeczy z kopii zapasowych
- ✓bardzo duże koszta związane z podróżami służbowymi
- ✓duże zdenerwowanie szeregowych pracowników
- ✓atak był inicjatorem wielu zmian w security i jak firma na to patrzy

BWSK

T.Łukaszewski

Programy destrukcyjne
ile to kosztuje

BwSK

T.Łukaszewski

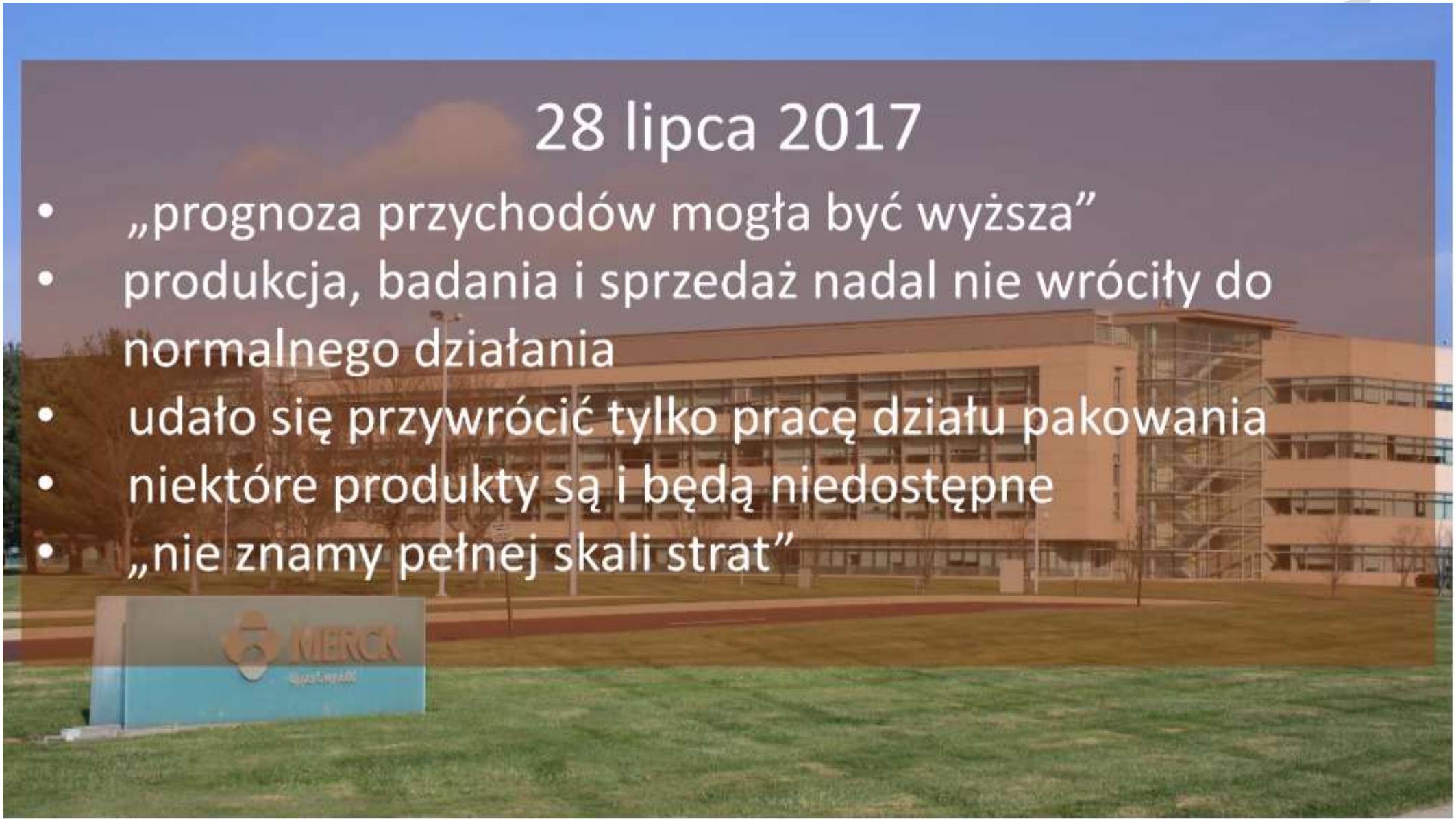
Programy destrukcyjne
ile to kosztuje

BWSK
T.Łukaszewski

Programy destrukcyjne
ile to kosztuje

BWSK
T.Łukaszewski

Programy destrukcyjne
ile to kosztuje



BWSK
T.Łukaszewski

Programy destrukcyjne
ile to kosztuje

BWSK

T.Łukaszewski

Programy destrukcyjne
ile to kosztuje – 915 mln USD

Programy destrukcyjne
ile to kosztuje – 275 mln USD

CYBER RISK OCTOBER 19, 2017 / 5:37 PM / 4 MONTHS AGO

Merck cyber attack may cost insurers $275 million: Verisk's PCS

Reuters Staff

3 MIN READ

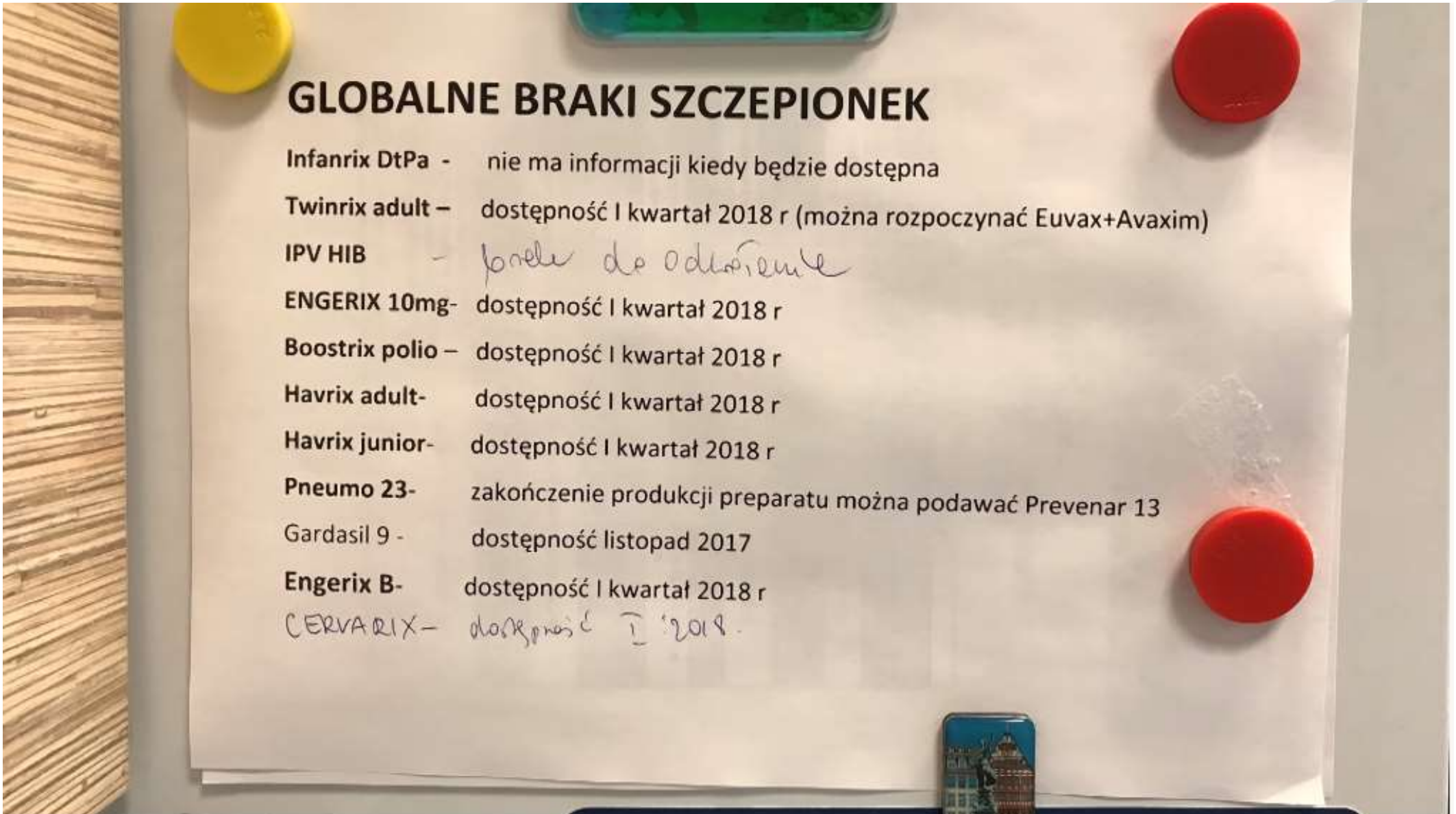
NEW YORK (Reuters) - Insurers could pay $275 million to cover the insured portion of drugmaker Merck & Co's loss from a cyber attack in June, according to a forecast by Verisk Analytics Inc's Property Claim Services (PCS) unit.

BWSK

T.Łukaszewski

Programy destrukcyjne

ile to kosztuje – brak szczepionek



Programy destrukcyjne
ile to kosztuje – brak szczepionek

Secure | https://www.merckvaccines.com/INTERSHOP/web/WFS/Merck-MerckVaccines-Site/en_US/-/USD/SupplyS...

Product	NDC	Package Size	Status	Notes
PNEUMOVAX® 23 (Pneumococcal Vaccine Polyvalent)	00006483702	one 0.5 mL single-dose pre-filled Luer-Lok® syringe with tip cap	**Temporarily Unavailable for Order**	Package is not anticipated to be available in 2018. Packages of ten (10) 0.5 mL single-dose pre-filled Luer-Lok® syringes with tip caps and 10 single-dose 0.5 mL vials remain available. Supply status will be updated with latest information, as available
RECOMBIVAX HB® [Hepatitis B Vaccine (Recombinant)] - **Adult Formulation**	00006409402	ten (10) 10 mcg/1 mL single-dose pre-filled Luer-Lok® syringes with tip caps	**Temporarily Unavailable for Order**	Adult formulation is not anticipated to be available in 2018. Supply status will be updated with latest information, as available.
RECOMBIVAX HB® [Hepatitis B Vaccine (Recombinant)] - **Adult Formulation**	00006499500	10 mcg/mL - one single-dose 1 mL vial	**Temporarily Unavailable for Order**	Adult formulation is not anticipated to be available in 2018. Supply status will be updated with latest information, as available
RECOMBIVAX HB® [Hepatitis B Vaccine (Recombinant)] - **Adult Formulation**	00006499541	10mcg/mL - 10 single-dose 1 mL vials	**Temporarily Unavailable for Order**	Adult formulation is not anticipated to be available in 2018. Supply status will be updated with latest information, as available.
RECOMBIVAX HB® [Hepatitis B Vaccine (Recombinant)] — **Pediatric/Adolescent Formulation**	00006409302	ten (10) 5 mcg/0.5 mL single-dose pre-filled Luer-Lok® syringes with tip caps	**Temporarily Unavailable for Order**	Orders are anticipated to begin shipping the week of 04/02/18. Supply status will be updated with latest information, as available
RECOMBIVAX HB® [Hepatitis B Vaccine (Recombinant)] — **Pediatric/Adolescent Formulation**	00006498100	5mcg/0.5 mL - 10 single-dose 0.5 mL vials	**Temporarily Unavailable for Order**	Orders are anticipated to begin shipping the week of 04/02/18. Supply status will be updated with latest information, as available
VAQTA® (Hepatitis A Vaccine, Inactivated) - **Pediatric/Adolescent Formulation**	00006409502	ten (10) 25U/0.5 mL single-dose pre-filled Luer-Lok® syringes with tip caps	**See Notes**	Package is not anticipated to be available until 2Q18. Package containing ten single-dose 25U/0.5mL vials remains available. Supply status will be updated with latest information, as available.

BWSK

T.Łukaszewski

Programy destrukcyjne
ile to kosztuje

BwSK
T.Łukaszewski

Programy destrukcyjne
ile to kosztuje

- Zeszyty i długopisy
- Nie wiemy kiedy przywrócimy pełną funkcjonalność
- Niektórych danych na pewno nie odzyskamy
- UBS obniża rekomendację dla FedEx'a
- Wrzesień 2017 – straty co najmniej 300 mln USD

Programy destrukcyjne
ile to kosztuje

Mondelez

- Kwartalna sprzedaż niższa o 5%
- Poniesione koszty i utracone zyski ok. 150 mln USD

BwSK

T.Łukaszewski

Programy destrukcyjne
ile to kosztuje

Reckitt Benckiser

- Szacowane straty 130 mln USD
- 2000 serwerów, 15000 laptopów

BWSK
T.Łukaszewski

Programy destrukcyjne
ile to kosztuje

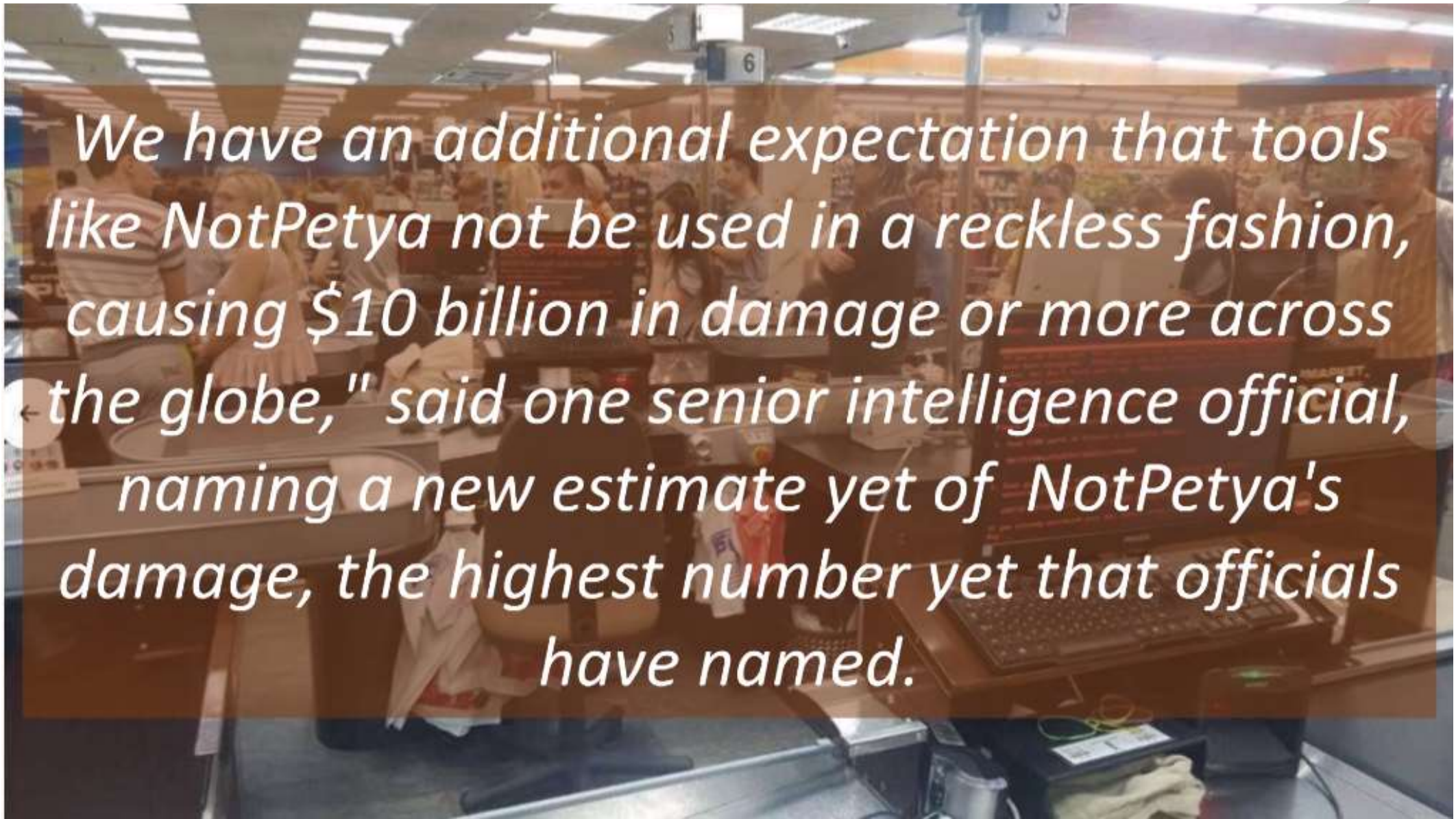
Saint Gobain

- Sprzedaż niższa o 220 mln EUR
- W H1 zysk niższy o 65 mln EUR
- Szacowane straty w 2017 330 mln EUR

SAINT-GOBAIN

BwSK
T.Łukaszewski

Programy destrukcyjne
ile to kosztuje



BWSK

T.Łukaszewski

Programy destrukcyjne
ile to kosztuje - Ukraina

BWSK
T.Łukaszewski

Programy destrukcyjne
ile to kosztuje – Ukraina

- **Urzędy**: Rada Ministrów, MSW, Ministerstwo Kultury, Ministerstwo Finansów, Komenda Główna Policji, Rada Miejska Lwowa, Ministerstwo Energii, Bank Narodowy
- **Banki**: Oschadbank, Sberbank, TASKomertzbank, Ukrgasbank, Pivdenny, OTP Bank, Kredobank.
- **Transport**: Lotnisko Boryspol, kijowskie metro, Koleje Uraińskie
- **Media**: Radio Era-FM, Football.ua, STB, Inter, First National, TV Channel 24, Radio Lux, Radio Maximum, ATP Channel, Correspondent.net.
- **Firmy**: Novaya Pochta, Kyivenergo, Naftogaz of Ukraine, DTEK, Dniproenergo, Kievvodokanal, Novus, Epicentra, Arcelor Mittal, Ukrtelecom, Ukrposhta.
- **Sieci komórkowe**: Lifecell, Kyivstar, Vodafone Ukraine.
- **Sektor medyczny**: "Farmak", clinic Boris, hospital Feofaniya, corporation Arterium.
- **Stacje paliw**: Shell, WOG, Klo, TNK.

Programy destrukcyjne
najważniejsze pytanie

securitum

Czy samo otworzenie docx / pdf może zainfekować komputer?

Teoretycznie nie,
ale zdarzają się przypadki infekcji …

BwSK

T.Łukaszewski

Programy destrukcyjne
najważniejsze pytanie

Zagrożenia
Podatności
Ataki

BwSK

Zagrożenia, Podatności, Ataki
największy problem

securitum

Największy problem

Brak świadomości zagrożeń

0111001100001

Psychologia zagrożeń

- mamy tendencję do **wyolbrzymiania** spektakularnych i rzadkich zagrożeń i **bagatelizowania typowych zagrożeń**
- **nieznane** jest postrzegane jako bardziej ryzykowne niż **znajome**
- **spersonalizowane** ryzyka są postrzegane jako większe niż **anonimowe**
- ludzie **przeceniają** ryzyko w sytuacjach w których nie mają kontroli a **nie doceniają** ryzyka w sytuacjach, nad którymi mają kontrolę

Zagrożenia, Podatności, Ataki
źródła zagrożeń

Źródła zagrożeń (Network Security Threads):

- **błędy w systemach, technologiach** (protokół TCP/IP, systemy operacyjne, ochrona haseł, brak uwierzytelniania)
- **zła konfiguracja** (ujawnianie informacji o kontach, proste hasła, niebezpieczne ustawienia domyślne)
- **niedostateczne przeszkolenie użytkowników, brak odpowiedniej polityki bezpieczeństwa** (brak polityki, brak lub błędna kontrola dostępu, nieprzestrzeganie zasad, brak planów na wypadek katastrof)

Zagrożenia, Podatności, Ataki
rodzaje zagrożeń

- **przejęcie dokumentów i danych**
- **wprowadzenie nieprawdziwych danych do systemu**
- **niszczenie danych**
- **kradzież tożsamości**

- **uzyskanie nieautoryzowanego dostępu** (ataki na hasła, social engineering, wykorzystanie błędów protokołów systemów konfiguracji)
- **podszywanie się pod użytkowników, przechwycenie sesji**
- **zmiany konfiguracji serwerów i urządzeń sieciowych**

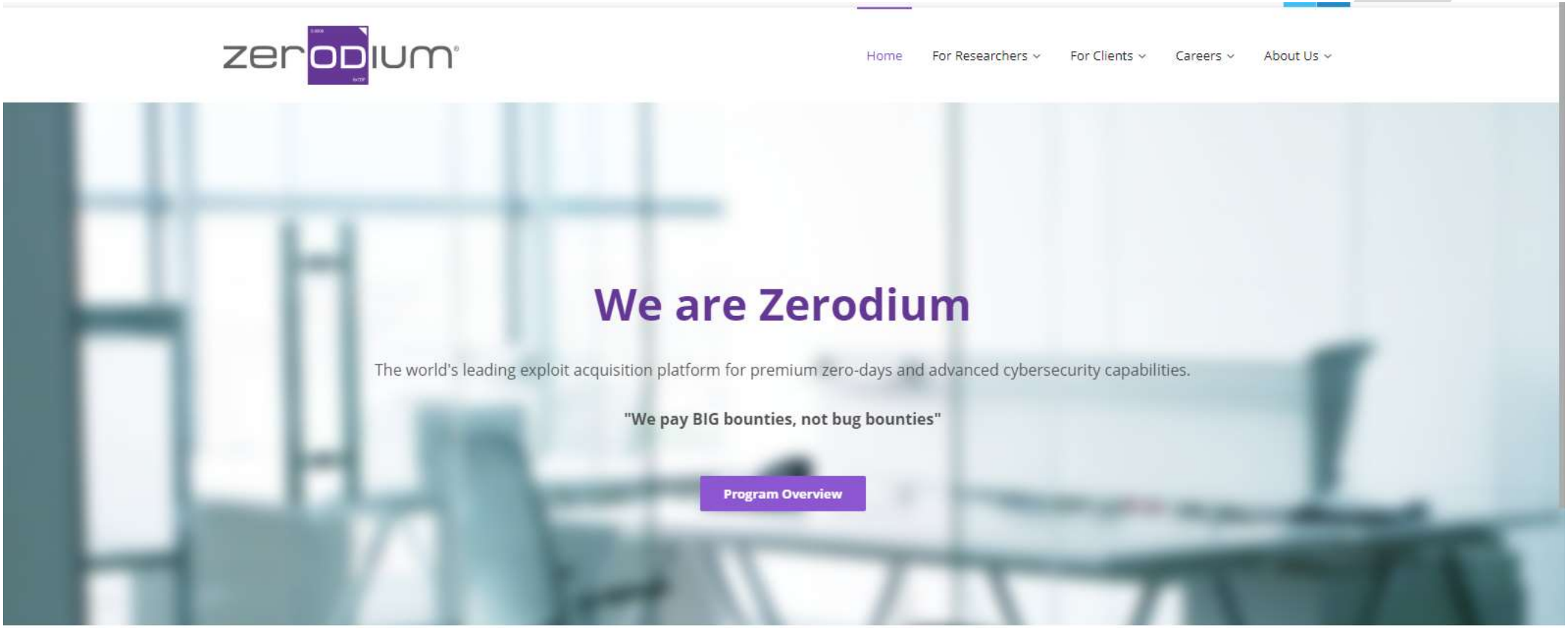
- **blokowanie komputerów lub poszczególnych usług (DoS)**
- **zainfekowanie systemu szkodliwymi programami**

Zagrożenia, Podatności, Ataki
konsekwencje zagrożeń

- nielegalne wykorzystanie zasobów firmy
- ośmieszenie i utrata zaufania klientów i firm współpracujących
- utrata lub zniszczenie istotnych dla firmy danych
- kradzież poufnych dokumentów dotyczących działania firmy
- kradzież nowych technologii
- przerwa w działaniu istotnych systemów informatycznych firmy
- bankructwo firmy

BwSK

Zagrożenia, Podatności, Ataki
podatności



ZERODIUM Payouts for Desktops/Servers*

Windows
macOS
Linux/BSD
Any OS

RCE: Remote Code Execution
LPE: Local Privilege Escalation
SBX: Sandbox Escape or Bypass
VME: Virtual Machine Escape

Up to $1,000,000										1.001 Win RCE Zero Click Win
Up to $500,000							3.001 Chrome RCE+LPE Win	2.001 Apache RCE Linux	2.002 MS IIS RCE Win	
Up to $250,000					5.001 MS Outlook RCE Win	4.001 MS Exchange RCE Win	2.003 OpenSSL RCE Linux	2.004 PHP RCE Linux		
Up to $200,000	6.001 VMware ESXi VME	5.002 Thunderbird RCE Win/Linux		4.002 Sendmail RCE Linux	4.003 Postfix RCE Linux	4.004 Dovecot RCE Linux	4.005 Exim RCE Linux	2.005 nginx RCE Linux		
Up to $100,000		3.002 Safari RCE+LPE Mac	3.003 Edge RCE+LPE Win	3.004 Firefox RCE+LPE Win	5.003 Word/Excel RCE Win	7.001 WordPress RCE Linux	7.002 cPanel/WHM RCE Linux	7.003 Plesk RCE Linux	7.004 Webmin RCE Linux	
Up to $80,000	6.002 VMware WS VME Win/Linux					5.004 Adobe PDF RCE+SBX Win	5.005 WinRAR RCE Win	5.006 7-Zip RCE Win	6.003 Windows LPE/SBX Win	
Up to $50,000	6.004 USB LPE Win/Mac	8.001 Antivirus RCE Win			5.007 WinZip RCE Win	5.008 tar RCE Linux	6.005 macOS LPE/SBX Mac	6.006 Linux LPE Linux	6.007 BSD LPE BSD	
Up to $10,000	9.001 Routers RCE	8.002 Antivirus LPE Win	7.005 phpBB RCE Linux	7.006 vBulletin RCE Linux	7.007 MyBB RCE Linux	7.008 Joomla RCE Linux	7.009 Drupal RCE Linux	7.010 Roundcube RCE Linux	7.011 Horde RCE Linux	

* All payouts are subject to change or cancellation without notice. All trademarks are the property of their respective owners.

2019/01 © zerodium.com

Zagrożenia, Podatności, Ataki
klasy i rodzaje ataków

Klasy ataków:

- Ataki pasywne/aktywne
- Ataki lokalne/zdalne

Podstawowe rodzaje ataków:

- Ataki rozpoznawcze – zazwyczaj wstęp dla dwóch pozostałych
- Ataki w celu uzyskania (nieautoryzowanego) dostępu
- Ataki w celu zablokowania usługi (ataki DoS)

Zagrożenia, Podatności, Ataki
formy ataków

Formy ataków:

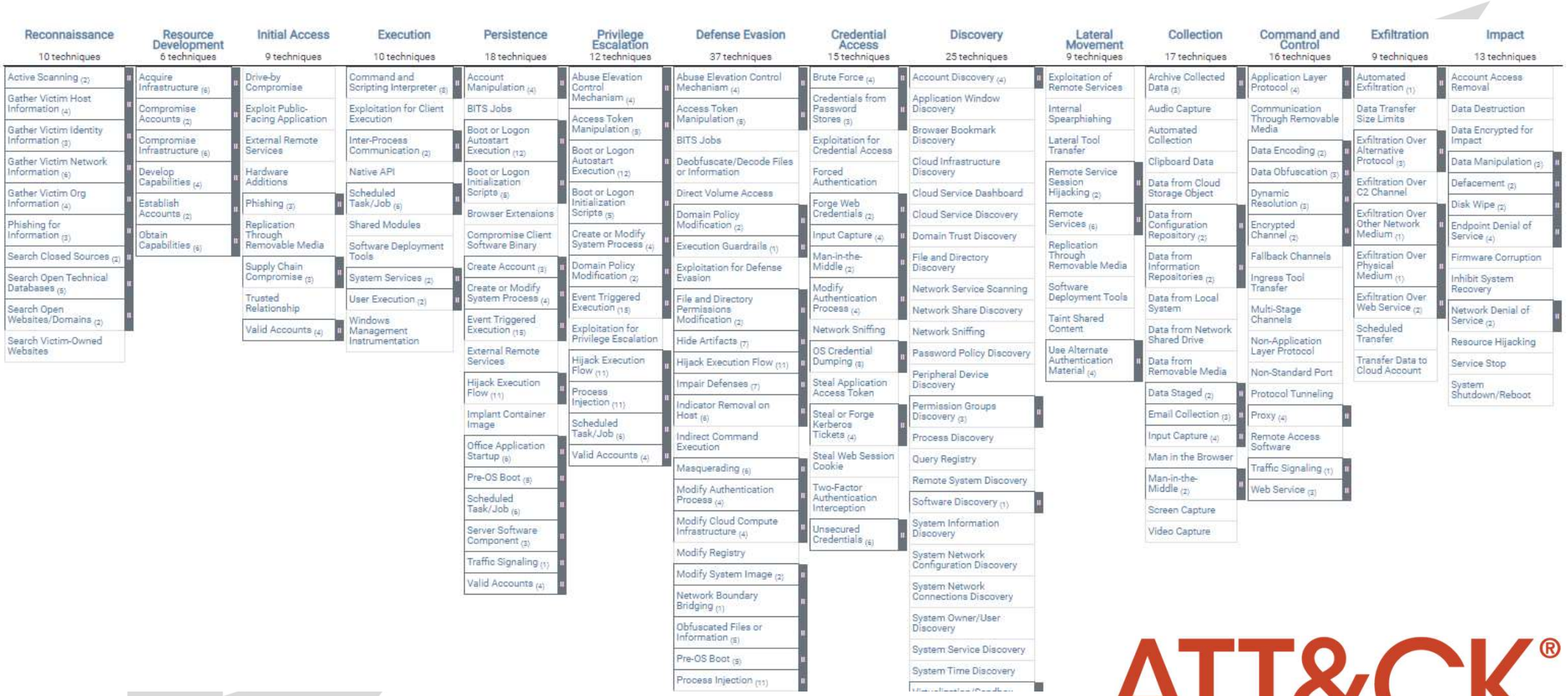
- podszywanie się (masquerading)
- podsłuch (eavesdropping)
- odtwarzanie (replaying)
- manipulacja (tampering)
- wykorzystywanie luk w systemie (exploiting)

BwSK

Zagrożenia, Podatności, Ataki

baza ataków - https://attack.mitre.org/

T.Łukaszewski



ATT&CK®

CYBER KILL CHAIN

SEQRED

2. UZBROJENIE

Intruz tworzy złośliwy kod umożliwiający dostęp do zdalnego systemu, taki jak wirus lub robak, dostosowany do jednego lub więcej słabych punktów

4. WYKORZYSTANIE

Uruchomienie kodu programu złośliwego oprogramowania, w celu wykorzystania luki w zabezpieczeniach

6. DOWODZENIE I KONTROLA

Punkt dostępowy zapewnia intruzowi posiadanie stałego dostępu do sieci docelowej

1. ROZPOZNANIE

Intruz wybiera cel, bada go i próbuje zidentyfikować luki w docelowej sieci

3. DOSTARCZENIE

Intruz przekazuje złośliwy kod do celu

5. INSTALACJA

Złośliwy kod instaluje punkt dostępowy (np. "Backdoor"), który będzie wykorzystywany przez intruza

7. DZIAŁANIE

Intruz podejmuje działania w celu osiągnięcia swoich celów

Na podstawie: Gaining The Advantage. Applying Cyber Kill Chain Methodology to Network Defense, Lockheed Martin

Cyberbezpieczeństwo

BwSK

Cyberbezpieczeństwo
geneza

Computer security (cybersecurity)

- 1967 sesja zorganizowana przez **Willisa Ware'a** w ramach konferencji: Spring Joint Computer Conference; artykuł: **Security and Privacy in Computer Systems**
- 1970 raport Willisa Ware'a: **Security Controls for Computer Systems**
- https://en.wikipedia.org/wiki/Computer_security
- https://en.wikipedia.org/wiki/Security_and_Privacy_in_Computer_Systems
- https://www.rand.org/pubs/reports/R609-1.html#i-the-security-problem-

Cyberbezpieczeństwo
definicja

Czym jest cyberbezpieczeństwo?

- **Poziom, do jakiego program lub urządzenie jest zabezpieczone przed nieautoryzowanym wykorzystaniem** (w danej chwili – ponieważ ciągle pojawiają się nowe zagrożenia)
- **Poziom cyberbezpieczeństwa** zależy od:
  - możliwych do poniesienia wydatków
  - kompromisu pomiędzy bezpieczeństwem a użytecznością

Wyścig zbrojeń między atakującym a obrońcą !!!!!!!!

Cyberbezpieczeństwo
czy istnieje absolutne bezpieczeństwo?

Nie istnieje **absolutne (100%) bezpieczeństwo**:

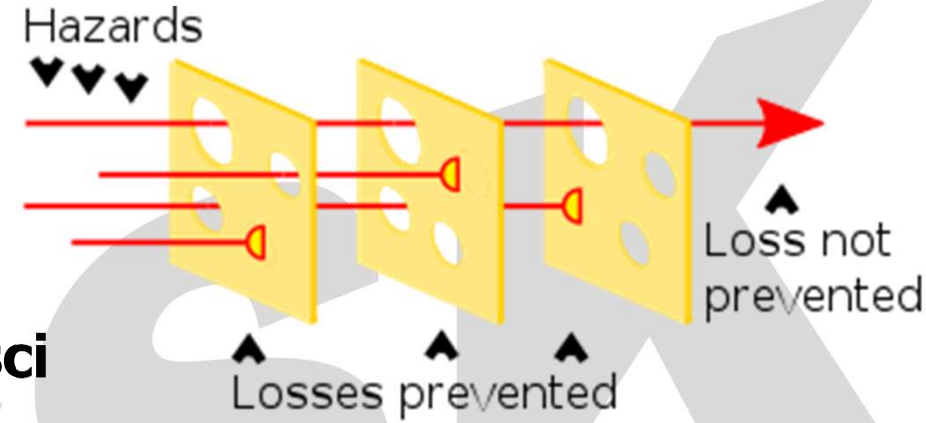
- Nie jesteśmy w stanie przewidzieć **wszystkich** zagrożeń
- Czas reakcji na zagrożenia nie jest **zerowy**
- Ludzka **słabość**, **omylność** projektantów
- **Niewłaściwe** i **niefrasobliwe** wykorzystanie aplikacji

Zatem co możemy zrobić? …

Cyberbezpieczeństwo
swiss cheese model

Model sera szwajcarskiego

James T. Reason



- **Każda bariera ma swoje słabości**
- Model używany w:
  - Analizie ryzyka
  - Zarządzaniu ryzykiem
- Baza
  - **Bezpieczeństwo warstwowe** (ang. layered security)
  - Obrona w głębi (ang. defense in depth) (wojsko)

Cyberbezpieczeństwo
bezpieczeństwo warstwowe

Warstwy (system/aplikacja)

- Uwierzytelnianie (wieloczynnikowe) + kontrola dostępu
- Antywirus + IPS + IDS

Warstwy (sieć)

- Firewall + DMZ + VPN

Warstwy (fizyczna ochrona)

- Ochrona fizyczna
- Bezpieczeństwo skoncentrowane na danych (data-centric security)

BwSK

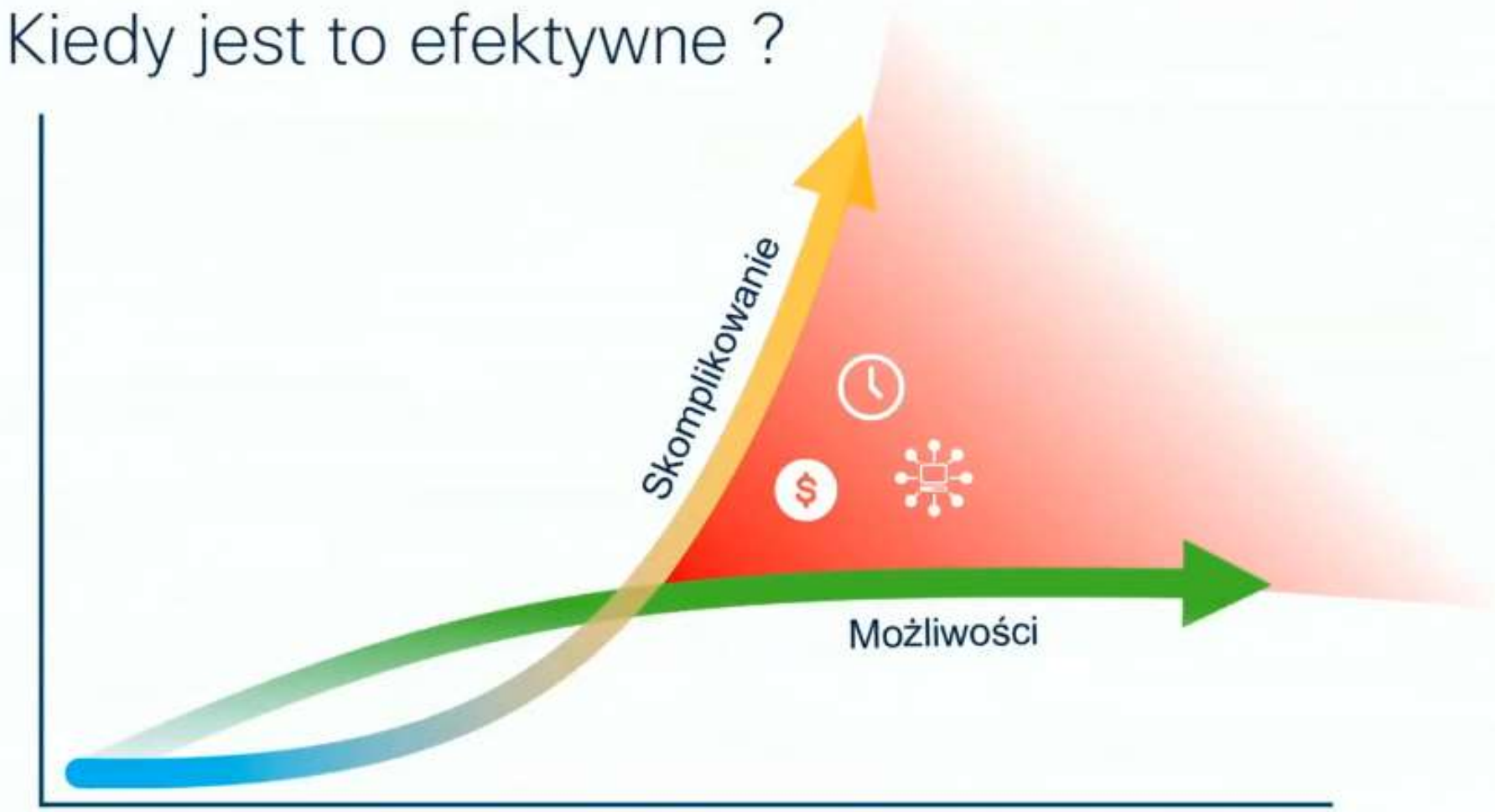
Cyberbezpieczeństwo
jak się chronić ?

Osiągać taki poziom bezpieczeństwa, by **atakującemu nie opłacało się nas zaatakować**

Utrudniając życie atakującemu należy pamiętać, że:

- Atakujący na ogół **omija zabezpieczenia**, atakując od środka
- Obrona powinna składać się z **kilku linii**
- **Złożoność** (skomplikowanie) jest **wrogiem bezpieczeństwa**
- Brak zaobserwowania ataku nie oznacza że go nie było

Cyberbezpieczeństwo
złożoność rozwiązań a bezpieczeństwo



© 2020 Cisco and/or its affiliates. All rights reserved. Cisco Confidential

Cyberbezpieczeństwo
obszary bezpieczeństwa informacji

Podstawowe **obszary bezpieczeństwa** informacji – **CIA + AAN**:

- **C**onfidentiality (**poufność**): dostęp tylko dla stron upoważnionych
- **I**ntegrity (**integralność**): możliwość wykrycia modyfikacji
- **A**vailability (**dostępność**): zapewnienie niezakłóconego dostępu

- **A**uthentication (**uwierzytelnianie**): weryfikacja tożsamości osoby
- **A**uthorization (**autoryzacja**): kontrola dostępu do zasobów
- **N**onrepudation (**niezaprzeczalność**): możliwość udowodnienia inicjatorowi transakcji, że to faktycznie ona była inicjatorem

Cyberbezpieczeństwo
bezpieczeństwo elementem wiarygodności

System wiarygodny:

- **Dyspozycyjny** (available) – dostępny na bieżąco
- **Niezawodny** (reliable) – odporny na awarie
- **Bezpieczny** (secure) – zapewniający ochronę danych
- **Bezpieczny** (safe) – bezpieczny dla otoczenia

BwSK

BwSK

T.Łukaszewski

Cyberbezpieczeństwo
reagować czy zapobiegać?

THE H@CK SUMMIT

Cyberbezpieczeństwo
human factor

Naruszenie procedur bezpieczeństwa – czynnik ludzki

- Niewłaściwe działanie
- Zaniechanie działania

Cyberbezpieczeństwo
human factor

Przyczyny pozasystemowe (ludzkie)

- predyspozycje psychofizyczne – „wypadkowicze” (Karl Marbe – niemiecki psycholog, 1926)
- osobowość, styl życia, sytuacja życiowa – „pilot lata tak, jak żyje” (P. Rippon 1928)
- ograniczenia sprawności, adaptacji, przetwarzania procesów informacyjnych (Frank Mckenny lata 80-te XXw.)
- gdy zawodzą: skills-rules-knowledge (J. Rasmussen 1996)
- sytuacja normalna zmienia się w trudną w wyniku stresu i ryzyka (Ryszard Makarowski)

Cyberbezpieczeństwo
human factor

Przyczyny systemowe (człowiek elementem systemu)

- **SHEL**: Software, hardware, environment, liveware – **nieprawidłowe działanie elementu ma wpływ na pozostałe** (E.Edwards 1972)
- Model sera szwajcarskiego (J.Reason, psycholog, lata 90-te XX wieku)
  - Zarządzanie, kierowanie, warunki, operator, systemy ostrzegawcze
  - Wypadek, gdy błąd na danym (wyższym) poziomie nie zostanie wykryty na innych (niższych) poziomach

BwSK

Cyberbezpieczeństwo
human factor – rozwiązanie !!!

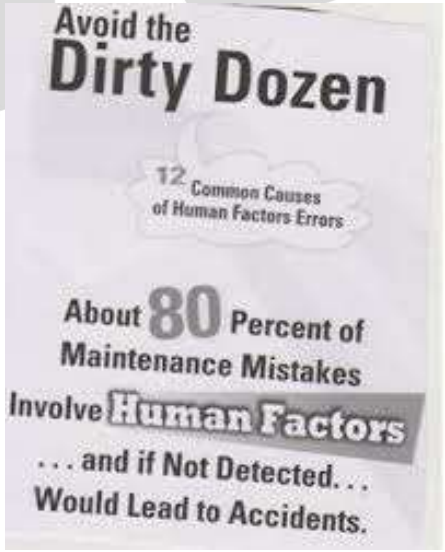
Przyczyny systemowe (człowiek elementem systemu)

- SMS: **Safety Management System** (G. Dupont 1995)
  - zmniejszenie wpływu czynnika ludzkiego przez **szkolenie**, które ma nauczyć unikania błędów oraz zredukować popełnianie błędów do poziomu **As Low As Reasonably Practical**
  - bezpieczeństwo priorytetem (**kultura bezpieczeństwa**)
  - **badanie incydentów związanych z czynnikiem ludzkim w atmosferze zaufania, otwartości i uczciwości**
  - **polityka administracyjna, traktująca niezamierzone błędy jedynie do wyciągnięcia wniosków a nie do działań dyscyplinarnych + raportowanie błędów i incydentów**

Cyberbezpieczeństwo
human factor – rozwiązanie !!!

Przyczyny systemowe (człowiek elementem systemu)

- SMS: Safety Management System (G. Dupont 1995) **dirty dozen**
  - Brak komunikacji
  - Fałszywe poczucie bezpieczeństwa
  - Brak wiedzy
  - Rozproszenie uwagi
  - Nieumiejętność współpracy w grupie
  - Zmęczenie
  - Brak zasobów lub środków finansowych
  - Presja
  - Brak asertywności
  - Stres
  - Brak świadomości
  - Normy



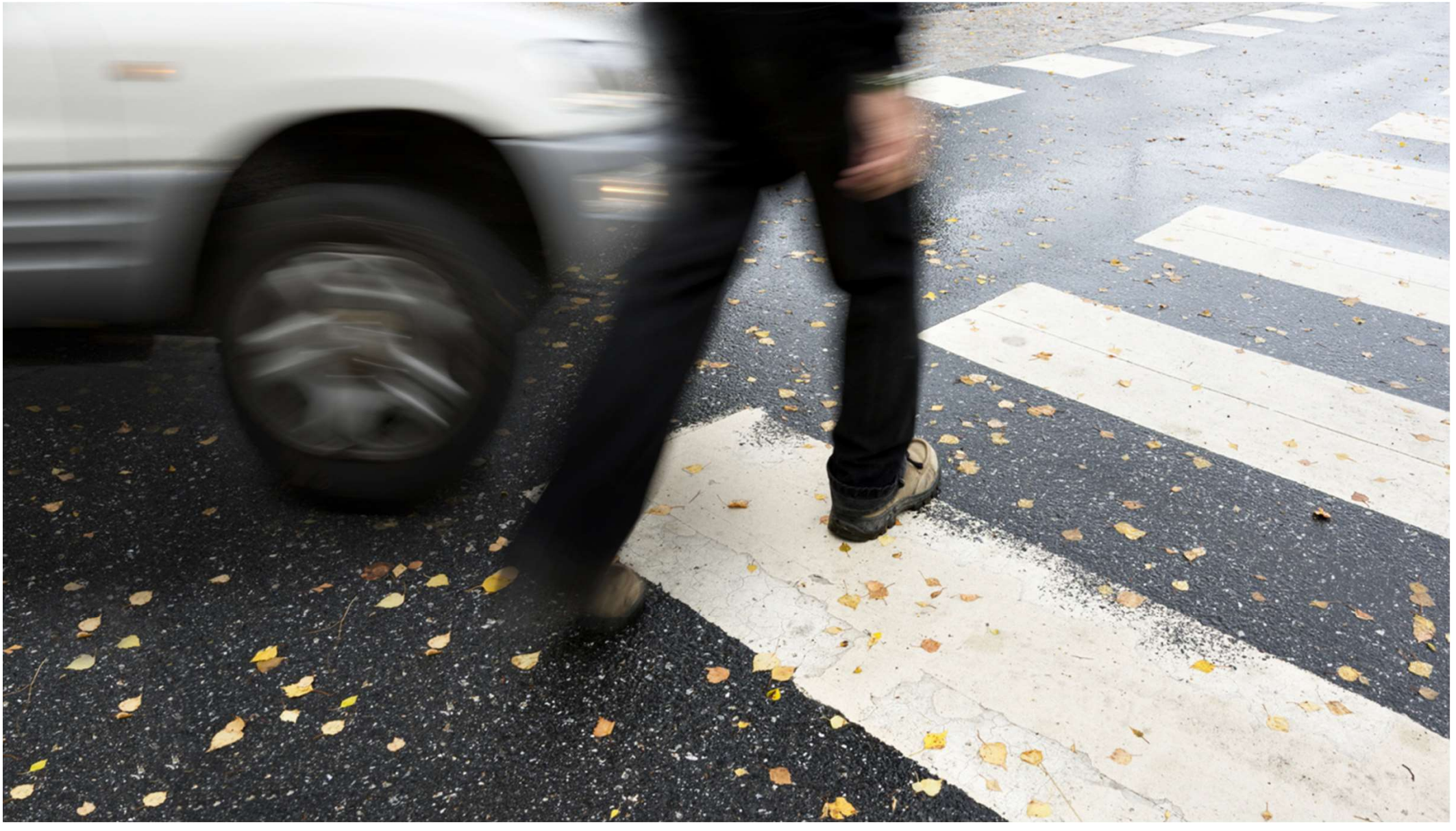
PODSUMOWANIE

BwSK

BwSK

T.Łukaszewski

Podsumowanie
fałszywe poczucie bezpieczeństwa



Podsumowanie
zaufanie i kontrola

BWSK

T.Łukaszewski

Podsumowanie
dobre praktyki

BwSK

T.Łukaszewski

Podsumowanie
dobre praktyki

Proste vs wymagające wiedzy vs wymagające doświadczenia

- Używaj unikalnego hasła
- Używaj oprogramowania zabezpieczającego
- Nie wysyłaj nikomu haseł, nie przekazuj ich ustnie
- Uważaj, tego nie robimy
- Stosuj MFA
- Aktualizuj urządzenia i oprogramowanie
- Sprawdzaj aktywność na koncie
- Przed zamknięciem przeglądarki wyloguj się z serwisu
- Nie zapisuj haseł na karteczkach
- Nie zapisuj haseł na obcych komputerach
- NIe loguj się na obcych urządzeniach
- Przeprowadź kontrolę konta (funkcja)
- Użwaj blokady ekranu i hasła urządzenia
- Nie instaluj oprogramowania spoza oficjalnych źródeł
- Używaj firwalla
- Usuń nieużywane aplikacje i urządzenia z konta
- Kontroluj dostęp nieletnich
- Upewnij się że nikt nie widzi gdy wprowadzasz hasło
- Używaj menadżera haseł
- Nie używaj konta administratora do zwykłej aktywności
- Potwierdź prośby od znajomych innym kanałem

- Twórz hasło ze znakami specjalnymi
- Weryfikuj treść komunikatów
- raportuj phishing i naruszenia
- Weryfikuj bezpieczeństwo sieci WiFi
- Zwracaj uwagę na komunikaty
- Weryfikuj certyfikaty
- Weryfikuj bezpieczeństwo obcego urządzenia
- Dodawaj zaufanych i blokuj niechcianych odbiorców
- Dodawaj tylko osoby które znasz do swojego profilu
- Skontaktuj się z dostawcą w celu potwierdzenia usługi
- Używaj SMS jako 2FA

- Nie klikaj w podejrzane linki
- Nie otwieraj załączników z wiadomości podejrzanych lub nieznanego pochodzenia
- Uważaj na wiadomości nakłaniające Cię do zrobienia czegoś (kliknięcia, otwarcia dokumentu, podania danych)
- Weryfikuj linki i adresy stron
- Twórz hasło o minimalnej długości mniejszej niż 9 znaków
- Zmieniaj regularnie hasła
- nigdy nie zapisuj hasła i nie pozwól by było zapamiętane przez jakąś aplikację
- Twórz hasło krótsze niż 16 znaków
- Weryfikuj numer telefonu

W te stronę maleje szansa użycia praktyki gdy jest potrzebna

Idąc w tym kierunku dobre praktyki stają się „niejasne”
a koszt ich stosowania nie jest usprawiedliwiony obserwacją, tj.
brakuje wsparcia od efektów: pójścia za stadem i powtarzalności

Bezpieczeństwo haseł

Bezpieczeństwo haseł i kryptografii

- ’Psychologia haseł’
  - jak użytkownicy tworzą hasła, zalecenia, 2FA
- Przechowywanie haseł
  - od MD5 do bcrypt
- Łamanie haseł
  - słowniki, reguły, brute force, wycieki

The journey begins…

’Psychologia haseł’

’Psychologia haseł’

Wymagania odnośnie haseł:

1. brak (min. długość 5 znaków)
2. przynajmniej jedna cyfra i przynajmniej jedna duża litera

Które rozwiązanie lepsze?

’Psychologia haseł’

Liczba kombinacji hasła o określonej długości to nic innego jak wariacje z powtórzeniami, wzór:

$$V_n^k = n^k$$

Hasła z samych małych liter pięcioznakowe:

26^5 = 11 mln kombinacji

Hasła z małych i wielkich liter, oraz cyfr, sześcioznakowe:

$(26+26+10)^6 = 62^6$ = 57 mld kombinacji

’Psychologia haseł’

’Psychologia haseł’

Wymóg cyfry w haśle:

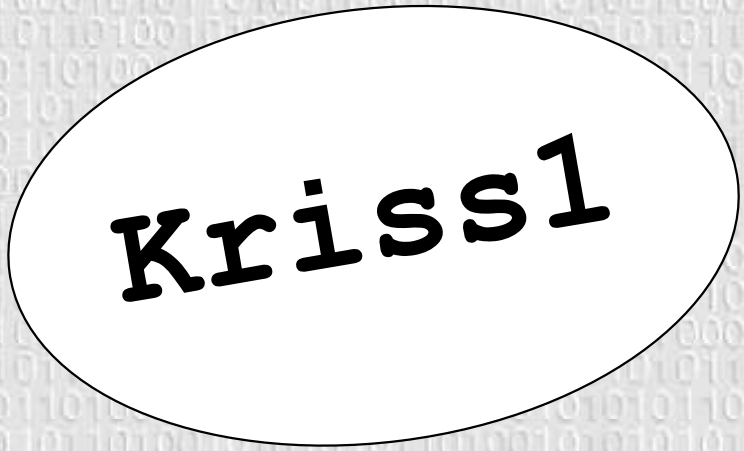
- Gdzie trafi ta cyfra?
- Jaka to będzie cyfra?

do 90%

Wymóg wielkiej litery w haśle:

- Gdzie trafi ta litera?

do 95%



’Psychologia haseł’

Ciekawostka:

- Zasada wielkich i małych liter, cyfr i znaków specjalnych i zmiany hasła co 3 miesiące została zaproponowana w 2003 roku przez Billa Burra pracującego dla amerykańskiego Instytutu ds. Standardów i Technologii.
- W 2017 roku w wywiadzie przyznał szczerze, że żałuje tego co wcześniej zaproponował

- W praktyce bowiem powstają hasła typu **Wiosna2024!** które są słabe i łatwe do złamania

’Psychologia haseł’

Zalecenia:

securitum

Jak wygląda dobre hasło?

Stare zalecenia

minimalnie: 8 znaków, mała, duża litera, znak specjalny, cyfra

Czy takie hasło jest bezpieczne?

Katarzyna!1

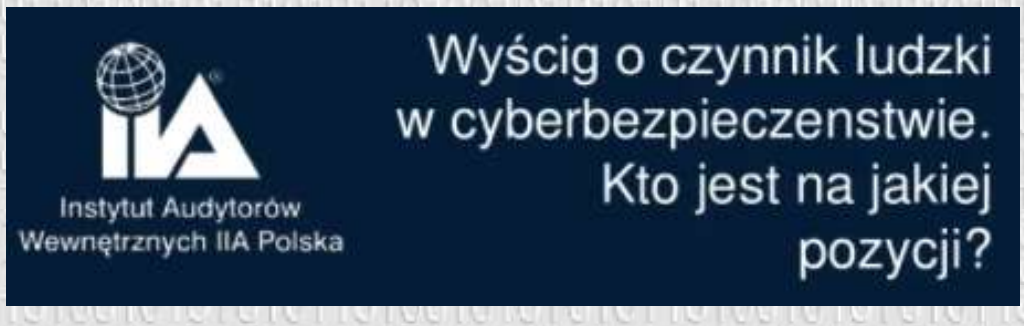
Zobaczmy: https://password.kaspersky.com/

0111001100001

’Psychologia haseł’

(slajd z 2019) Generacje haseł:

GEN	TYP	PROSTE	ZŁOŻONE	WYSIŁEK ZAPAMIĘTANIA	WYSIŁEK UŻYCIA
I	SEKWENCYJNE	PIN (**1234**)	KOLEJNE KLAWISZE (**QWERTY**)	ŁATWE	TRYWIALNE
II	KONTEKSTOWE	DATA (**5/10/90**)	UPRAWNIENIE (**ADMINISTRATOR**)	ŚREDNI	ŁATWE
III	LOSOWE	JEDNORAZOWE (**105 374**)	SPEŁNIAJĄCE KRYTERIA (**K80A^3!#p**)	BARDZO TRUDNE	BARDZO TRUDNE
IV	SCHEMATYCZNE	PODSTAWIENIA (PASS->**1455**)	PODSTAWIENIE I KRYTERIA (STRONGPASSWORD **&7R0NGP455worD**)	WYZWANIE	TRUDNE
V	DŁUGIE ZDANIE	PIN WIZUALNY (**1397**)	WYRAŻENIE HASŁOWE* (**czas na druga kawe**)	ŚREDNI	ŁATWE



’Psychologia haseł’

Zalecenia:

securitum

Jak wygląda dobre hasło?

Nowe zalecenia

~Hasło powinno być długie

np. 20+ znaków, hasło złożone z 4+ względnie losowych słów:

tegohaslanigdyniezapomnisz

0111001100001

’Psychologia haseł’

Zalecenia:

securitum

Jak wygląda dobre hasło?

jeszcze lepsze hasło?

tegochaslanigdyniezapomniż

tegochasla_nigdyniezapomniż

tegochasla_nigdynieZapomniż

0111001100001

’Psychologia haseł’

A może inaczej: 2FA

securitum

2FA

"dwuczynnikowe uwierzytelnienie"

"weryfikacja dwuetapowa"

"uwierzytelnianie dwuskładnikowe"

0111001100001

’Psychologia haseł’

A może inaczej: 2FA (Google Authenticator, SMS)

securitum

Ktoś nam przejmie hasło, ale nie ma dostępu do naszego telefonu!

= nie może się zalogować

0111001100001

A może inaczej: 2FA (klucz)

securitum

Najbezpieczniejsza metoda logowania

Klucz sprzętowy

https://www.yubico.com/products/

0111001100001

In the middle of the journey …

Przechowywanie haseł

Przechowywanie haseł

Przechowywanie niezakodowane (plain text):

- hasło jest widoczne dla nas
- hasło jest widoczne dla naszych pracowników / współpracowników, którzy mają jakiś dostęp
- w razie jakiegokolwiek wycieku od razu dostępne są hasła
- narażamy się na ośmieszenie, jeżeli to wyjdzie
- jako użytkownik serwisu chciałbym wiedzieć, że koduje hasła

Przechowywanie haseł

Przechowywanie niezakodowane (plain text):

- Facebook 2019 – 600 mln haseł użytkowników bez szyfrowania. Dane były wprawdzie w wewnętrznej sieci Facebooka, ale dostęp do nich miało … 20000 osób

- 2018 – Twitter i GitHub przechowywały hasła bez szyfrowania w logach niedostępnych publicznie

Przechowywanie haseł

Przechowywanie **skrótu hasła** (hash):

- łatwe
- szybkie
- nie kosztuje
- i podobno jest dobre…

Więc właściwie czemu tego nie robić?

Przechowywanie haseł

Standard (z przeszłości) - MD5

Nowe funkcje skrótu:

FAQ

6. Dobre algorytmy do przechowywania haseł?

bcrypt

PBKDF2

Argon2

Manager haseł

keepass.info

KeePass Password Safe

OSI certified

KeePass
Password Safe

This is the official website of KeePass, the free, open source, light-weight and easy-to-use password manager.

[Awards] [RSS Feed]

Home
- Home & News
- Forums
- Feature List
- Screenshots

Getting KeePass
- Downloads
- Translations
- Plugins / Ext.

Information / WWW
- Help
- FAQ
- Security
- Awards
- Links

Support KeePass
- Donate

Latest News

KeePass 2.46 released
2020-09-10 14:03. Read More »

KeePass 2.45 released
2020-05-07 14:51. Read More »

KeePass 2.44 released
2020-01-20 14:22. Read More »

KeePass 1.38 released
2020-01-13 15:02. Read More »

[News Archive]

Why KeePass?
Today, you have to remember many passwords. You need a password for a lot of websites, your e-mail account, your webserver, network logins, etc. The list is endless. Also, you should use a different password for each account, because if you would use only one password everywhere and someone gets this password, you would have a problem: the thief would have access to *all* of your accounts.

KeePass is a free open source password manager, which helps you to manage your passwords in a secure way. You can store all your passwords in one database, which is locked with a master key. So you only have to remember one single master key to unlock the whole database. Database files are encrypted using the best and most secure encryption algorithms currently known (AES-256, ChaCha20 and Twofish). For more information, see the features page.

Is it really free?
Yes, KeePass is really free, and more than that: it is open source (OSI certified). You can have a look at its full source code and check whether the security features are implemented correctly.

As a cryptography and computer security expert, I have never understood the current fuss about the open source software movement. In the cryptography world, we consider open source necessary for good security; we have for decades. Public security is always more secure than proprietary security. It's true for cryptographic algorithms, security protocols, and security source code. For us, open source isn't just a business model; it's smart engineering practice.
Bruce Schneier, Crypto-Gram 1999-09-15.

Copyright © 2003-2020 Dominik Reichl. [Legal Contact / Imprint] [Terms & Privacy] [Acknowledgements] [Donate]

Final battle…

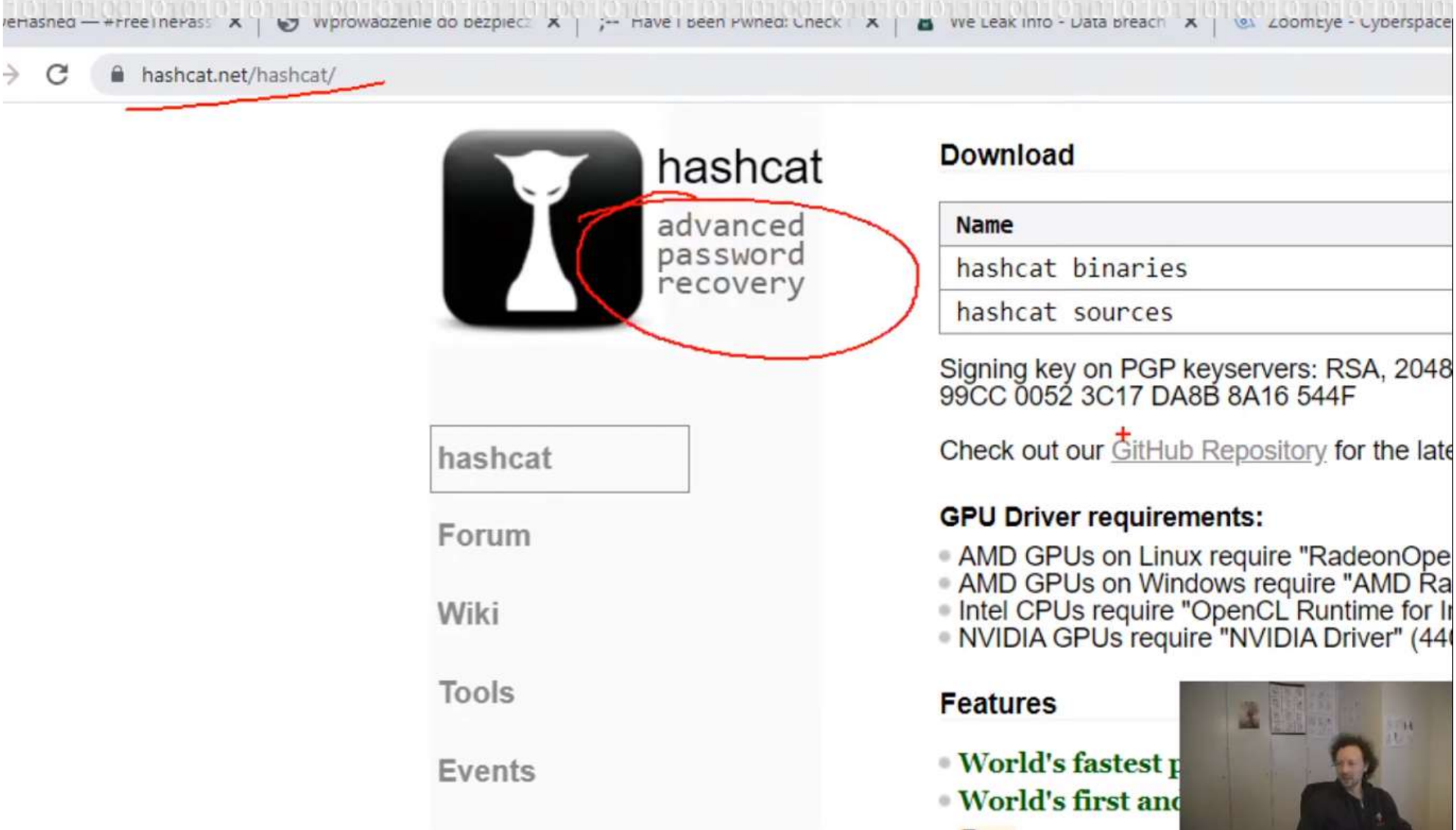
Łamanie haseł

Łamanie haseł

Jak łamać hasła (mając bazę hashy)?

- Generujemy hashe ze słownika (+modyfikacje regułami) (**atak słownikowy/heurystyczny**)
- Generujemy hashe dla wszelkich możliwych ciągów znaków **(atak brute force)**
-
- Generujemy hashe dla wszelkich możliwych haseł i zapamiętujemy (**atak z bazą danych**)

Jak łamać hasła?



Łamanie haseł

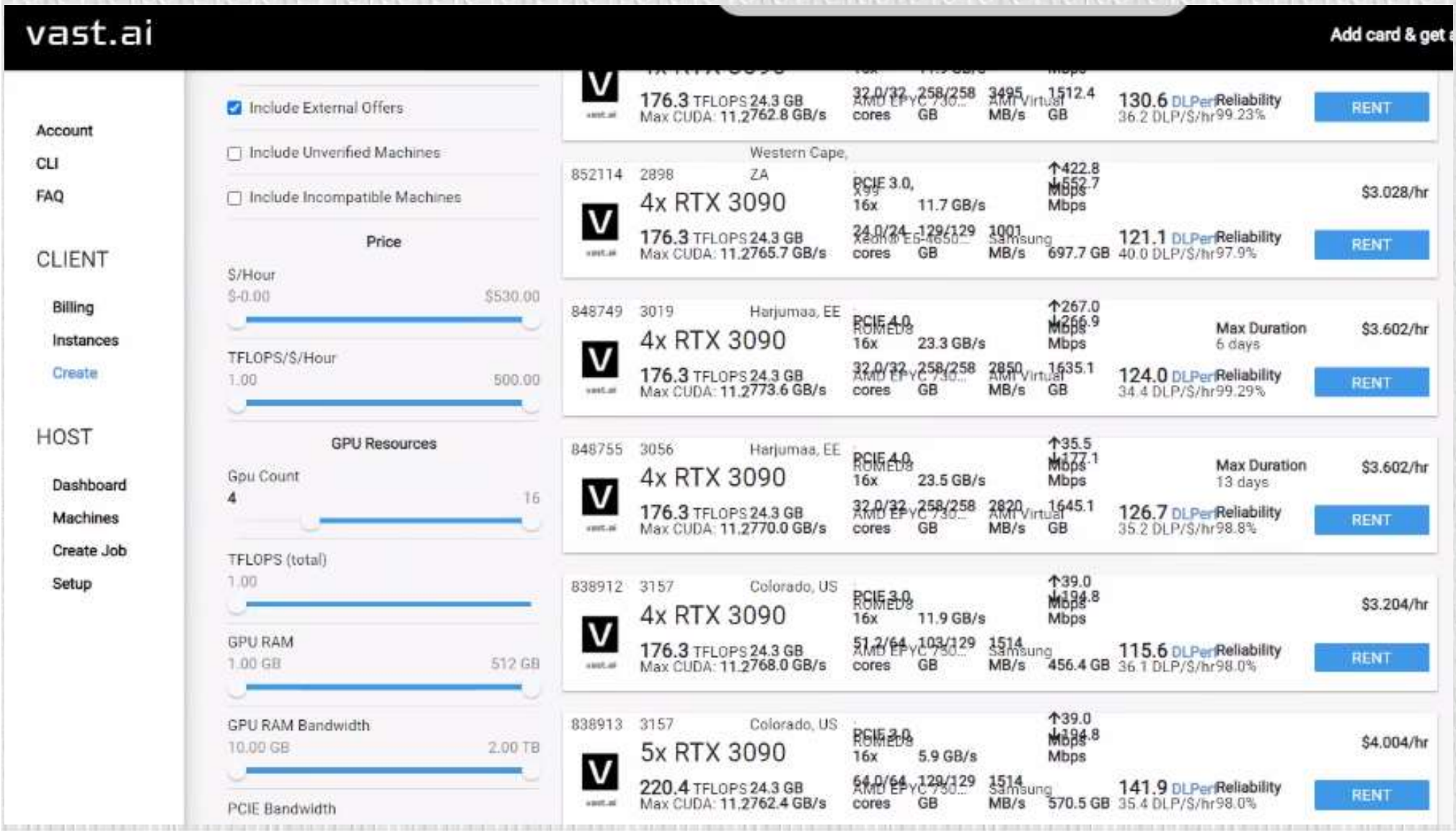
Estimated Password Recovery Times — 1x Terahash Brutalis, 44x Terahash Inmanis (448x Nvidia RTX 2080)

Full US keyboard mask attack with Terahash Hashstack

Lipiec 2019

	Speed	Length 4	Length 5	Length 6	Length 7	Length 8	Length 9	Length 10	Length 11	Length 12	Length 13
NTLM	31.82 TH/s	Instant	Instant	Instant	Instant	3 mins 29 secs	5 hrs 30 mins	3 wks 0 day	5 yrs 7 mos	538 yrs 1 mo	51.2 mil
MD5	17.77 TH/s	Instant	Instant	Instant	Instant	6 mins 14 secs	9 hrs 50 mins	1 mo 1 wk	10 yrs 1 mo	963 yrs 4 mos	91.6 mil
NetNTLMv1 / NetNTLMv1+ESS	16.82 TH/s	Instant	Instant	Instant	Instant	6 mins 35 secs	10 hrs 24 mins	1 mo 1 wk	10 yrs 8 mos	1 mil	96.8 mil
LM	15.81 TH/s	Instant	Instant	Instant	Instant						
SHA1	5.89 TH/s	Instant	Instant	Instant	Instant	18 mins 47 secs	1 day 5 hrs	3 mos 3 wks	30 yrs 7 mos	2.9 mil	276.3 mil
SHA2-256	2.42 TH/s	Instant	Instant	Instant	Instant	45 mins 39 secs	3 days 0 hr	9 mos 1 wk	74 yrs 4 mos	7.1 mil	671.9 mil
NetNTLMv2	1.22 TH/s	Instant	Instant	Instant	Instant	1 hr 30 mins	5 days 23 hrs	1 yr 6 mos	147 yrs 10 mos	14.1 mil	1335.5 mil
SHA2-512	801.9 GH/s	Instant	Instant	Instant	1 min 28 secs	2 hrs 17 mins	1 wk 2 days	2 yrs 4 mos	224 yrs 9 mos	21.4 mil	2029.7 mil
descrypt, DES (Unix), Traditional DES	647.59 GH/s	Instant	Instant	Instant	1 min 48 secs	2 hrs 50 mins	1 wk 4 days	2 yrs 11 mos	278 yrs 3 mos	26.5 mil	2513.3 mil
Kerberos 5, etype 23, TGS-REP	206.97 GH/s	Instant	Instant	Instant	5 mins 38 secs	8 hrs 54 mins	1 mo 0 wk	9 yrs 2 mos	870 yrs 10 mos	82.8 mil	7864 mil
Kerberos 5, etype 23, AS-REQ Pre-Auth	206.78 GH/s	Instant	Instant	Instant	5 mins 38 secs	8 hrs 54 mins	1 mo 0 wk	9 yrs 2 mos	871 yrs 8 mos	82.9 mil	7871.2 mil
md5crypt, MD5 (Unix), Cisco-IOS 1 (MD5)	7.61 GH/s	Instant	Instant	1 min 37 secs	2 hrs 33 mins	1 wk 3 days	2 yrs 7 mos	249 yrs 5 mos	23.7 mil	2252.6 mil	213995.1 mil
LastPass + LastPass sniffed	1.78 GH/s	Instant	Instant	6 mins 52 secs	10 hrs 52 mins	1 mo 1 wk	11 yrs 2 mos	1.1 mil	101.1 mil	9600.8 mil	912079.6 mil
macOS v10.8+ (PBKDF2-SHA512)	335.09 MH/s	Instant	Instant	36 mins 34 secs	2 days 9 hrs	7 mos 2 wks	59 yrs 7 mos	5.7 mil	538.2 mil	51127.7 mil	4857134 mil
WPA-EAPOL-PBKDF2	277.23 MH/s					9 mos 0 wk	72 yrs 0 mo	6.8 mil	650.5 mil	61799.3 mil	5870931.8 mil
TrueCrypt RIPEMD160 + XTS 512 bit	211.78 MH/s	Instant	Instant	57 mins 52 secs	3 days 19 hrs	11 mos 3 wks	94 yrs 3 mos	9 mil	851.6 mil	80899.5 mil	7685455.6 mil
7-Zip	181.51 MH/s	Instant	Instant	1 hr 7 mins	4 days 10 hrs	1 yr 1 mo	110 yrs 0 mo	10.5 mil	993.6 mil	94389.2 mil	8966975.1 mil
sha512crypt 6, SHA512 (Unix)	119.46 MH/s	Instant	1 min 5 secs	1 hr 42 mins	6 days 18 hrs	1 yr 9 mos	167 yrs 2 mos	15.9 mil	1509.7 mil	143419.6 mil	13624861.4 mil
DPAPI masterkey file v1	47.23 MH/s	Instant	2 mins 44 secs	4 hrs 19 mins	2 wks 3 days	4 yrs 5 mos	422 yrs 10 mos	40.2 mil	3818.1 mil	362723.1 mil	34458696.1 mil
RAR5	28.15 MH/s	Instant	4 mins 35 secs	7 hrs 15 mins	4 wks 0 day	7 yrs 5 mos	709 yrs 7 mos	67.4 mil	6407.6 mil	608720.6 mil	57828453.9 mil
DPAPI masterkey file v2	27.82 MH/s	Instant	4 mins 39 secs	7 hrs 20 mins	4 wks 1 day	7 yrs 6 mos	717 yrs 10 mos	68.2 mil	6482.1 mil	615797.6 mil	58500769.5 mil
RAR3-hp	20.84 MH/s	Instant	6 mins 12 secs	9 hrs 47 mins	1 mo 1 wk	10 yrs 1 mo	958 yrs 2 mos	91.1 mil	8652.3 mil	821972.3 mil	78087367.8 mil
KeePass 1 (AES/Twofish) and KeePass 2 (AES)	17.8 MH/s	Instant	7 mins 15 secs	11 hrs 28 mins	1 mo 2 wks	11 yrs 9 mos	1.1 mil	106.7 mil	10131.9 mil	962529.5 mil	91440305.8 mil
bcrypt $2*$, Blowfish (Unix)	11.37 MH/s	Instant	11 mins 21 secs	17 hrs 57 mins	2 mos 1 wk	18 yrs 5 mos	1.8 mil	167 mil	15860.3 mil	1506727.9 mil	143139150.9 mil
Bitcoin/Litecoin wallet.dat	3.55 MH/s	Instant	36 mins 18 secs	2 days 9 hrs	7 mos 2 wks	59 yrs 1 mo	5.6 mil	534.1 mil	50743.7 mil	4820655.6 mil	457962282.7 mil

Karty GPU do wynajęcia - prywatne



Karty GPU do wynajęcia - Amazon EC2 G3

Name	GPUs	vCPU	Memory (GiB)	GPU Memory (GiB)	Price/hr* (Linux)	Price/hr* (Windows)
g3s.xlarge	1	4	30.5	8	$0.75	$0.93
g3.4xlarge	1	16	122	8	$1.14	$1.876
g3.8xlarge	2	32	244	16	$2.28	$3.752
g3.16xlarge	4	64	488	32	$4.56	$7.504

Karty GPU do wynajęcia - Amazon EC2 P3

Amazon EC2 P3 instance product details

Instance Size	GPUs - Tesla V100	GPU Peer to Peer	GPU Memory (GB)	vCPUs	Memory (GB)	Network Bandwidth	EBS Bandwidth	On-Demand Price/hr*
p3.2xlarge	1	N/A	16	8	61	Up to 10 Gbps	1.5 Gbps	$3.06
p3.8xlarge	4	NVLink	64	32	244	10 Gbps	7 Gbps	$12.24
p3.16xlarge	8	NVLink	128	64	488	25 Gbps	14 Gbps	$24.48
p3dn.24xlarge	8	NVLink	256	96	768	100 Gbps	19 Gbps	$31.218

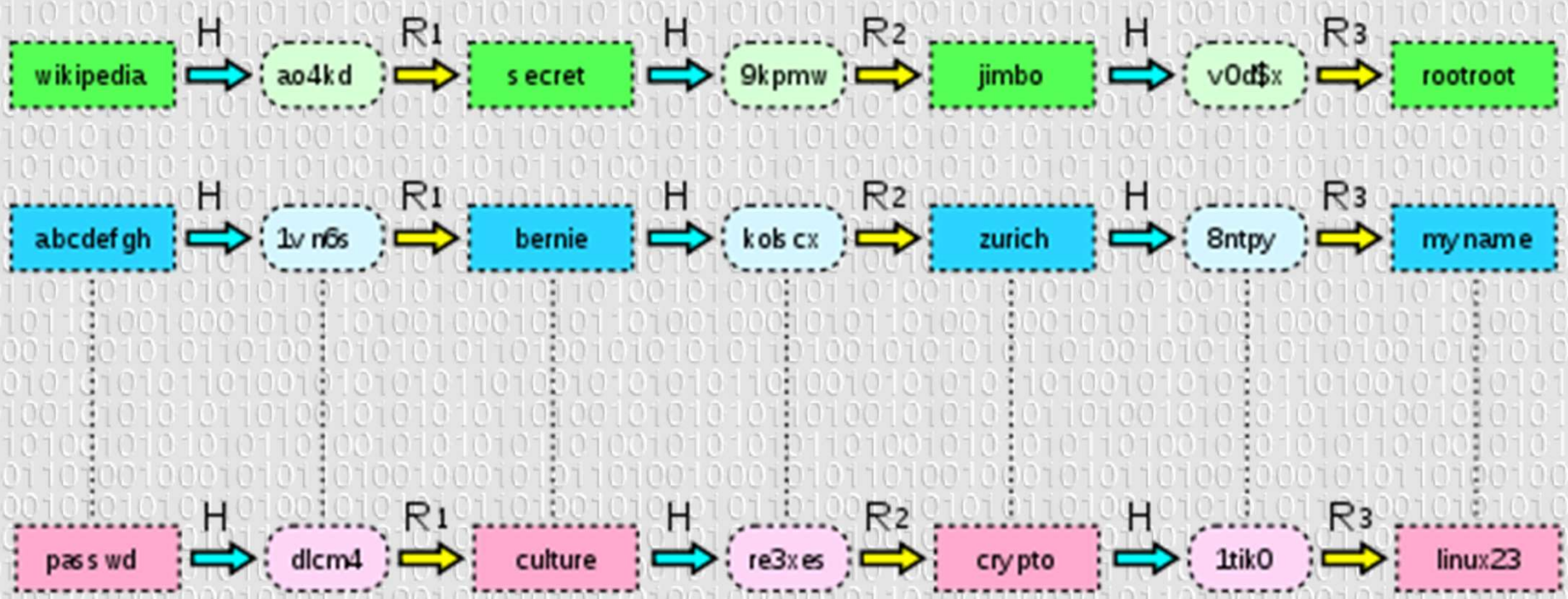
Reverse MD5 - bazy hashy MD5:

http://google.pl/search?q=200820e3227815ed1756a6b531e7e0d2

http://ilia.ws/archives/89-Reverse-MD5-Search-Aggregator.html

Jednak skuteczność ograniczona do bazy…

Rozwiązanie: Tęczowe tablice (Rainbow tables – RT)



RT: Zamiast całych list hashy przechowywane są pierwszy plaintext i ostatni hash z łańcucha:

```
plaintext hash
iaisudhiu 4259cc34599c530b1e4a8f225d665802
oxcvioix c744b1716cbf8d4dd0ff4ce31a177151
9da8dasf 3cd696a8571a843cda453a229d741843
[...] [...]
sodifo8sf 7ad7d6fa6bb4fd28ab98b3dd33261e8f
```

Algorytm wykonuje operacje wyłącznie na tym naszym hashu, który łamiemy, co wielokrotnie obniża złożoność obliczeniową.

Łamanie haseł

- RT:

MD5 Rainbow Tables

Table ID	Charset	Plaintext Length	Key Space	Success Rate	Table Size
md5_ascii-32-95#1-7	ascii-32-95	1 to 7	70,576,641,626,495	99.9 %	52 GB 64 GB
md5_ascii-32-95#1-8	ascii-32-95	1 to 8	6,704,780,954,517,120	96.8 %	460 GB 576 GB
md5_mixalpha-numeric#1-8	mixalpha-numeric	1 to 8	221,919,451,578,090	99.9 %	127 GB 160 GB
md5_mixalpha-numeric#1-9	mixalpha-numeric	1 to 9	13,759,005,997,841,642	96.8 %	690 GB 864 GB
md5_loweralpha-numeric#1-9	loweralpha-numeric	1 to 9	104,461,669,716,084	99.9 %	65 GB 80 GB
md5_loweralpha-numeric#1-10	loweralpha-numeric	1 to 10	3,760,620,109,779,060	96.8 %	316 GB 396 GB

http://project-rainbowcrack.com

Jak się bronić, czyli salt (ang. sól)

```
#znak którego nie ma w tablicach
$hash = md5( $passwd."\n" );
```

```
#stały salt
$salt = "[w&3.B+ó`";
$hash = md5( $salt.$passwd );
```

```
#paranoja bywa dobra
$hash = md5( $salt.md5($passwd) );
```

```
#zmienny salt
$salt = microtime();
$hash = md5( $salt.md5($passwd) );
zapisz_salt();
```

```
#zmienny salt, który mamy już zapamiętany
$j = md5( $line['joined'] );
$salt = "[".$j[3]."&".$j[27].".".$j[11]."+".$j[16]."`";
$hash = md5( $salt.md5($passwd) );
```

Łamanie haseł

Jak się bronić, czyli salt (ang. sól)

Sól była zabezpieczeniem przed tęczowymi tablicami

Sól wydłuża czas łamania

Sól powinna być unikalna dla każdego użytkownika – spada szybkość łamania

Dlaczego warto mieć różne hasła do różnych serwisów …

… wycieki danych osobowych (w tym haseł)

Wycieki haseł

securmum

Jak sprawdzić czy moje dane wyciekły?

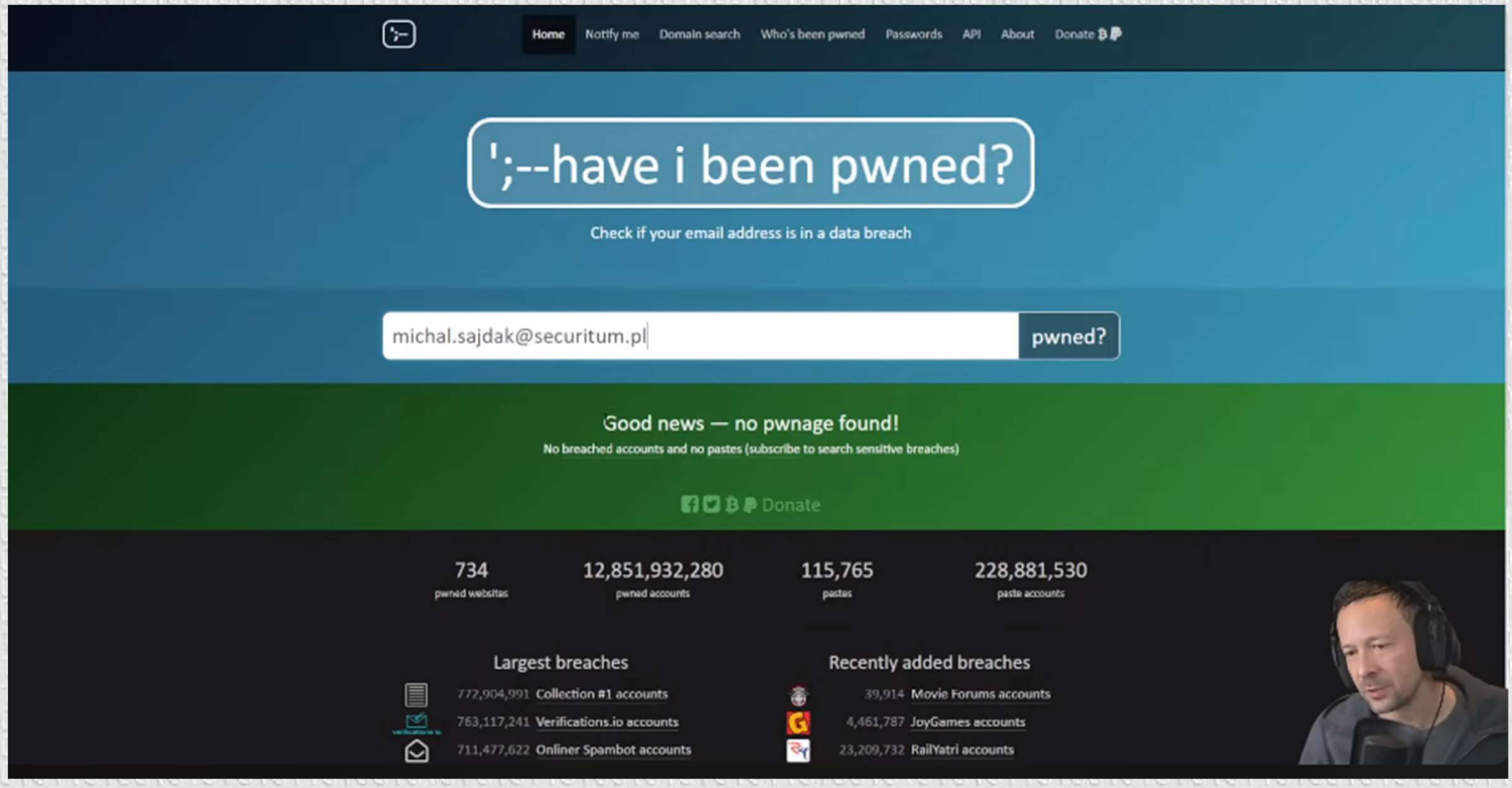
https://haveibeenpwned.com/

https://weleakinfo.to/

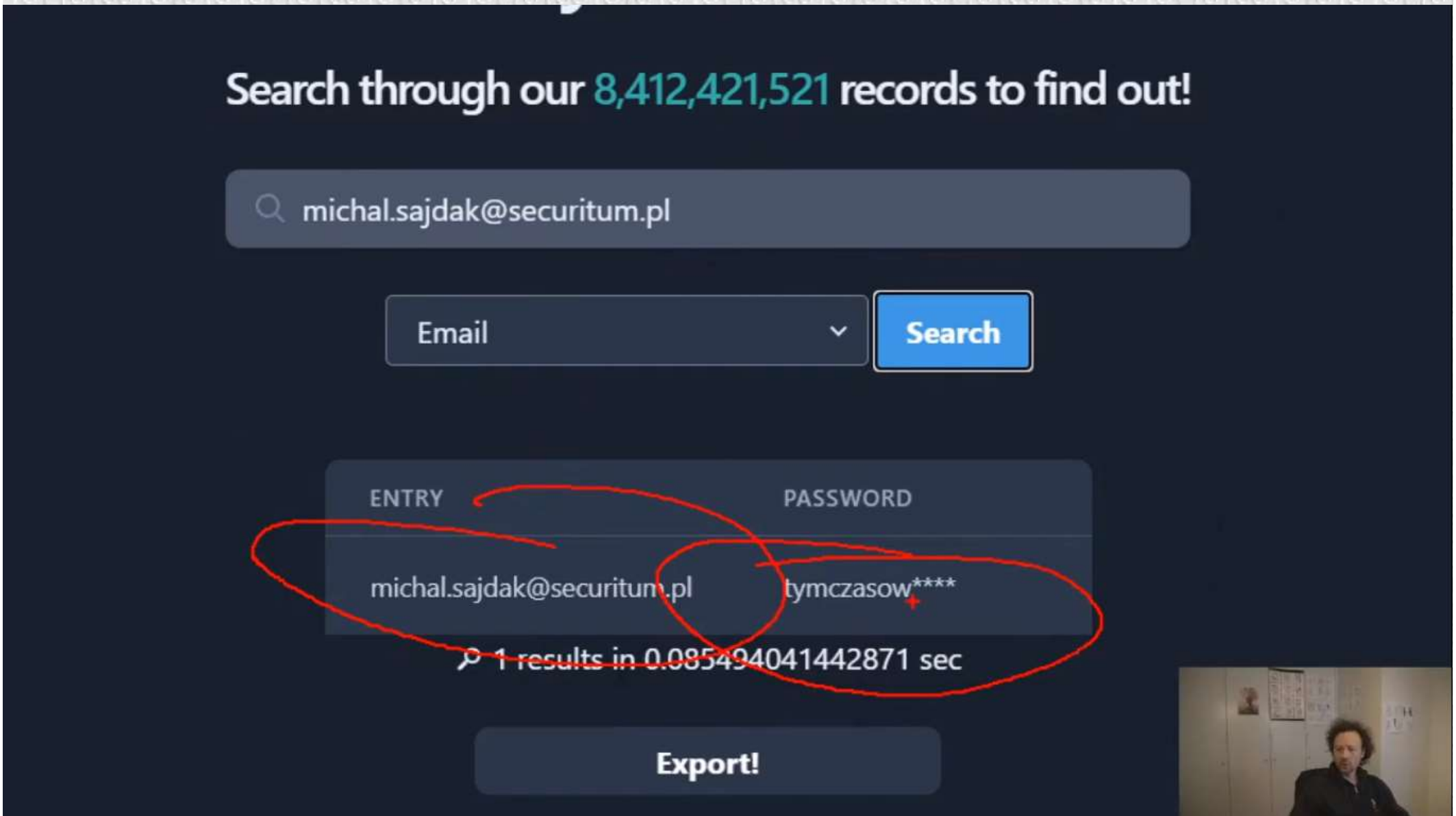
https://dehashed.com/

0111001100001

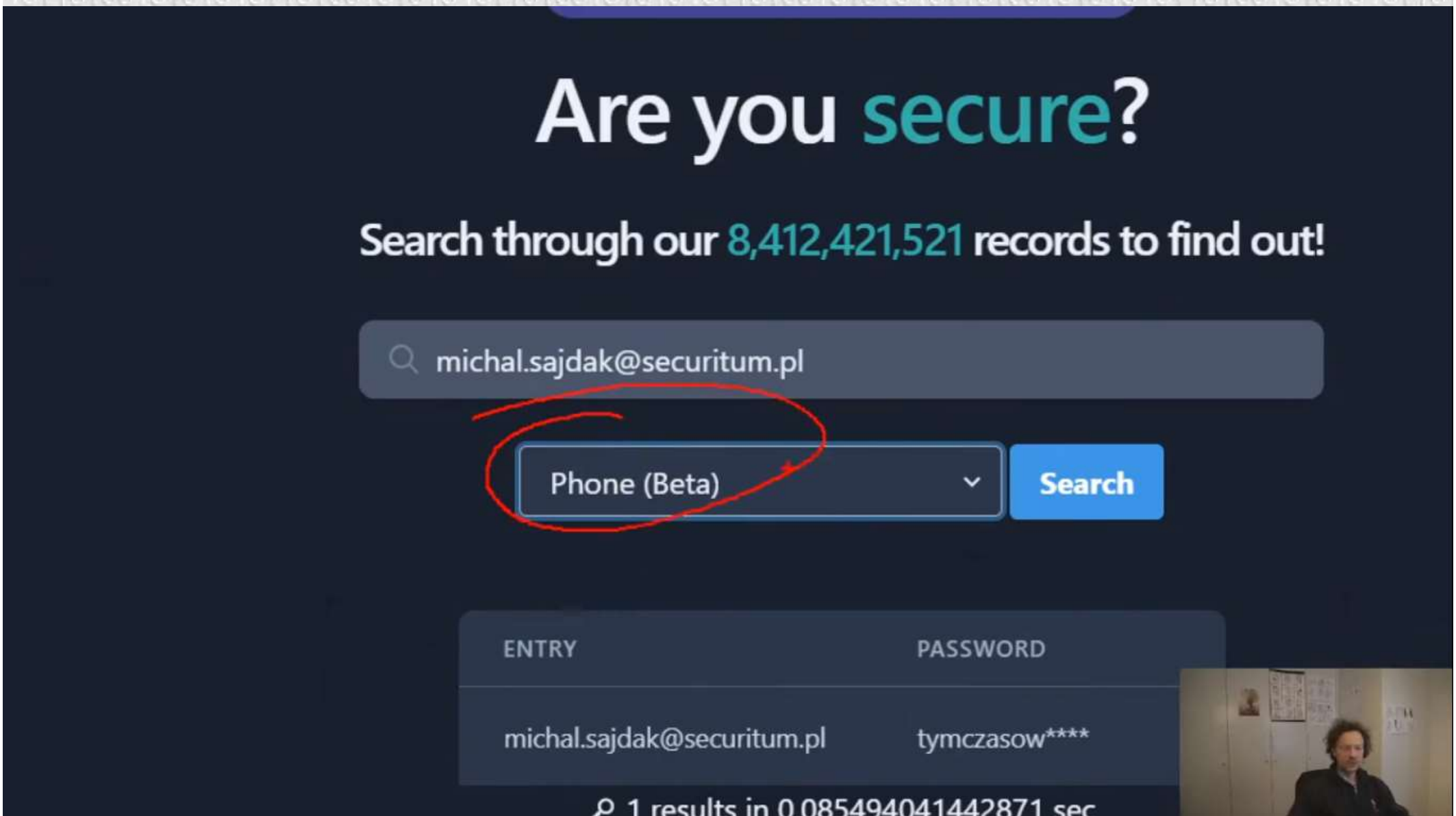
Wycieki – have i been pwned



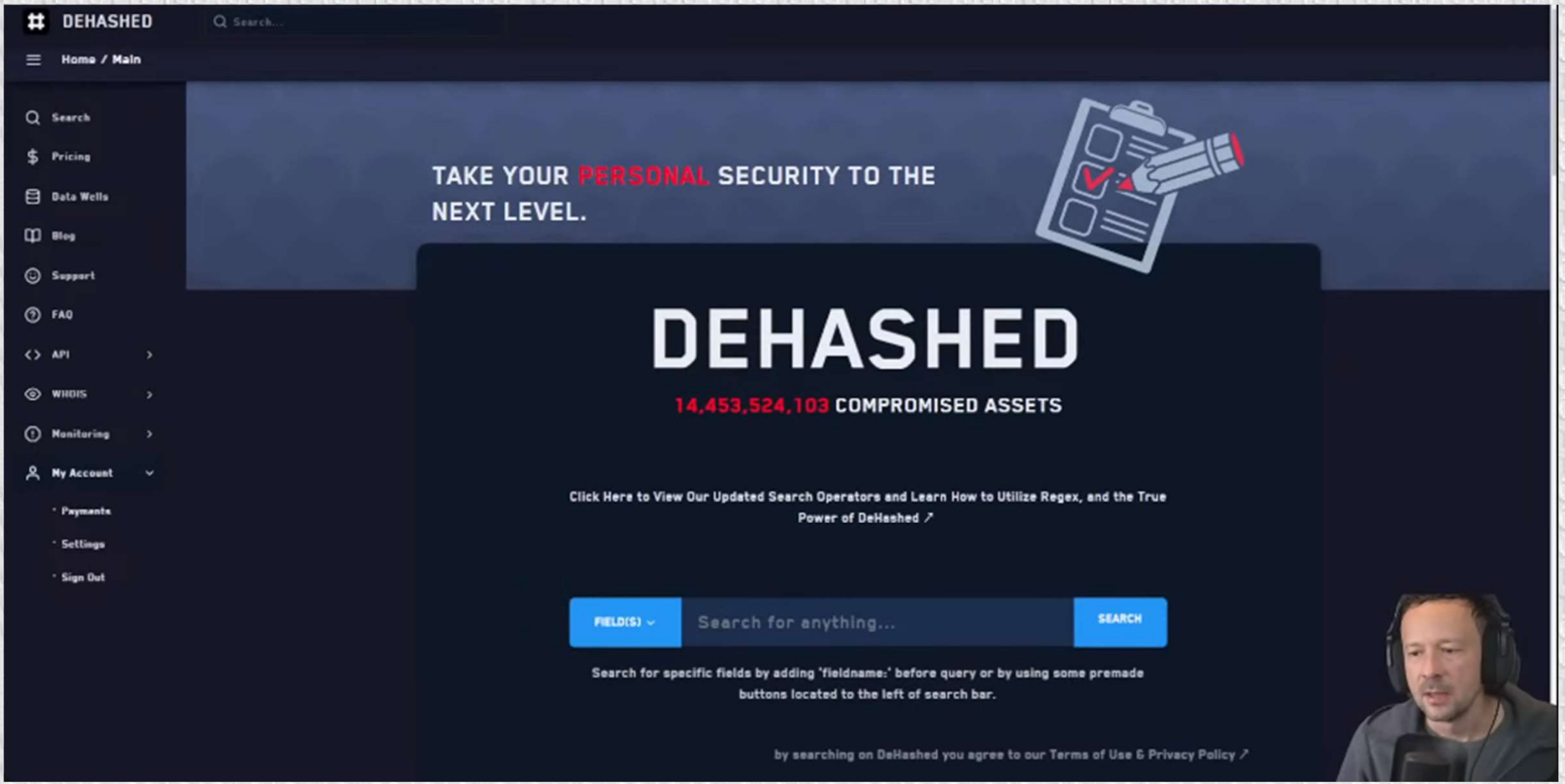
Wycieki – we leak info v2.



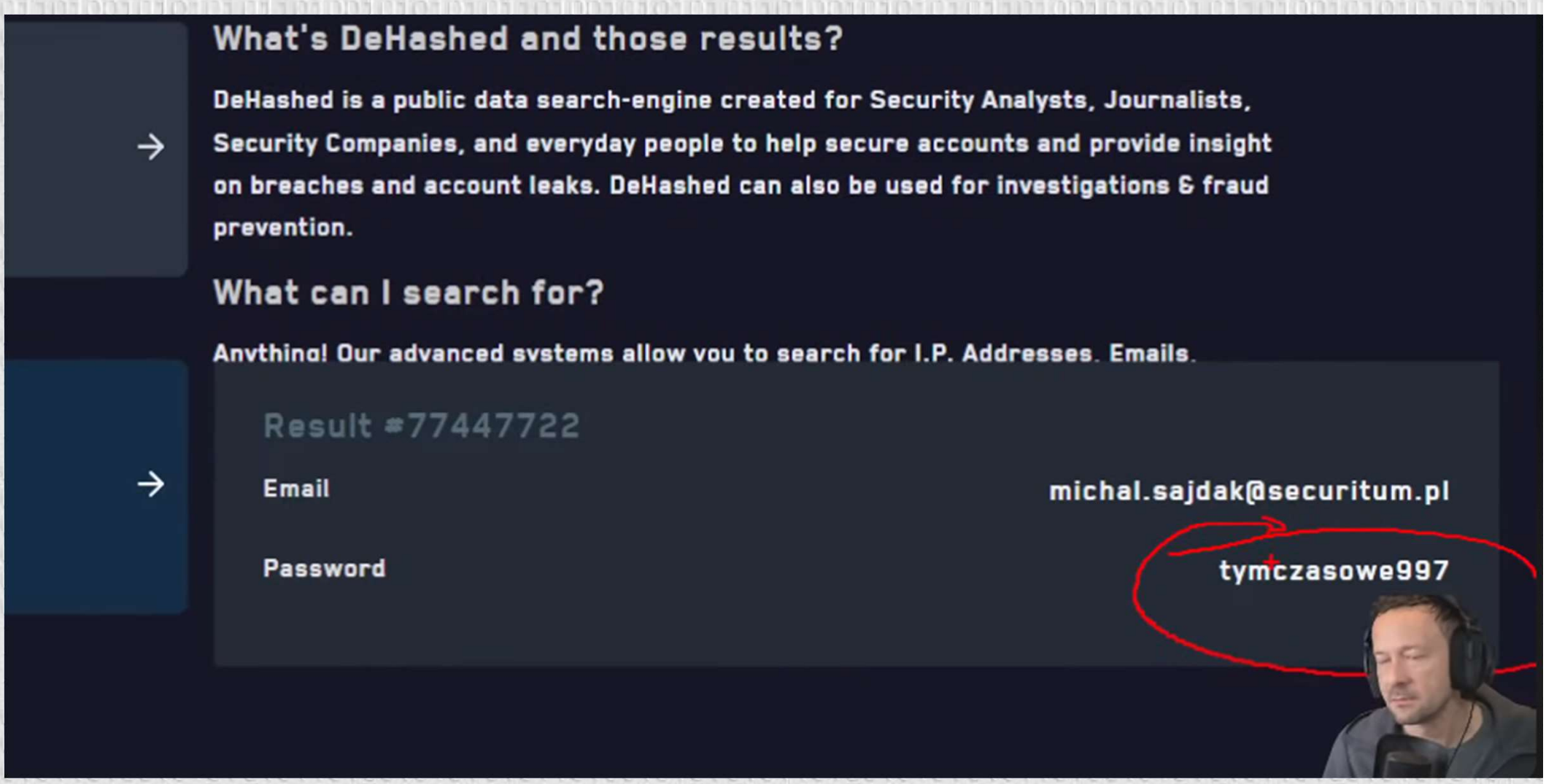
Wycieki – we leak info v2.



Wycieki – dehashed



Wycieki – dehashed



Wycieki – hashes.org (FBI/awaria?)

Kampanie fałszywych e-maili po wyciekach

securitum

Kampania fałszywych maili (również po polsku) sugerujących dostęp do kamery / mikrofonu i żądających okupu w BTC

https://sekurak.pl/kampania-falszywych-maili-rowniez-po-polsku-sugerujacych-dostep-do-kamery-mikrofonu-i-zadajacych-okupu-w-btc/

0111001100001

Cześć!

Niestety, mam dla Ciebie złe wiadomości.
Parę miesięcy temu zdobyłem dostęp do urządzenia, którego używasz do przeglądania internet.
Od tego czasu monitorowałem Twoją aktywność internetową.

Jako regularny odwiedzający stron dla dorosłych, mogę potwierdzić, że ty jesteś za to odpowiedzialny.
Mówiąc wprost, strony, które odwiedzasz, dały mi dostęp do Twoich danych.

Załadowałem Trojana w bazę Twoich driverów, który uaktualnia swoją sygnaturę parę razy dziennie, co sprawia, że antywirus nie jest w stanie go wykryć.
Na dodatek daje mi on dostęp do Twojej kamery i mikrofonu.
Co więcej, zapisałem wszystkie dane, w tym zdjęcia, media społecznościowe, czaty i kontakty.

Ostatnio wpadłem na zajebisty pomysł stworzenia filmu, gdzie dochodzisz w jednej części ekranu, gdy w drugiej jednocześnie odtwarza się film, który oglądałeś.
To było śmieszne!

Bądź spokojny, że z łatwością mogę wysłać ten film do wszystkich Twoich kontaktów paroma klikami, zakładam, że wolałbyś uniknąć takiego scenariusza.

Mając to na uwadze, taka jest moja propozycja:
Prześlij równowartość 1230 EUR na mój portfel Bitcoin, a zapomnę o całej sprawie. Usunę również wszystkie dane i filmy na zawsze.

Według mnie to dość umiarkowana cena za moją pracę.
Możesz zorientować się, jak kupić Bitcoiny za pomocą wyszukiwarek Google, czy Bing, sam zobaczysz, że nie jest to aż tak trudne.

Mój portfel Bitcoin (BTC): 15f7b4FfPS8fWwkDmh4QMdvsfhja1yN8As

Masz 48 godzin na odpowiedź, powinieneś pamiętać o tym, że:
Nie ma sensu mi odpowiadać — adres został wygenerowany automatycznie.
Nie ma sensu narzekać, ponieważ wiadomość wraz z portfelem Bitcoin nie mogą być namierzone.
Wszystko zostało precyzyjnie zaplanowane.

Jeśli wykryję, że powiedziałeś komuś o tym liście - film natychmiast zostanie udostępniony, a Twoje kontakty otrzymają go jako pierwsze.
Następnie film zostanie opublikowany w sieci!

P.S. Czas odliczania się rozpocznie, gdy otworzysz ten list. (Program ma wbudowany zegar).

Powodzenia i uważaj na siebie! Miałeś pecha, następnym razem bądź ostrożniejszy.

Postępowanie po wyciekach haseł/danych

securitum

Co robić?

Zmiana haseł

Unikalne hasła

BIK

- alert BIK gdy kredyt
- zastrzeżenie kredytowe

e-sąd Lublin - powiadomienia mailowe

posiadając konto dostanę wszelkie informacje o toczącym się postępowaniu (powiadomienia)

PODSUMOWANIE

securitum

Używaj bezpiecznych haseł!

Idealnie: 4+ nieoczywiste sklejone słowa. Długość: >= 15 znaków

smiesznelatwedozapamietania

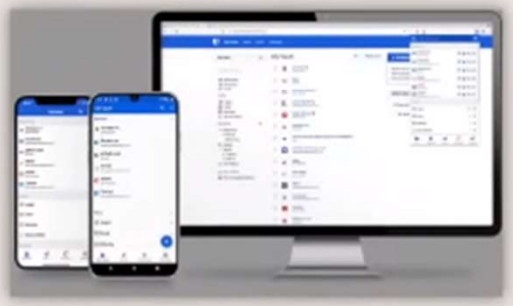
Nie używaj tego samego hasła w różnych systemach!

DEMO

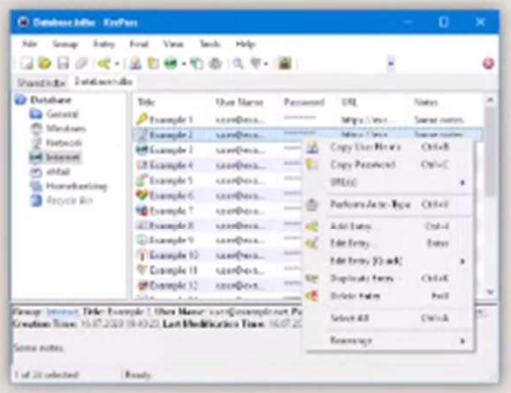
PODSUMOWANIE

securitum

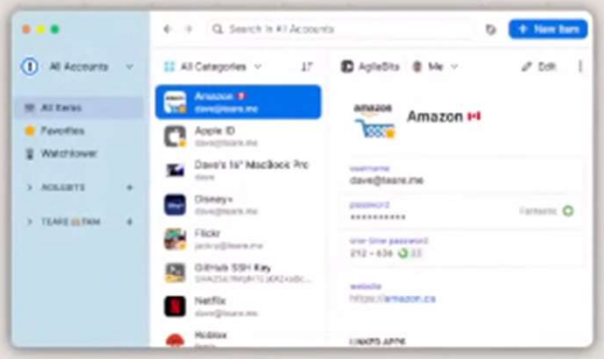
Używaj managerów haseł!



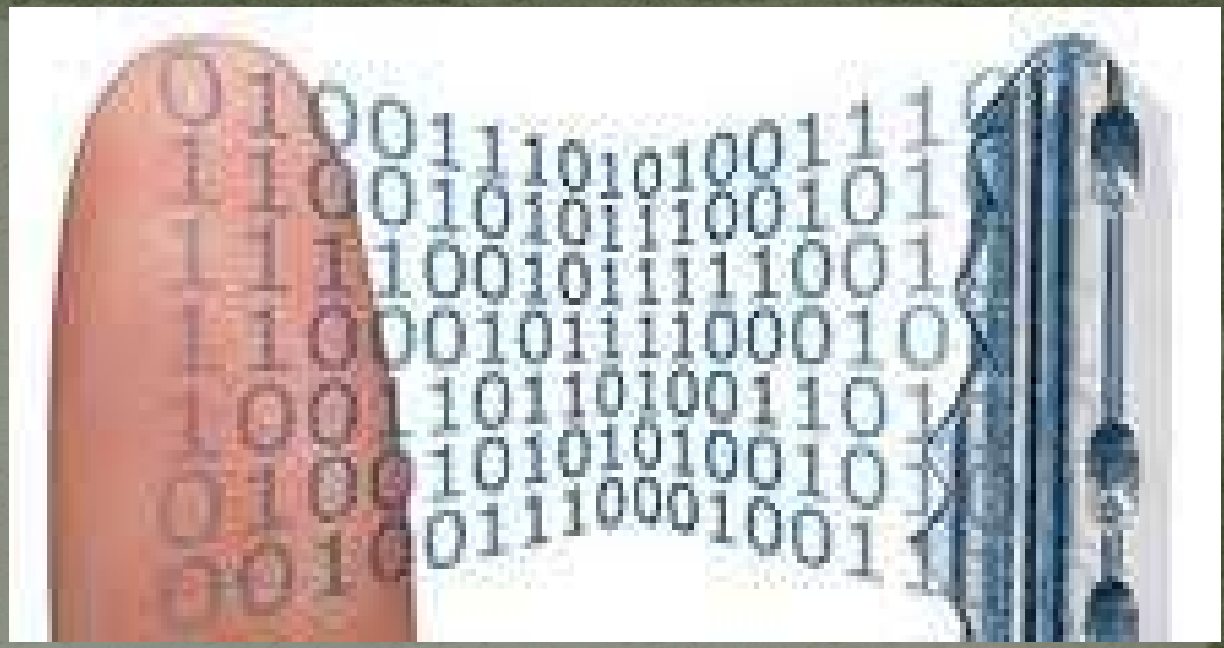
Bitwarden



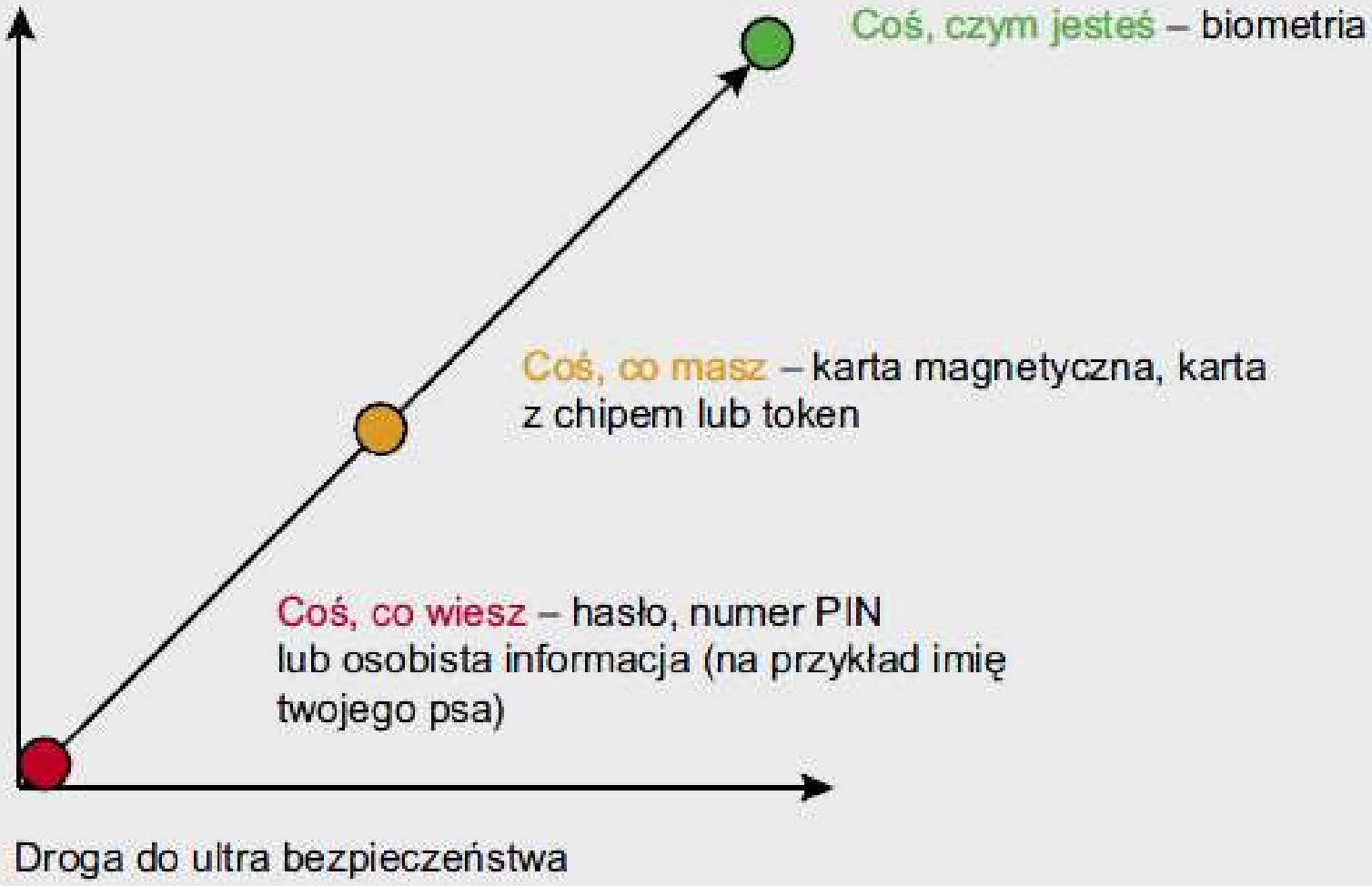
KeePass



1Password



Biometria

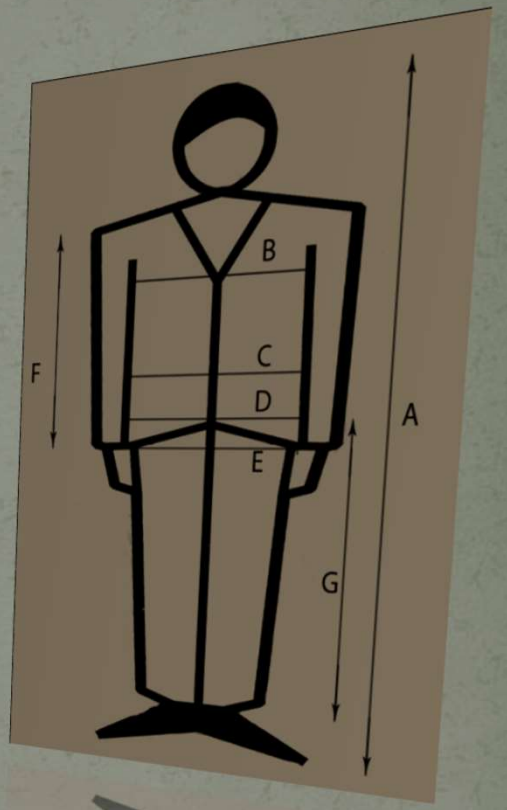

Coś, czym jesteś – biometria
Coś, co masz – karta magnetyczna, karta z chipem lub token
Coś, co wiesz – hasło, numer PIN lub osobista informacja (na przykład imię twojego psa)
Droga do ultra bezpieczeństwa

Czym jest biometria

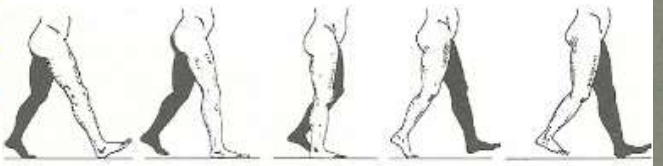
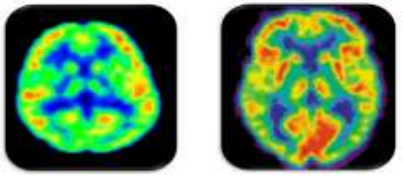
Z greckiego: Bios - życie, Metricos - miara

Biometria - nauka zajmująca się badaniem zmienności populacji organizmów, wykorzystująca pomiary biometryczne.

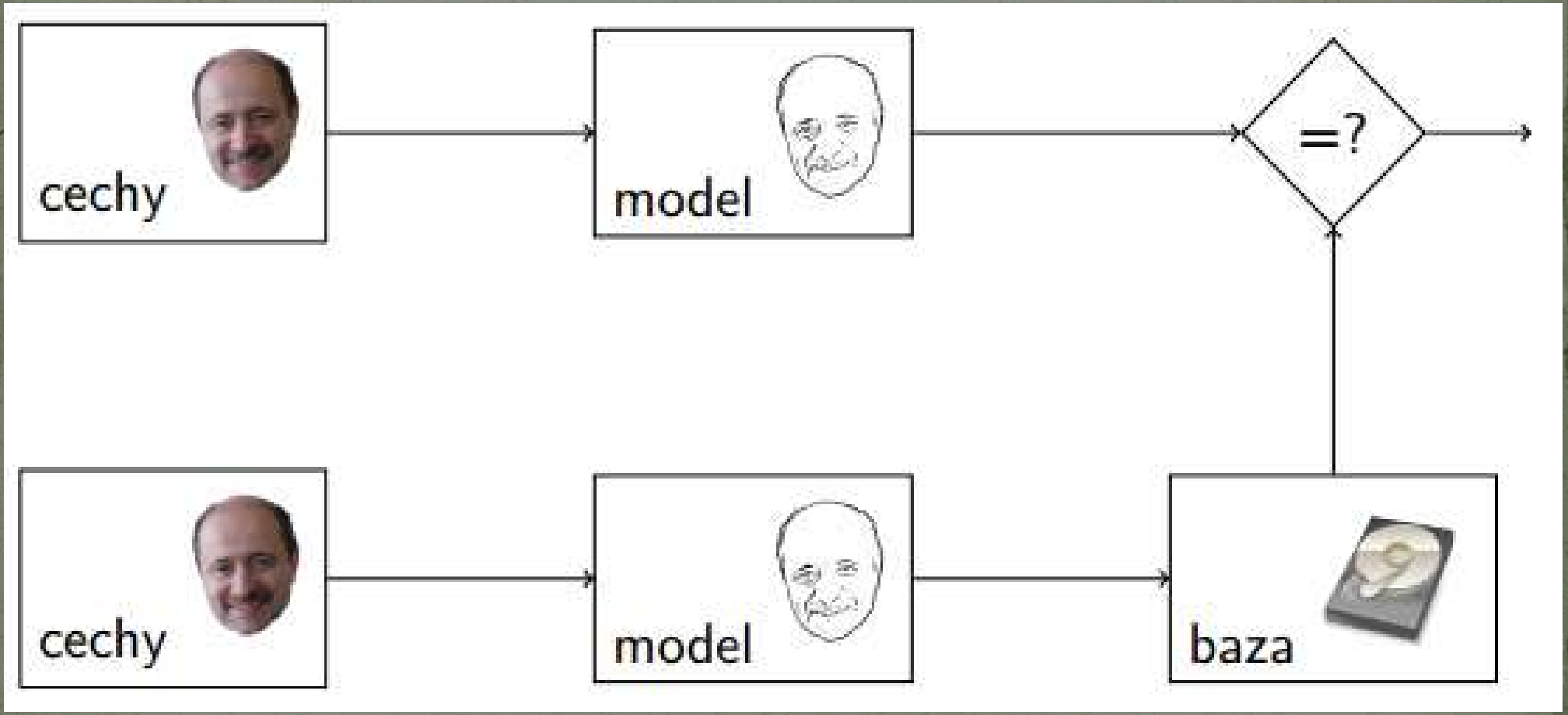
Biometryka - badanie i rozwijanie statystycznych i matematycznych metod stosowanych do analizy danych biologicznych.



Co jest mierzone

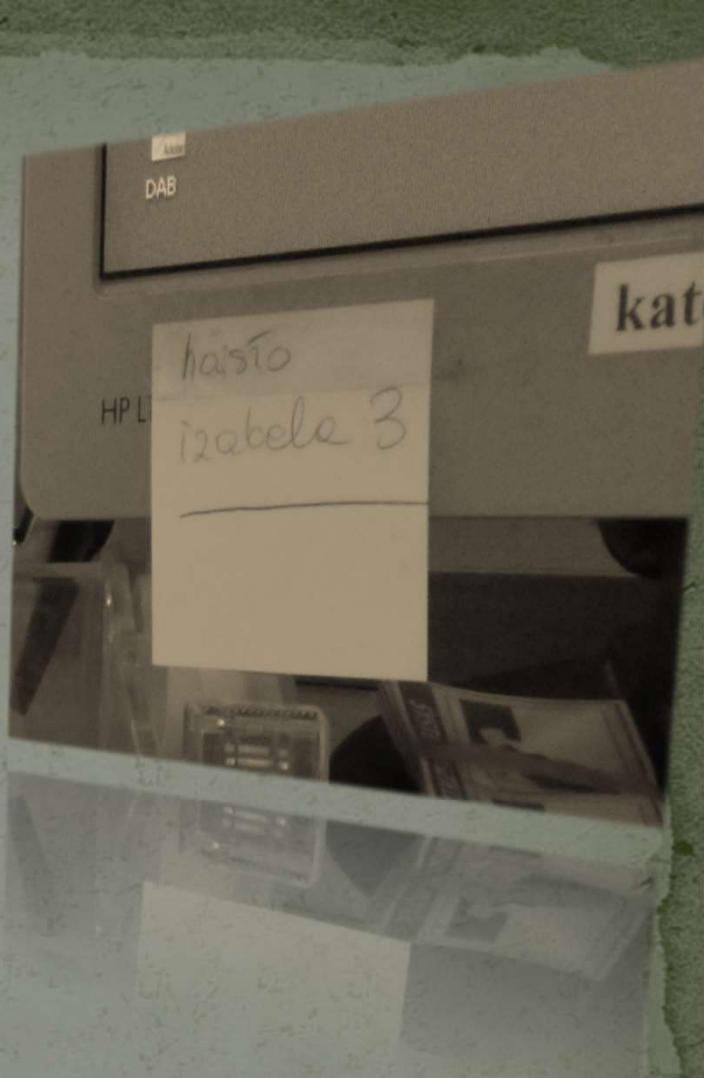
- Cechy Fizyczne
  - Twarz
  - Odciski palców
  - Dłoń
  - Siatkówka
  - DNA
  - Ucho, nos, zęby, zapach
- Cechy wyuczone (behawioralne)
  - Głos
  - Częstotliwość uderzen w klawisze
  - Podpis
  - Chód 
  - Reakcje mózgu na bodźce 

Jak jest mierzone



Po co...

- Bezpieczeństwo informacji
  - Uwierzytelnianie osób
  - Autoryzacja dostępu do danych
- Gromadzenie informacji
  - Identyfikacja osób
  - Poszukiwanie osób
- Rozrywka
  - Poszukiwanie sobowtórów znanych osób



Dlaczego... **w teorii...**

- Cechy biometryczne
  - Uniwersalne
  - Unikalne
  - Trwałe
  - Mierzalne

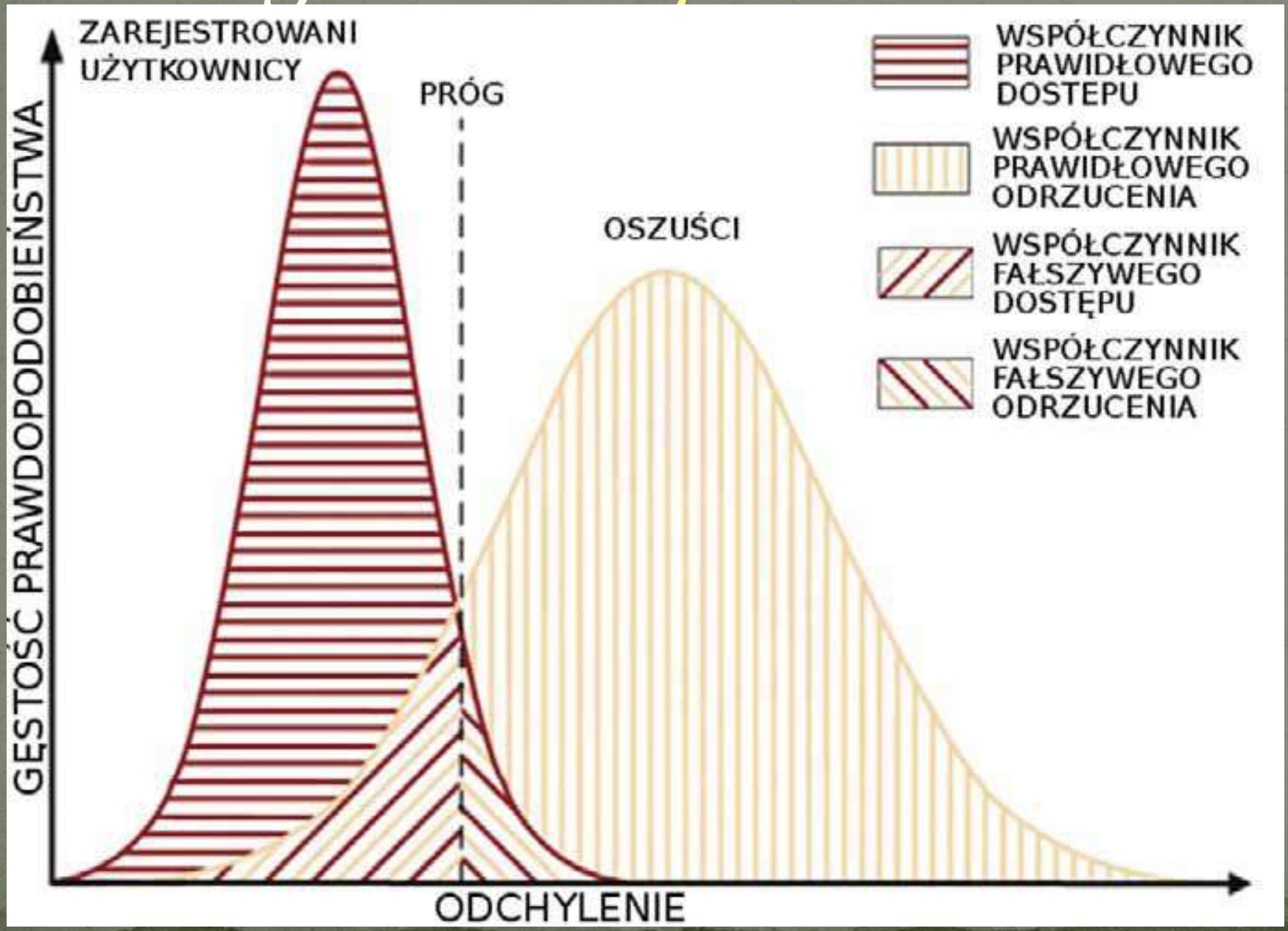
- Metody pomiaru:
  - Wydajne
  - Akceptowalne przez społeczeństwo

Dlaczego... **rzeczywistość**...

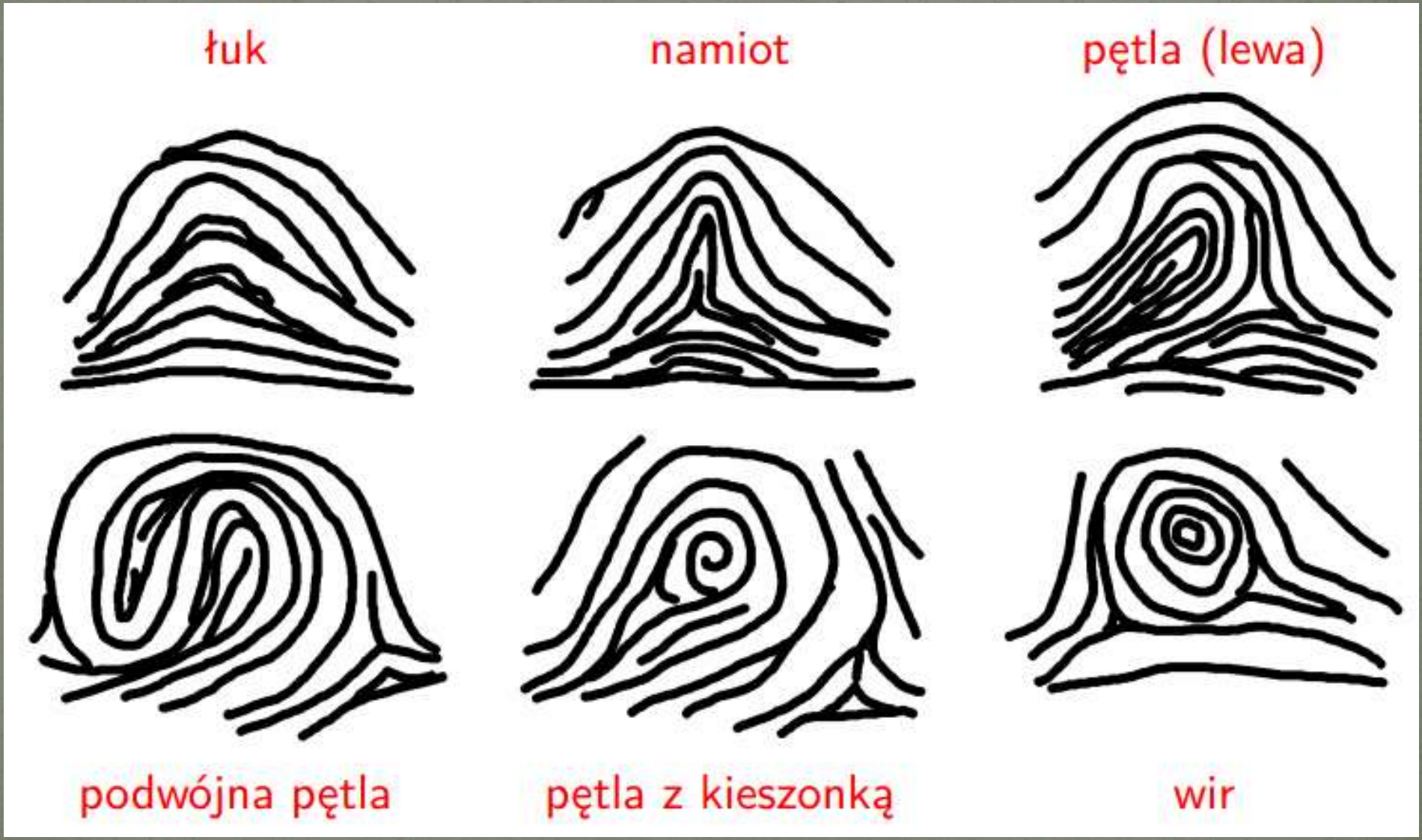
- Cechy biometryczne
  - Uniwersalne
  - Unikalne – możliwość spreparowania mierzonej cechy
  - Trwałe – zmienność wynikająca z czynników zewnętrznych
  - Mierzalne – wyniki pomiaru zależne od warunków w jakich jest on dokonywany

- Metody pomiaru:
  - Wydajne
  - Akceptowalne przez społeczeństwo – nie całkowicie

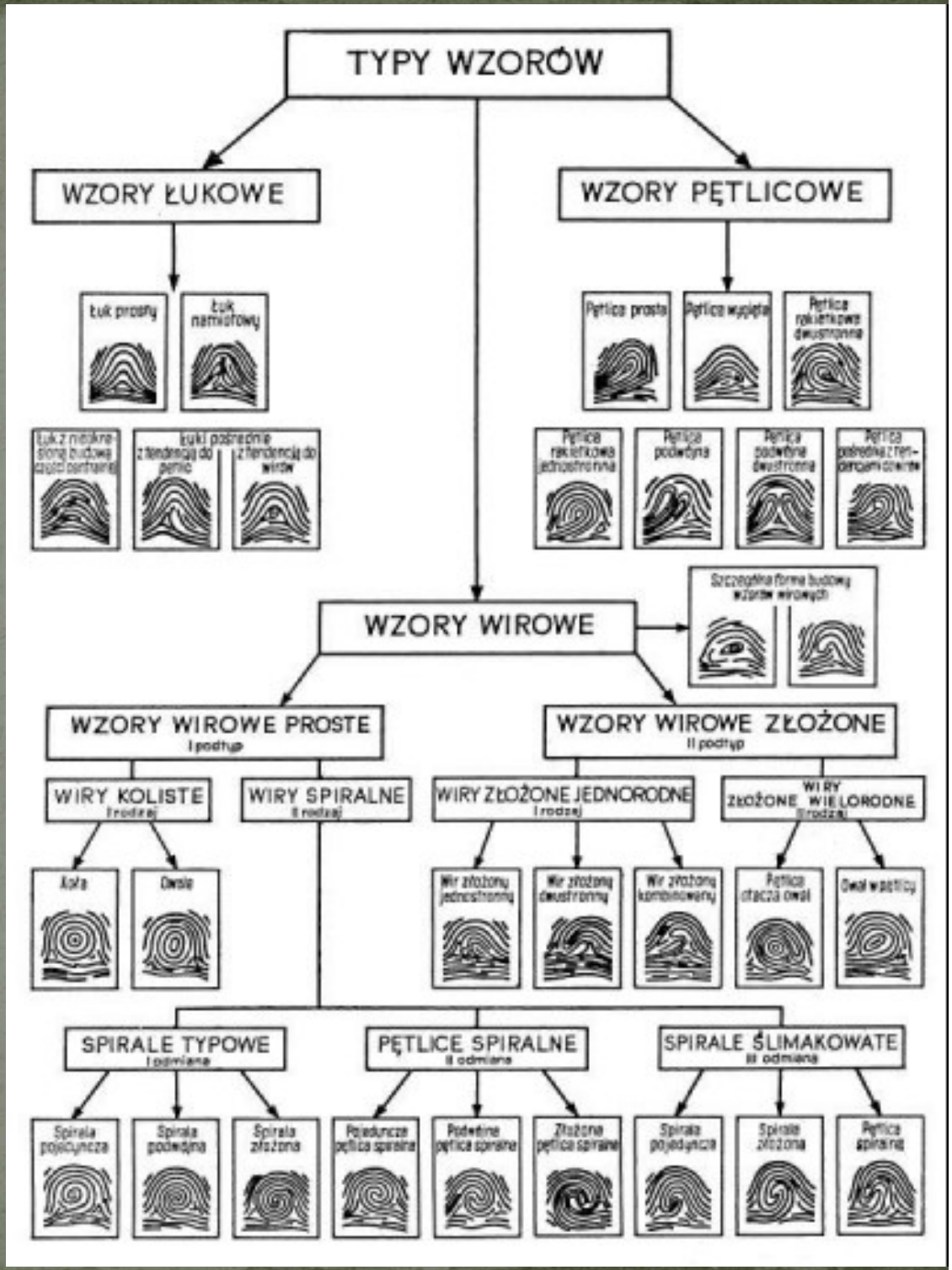
Dlaczego... **rzeczywistość**...



Linie papilarne - charakterystyka

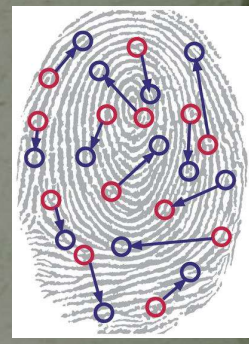


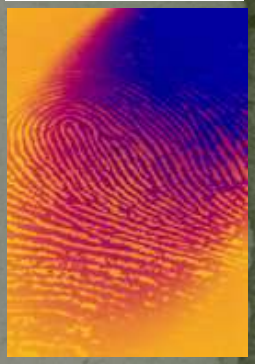
Linie papilarne



Linie papilarne – czytniki

- Optyczne (2D) – tanie, łatwe do oszukania;
- Pojemnościowe (2D) – niedrogie, trudne do oszukania;
- Termiczne (2D) – Pomiar temperatur grzbietu i doliny odcisku, średnio trudne do oszukania, tanie;
- Ultradźwiękowe (3D) – drogie, teoretycznie (!) bardzo trudne do oszukania, skanują głębsze warstwy skóry, działają podobnie do USG rejestrując echo fal ultradźwiękowych.





Linie papilarne – wady i zalety

ZALETY

- Szybka i wygodna autoryzacja.

WADY:

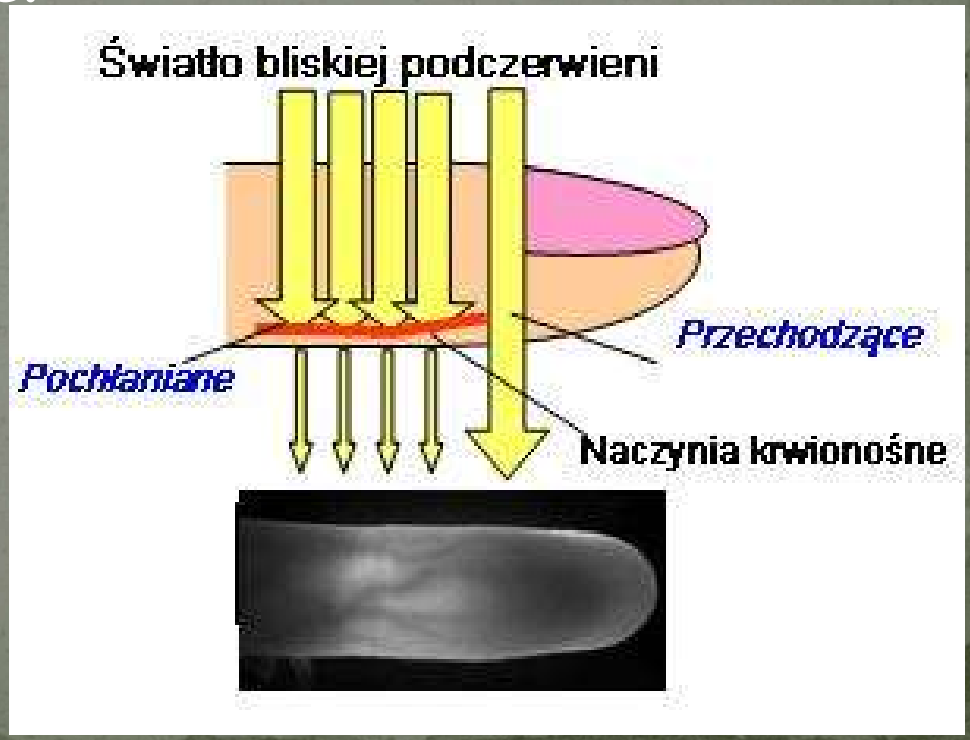
- Uszkodzenie palca.
- Osoby bez dłoni.
- Możliwość prostego złamania zabezpieczeń poprzez stworzenie sztucznego palca.

WNIOSEK: AUTORYZACJA POPRZEZ LINIE PAPILARNE NIGDY NIE POWINNA BYĆ JEDYNĄ DROGĄ AUTORYZACJI

Projekt Finger Vein (Hitachi)

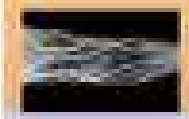
Siatka naczyń krwionośnych w palcu/dłoni.

- Unikalny dla każdego człowieka.
- Niezmienne przez całe życie.
- Trudno o uszkodzenie.
- Trudno teoretycznie (!) go podrobić.



Projekt Finger Vein (Hitachi)

Siatka naczyń krwionośnych w palcu.

Informacja Biometryczna		Zasada działania	Koszt	Sprzeciw użytkownika	Bezpieczeństwo	Rozmiar urządzenia
	Naczynia krw. palca	Używa wzoru układu naczyń krw. palca	niski	niski	wysokie	średni / mały
	Naczynia krw. ręki	Używa wzoru układu naczyń krw. ręki	niski	niski	wysokie	średni
	Odciski Palców	Używa charakterystycznych punktów odcisków palców	b.niski	wysoki	średnie	mały
	Twarz	Używa konturów twarzy, położenie i kształt oczu oraz nosa	średni	niski	niskie	średni
	Tęczowka	Używa wzoru cech radialnych tęczówki	wysoki	wysoki	wysokie	duży

Projekt Finger Vein (Hitachi)

- Warszawa ul. Płocka, oddział Banku Polskiej Spółdzielczości S.A., stanął pierwszy w Polsce bankomat wykorzystujący technologię biometryczną Finger Vein.

Projekt Finger Vein (Hitachi)

- 2019 Grupa Chaos Computer Club pokazała, że można oszukać skaner żył ręką z wosku.
- Do ataku wystarczy zdjęcie zrobione aparatem z odległości 5 metrów (trzeba usunąć filtr podczerwieni z aparatu cyfrowego)
- Zdjęcie można zrobić przez zainstalowanie odpowiednich aparatów w suszarkach do rąk !!!

Projekt Finger Vein (Hitachi)

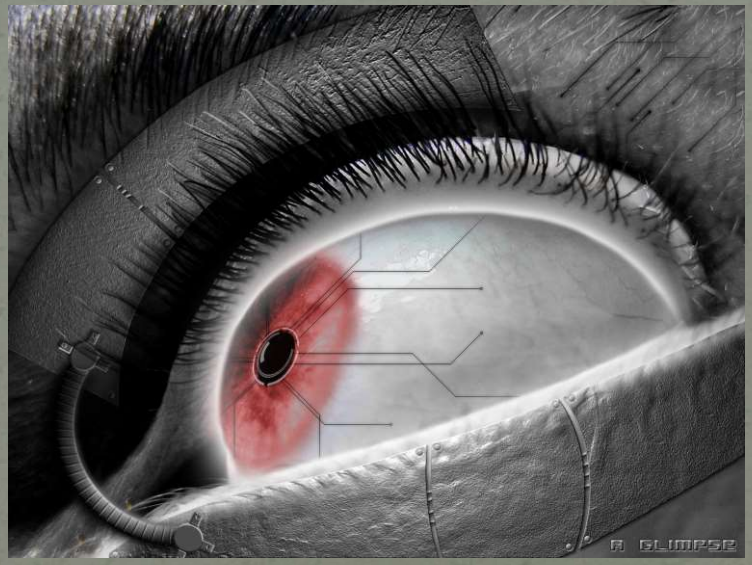
- Przykład zdjęcia z tylnim podswietleniem

Tęczówka oka - charakterystyka

- Tęczówka kształtuje się w ciągu pierwszych lat życia.
- Nie zmienia się do końca życia.
- Ulega zniszczeniu natychmiast po śmierci.

Tęczówka oka – próba ataku

- Stworzenie zdjęcia oka o wysokiej rozdzielczości
- Gdy system sprawdza odblaski, wycięcie ze zdjęcia samej tęczówki i przyłożenie do własnej źrenicy oka



Tęczówka oka – wady i zalety

ZALETY

- Szybka i wygodna autoryzacja.
- Wyższa skuteczność.

WADY:

-Systemy nie radzą sobie z osobami będącymi pod wpływem alkoholu, przemęczonymi i niewyspanymi.

- Możliwość oszukania niektórych skanerów zdjęciami o wysokiej rozdzielczości.

Podpis biometryczny

- Analiza dwóch parametrów.
- Grafika kształtu podpisu.
- Dynamika składania podpisu.
  - szybkość
  - nacisk

Identyfikacja przez klawisze.

- Wymagane hasło.
- Rozpoznawanie użytkownika po charakterystyce pisania na klawiaturze.
  - Łączny czas pisania.
  - Odstępy czasu pomiędzy naciśnięciem klawiszy.
  - Sprawdzanie używania klawiatury numerycznej.

Podsumowanie

- Wygoda zastosowania
- Podatność na fałszerstwa

- Systemy pomocnicze
- Komercyjne rozwiązania często są nieskuteczne
- Przyszłość – poprawa działania

Podsumowanie

- Człowiek może i jest unikalny, ale niestety jest niesamowitym śmieciarzem, który wszędzie zostawia swój biometryczny ślad.

Łamanie kryptografii

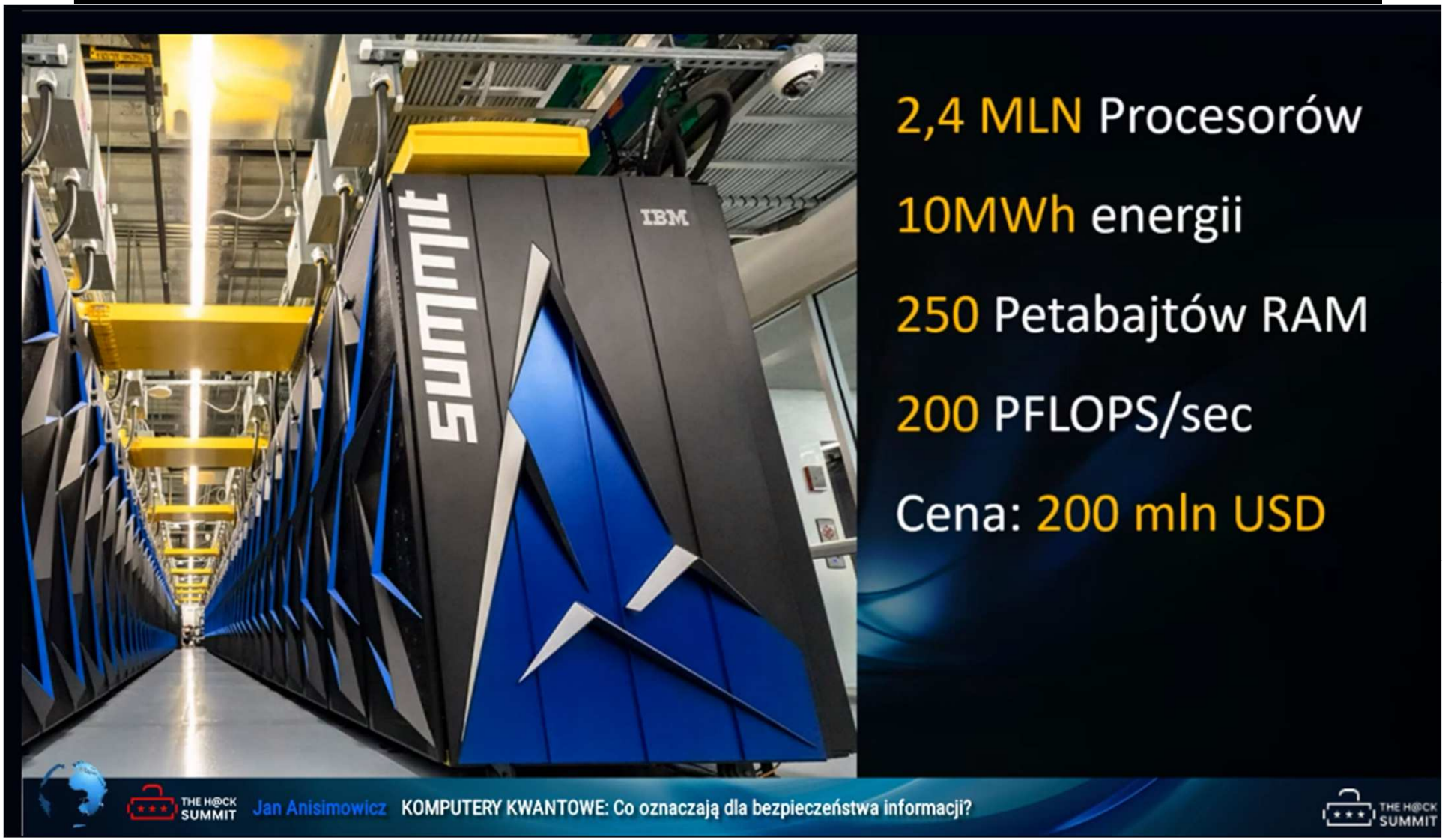
BwSK

BwSK

T.Łukaszewski

Łamanie kryptografii

The best (do czerwca 2020 roku)



BwSK

T.Łukaszewski

Łamanie kryptografii
porównanie mocy

200 PFLOPS/sec

=

20 tysięcy PS 5(*)

BwSK

T.Łukaszewski

Łamanie kryptografii
podwojenie mocy

BwSK

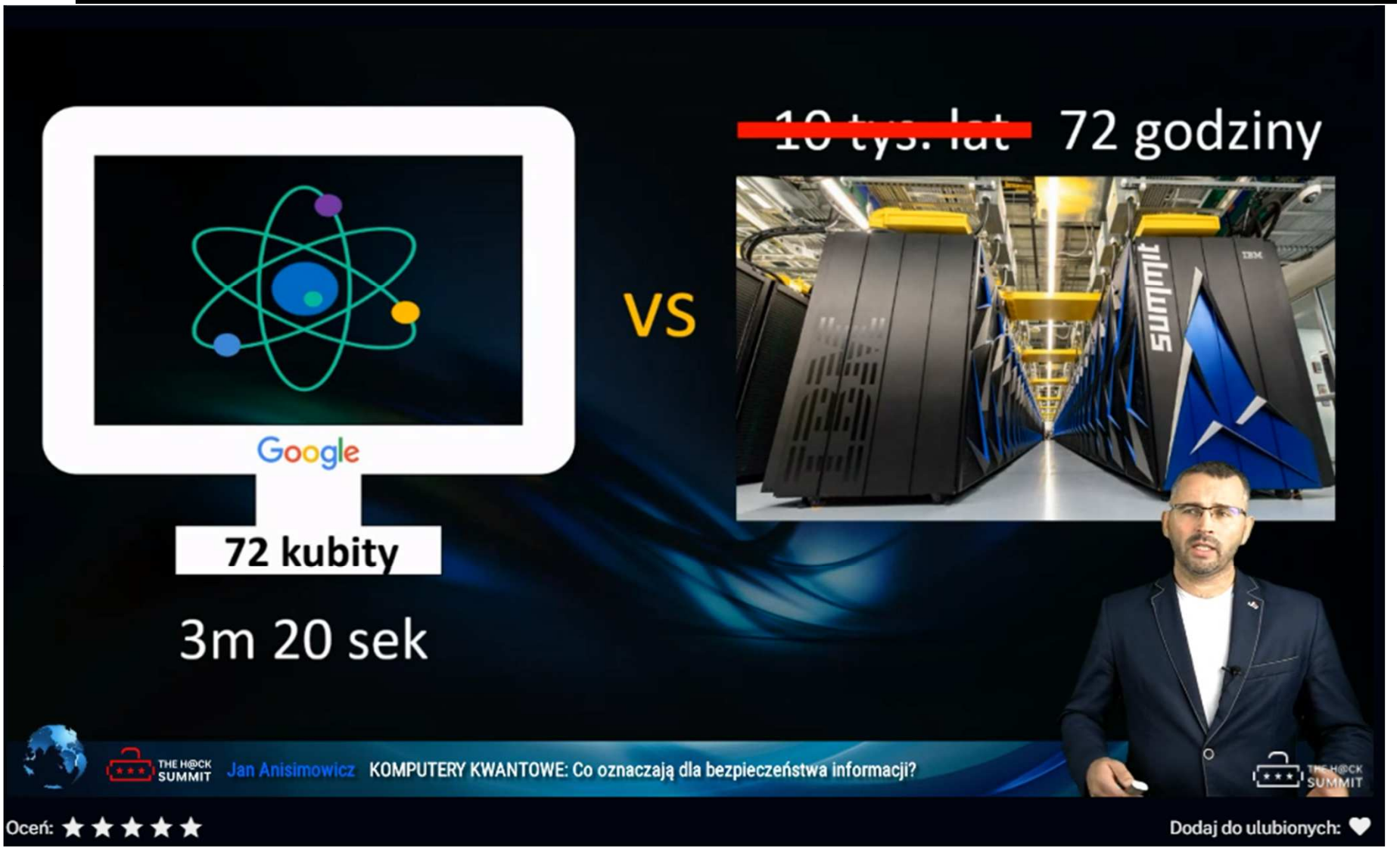
T.Łukaszewski

Łamanie kryptografii
podwojenie mocy

BwSK

T.Łukaszewski

Łamanie kryptografii
pojedynek (X 2019)



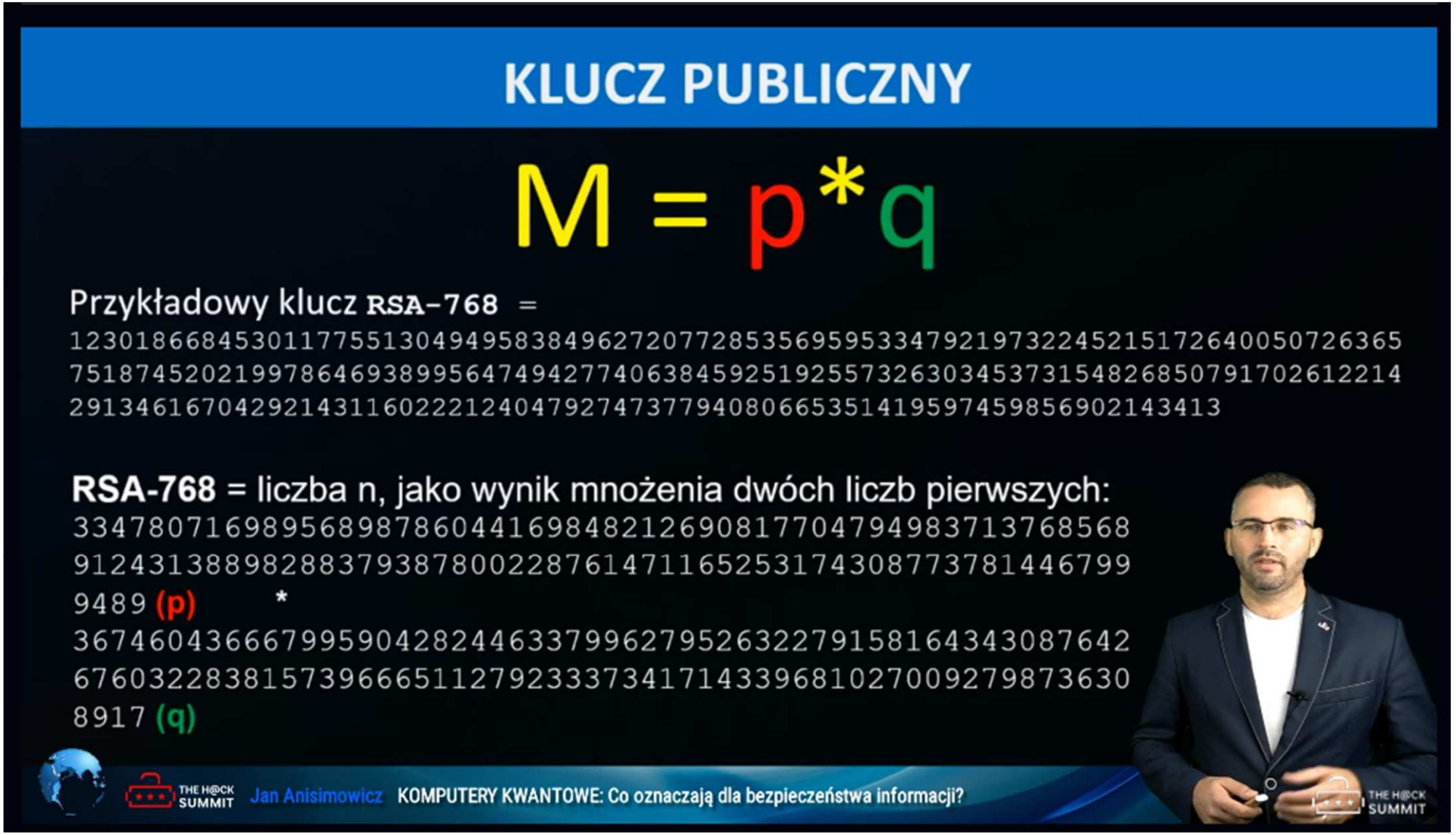
Łamanie kryptografii

Łamanie RSA – faktoryzacja dużej liczby (do liczb pierwszych)

T.Łukaszewski

Łamanie kryptografii

Łamanie RSA – złamane RSA-768



BwSK

T.Łukaszewski

Łamanie kryptografii

Łamanie RSA – „znaczny” czas faktoryzacji

Czy RSA jest bezpieczny?

Rozkład liczb naturalnych na czynniki pierwsze (faktoryzacja) jest klasycznie trudnym problemem!

Algorytm “sito ciała liczbowego” ma (sub)ekspotencjalny czas faktoryzacji:

$$t_F \propto \exp[(64/9)^{1/3}(\ln N)^{1/3}(\ln \ln N)^{2/3}$$

THE H@CK SUMMIT Jan Anisimowicz KOMPUTERY KWANTOWE: Co oznaczają dla bezpieczeństwa informacji?

Oceń: ★★★★★ Dodaj do ulubionych:

BwSK

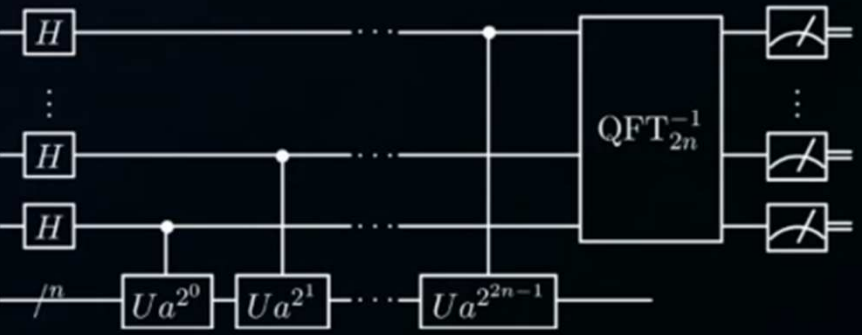
T.Łukaszewski

Łamanie kryptografii

Łamanie RSA – kwantowe alg. wielomianowe!

Peter W. Shor

Algorytm Shora (1994), algorytm kwantowy, który znacząco redukuje czas faktoryzacji.



$$t_F \propto (\ln N)^3$$

Ze względu na wielomianową zależność czasu faktoryzacji od liczby bitów (N), algorytm RSA nie jest bezpieczny względem algorytmu Shora

THE H@CK SUMMIT Jan Anisimowicz KOMPUTERY KWANTOWE: Co oznaczają dla bezpieczeństwa informacji?

THE H@CK SUMMIT

Łamanie kryptografii
przyszłość kryptografii

WYMAGANIA:

Kryptografia postkwantowa:

- skuteczniejsze algorytmy asymetryczne, odporne na obliczenia kwantowe (algorytm Shora – faktoryzacja)

Kryptografia w dobie komputerów kwantowych:

- eliminacja operacji przesyłania kluczy kryptograficznych publicznym kanałem

BwSK

T.Łukaszewski

Łamanie kryptografii

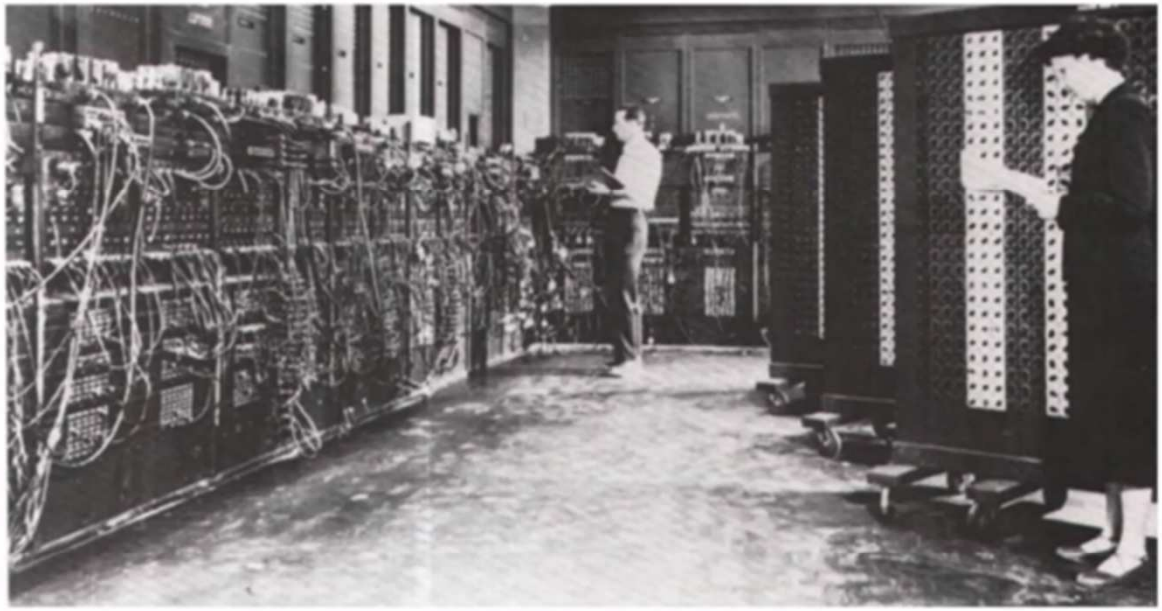
Początki: kwantowy vs elektroniczny (ENIAC)

BwSK

T.Łukaszewski

Łamanie kryptografii

Komputery / procesory BITOWE



Eniac: **7 mln $**

Układ IBM: **0,1 $**

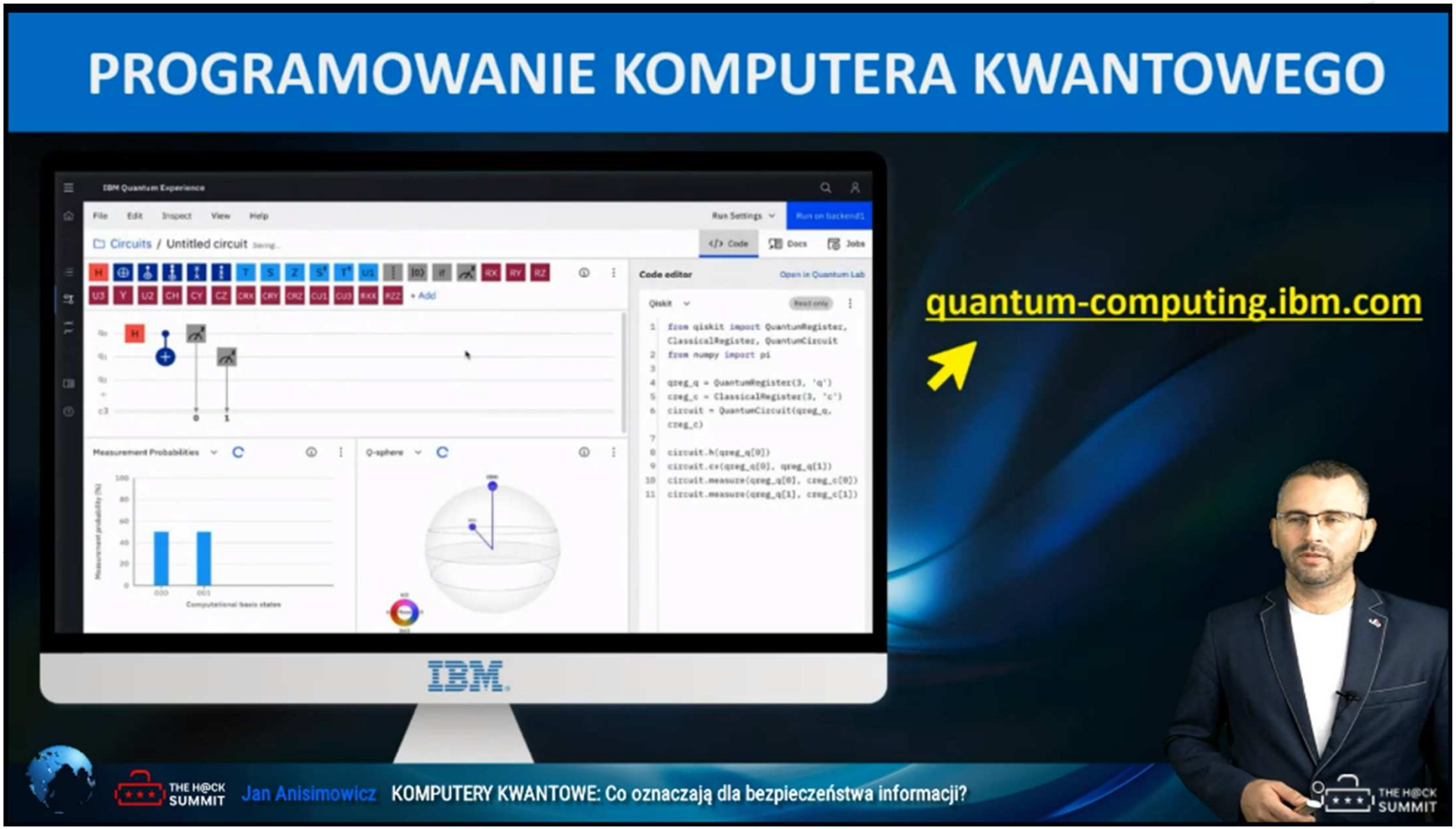
70 lat, porównywalna wydajność

BwSK

T.Łukaszewski

Łamanie kryptografii

Komputery kwantowe dla Kowalskiego ...



BwSK

T.Łukaszewski

Phishing

- 1. Przykłady
- 2. Phishing - Red Team
- 3. Podsumowanie

BwSK

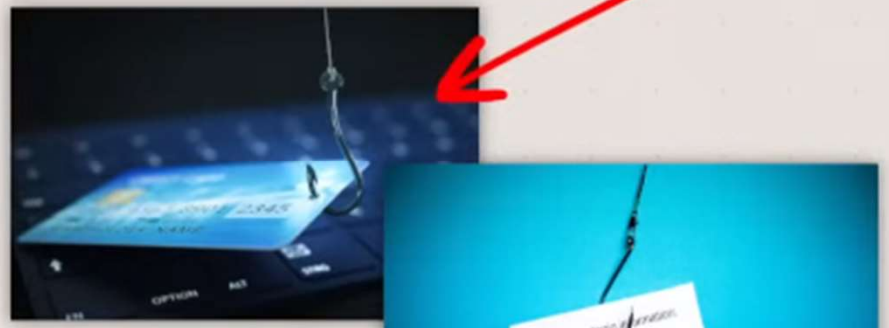
Przykłady
cel phishingu

securitum

Phishing

wykradanie danych

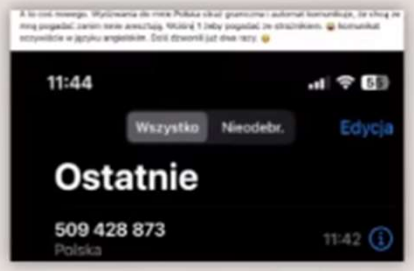
próba zainfekowania komputera



Przykłady
forma phishingu

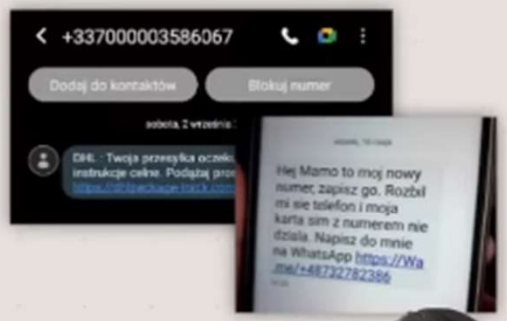
securitum

email

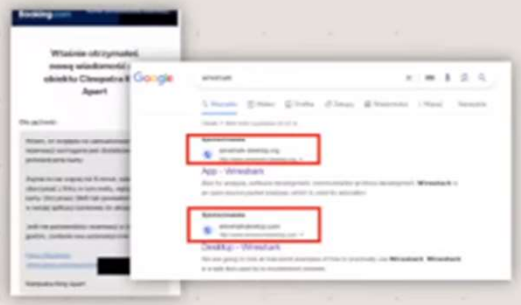


telefon

SMS



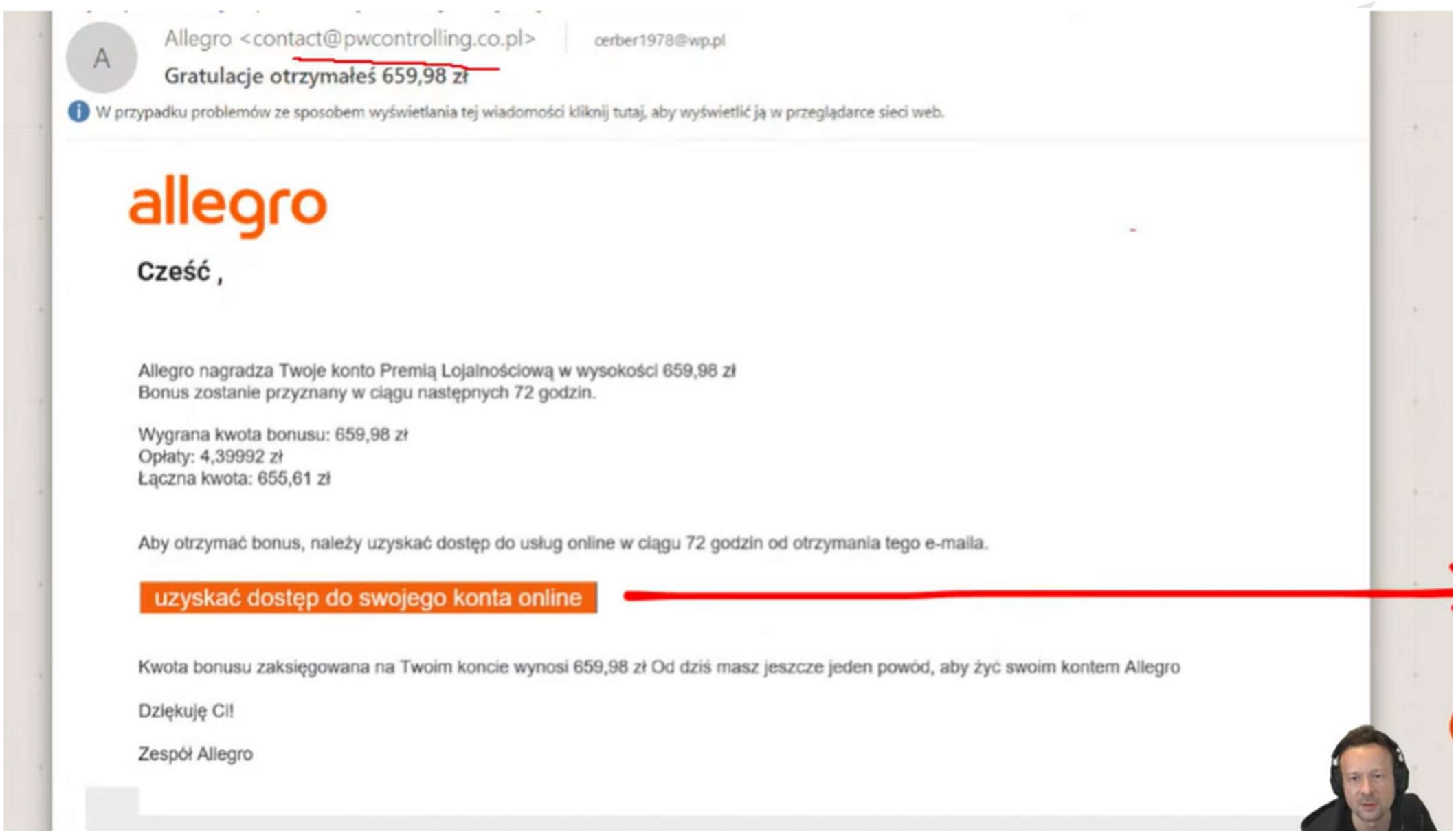
przeglądarka



QR kod

0111001100001

Przykłady
fałszywe emaile



A

Allegro <contact@pwcontrolling.co.pl> cerber1978@wp.pl

Gratulacje otrzymałeś 659,98 zł

W przypadku problemów ze sposobem wyświetlania tej wiadomości kliknij tutaj, aby wyświetlić ją w przeglądarce sieci web.

allegro

Cześć ,

Allegro nagradza Twoje konto Premią Lojalnościową w wysokości 659,98 zł
Bonus zostanie przyznany w ciągu następnych 72 godzin.

Wygrana kwota bonusu: 659,98 zł
Opłaty: 4,39992 zł
Łączna kwota: 655,61 zł

Aby otrzymać bonus, należy uzyskać dostęp do usług online w ciągu 72 godzin od otrzymania tego e-maila.

uzyskać dostęp do swojego konta online

Kwota bonusu zaksięgowana na Twoim koncie wynosi 659,98 zł Od dziś masz jeszcze jeden powód, aby żyć swoim kontem Allegro

Dziękuję Ci!

Zespół Allegro

Przykłady
fałszywe emaile

Zatwierdzenie wniosku o zwrot podatku.

K A S <kas@vat-poland.com>
CC: K A S <kas@vat-poland.com>

Krajowa Administracja Skarbowa

Drogi Obywatelu,

Miło nam poinformować, że Państwa wniosek o automatyczny zwrot podatku za okres od 17 września 2022 r. do 17 grudnia 2022 r. został pozytywnie rozpatrzony.

Twoje tymczasowe hasło to **658044**, użyj go, aby zażądać wypłaty:

http://vat-poland.com/PD2162

Aby zapewnić bezpieczeństwo transakcji, korzystaj z naszego portalu internetowego wyłącznie na swoim urządzeniu mobilnym.

Z poważaniem,
Administracja finansowa refundacji

Przykłady
fałszywe emaile (legalne adresy ???)

securitum

OD: GUS-Portal@info.stat.gov.pl

Szanowni Państwo,

Główny Urząd Statystyczny uprzejmie informuje, że Państwa firma została objęta obowiązkiem sprawozdawczym: Sprawozdanie o produkcji (P-01)

W załączeniu przesyłamy elektroniczny formularz zgłoszenia

Termin przekazania sprawozdania upływa w dniu: 2023-02-28

Badanie jest realizowane zgodnie z przepisami Rozporządzenia Parlamentu Europejskiego i Rady (UE) 2016/679 z dnia 27 kwietnia 2016 r. w sprawie ochrony osób fizycznych w związku z przetwarzaniem danych osobowych i w sprawie swobodnego przepływu takich danych oraz uchylenia dyrektywy 95/46/WE (RODO). Szczegółowe informacje dotyczące stosowania RODO w statystyce publicznej oraz przetwarzania danych osobowych w celu statystycznym są dostępne na stronie internetowej: https://bip.stat.gov.pl/rodo/klauzule-informacyjne/prze-danych-osobcelu-statystycznym/

Dane uzyskane w badaniu są objęte tajemnicą statystyczną i będą wykorzystane wyłącznie do opracowań zbiorczych (art. 10 ww. ustawy). Udział w badaniu jest obowiązkowy.

Obowiązek przekazania danych wynika z:
- art. 30 ust. 1 pkt 3 ustawy z dnia 29 czerwca 1995 r. o statystyce publicznej (Dz. U. z 2022 r. poz. 459, z późn. zm.). Tekst jednolity ustawy o statystyce publicznej dostępny jest pod adresem: https://bip.stat.gov.pl/prawo/akty-pne/ustawa-o-stat-publicznej/,
- rozporządzenia Rady Ministrów z dnia 25 września 2020 r. w sprawie programu badań statystycznych statystyki publicznej na rok 2021 (Dz. U. poz. 2062, z późn. zm.). Treść rozporządzenia dostępna jes pod adresem: https://bip.stat.gov.pl/dzialalnosc-statpublicznej/-statystycznych/pbssp-2021/.

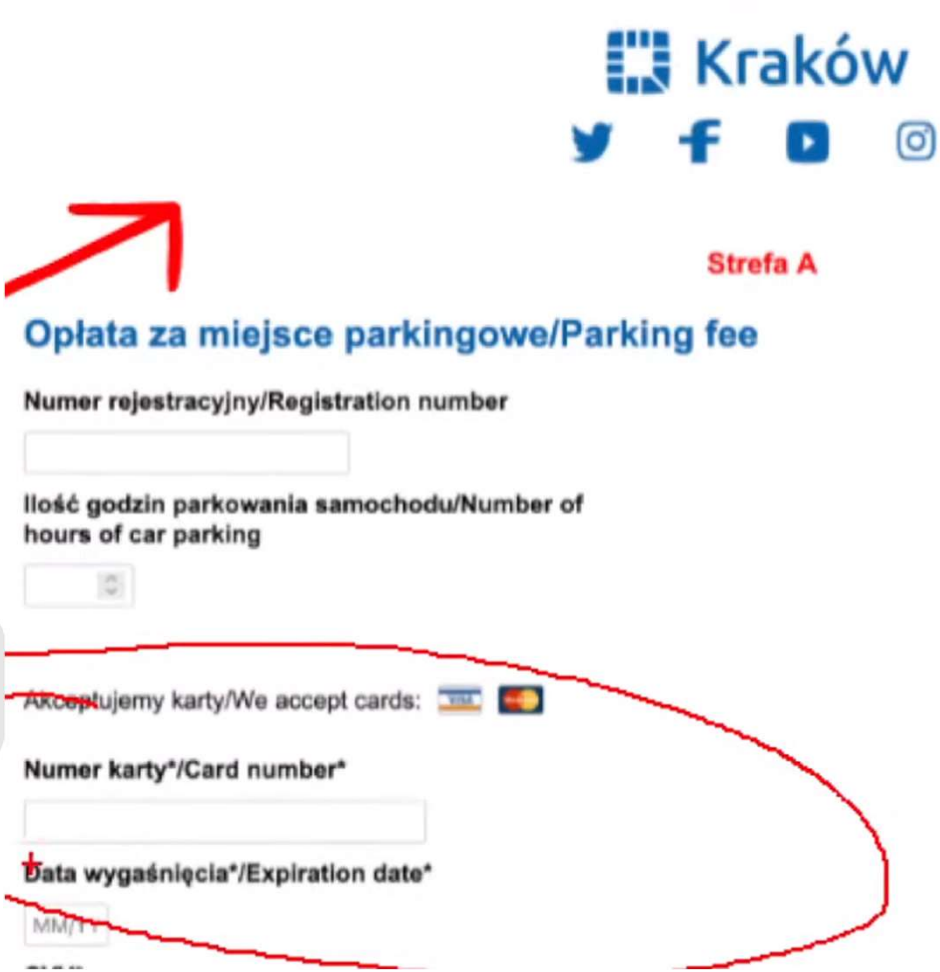
Przykłady
fałszywe QR kody

Fałszywe kody QR na parkingach w Krakowie

https://sekurak.pl/w-krakowie-na-parkingach-pojawily-sie-falszywe-kody-qr-uwazajcie-na-zawartosc-swojego-konta-bankowego/

Przykłady
fałszywe QR kody

QR kod prowadził do fałszywej strony internetowej



Przykłady
fałszywe QR kody

securitum

"Nieodpowiedzialne korzystanie z gier komputerowych może nieść za sobą wiele zagrożeń. Przekonał się o tym mieszkaniec naszego powiatu, który stracił kilkaset złotych, po tym jak jego 12-letni syn zeskanował otrzymany przez innego gracza kod. Chłopiec miał w ten sposób otrzymać atrakcyjne przedmioty w grze. Jak się okazało, poprzez kod uruchomił płatne usługi."

https://kolbuszowa.policja.gov.pl/rkl/aktualnosci/wydarzenia/120253,Przez-zeskanowany-kod-QR-stracil-kilkaset-zlotych.html

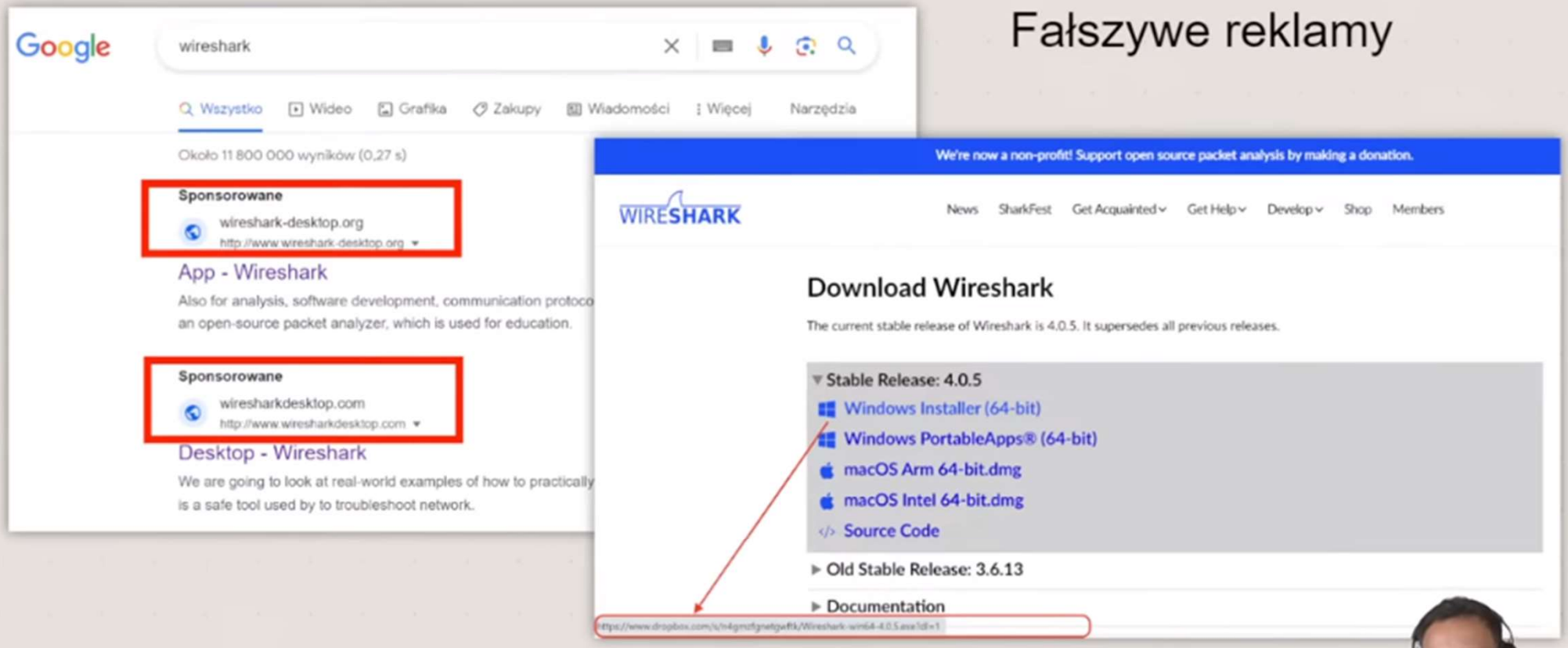
Przykłady
fałszywe QR kody

Atakujący prosi o zeskanowanie QR kodu w aplikacji „Google Messages”
Atakujący dostanie dostęp do SMSów ofiary i może wysyłać SMSy

Przykłady
fałszywe reklamy

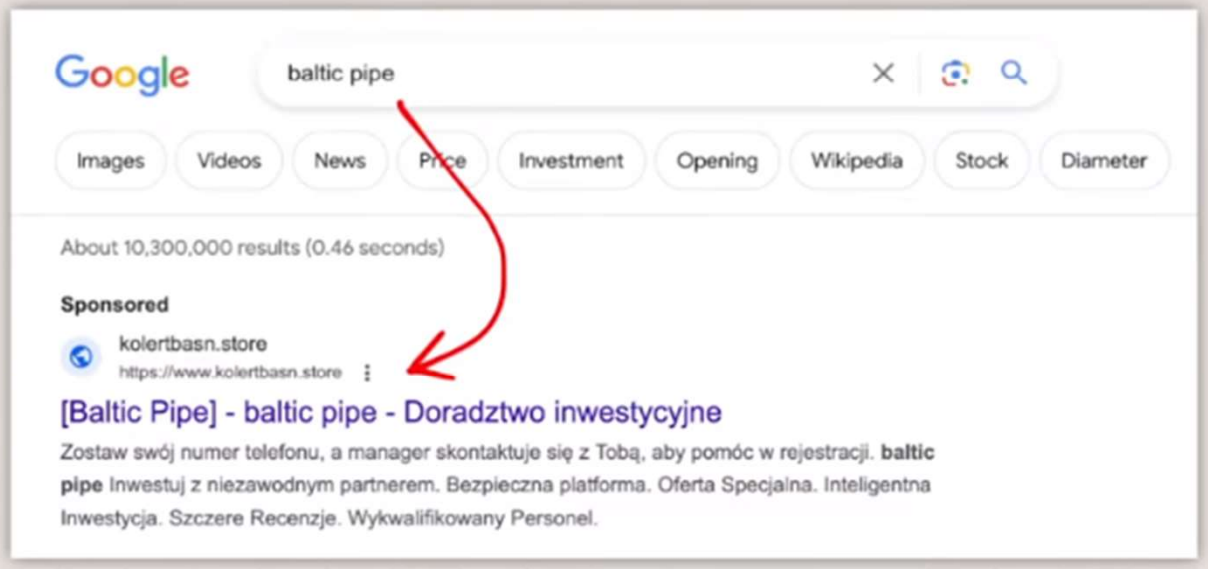
T.Łukaszewski

securitum



Przykłady
fałszywe inwestycje

securitum



Fałszywe inwestycje

DEMO

"rekordzista" zgłosił się do nas z informacją o oszustwie na 600 000 zł !

uwaga na podpuchę z początkowo "prawdziwymi" zyskami, które wpływają na konto

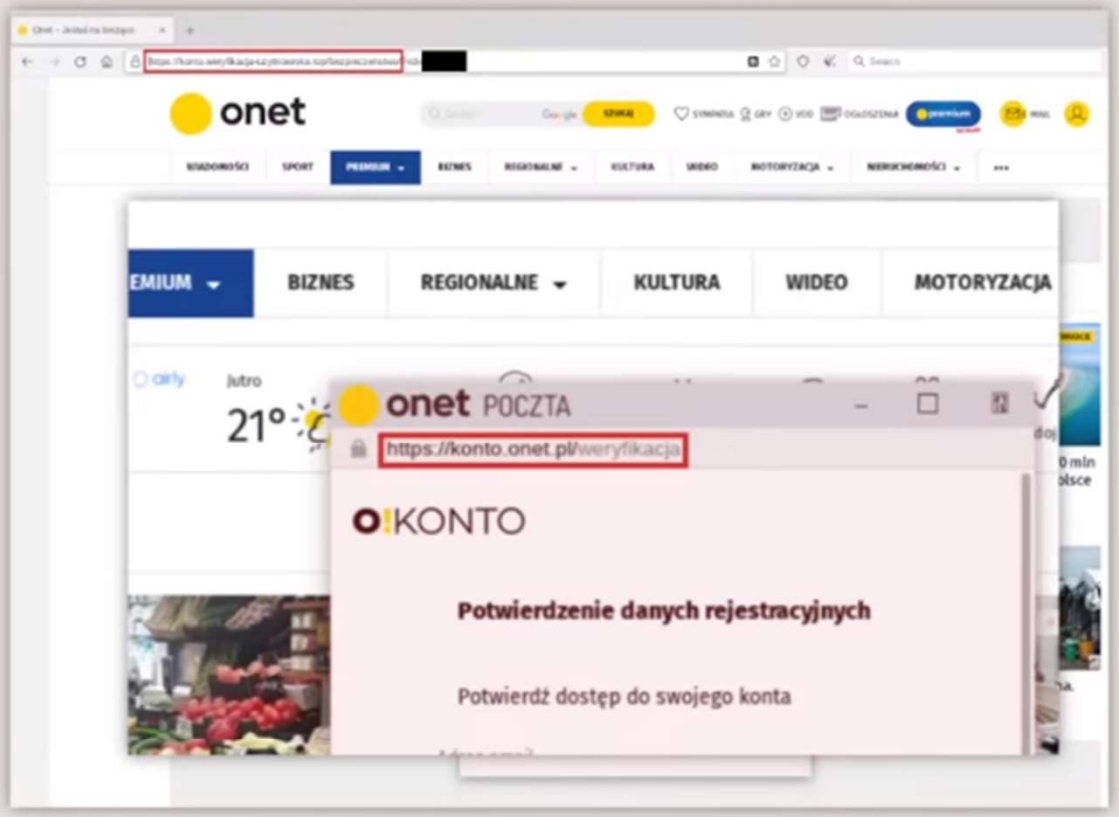
Przykłady
fałszywe oferty pracy

securitum

muł finansowy to osoba, która przekazuje pieniądze innej osobie (cyfrowo lub w gotówce), otrzymane od osoby trzeciej, za co uzyskuje prowizję. (…) Jeśli ktoś poprosi Cię o transfer pieniędzy za pośrednictwem konta bankowego w zamian za gotówkę, to oznacza, iż jesteś nakłaniany do zostania mułem finansowym.

https://www.europol.europa.eu/sites/default/files/documents/pl_flyers.pdf

Przykłady
fałszywe okienka

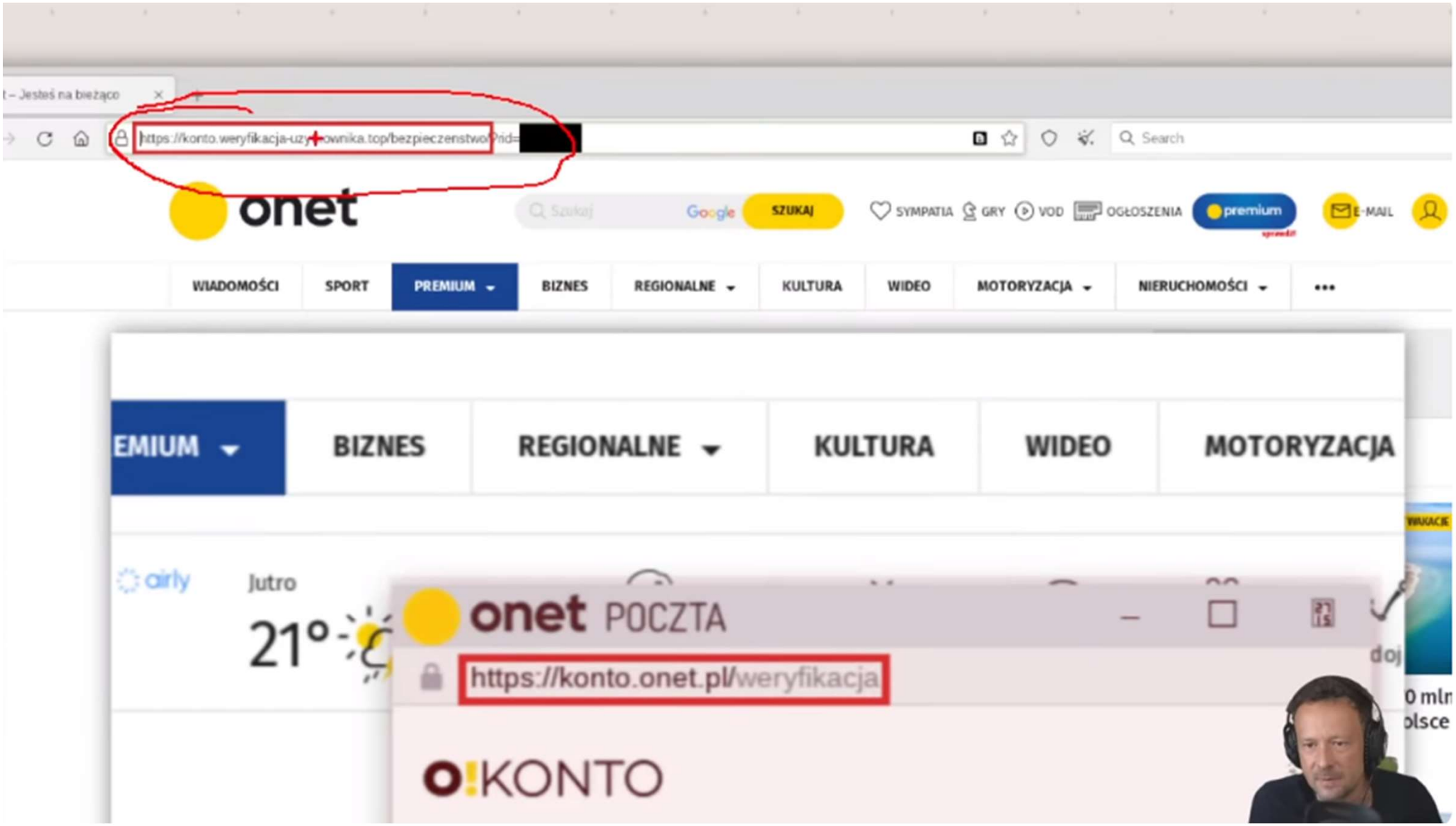


Technika BITB (Browser In The Browser)

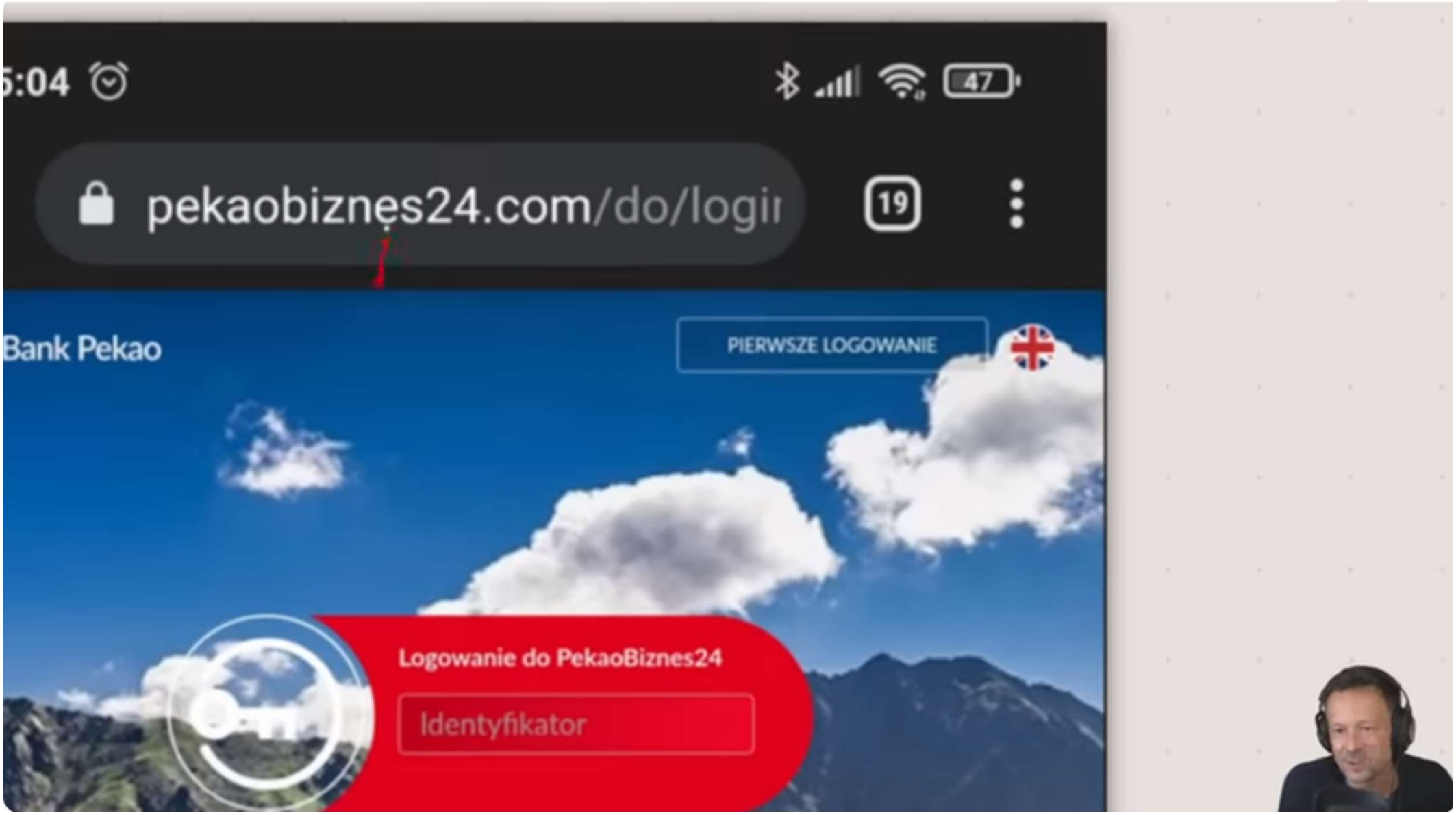
BwSK

T.Łukaszewski

Przykłady
fałszywe okienka

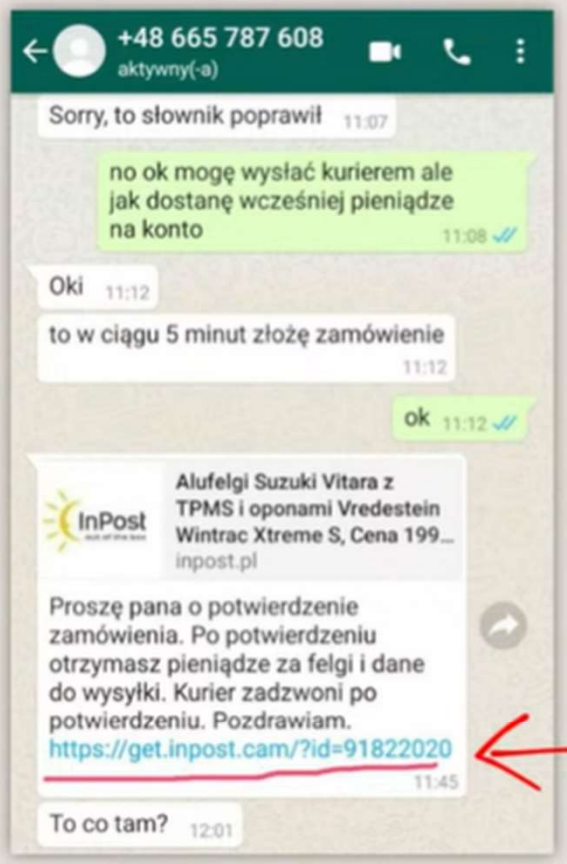


Przykłady
fałszywe adresy



Przykłady
scam „na OLX”

securitum



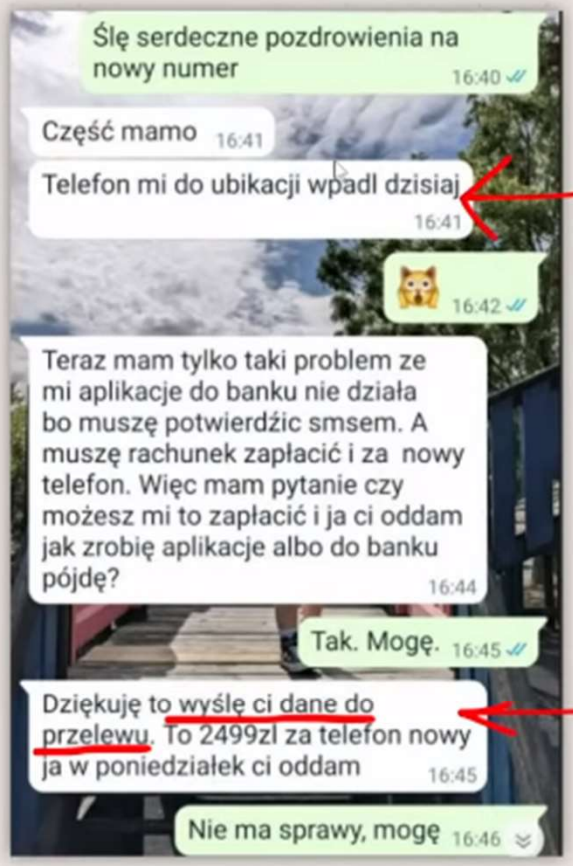
Klasyczna wersja scamu "na OLX"

Próbuje się okradać sprzedających

Przykłady
fałszywe smsy (przekierowanie na WA)

https://cert.orange.pl/aktualnosci/mamo-tato-to-moj-nowy-numer-uwaga-na-oszustwo

Przykłady
fałszywe smsy (cd. na WA)

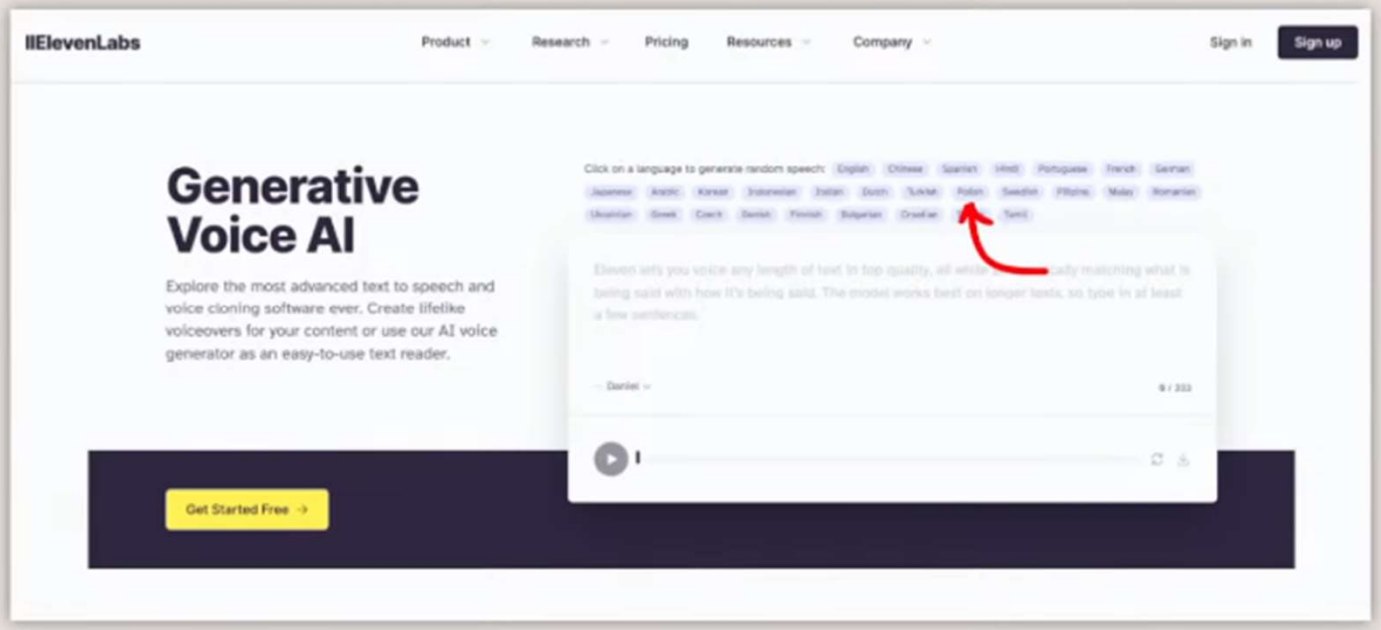


Źródło: CERT Orange

Przykłady
fałszywe telefony

securitum

Przy okazji... klonowanie głosu/AI



Przykłady
fałszywe telefony

Nowy rodzaj cyberprzestępczości

Dyrektor generalny brytyjskiej firmy energetycznej myślał, że rozmawia przez telefon ze swoim szefem, dyrektorem naczelnym niemieckiej firmy macierzystej, który poprosił go o przesłanie funduszy węgierskiemu dostawcy.
Rozmówca zaznaczył, że sprawa jest pilna i polecił dyrektorowi zapłacić w ciągu godziny.

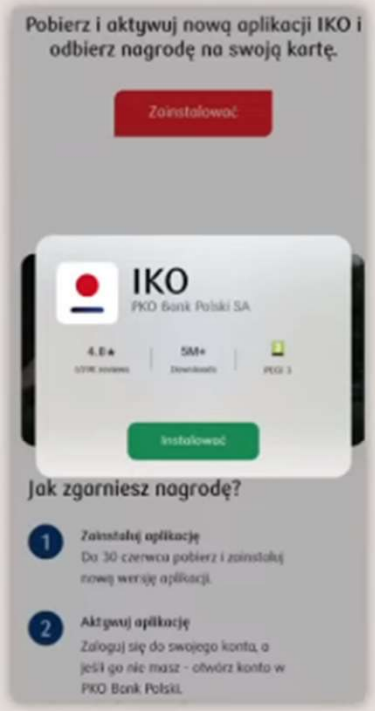
Dyrektor generalny rozpoznał w telefonie lekki niemiecki akcent swojego szefa i tembr jego głosu.

Źródło: www.wsj.com/articles/fraudsters-use-ai-to-mimic-ceos-voice-in-unusual-cybercrime-case-11567157402

Przykłady
fałszywe aplikacje na telefony

Nietypowa appka udająca prawdziwą appkę IKO

https://ipk0-pl.online/



https://cebrf.knf.gov.pl/komunikaty/artykuly-csirt-knf/362-ostrzezenia/874-wykorzystanie-tehnologii-webapk-do-ataku-phishingowego

Przykłady
fałszywe aplikacje na telefony

securitum

WebAPK *działa poprzez generowanie pliku APK (Android Package Kit) dla aplikacji internetowej. APK to format pliku używany przez system operacyjny Android do dystrybucji i instalacji aplikacji mobilnych. Kiedy użytkownik decyduje się na „dodanie do ekranu głównego" aplikacji internetowej, system Android automatycznie generuje plik APK dla tej aplikacji.*

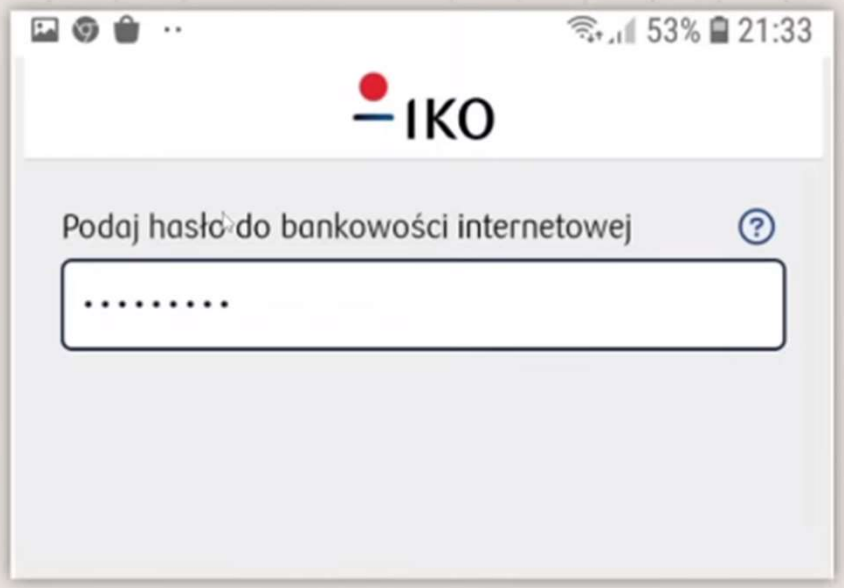
Jednym z głównych atutów technologii WebAPK jest to, że ***pozwala ona na instalację aplikacji internetowych bezpośrednio z przeglądarki, bez konieczności korzystania z Google Play Store.***

(…) Kluczowe było to, że ***proces instalacji nie wywoływał typowych ostrzeżeń o instalacji z niezaufanych źródeł.***

Przykłady
fałszywe aplikacje na telefony

securitum

Kolejne ekrany prosiły użytkownika o podanie loginu, hasła, kodu 2FA oraz kodu sms, który był już wykorzystywany do autoryzacji operacji.



Red Team

Phishing – Red Team

Seriously About Phishing

Or How To Phish Silently And Efficiently

Dorota Kulas
Red Team

sekurak

Phishing – Red Team

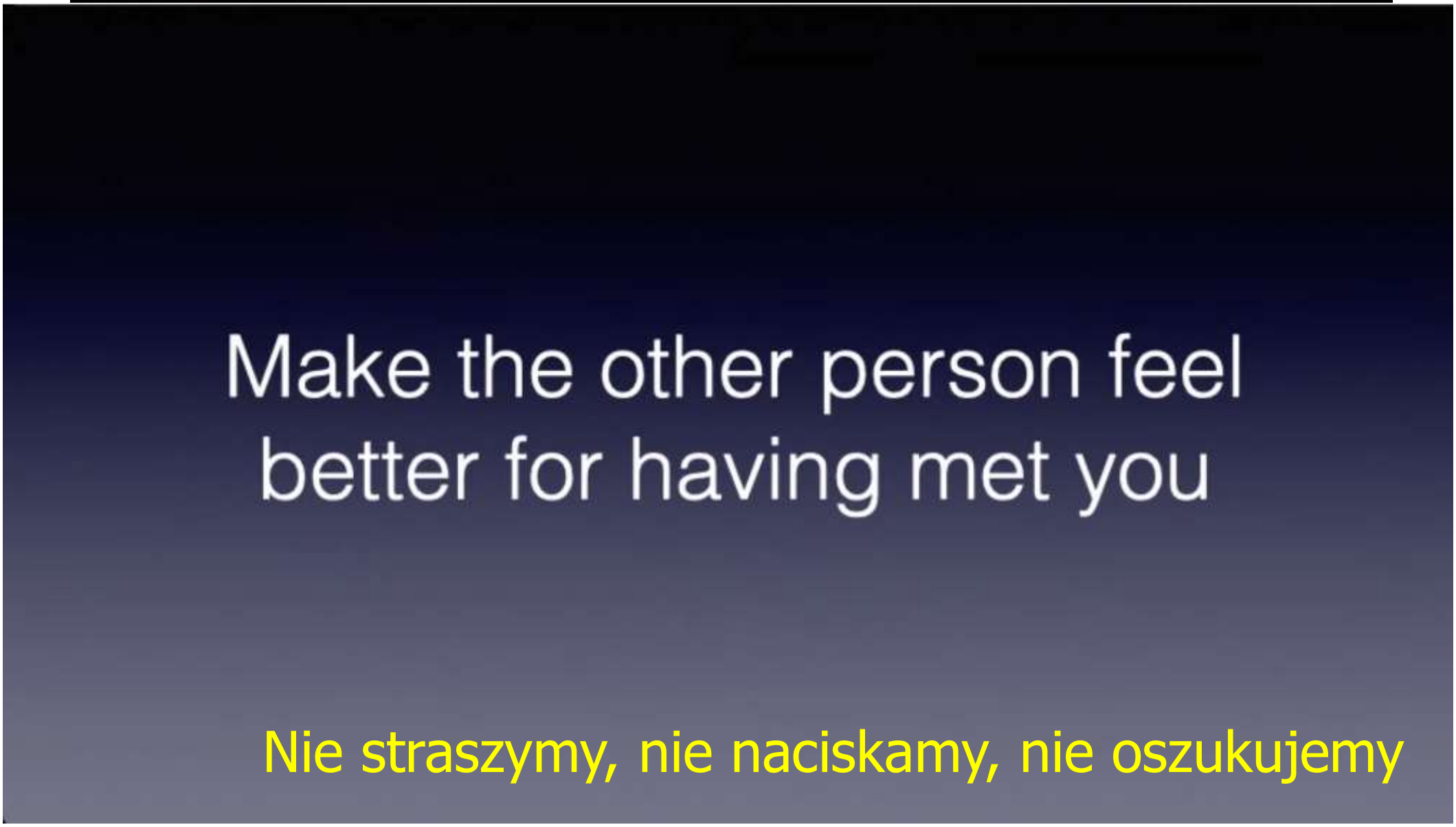
Zakres i założenia kampanii phishingowej

- Ustalenie oczekiwań klienta
  - atak na weryfikowane osoby
  - atak na dokument, tajemnicę firmy
- Etyka – pewnych rzeczy się nie robi (chyba że są wyjątki)
  - nie podszywamy się pod rzeczywiste osoby, inne legalne firmy
  - nie atakujemy kont e-mailowych (nie czytamy e-maili)
- Podszywamy się pod nieistniejący dział w firmie
- Raporty nie zawierają danych osobowych
- Kampania trwa od 2 tygodni do wielu miesięcy

BwSK

T.Łukaszewski

Phishing – Red Team



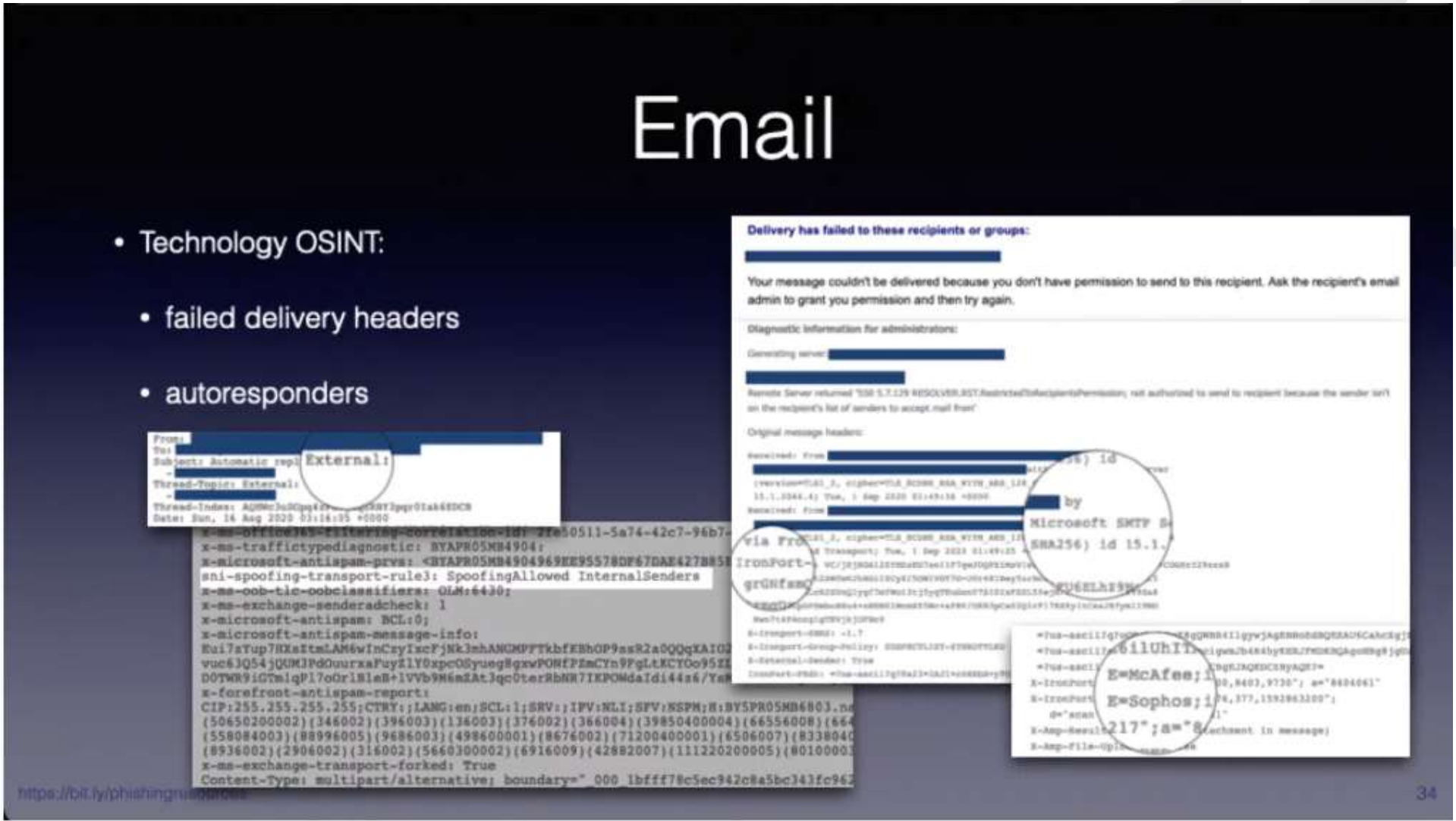
Phishing – Red Team

OSINT – biały wywiad (social media)

- zbieramy informację o firmie/wydziale/pracownikach
- narzędzia (**Maltego, recon-ng**) do wstępnej analizy
- ręczna ostateczna analiza źródeł informacji

Phishing – Red Team

OSINT – biały wywiad (analiza nagłówków)



Phishing – Red Team

Kampania phishingowa

- **Co może wpłynąć na odbiorcę**, że kliknie on w link/załącznik?
  - **ciekawość, chciwość**
- \+ **psychologia społeczna** (np. **Robert Beno Cialdini)**
  - wzajemność (reciprocity)
  - niedostatek (scarcity)
  - autorytet (authority)
  - spójność (consistency)
  - chcemy być lubiani (liking)
  - zgoda, konfirmizm (consensus)

Phishing – Red Team

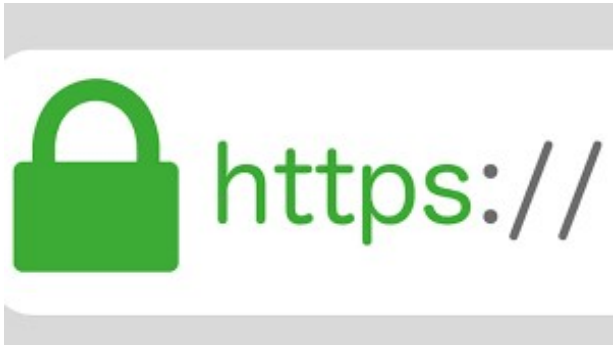
Domena do wysyłania e-maili

- **Nowa domena** może być „zablokowana” przez automaty
- Wybór **używanej domeny**:
  - **scoring** domen/domeny które wygasły:
    - https://www.alexa.com/siteinfo
    - https://www.expireddomains.net
  - **WHOIS privacy** – dane abonenta rejestrującego domenę są częściowo ukryte w bazie WHOIS (osoby prywatne) lub po aktywowaniu **privacy**
  - **WHOIS history**
    - https://whois-history.whoisxmlapi.com/

Phishing – Red Team

Hasła - klonowanie strony z formularzami

- **Strona wygląda jak zawsze**
- **Jest „kłódka”**
- **Social Engineer Toolkit** (klonowanie stron)
  - https://github.com/trustedsec/social-engineer-toolkit
- **MiTM w celu oszukania 2FA**
  - https://github.com/kgretzky/evilginx2
  - Certyfikat będzie POPRAWNY
  - Adres będzie **FAŁSZYWY**



Phishing – Red Team

Atak

- **Exploit dla przeglądarki (antywirusy są coraz lepsze)**
- **Aktywny kod (Java, JavaScript, ActiveX) (przeglądarki coraz częściej wymagają podpisania kodu – zakup klucza na firmę)**
- **Załącznik lub link (dokument/binarka)**

Phishing – Red Team
jak przygotować Emaila

Email

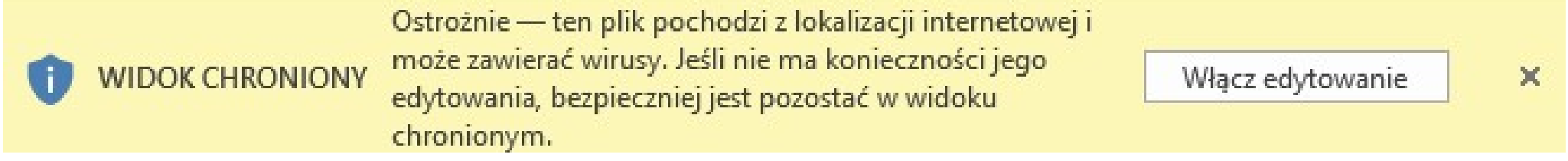
- Address the target by name (“Dear Dorota”)
- Make it familiar
- Start with easily verifiable facts
- Don't provide too much information
- **Hook them in** (a draw to win? a mandatory action? “check if you are eligible”?)
- Too good to be true?
- Don't promise something you can't deliver

Phishing – Red Team
Email z MAKRO

T.Łukaszewski

Czy antywirus może wykryć makro wykonujące kod?

- **Wykrywanie technik wykonania kodu w makrze**
  - **AutoExec()**
  - **Document_Open()**
  - **Auto_Open()**
  - **Workbook_Open()**
  - **CommandButton1_Click()**
- **Pełne zestawienie „niebezpiecznych” funkcji – następna strona**



Phishing – Red Team
Email z MAKRO

Where to start?

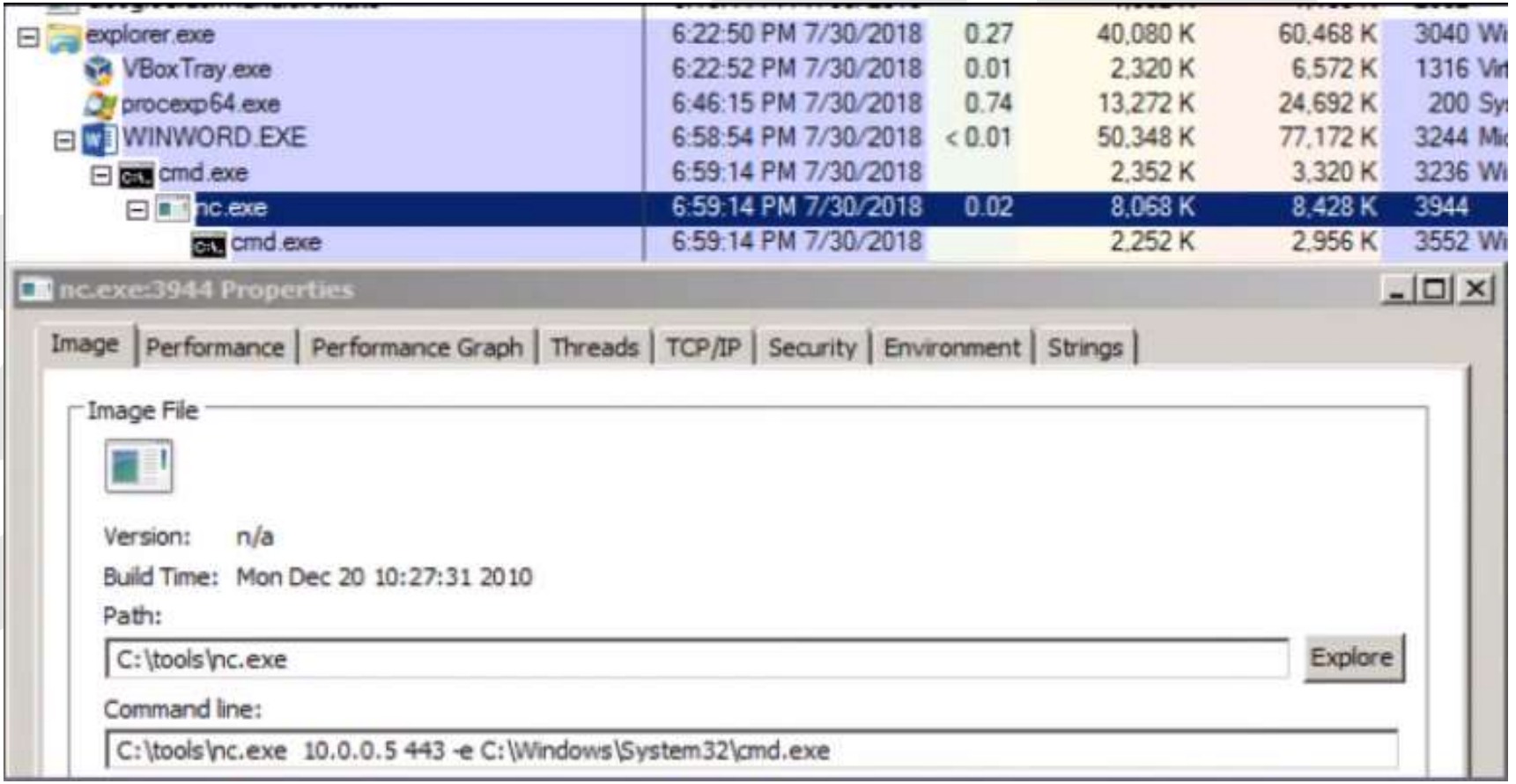
- Need to find an entry point
  - Auto Start Functions:
    - autoopen, document_open, autoclose,
    - document_close, auto_open, autoexec,
    - autoexit, document_beforeclose, workbook_open,
    - workbook_activate, auto_close, workbook_close,
    - workbook_deactivate, documentopen, app_documentopen
  - Callback Functions:
    - Activate, BeforeNavigate2, BeforeScriptExecute, Change,
    - DocumentComplete, DownloadBegin, DownloadComplete,
    - FileDownload, GotFocus, Layout, LostFocus, MouseEnter,
    - MouseHover, MouseLeave, MouseMove, NavigateComplete2,
    - NavigateError, Painted, Painting, ProgressChange,
    - PropertyChange, Resize, SetSecureLockIcon, StatusTextChange,
    - TitleChange, Initialize, Click, OnConnecting, BeforeClose,
    - OnDisconnected, OnEnterFullScreenMode, Zoom, Scroll, BeforeDropOrPaste
  - User Interaction
    - Hotkey Presses
    - Form Button Clicks

Thanks to Ken Towne

Phishing – Red Team
Email z MAKRO

Skutki odpalenia „poleceń” z makra

- **widoczne w proces eksplorerze (PONIŻEJ)**
- **„niewidoczność” - wstrzyknięcia kodu do nowego wątku**



Phishing – Red Team
obrona

Wiem (Red Team) że ty wiesz (Blue Team)
Wykrywanie procesu wykrycia ataku

- **Wykrycie hasha kodu na VT (BT sprawdza kod)**
- **Podejrzane loginy/hasła od formularzy (BT testuje)**
- **Podejrzany ruch do serwerów Red Teamu (BT testuje)**

Phishing – Red Team
obrona

Obrona - narzędzia do analizy makra

Macro - Analysis

- https://github.com/decalage2/oletools/wiki/olevba
- Interesting options:

  --code

  --analysis

  --reveal

```
VBA MACRO Sheet2.cls
in file: xl/vbaProject.bin - OLE stream: u'VBA/Sheet2'
+----------+--------------------+--------------------------------------------+
|Type      |Keyword             |Description                                 |
+----------+--------------------+--------------------------------------------+
|Suspicious|CreateObject        |May create an OLE object                    |
|Suspicious|Environ             |May read system environment variables       |
|Suspicious|Run                 |May run an executable file or a system      |
|          |                    |command                                     |
|Suspicious|Open                |May open a file                             |
|Suspicious|RegRead             |May read registry keys                      |
|Suspicious|Chr                 |May attempt to obfuscate specific strings   |
|          |                    |(use option --deobf to deobfuscate)         |
|Suspicious|Xor                 |May attempt to obfuscate specific strings   |
|          |                    |(use option --deobf to deobfuscate)         |
|Suspicious|                    |                                            |
|          |                    |                                            |
|Suspicious|                    |                                            |
|          |                    |                                            |
|Suspicious|codemodule          |May attempt to modify the VBA code (self-   |
|          |                    |modification)                               |
|Suspicious|                    |                                            |
|          |                    |                                            |
|Suspicious|Shell               |May run an executable file or a system      |
|          |                    |command (obfuscation: Hex)                  |
|Suspicious|Windows             |May enumerate application windows (if       |
|          |                    |combined with Shell.Application object)     |
|          |                    |(obfuscation: Hex)                          |
|Suspicious|                    |                                            |
|          |                    |                                            |
|Suspicious|System              |May run an executable file or a system      |
|          |                    |command on a Mac (if combined with          |
|          |                    |libc.dylib) (obfuscation: Hex)              |
|Suspicious|Hex Strings         |Hex-encoded strings were detected, may be   |
|          |                    |used to obfuscate strings (option --decode to|
|          |                    |see all)                                    |
|Hex String|https://re          |68747470733a2f2f7265                        |
|Hex String|                    |                                            |
|Hex String|                    |                                            |
|Hex String|/upd                |2f757064                                    |
|Hex String|/visitormatch?      |2f76697369746f726d6174636683f               |
|Hex String|p=7hXcAV            |703d376858634156                            |
```

https://bit.ly/phishingresources

Thanks to Ken Towne

Phishing – Red Team
Podsumowanie

Obrona & Detekcja **(Podsumowanie)**

- zapobiegaj spoofingowi (SMTP)
- polityka wobec nowych domen
- starać się myśleć jak atakujący – np. sandboxy odpalać także z „normalnych adresów”
- ASR (Attack Surface Reduction) rules (Microsoft)
- ograniczać ruch wychodzący (np. proxy)
- no local admin
- Logi, SIEM

Phishing – Red Team
Podsumowanie

Obrona & **Detekcja (Podsumowanie)**

- wiek domeny (nowa domena = podejrzane)
- posiadacz domeny (dziwne dane = podejrzane)
- WHOIS privacy (nieukryte dziwne dane = podejrzane)
- WHOIS privacy (ukryte dane = podejrzane)
- historia WHOIS (częsta zmiana właściciela = podejrzane)
- certyfikat SSL (dziwne dane, nowy = podejrzane)
- Web Archive (różne treści = podejrzane)

Więcej:

- https://pastebin.com/SJ1hBYLr
- https://pastebin.com/gYGAC4Up

Podsumowanie

Podsumowanie
zalecenia

securitum

Jak rozpoznać do jakiego serwera się łączymy?

https://sekurak.pl/test.gov.pl

Szyfrowanie połączenie

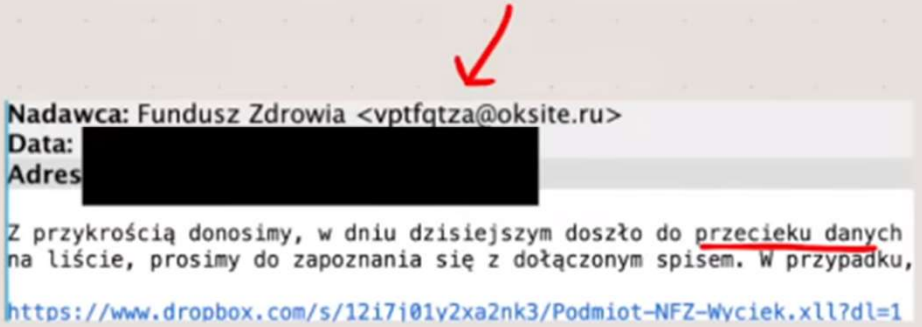
Prawdziwy adres serwera

Podsumowanie
zalecenia

T.Łukaszewski

securitum

- Sprawdź adres nadawcy e-maila, a nie jego nazwę



- Nie klikaj w linki w e-mailach "bankowych"

- Pamiętaj, że link może prowadzić do innego miejsca niż sugeruje jego nazwa

Podsumowanie
zalecenia

securitum

- QR kod to nośnik danych (często zawiera po prostu link)
  Link może być złośliwy bądź normalny

- QR kod naklejony fizycznie, wyglądający profesjonalnie,
  wcale nie musi oznaczać "normalności" linku

- Uwaga na skanowanie kodów QR w aplikacji Wiadomości
  (Android)

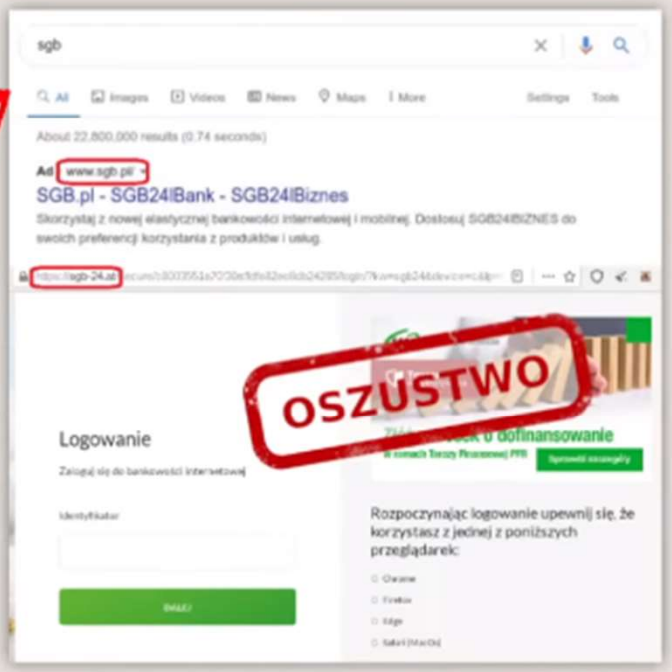
BwSK
T.Łukaszewski

Podsumowanie
zalecenia

securitum

Na strony bankowe wchodź "ręcznie" lub z zakładek

stworzenie nowej zakładki:
ctrl+d w przeglądarce



nie używaj google
do wchodzenia na stronę swojego banku

Podsumowanie
zalecenia

- Weryfikuj czy rozmawiasz z prawdziwą osobą (prezes, straż graniczna, konsultant z banku, UODO, Twoje dziecko, etc)

- Uważaj na propozycję łatwej i rewelacyjnie płatnej pracy

Podsumowanie
zalecenia

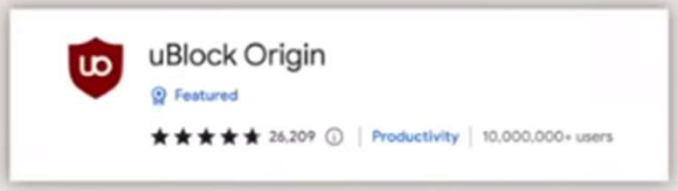
securITum

- Uwaga na instalację appek polecanych linkiem w SMS, w linku przesłanym przez znajomego, etc

Podsumowanie
zalecenia

securitum

- Zainstaluj AD blocker (bloker reklam) w przeglądarce - np. uBlock Origin



- Zawsze analizuj z jakiej strony pobierasz oprogramowanie

- Przed instalacją oprogramowania możesz przeanalizować je w serwisie virustotal.com

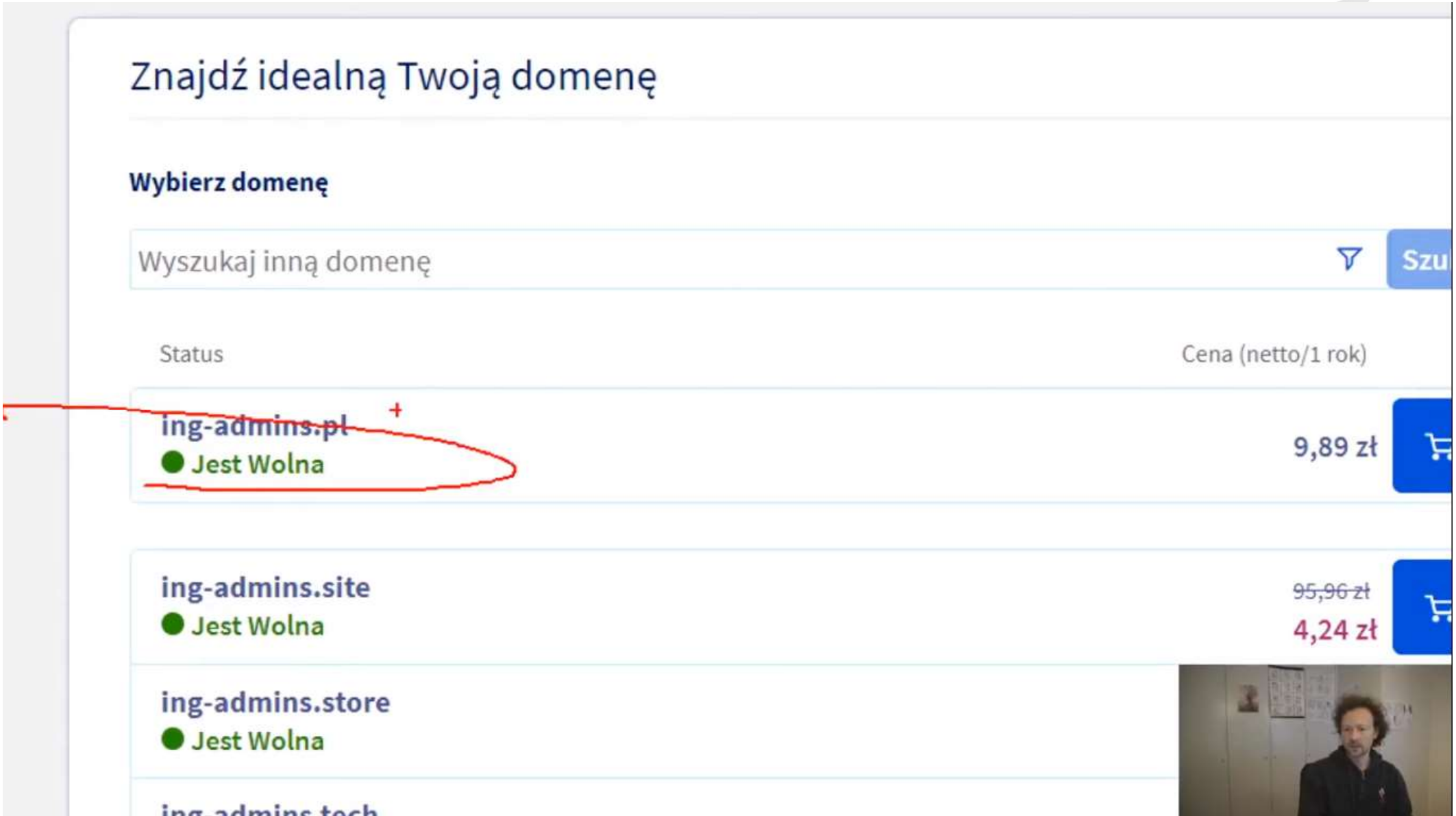
Podsumowanie
zalecenia

securitum

- Uważaj na łatwe / szybkie propozycje wzbogacenia się / inwestycje
- Nie instaluj oprogramowania polecanego przez "konsultantów" inwestycyjnych

BwSK
T.Łukaszewski

Podsumowanie
uważaj na „podobne domeny”

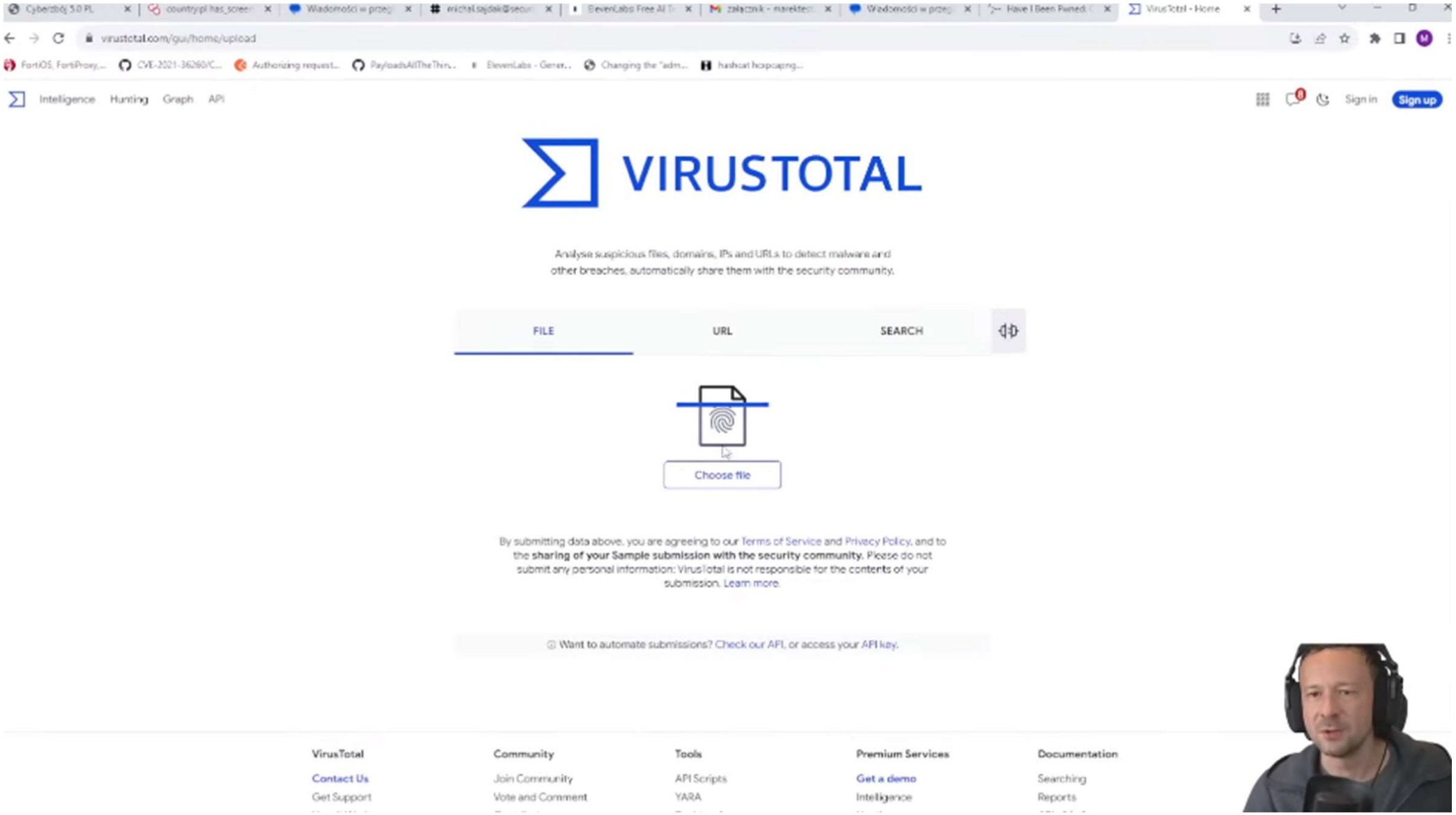


BwSK

T.Łukaszewski

Podsumowanie

weryfikacja podejrzanych załączników

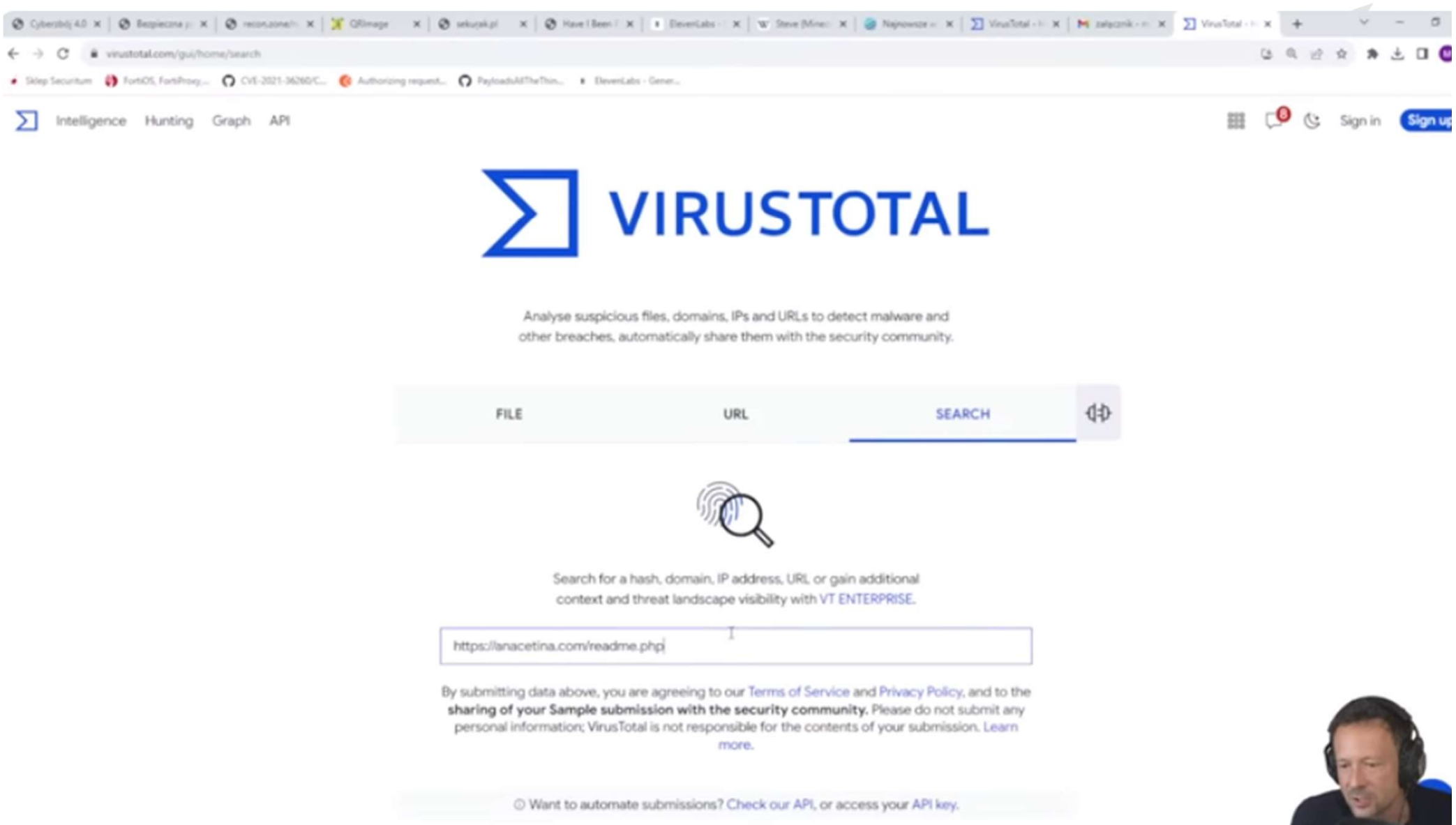


BwSK

T.Łukaszewski

Podsumowanie

weryfikacja podejrzanych linków



Przykłady ataków Polska i Świat

Przykłady ataków

securitum

Przegląd ostatnich / głośnych cyberataków na firmy / internautów w Polsce.

michal.sajdak@securitum.pl
@sajdoor

Przykłady ataków

securitum

Największy problem

Brak świadomości zagrożeń

0111001100001

Przykłady ataków
nie publikujmy danych !!!

securitum

Zdjęcia wrzucane do Internetu

BwSK

T.Łukaszewski

Przykłady ataków

co można zrobić z danymi ...

dokumenciki.net

Dokumenty kolekcjonerskie - najwyższa jakość, szybka realizacja, wysyłka za pobraniem

Prawo jazdy kolekcjonerskie Dowód osobisty kolekcjonerski

Czym charakteryzuje się nasz **dowód osobisty kolekcjonerski?**

Wykonywane przez nas kolekcjonerskie dowody osobiste posiadają wszystkie niezbędne emblematy, dzięki którym wyglądają dokładnie jak oryginalny dokument. Zastosowanie prawdziwych hologramów, grawerów, znaków Braille i farby optycznie zmiennej (OVI), daje w rezultacie doskonałą kopię oryginalnego dokumentu. Jako jedyni produkujemy dowody osobiste kolekcjonerskie z prawdziwymi hologramami, a nie złotą farbą udającą hologram. Profesjonalne maszyny oraz wieloletnie doświadczenie gwarantują, że otrzymają Państwo najwyższej jakości kolekcjonerski dowód, nawet na drugi dzień od złożenia zamówienia.

Kolekcjonerskie dokumenty mogą być wykorzystywane tylko i wyłącznie w celach prywatnych. Nie można stosować ich jako autentyczny dokument tożsamości, który przedstawimy, np. w urzędzie, policji, czy nawet listonoszowi. Nasze dokumenty produkowane są poza granicami Rzeczpospolitej Polskiej i nie naruszają prawa kraju, w którym są produkowane.

ZAMÓW JUŻ TERAZ!

Do czego służą lub mogą posłużyć kolekcjonerskie dowody osobiste?

Dokumenty kolekcjonerskie to z założenia repliki oryginalnych dokumentów, wykonane na dowolne dane dostarczone przez klienta. Służą przede wszystkim jako zastępstwo oryginalnego dokumentu, na przykład w przypadku jego zagubienia. Dlaczego więc wiele osób wybiera dokument kolekcjonerski, zamiast wyrobić w urzędzie nowy? Powodów jest wiele. Przede wszystkim czas. Wiele osób decyduje się na zakup kolekcjonerskiego dowodu osobistego np. Z powodu pilnego wyjazdu. Ponieważ czas wykonania dowodu osobistego w urzędzie nie rzadko przekracza 20-25 dni, natomiast nasze dokumenty wysyłamy już następnego dnia i docierają one do adresata w ciągu średnio 36 godzin. Wiele osób składa zamówienia w celu sprawienia komuś żartu, jako gadżet na wieczór panieński, czy osiemnastkę, albo w celu zmiany płci gdy ma problem z dokonaniem takiej zmiany w normalnym procesie urzędowym.

Najczęściej zadawane pytania:

Skąd mam wziąć numer pesel i numer dowodu?

— PESEL to 11-cyfrowy numer znajdujący się z tyłu dowodu osobistego.

— numer dowodu (tzw. Seria dowodu) to numer w postaci trzech liter i sześciu cyfr, np. CRP 123456, znajdziesz go z tyłu dowodu osobistego.

— Jeśli nie posiadasz ani numeru PESEL ani numeru dowodu (serii) możemy je dla Ciebie wygenerować, w tym celu zaznacz odpowiednie pole podczas składania zamówienia.

Przykłady ataków
co można zrobić z danymi ...

securitum

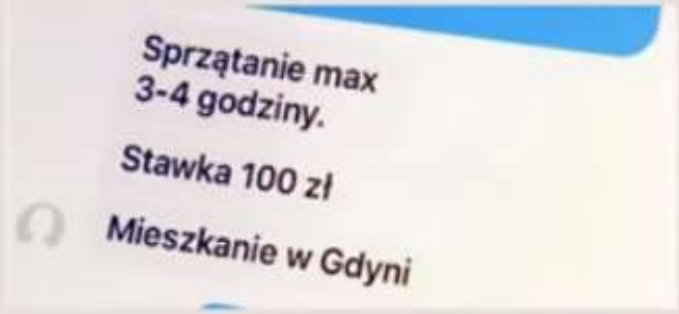
" Właściciel mówi, że kawalerki nie sprzedawał. Kupiec potwierdza: u notariusza spisał umowę z kimś innym. Nazwisko się zgadzało, PESEL też. Tylko że dowód osobisty był fałszywy. Po oszuście ani pieniądzach nie ma śladu. Spór o mieszkanie rozstrzygnie sąd.

https://warszawa.wyborcza.pl/warszawa/7,54420,24897298,oszustwo-doskonale-kto-sprzedal-cudze-mieszkanie-na-freta.html

Przykłady ataków
co można zrobić z danymi ...

securitum

Patrycja S. żyła z wyłudzania kredytów na niewinne osoby. Ogłaszała, iż szuka osób do sprzątania mieszkania, a gdy ofiary się zgłaszały, wysyłała je by np. wyrzuciły śmieci. Pod ich nieobecność kradła, kopiowała, czy skanowała ich dowody osobiste. Później wystarczyło udać się do parabanków. Skala oszust zdumiewa. Tylko w zeszłym roku kobieta usłyszała 250 zarzutów.



https://interwencja.polsatnews.pl/reportaz/2020-05-19/zatrudniala-do-sprzatania-i-zaciagala-na-ofiary-kredyty/

Przykłady ataków
co można zrobić z danymi ...

securitum

" opisałem bulwersującą historię, jaka spotkała panią Beatę. W ubiegłym roku dowiedziała się, że ktoś wyłudził na jej nazwisko 50.000 zł kredytu. Powiadomiła Policję i bank, ale wyjaśnienie sprawy zaczęło się ślimaczyć. A pani Beata miała sygnały, że bank będzie ściągał z niej pieniądze.

" Bank Credit Agricole – „winowajca" całej sytuacji – skontaktował się ze mną i zapewnił, że gra w tej samej drużynie, co pani Beata.

https://subiektywnieofinansach.pl/oszustwo-na-jej-nazwisko-wyludzono-50-000-zl-kredytu-bank-obiecuje-koniec-windykacji/

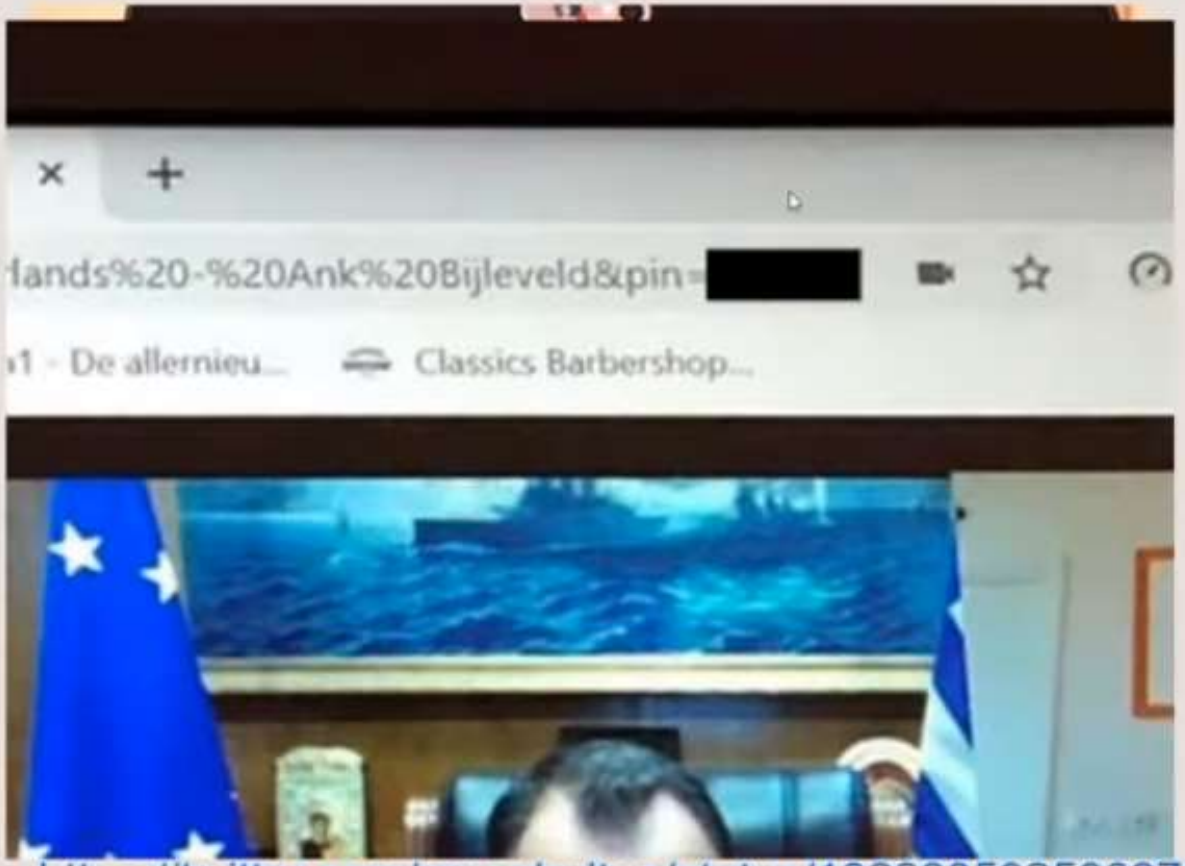
Przykłady ataków
nie chwalmy się !!!

securitum

https://twitter.com/mvanhulten/status/1329885925862760450

Przykłady ataków
konsekwencje chwalenia się ...

securitum



https://twitter.com/mvanhulten/status/1329885925862760450

0111001100001

Przykłady ataków
nieodpowiedzialność !!!

securitum

Przykłady ataków
nieodpowiedzialność !!!

securitum

Rumuński minister obrony okazał się blackhatem ;-)
Zdradził hasła na zdjęciach wrzuconych na Facebooka

https://sekurak.pl/rumunski-minister-obrony-okazal-sie-blackhatem-zdradzil-hasla-na-zdjeciach-wrzuconych-na-facebooka/

Przykłady ataków
utrata prywatności celebrytów (Japonia) !!!

securitum

Poznał lokalizację dziewczyny analizując na zdjęciu odbicie w jej oczach.

https://sekurak.pl/poznal-lokalizacje-dziewczyny-analizujac-na-zdjeciu-odbicie-w-jej-oczach-uwazajcie-jakie-fotki-wrzucacie-do-netu/

Przykłady ataków
w konsekwencji stalkowanie …

securitum

Poznał lokalizację dziewczyny analizując n

https://sekurak.pl/poznal-lokalizacje-dziewczyny-analizujac-na-zdjeciu-odbicie-w-jej-oczach-uwazajcie-jakie-fotki-wrzucacie-do-netu/

0111001100001

Przykłady ataków

securitum

Kilka słów o niezbyt dobrym zamazywaniu zdjęć...

DEMO?

0111001100001

BwSK

T.Łukaszewski

Przykłady ataków

zamazanie w PDFie poprawne ???

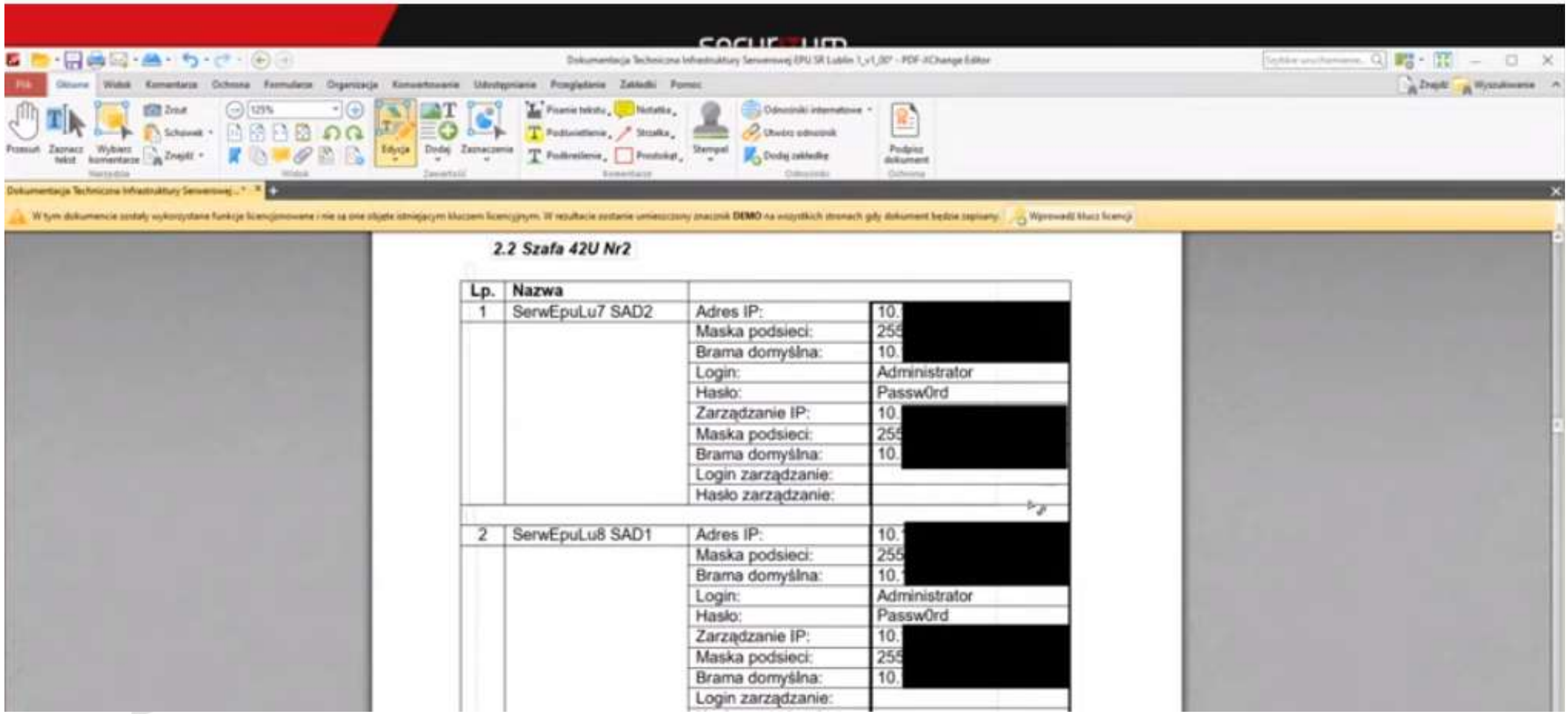
securitum

2.2 Szafa 42U Nr2

Lp.	Nazwa	
1	SerwEpuLu7 SAD2	Adres IP:
		Maska podsieci:
		Brama domyślna:
		Login:
		Hasło:
		Zarządzanie IP:
		Maska podsieci:
		Brama domyślna:
		Login zarządzanie:
		Hasło zarządzanie:
2	SerwEpuLu8 SAD1	Adres IP:
		Maska podsieci:
		Brama domyślna:
		Login:
		Hasło:
		Zarządzanie IP:
		Maska podsieci:
		Brama domyślna:
		Login zarządzanie:
		Hasło zarządzanie:
3	SerwEpuLu9 SFO2	Adres IP:
		Maska podsieci:
		Brama domyślna:
		Login:
		Hasło:
		Zarządzanie IP:

Przykłady ataków

NIE: edytując można odsłonić dane !!!



2.2 Szafa 42U Nr2

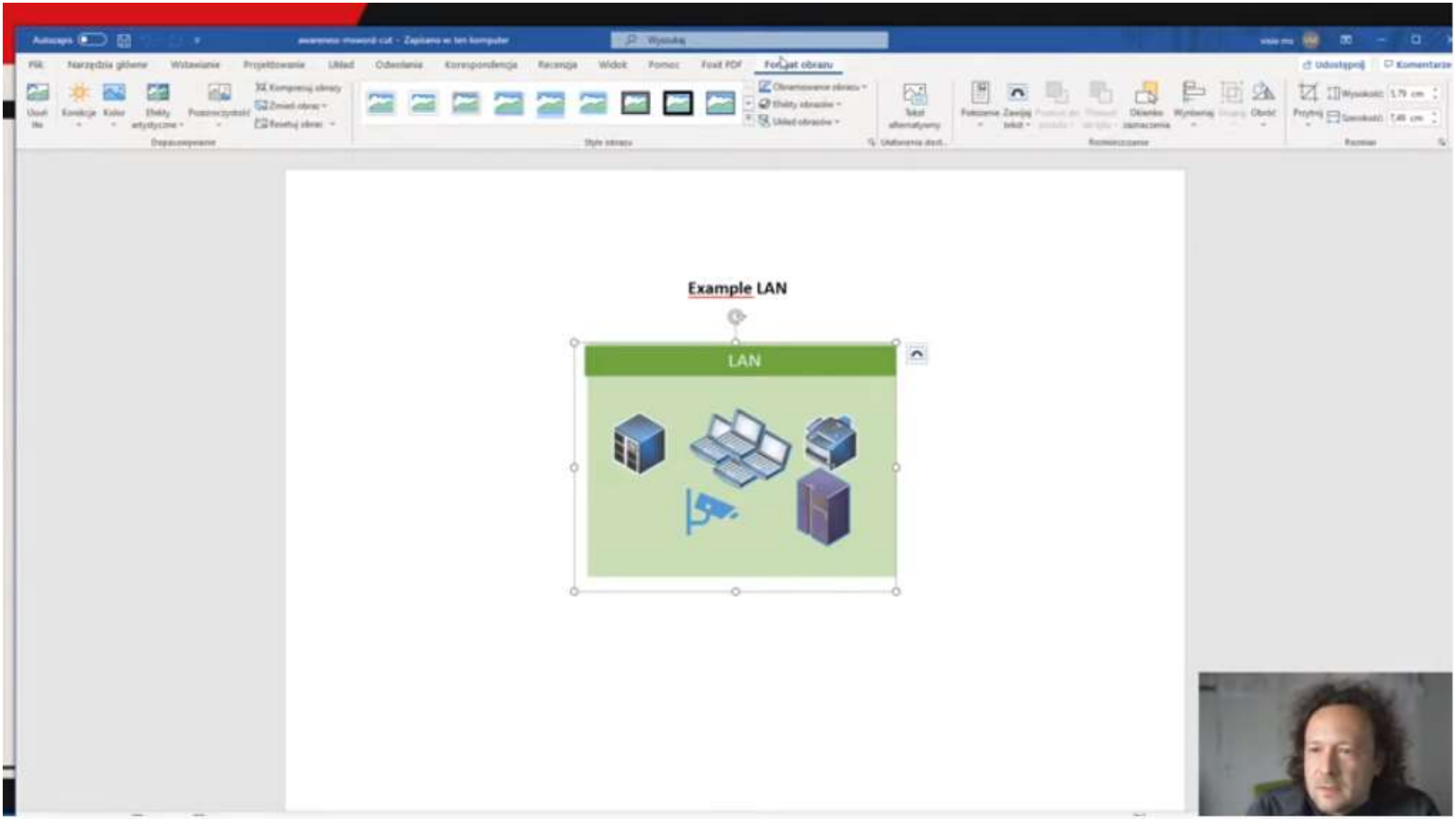
Lp.	Nazwa		
1	SerwEpuLu7 SAD2	Adres IP:	10. [redacted]
		Maska podsieci:	255
		Brama domyślna:	10.
		Login:	Administrator
		Hasło:	Passw0rd
		Zarządzanie IP:	10. [redacted]
		Maska podsieci:	255
		Brama domyślna:	10.
		Login zarządzanie:	
		Hasło zarządzanie:	
2	SerwEpuLu8 SAD1	Adres IP:	10. [redacted]
		Maska podsieci:	255
		Brama domyślna:	10.
		Login:	Administrator
		Hasło:	Passw0rd
		Zarządzanie IP:	10. [redacted]
		Maska podsieci:	255
		Brama domyślna:	10.
		Login zarządzanie:	

BwSK

T.Łukaszewski

Przykłady ataków

edycja w Wordzie poprawna ???

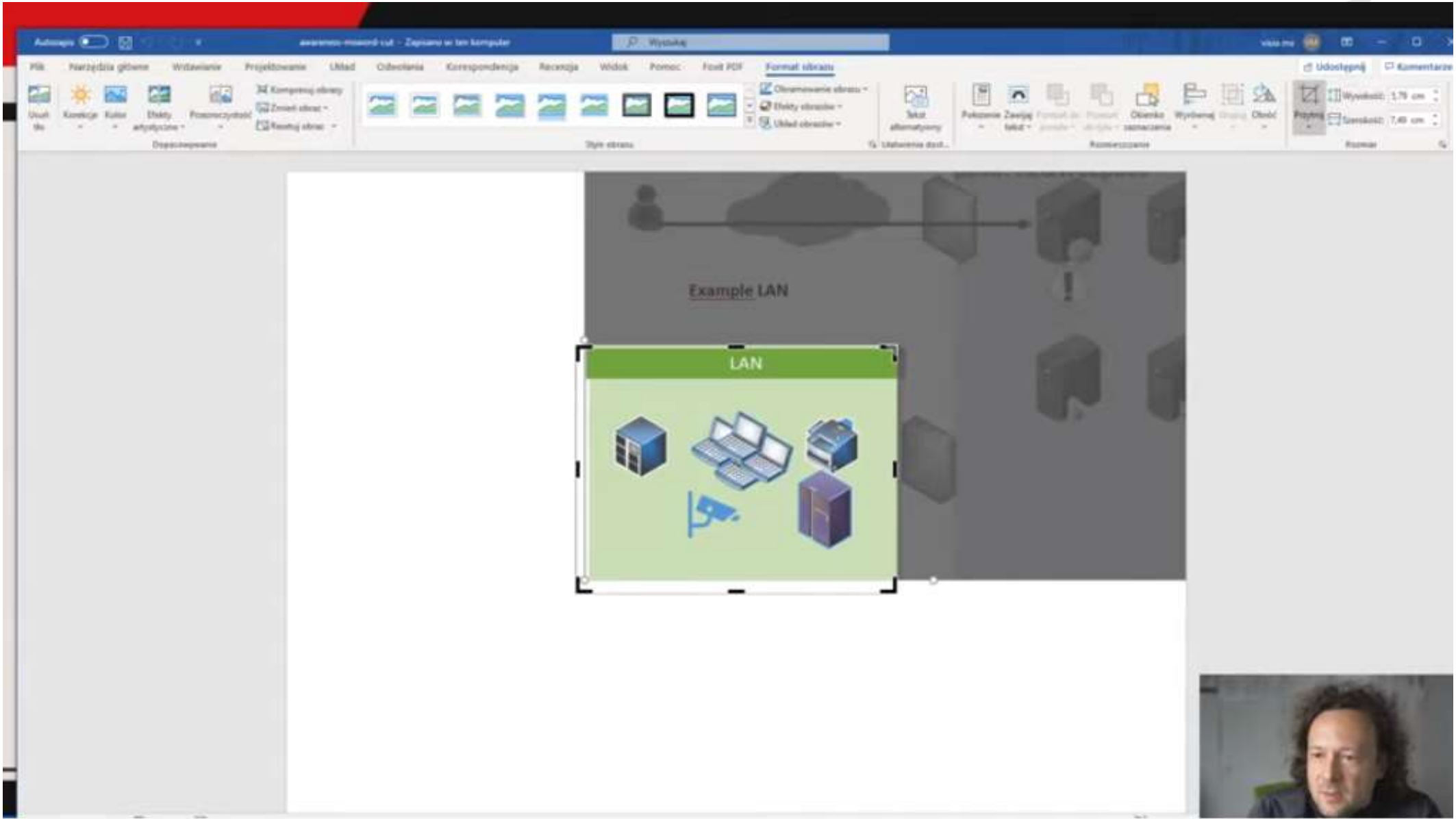


BwSK

T.Łukaszewski

Przykłady ataków

NIE: format + przytnij odsłania dane !!!

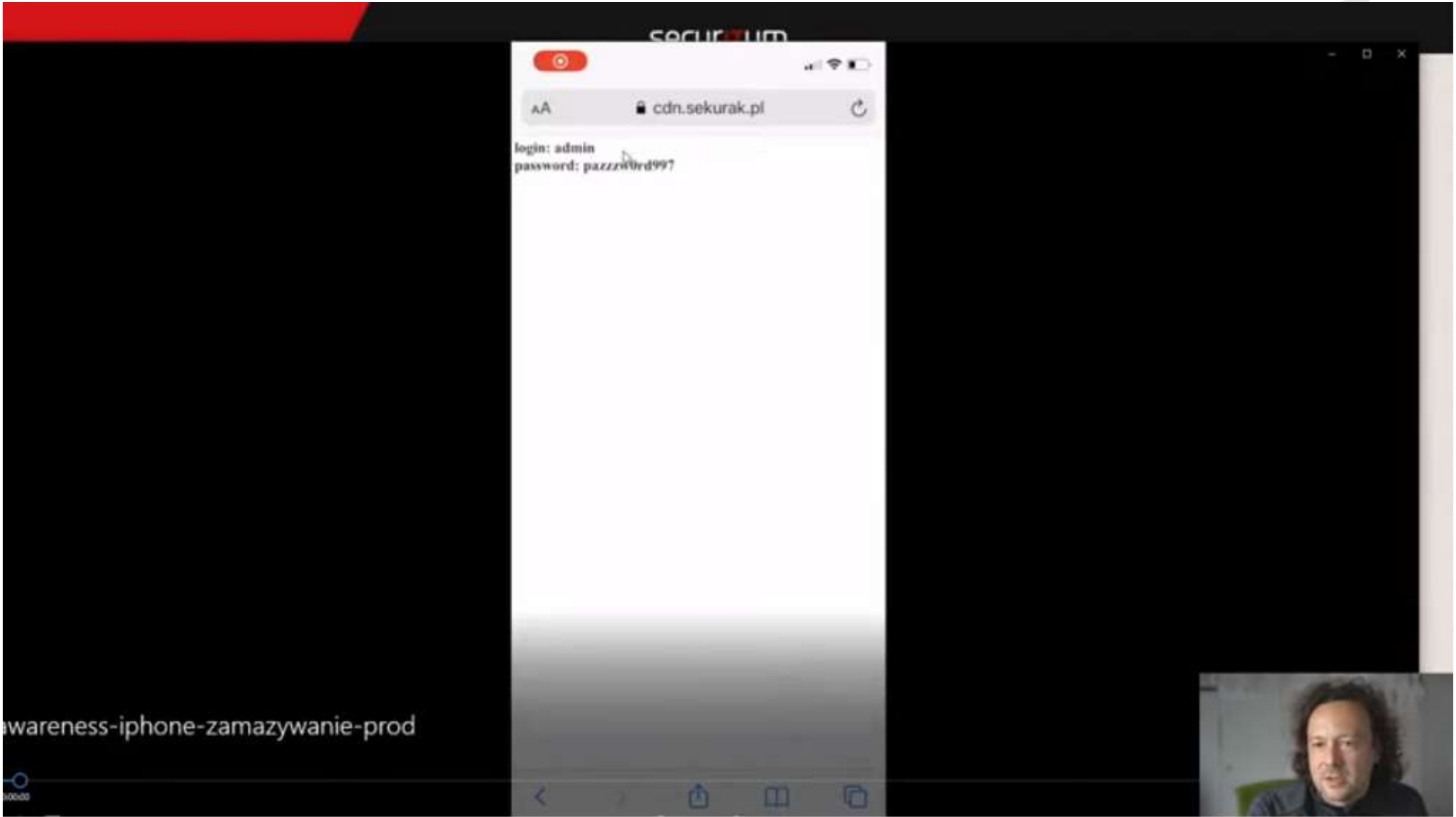


BwSK

T.Łukaszewski

Przykłady ataków

zamazywanie w telefonie poprawne ???

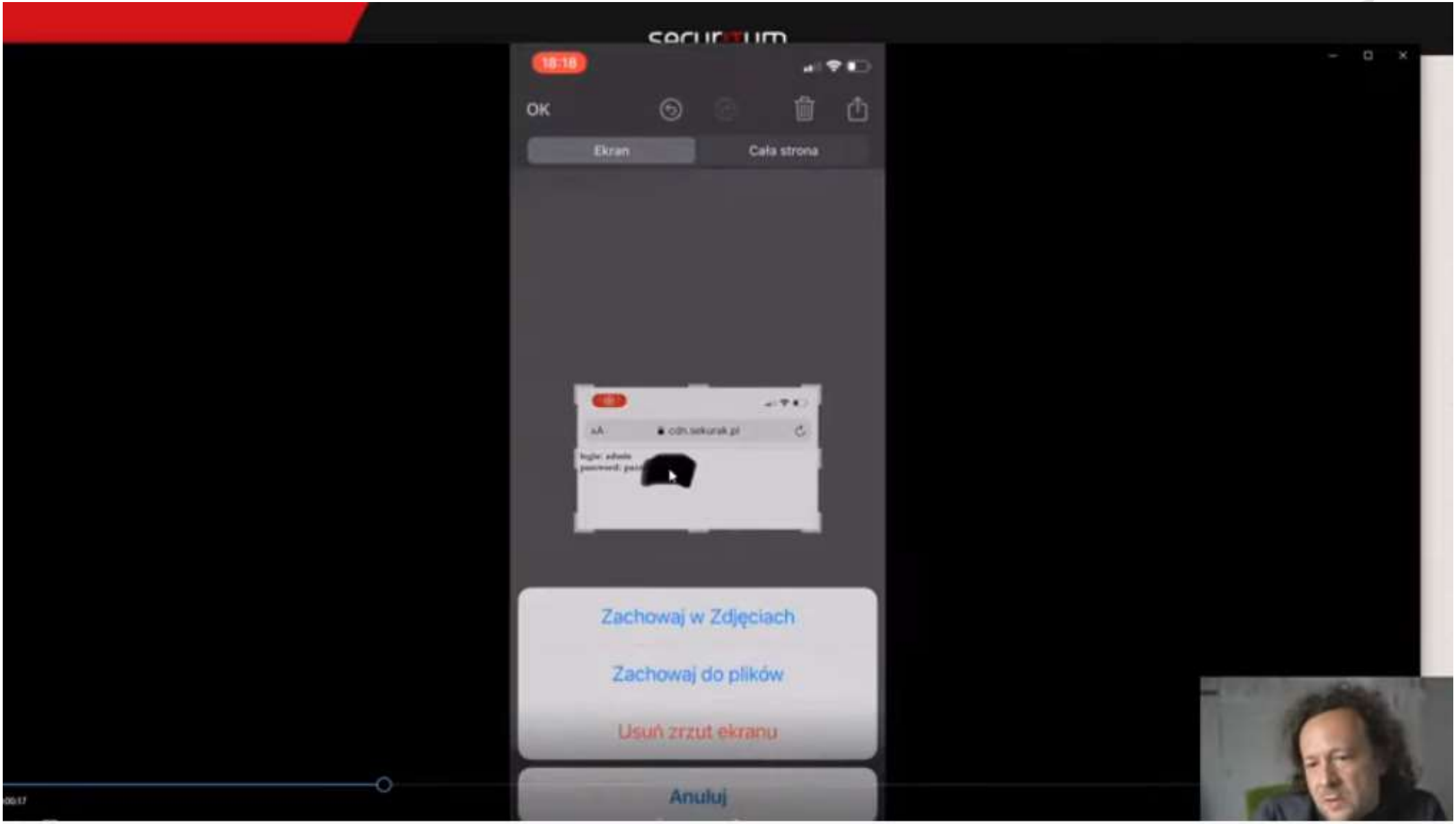


BwSK

T.Łukaszewski

Przykłady ataków

zamazywanie w telefonie poprawne ???



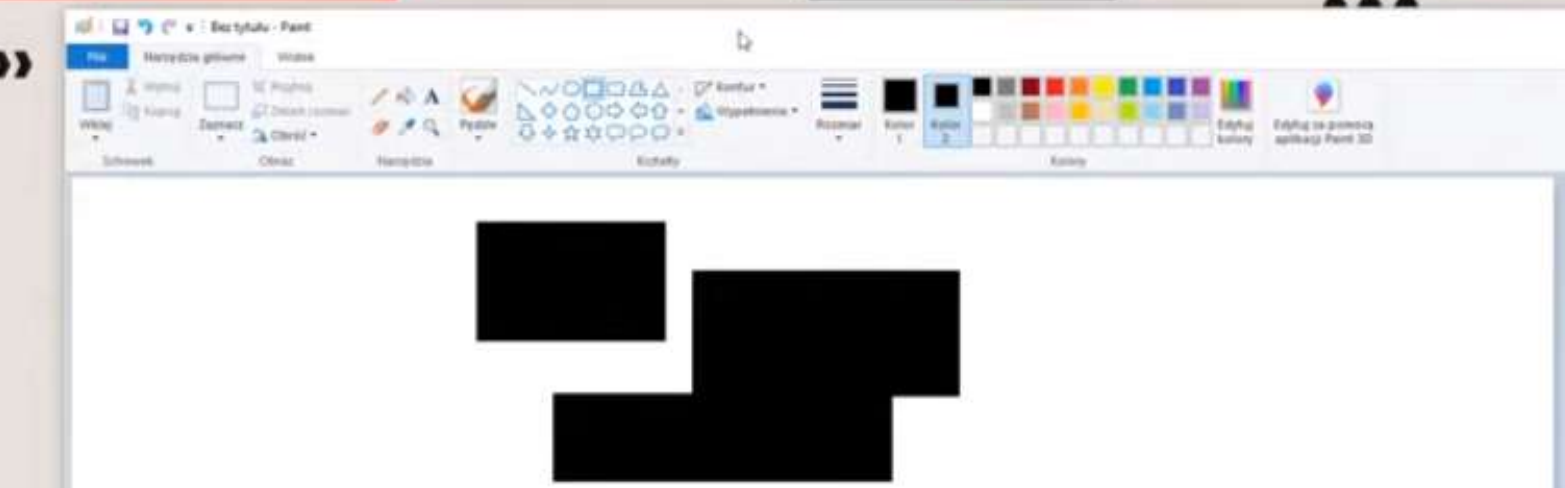
Przykłady ataków

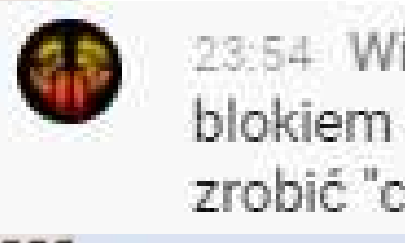
NIE: zmiana parametrów zdjęcia !!!

Przykłady ataków

poprawnie: Paint + zrzut ekranu !!!

securitum





23:54 Wilk Wilkowy Przy zamazaniu czarnym blokiem może pozostać ślad w kanale alfa. Lepiej zrobić "cut".

Przykłady ataków
Business Email Compromise

securitum

Przejęcie dostępu do e-maila (BEC)

Oslo, May 13th, 2020

Norfund has been exposed to a serious case of fraud through an advanced data breach. We are now cooperating closely with the police and other relevant authorities to get a full overview of the situation and to pursue and protect our interests.

https://www.norfund.no/norfund-has-been-exposed-to-a-serious-case-of-fraud/

Przykłady ataków
Business Email Compromise

securitum

Co się wydarzyło?

1. Atak na serwer pocztowy Norfund
2. Analiza języka używanego w korporacji / analiza e-maili
3. Wysyłka e-maila do jednego z partnerów (LOLC)
   - “ *Hej, mamy opóźnienia w przelewach (COVID-19...)*
4. Sfałszowany e-mail od LOLC do Norfund
   - “ *Hej, mamy nowy numer konta*
5. Norfund wysyła pieniądze na "lewe konto" (w Meksyku), LOLC nie odzywa się, że nie ma pieniędzy (przecież pisali że są opóźnienia...)

https://www.norfund.no/norfund-has-been-exposed-to-a-serious-case-of-fraud/

Przykłady ataków
Jak ukraść ... 500 mln

securitum

Jak ukraść 500 000 000 zł?

https://sekurak.pl/litwin-skazany-na-wiezienie-za-skuteczny-phishing-na-google-i-facebooka-wytransferowal-z-ich-kont-okolo-500-000-000-pln/

0111001100001

Przykłady ataków
Jak ukraść ... 500 mln

securITum

Ofiary: Google / Facebook

“ Litwin zarejestrował w swoim kraju firmę Quanta Computer (wiedział, że giganci zza oceanu kupują tam sprzęt IT), następnie wysłał stosowne, podrobione maile do Google i Facebooka (mowa tu jest o phishingu) m.in. z podrobionymi fakturami.

Akcja była tak dobrze przygotowana, że pieniądze rzeczywiście zostały przesłane do banków na Cyprze, Łotwie i kilku innych krajów (właścicielem kont była „lewa” spółka). Oświadczenie departamentu sprawiedliwości USA mówi o przelanej sumarycznej kwocie „ponad 100 milionów dolarów”

0111001100001

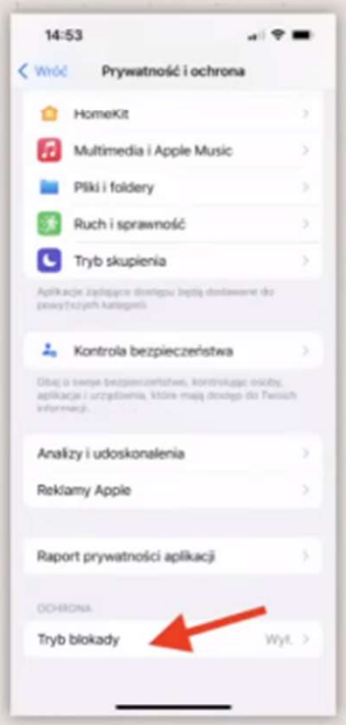
Przykłady ataków
Pegasus (2023)

securitum

Pegasus cały czas aktywny

BLASTPASS: załatana we wrześniu 2023
seria dwóch podatności 0day w iPhone

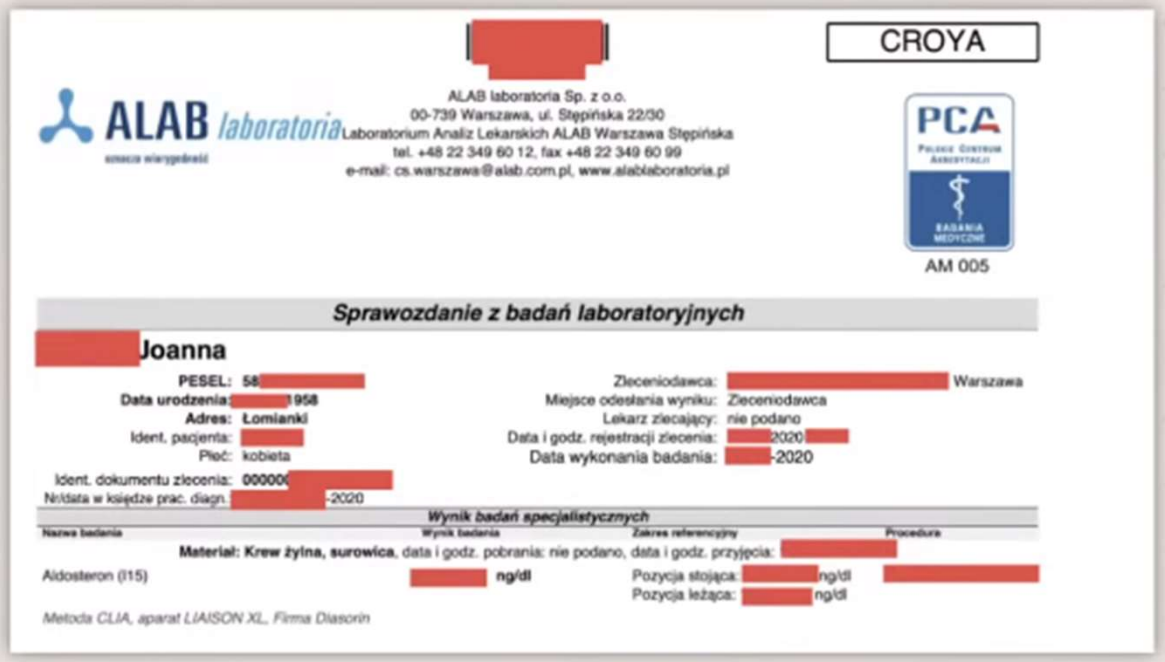
wiadomość imessage +
złośliwy obrazek → niewidoczna, zdalna infekcja telefonu



https://citizenlab.ca/2023/09/blastpass-nso-group-iphone-zero-click-zero-day-exploit-captured-in-the-wild/

Przykłady ataków
Wyciek danych (2023)

securitum



CROYA

ALAB laboratoria

ALAB laboratoria Sp. z o.o.
00-739 Warszawa, ul. Stępińska 22/30
Laboratorium Analiz Lekarskich ALAB Warszawa Stępińska
tel. +48 22 349 60 12, fax +48 22 349 60 99
e-mail: cs.warszawa@alab.com.pl, www.alablaboratoria.pl

PCA
AM 005

Sprawozdanie z badań laboratoryjnych

[redacted] **Joanna**

PESEL: 58[redacted]
Data urodzenia: [redacted]958
Adres: Łomianki
Ident. pacjenta: [redacted]
Płeć: kobieta
Ident. dokumentu zlecenia: 000000[redacted]
Nr/data w księdze prac. diagn. [redacted]-2020

Zleceniodawca: [redacted] Warszawa
Miejsce odesłania wyniku: Zleceniodawca
Lekarz zlecający: nie podano
Data i godz. rejestracji zlecenia: [redacted]2020[redacted]
Data wykonania badania: [redacted]-2020

Wynik badań specjalistycznych

Nazwa badania	Wynik badania	Zakres referencyjny	Procedura
Materiał: Krew żylna, surowica, data i godz. pobrania: nie podano, data i godz. przyjęcia: [redacted]			
Aldosteron (115)	[redacted] ng/dl	Pozycja stojąca: [redacted] ng/dl Pozycja leżąca: [redacted] ng/dl	[redacted]

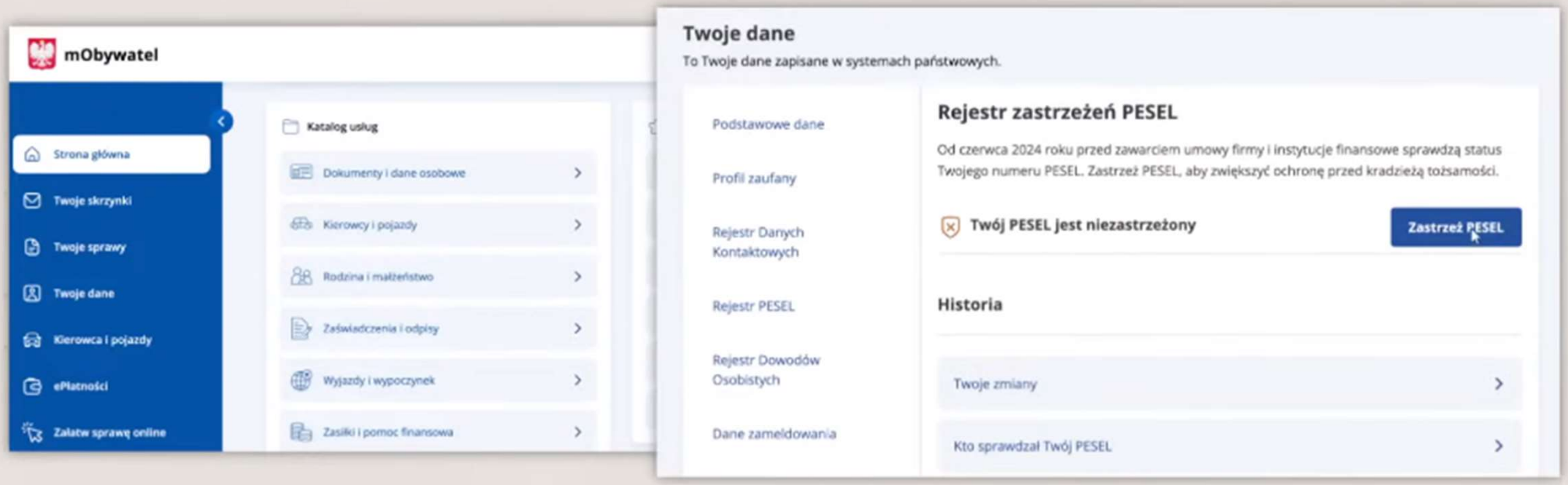
Metoda CLIA, aparat LIAISON XL, Firma Diasorin

https://zaufanatrzeciastrona.pl/post/wyniki-badan-medycznych-kilkudziesieciu-tysiecy-polakow-ujawnione-przez-wlamywaczy/

BwSK
T.Łukaszewski

Przykłady ataków
Można zastrzec PESEL

securitum



https://www.mobywatel.gov.pl/twoje-dane/rzp-pesel

Przykłady ataków
Można zastrzec PESEL

securitum

Co daje zastrzeżenie PESEL?

instytucje finansowe, telkomy, notariusze nie będą mogły w Twoim imieniu wykonywać pewnych czynności

(np. nikt nie weźmie na Twoje dane kredytów,
nie wyrobi duplikatu karty SIM,
a także nie sprzeda Ci mieszkania).

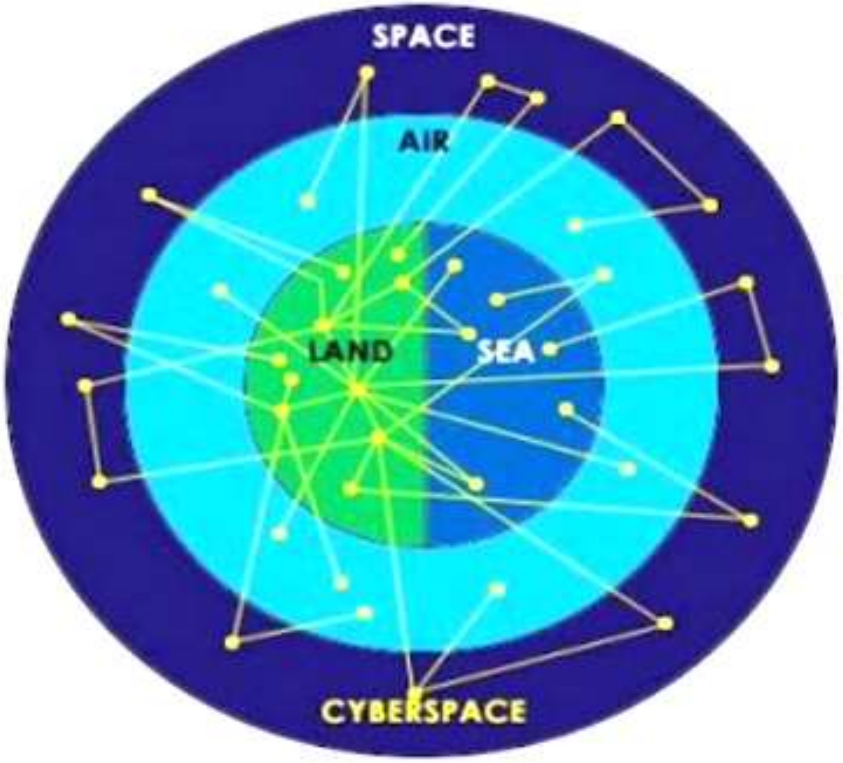
Cyberprzestrzeń

- CyberSzpiegostwo
- CyberWywiad
- CyberAtak
- CyberBezpieczeństwo

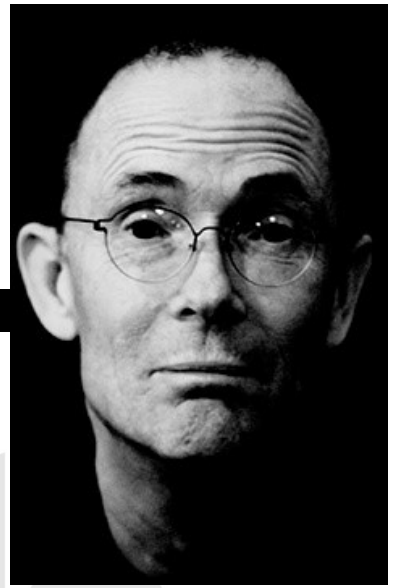
BwSK

Wprowadzenie

Kto panuje nad cyberprzestrzenią
panuje nad pozostałymi obszarami



Wprowadzenie



Cyberprzestrzeń (**rzeczywistość wirtualna**)

- Ogólnie rozumiana przestrzeń elektroniczna, w której odbywa się transfer informacji
- Nazwa spopularyzowana w powieści **Neuromancer** z 1984 Williama Gibsona:
  - Case, bezrobotny haker, zostaje wynajęty przez nieznanego mocodawcę do popełnienia, wydawałoby się niewykonalnego, przestępstwa
  - Wizja świata, gdzie państwa wypierane są przez korporacje i **cyberprzestrzeń**, nazywaną w książce matrycą (**matrix**)

Wprowadzenie

Cyberprzestrzeń (inwigilacja)

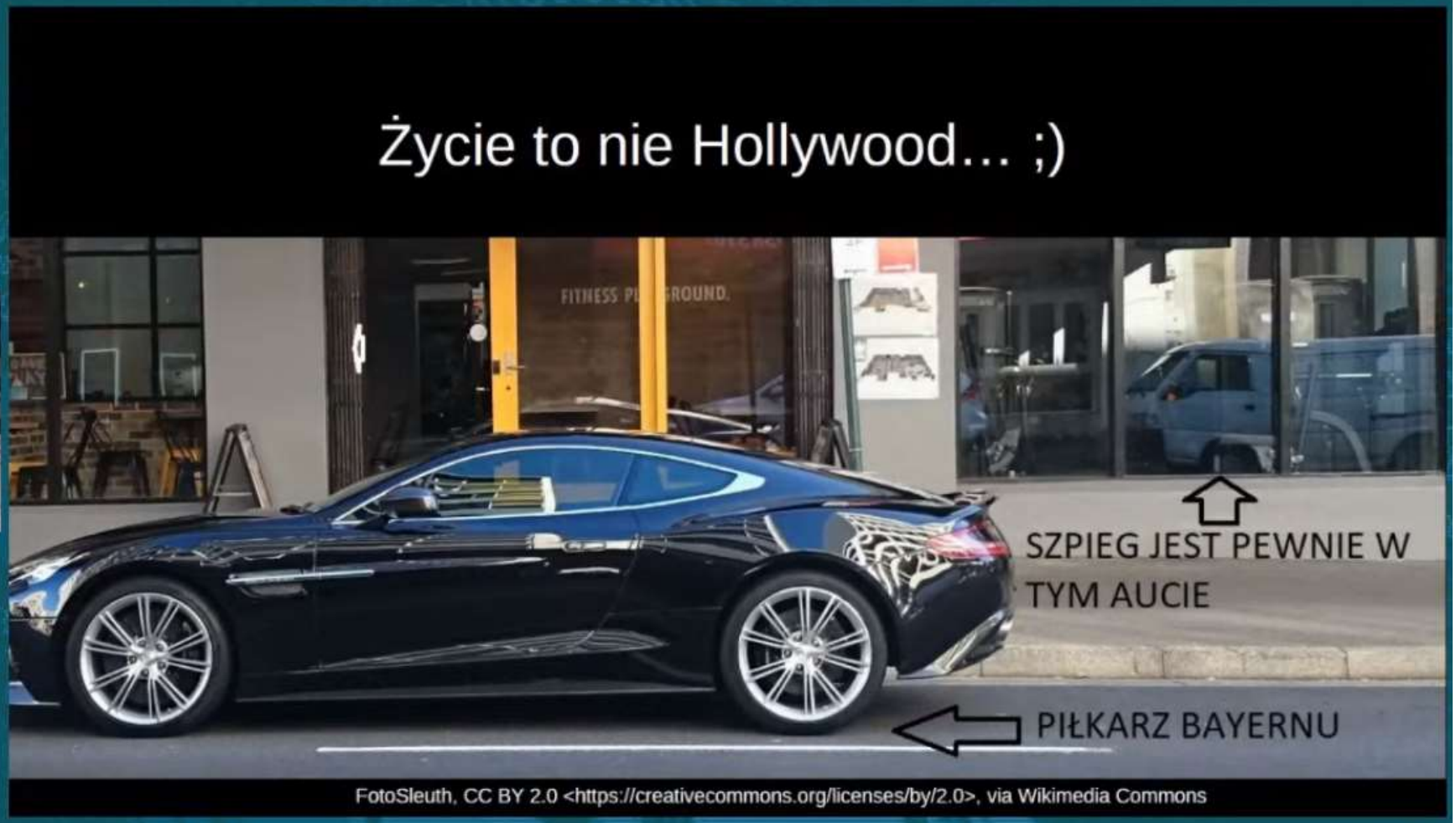
Nawet mieszkańcy NRD nie byli inwigilowani przez Stasi tak skutecznie, jak my jesteśmy codziennie inwigilowani w sieci. Nigdy w historii ludzkości nie pojawiła się sytuacja, w której wolność słowa, tajemnica korespondencji czy przepływy pieniędzy zależały od kilku korporacji, których działalność nie podlegała regulacjom. Politycy bawią się Twitterem z gorliwością gimnazjalisty obdarowanego smartfonem na urodziny. Dziennikarze technologiczni ekscytują się kolejnymi wodotryskami w kolejnych wersjach gadżetów. Większość pieje z zachwytu, **mało kto pyta o zagrożenia**.

"Internet. Czas się bać" Wojciech Orliński, Agora, 2013

CyberSzpiegostwo

CyberSzpiegostwo

CyberSzpiegostwo



CyberSzpiegostwo

Bezcennym elementem systemu bezpieczeństwa kontrwywiadowczego każdego państwa jest **świadomy zagrożeń obywatel!**

świadomy zagrożeń obywatel

------->

Star Wars, CC BY 2.0 <https://creativecommons.org/licenses/by/2.0>, via Wikimedia Commons

CyberSzpiegostwo

„**Sojusznicy**" podejmują działania szpiegowskie wobec „**przyjaciół**"

Stany Zjednoczone są obiektem zabiegów szpiegowskich ze strony Francji, Niemiec, Izraela, Chin itd. Ameryka nie pozostaje im dłużna.

[11.2004] Największe mocarstwa militarne wykorzystują Internet do szpiegowania swych wrogów i przygotowywania cybernetycznych ataków - oświadczył **Richard Clarke**, b. doradca Białego Domu w sprawach bezpieczeństwa narodowego i zagrożeń cybernetycznych

CyberWywiad

BwSK

CyberWywiad

Współczesny wywiad został stworzony w czasach nasilania się **faszyzmu**, a następnie umocniony w walce z nim.

Po roku 1945 cały aparat wywiadu świata zachodniego zwrócił się przeciwko światu **komunistycznemu**. To wtedy narodziły się wielkie tajne służby, które przetrwały do dnia dzisiejszego

Obecnie, po upadku komunizmu, wywiad zajął się przede wszystkim walką z **terrorystami** i **cyberterrorem**.

CyberWywiad
CIA, NSA, DHS

CIA powstała w 1947 roku na bazie utworzonego w czasie wojny OSS (Office of Strategic Services). Początkowym zadaniem CIA był wywiad dotyczący ludzi (HUMINT – human intelligence)

W październiku 1952 roku utworzono **NSA** mającą za zadanie wywiad techniczny (TECHINT – technical intelligence).

Po 11 września utworzono **DHS**, Departament Bezpieczeństwa Krajowego (Department of Homeland Security) – by uniknąć problemu **braku współpracy agencji**

CyberWywiad technologia & etyka

Grudzień 2016

Blisko 600 przedstawicieli firm technologicznych (alphabet, Oracle Google, Twitter, IBM i inni) zadeklarowało, że nie pomogą Donaldowi Trumpowi w budowie bazy danych pozwalających śledzić muzułmanów w USA.

Sygnotariusze przypominają rolę firm technologicznych w wielu ludobójstwach w ostatnich dekadach, np. technologie IBM pomagały nazistom przy prowadzeniu rejestru Żydów w czasie II wojny światowej.

CyberAtak

BwSK

CyberAtak

Cyberatak - atak informacyjny. Najprawdopodobniej nastąpi on w ciągu najbliższych kilkunastu lat. Zaatakowane mogą być struktury (teoria wojny informacyjnej):

- Telekomunikacja i sieci informatyczne
- Sieci energetyczne
- Sieci gazowe
- Banki i instytucje finansowe
- Transport
- Wodociągi
- Agencje rządowe

CyberAtak

Potencjalny atak może trwać minuty a nawet **sekundy**. Wszystko zależy od tego, w czyich rękach będą odpowiednie **technologie**.

Wprawdzie transfer technologii jest pod odpowiednią kontrolą od ponad pół wieku, to coraz trudniej opanować rozprzestrzenianie się **informacji**.

Nawet niewielkie państwo, organizacja, może zagrozić mocarstwu.

W 2007 Estonia była celem **ataku** rosyjskich hakerów (powód – usunięcie pomnika żołnierzy Armii Czerwonej).

W 2007 celem **ataku** był także Departament Obrony USA (Pentagon), Wielka Brytania i Niemcy – chińscy hakerzy

CyberAtak

2018 – grupy powiązane z GRU

Sandworm zaatakował m.in. niemieckich nadawców publicznych ZDF i WDR w 2018 i włamał się do serwerów Partii Demokratycznej w 2016 w czasie amerykańskich wyborów prezydenckich; pojawili się w sieci w 2013 atakując serwery NATO, zachodnich firm telekomunikacyjnych i ukraińskich dostawców energii.

GreyEnergy - zadaniem jest szpiegowanie ukraińskich i polskich firm energetycznych, wodociągów i przesyłających gaz od 2015 roku

CyberAtak

Social media as a tool of information warfare – Beata Biały (2018)

Zagrożenia

- wpływ na wybory
- zakłamywanie historii

Bezpieczeństwo

- analiza informacji, myślenie krytyczne
- nie poddawanie się popularnemu w sieci „efektowi potwierdzenia”

CyberAtak

Social media as a tool of information warfare – Beata Biały (2018)

Atak – Strategia 4D

- Dismiss – dyskretyzacja przeciwnika
- Distract – odwracanie uwagi
- Dismay – straszenie ludzi
- Distort – przeinaczanie faktów

Cyber Bezpieczeństwo

CyberBezpieczeństwo

W ramach Sił Zbrojnych USA od 2006 r. funkcjonuje **Cyber Command**, którego zadaniem jest prowadzenie operacji w cyberprzestrzeni, mających na celu ochronę krytycznej infrastruktury Stanów Zjednoczonych przed atakami hakerskimi, wsparcie poszczególnych rodzajów sił zbrojnych oraz ochronę infrastruktury informacyjnej Departamentu Obrony.

CyberBezpieczeństwo

Wielkie manewry w cyberprzestrzeni

W USA przeprowadza się co 2 lata ćwiczenia w walce z cyberterorryzmem – **CyberStorm**

- weryfikacja zdolności przygotowania się, zabezpieczenia i odpowiedzi na wypadek ataku
- ćwiczenia z podejmowania decyzji i koordynacji działań

CyberBezpieczeństwo

[gazeta.pl 11.04.2013]

USA zwiększą wydatki na cyberbezpieczeństwo, gdyż rocznie amerykańskie firmy tracą (szacunkowo) 400 mld dolarów z powodu szpiegostwa cybernetycznego.

USA przyznały w marcu, że cybernetyczne ataki są większym zagrożeniem dla USA niż terroryzm.

CyberBezpieczeństwo

[gazeta.pl 14.03.2011] **Niemcy gotowe na cyberwojnę**

Niemcy powołali do życia dwie organizacje rządowe:

- Nationales Cyber-Abwehrzentrum (NCAZ) (bezpieczeństwo Internetu)
- Nationaler Cyber-Sicherheitsrat (prowadzenie cyberwojny)

Dlaczego?

- rosnące zagrożenie ze strony wyspecjalizowanego malware'u
- rosnąca ilość "czułych punktów" przemysłu, od kiedy w coraz większym stopniu korzysta on z zaawansowanych technologii

CyberBezpieczeństwo Polska - CSIRT

Ustawa o Krajowym Systemie Cyberbezpieczeństwa (2018)

Ustawa obejmuje zespoły CSIRT – Zespoły Reagowania na Incydenty Bezpieczeństwa Komputerowego):

- CSIRT NASK
- CSIRT GOV
- CSIRT MON

CSIRT

CERT.PL

CyberBezpieczeństwo Polska – cyber.mil.pl

Polska – cyber.mil.pl

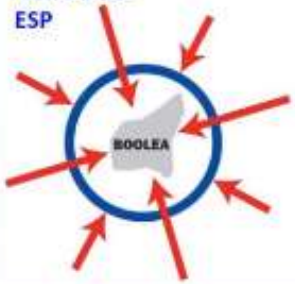
- Narodowe Centrum Bezpieczeństwa Cyberprzestrzeni
- Centrum Operacji Cybernetycznych
- Służba Kontrwywiadu Wojskowego

CyberBezpieczeństwo ćwiczenia Lock Shields

3 – Locked Shields 2013

Uczestnicy

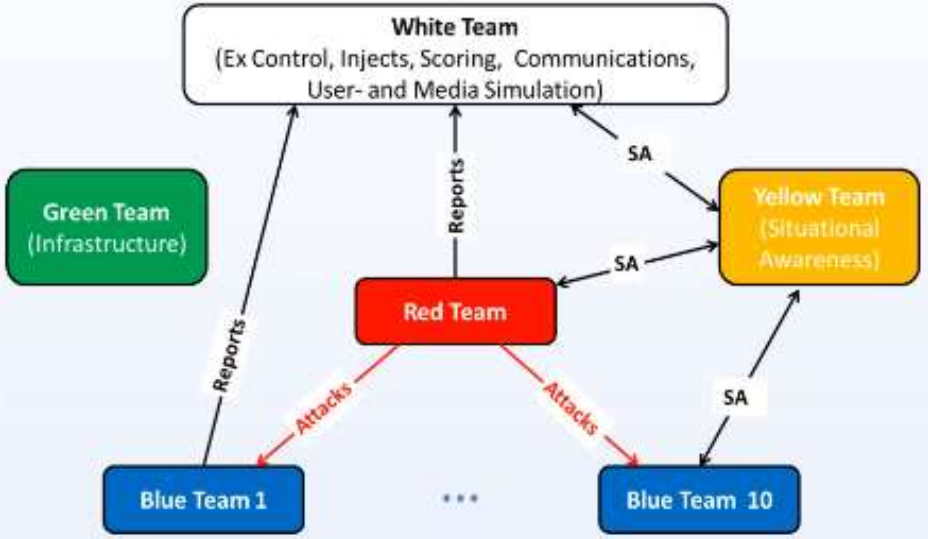
Blue Teams:	Others:
FIN	SWE
EST	GBR
LTU	FRA
POL	LVA
SVK	
DEU	
ITA	
NLD	
NATO CIRC	
ESP	



CCDCOE
NATO Cooperative Cyber Defence Centre of Excellence
Tallinn, Estonia

LOCKED SHIELDS

Koloryt ćwiczeń:



THE H@CK SUMMIT

CyberBezpieczeństwo
CYBER.EXE

Polska

https://www.cyberexepolska.pl/

CyberBezpieczeństwo ćwiczenia KSC-EXE

Polska

KSC-EXE 2020

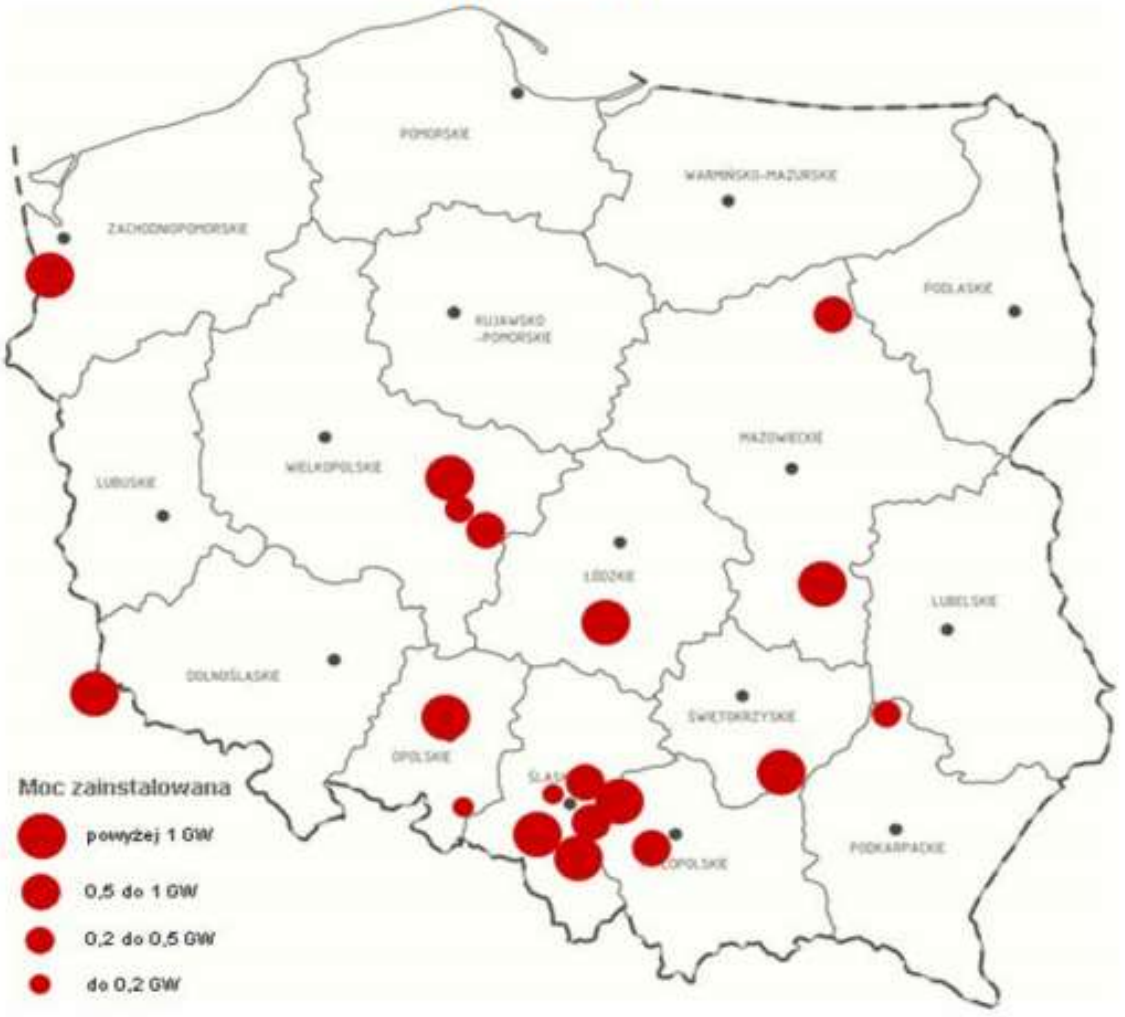
KSC-EXE POLSKA 2020
KRAJOWY SYSTEM CYBERBEZPIECZEŃSTWA

Międzysektorowe ćwiczenia sprawdzające działanie Krajowego Systemu Cyberbezpieczeństwa, w tym działanie procedur reagowania na incydenty oraz współpracę zespołów reagowania na incydenty

Polska

Strategia Cyberbezpieczeństwa Rzeczypospolitej Polskiej 2017-2022

Elektrownie w Polsce

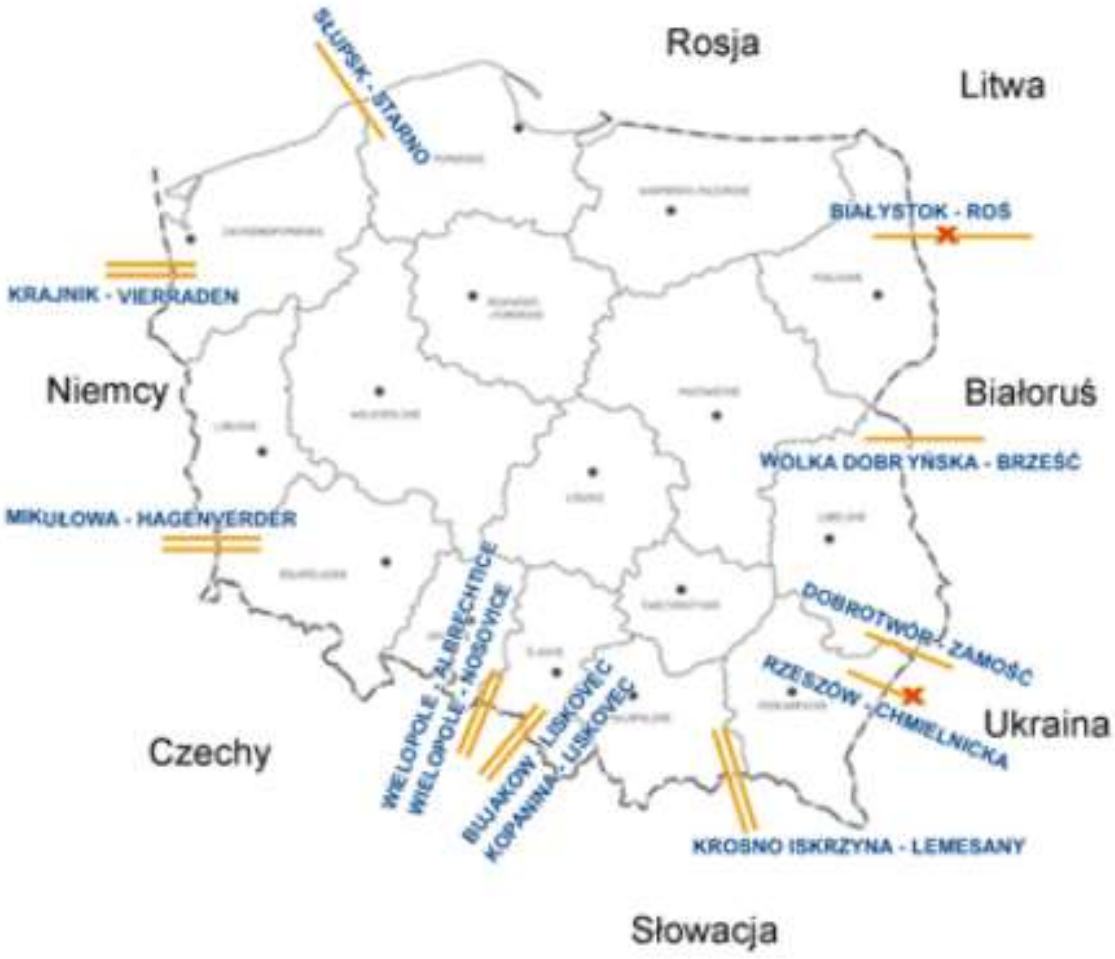


Źródło: cire.pl

Schemat sieci przesyłowej[2]

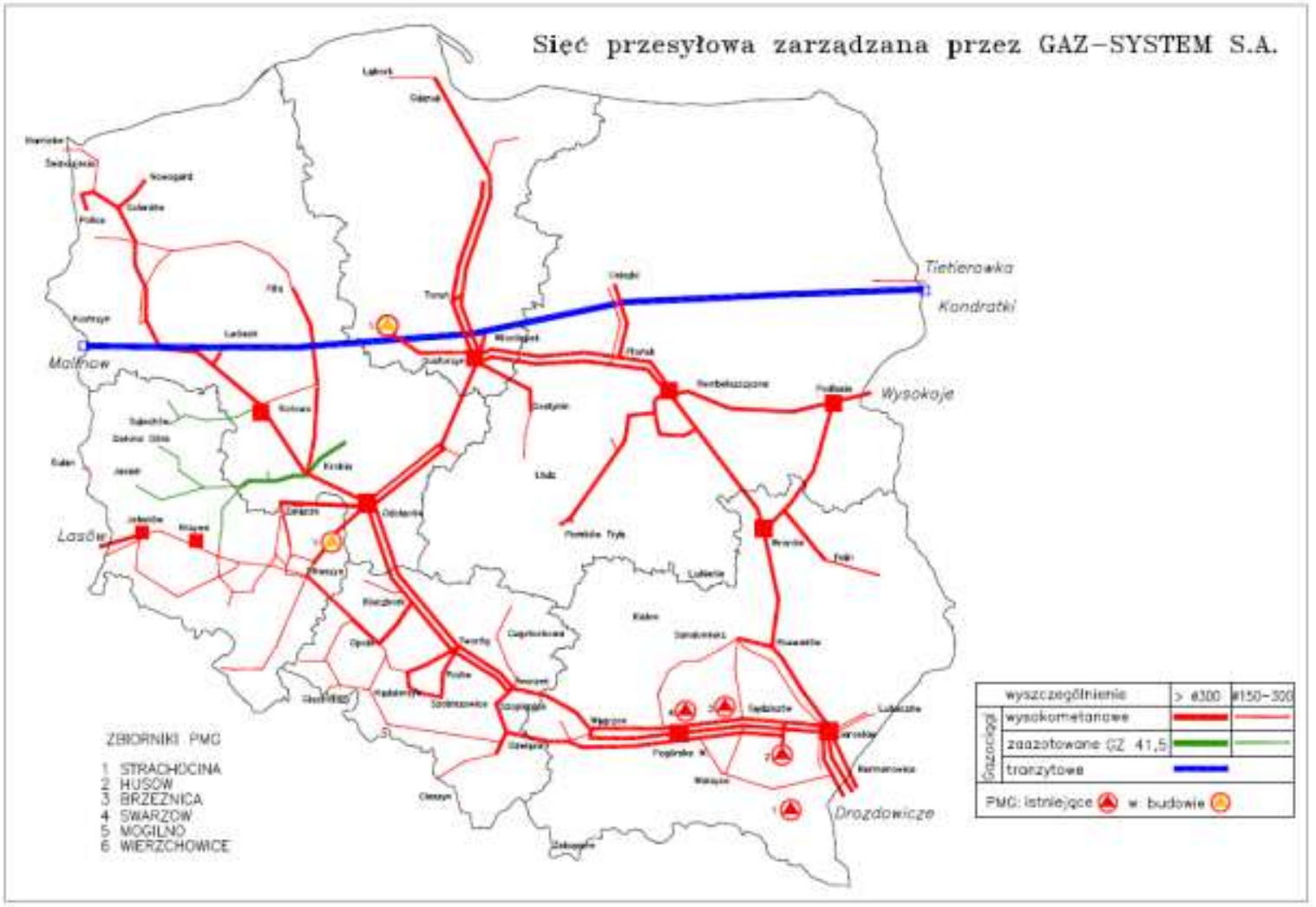
Źródło: PSE Operator S.A.

Międzynarodowe połączenia elektroenergetyczne



Źródło: cire.pl

CyberBezpieczeństwo

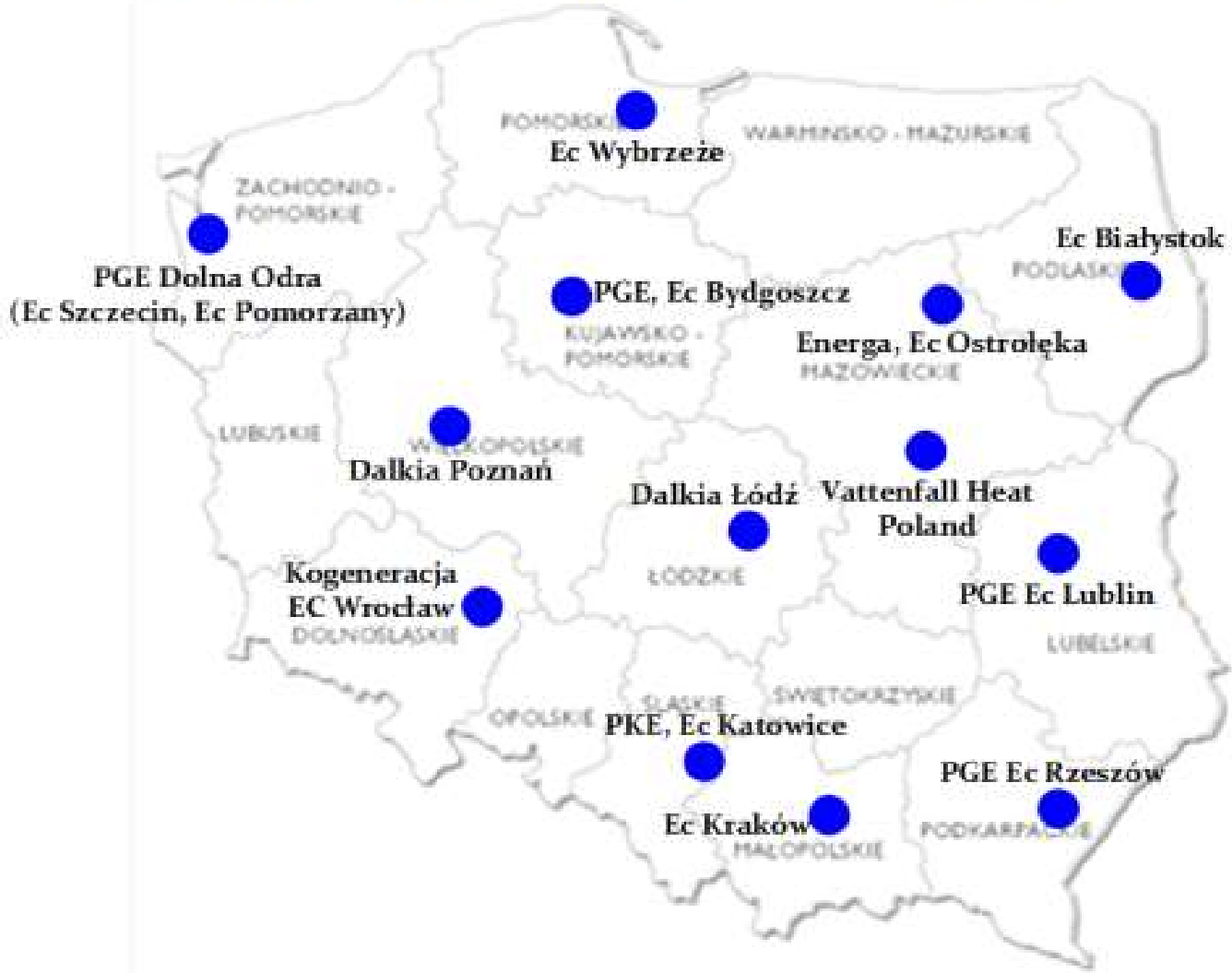


Źródło: GAZ-SYSTEM S.A.

Rurociągi w Polsce

Źródło: PERN S.A.

Największe elektrociepłownie zawodowe w Polsce



Media społecznościowe

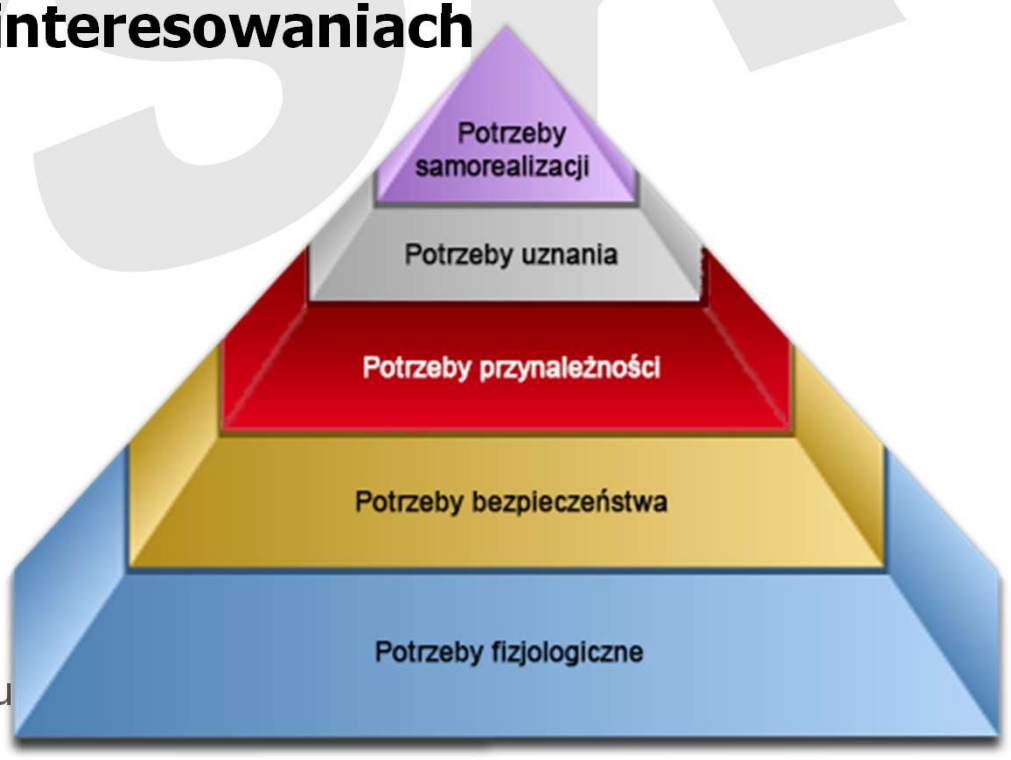
- Fenomen mediów społecznościowych
- Uzależnienie, depresja, śledzenie, prywatność
- FOMO
- Manipulacja obywatelami
- Efekt Streisand
- Facebook i CA

Fenomen Mediów Społecznościowych

Media społecznościowe
Fenomen mediów społecznościowych

Skąd taka popularność mediów społecznościowych:

- oryginalność formy przekazywanej informacji
- otrzymywanie aktualnych informacji
- **łatwość w komunikacji z innymi użytkownikami**
- **łączenie ludzi o podobnych zainteresowaniach**



Uzależnienie
depresja
śledzenie
prywatność

Media społecznościowe
Uzależnienie, depresja, śledzenie, prywatność

Media społecznościowe to także **uzależnienie** się od nich w sensie **nadmiernej** ilości poświęconego im czasu, co powoduje często zmiany w funkcjonowaniu człowieka w obrębie jego sfery:

- **Intelektualnej**: bierna postawa odbiorcy, bezrefleksyjność, ograniczenie twórczego nastawienia do rzeczywistości
- **Emocjonalnej**: wzrost agresji, kształtowanie nieaprobowanych społecznie postaw i zachowań
- **Społecznej**: rozluźniając więzy międzyludzkie

Media społecznościowe
Uzależnienie, depresja, śledzenie, prywatność

Psycholodzy twierdzą, że powtarzająca się w nieregularnych odstępach czasu nagroda uaktywnia ośrodek przyjemności powodując **uzależnienie** jak substancje psychoaktywne.

Taką nagrodą jest otrzymywanie przychylnych powiadomień

Media społecznościowe
Uzależnienie, depresja, śledzenie, prywatność

Media społecznościowe mogą doprowadzić do **stanów depresyjnych**

- przez poruszane w nich tematy
- odizolowanie od fizycznego kontaktu z ludźmi
- zbytnie liczenie się z opinią internautów
- możliwość oczerniania i zniesławiania ludzi

Media społecznościowe
Uzależnienie, depresja, śledzenie, prywatność

Media społecznościowe to także możliwość **śledzenia**

- potencjalnych ofiar przez przestępców
- kandydatów na stanowisko pracy przez pracodawców
- pożyczkobiorców przez pożyczkodawców
- dłużników przez komorników
- chorych przez zakłady ubezpieczeniowe

Media społecznościowe
Uzależnienie, depresja, śledzenie, prywatność

Ponadto dzielenie się prywatnymi danymi (na serwisach społecznosciowych) jest kontrowersyjne – jeżeli nasze zamiary nie są godne pochwały mogą (informacje) być użyte przeciw nam.

Media społecznościowe
Uzależnienie, depresja, śledzenie, prywatność

Pewien Irlandczyk tuż przed podróżą do USA napisał na Twitterze wiadomość, że wybiera się „żeby zniszczyć Amerykę”

W USA na lotnisku został zatrzymany, traktowany jako terrorysta i odesłany do domu.

Media społecznościowe

Uzależnienie, depresja, śledzenie, prywatność

Justine Sacco, dyrektor komunikacji InterActiveCorp straciła pracę z powodu jednego wpisu

FOMO

Fear Of Missing Out

BwSK

Media społecznościowe
FOMO

To choroba cywilizacji technologicznej - strach, że coś mnie omija – sprawdzamy emaile, powiadomienia, SMSy.

Manipulacja obywatelami

BwSK

Media społecznościowe
Manipulacja obywatelami

Media społecznościowe można wykorzystać do manipulowania obywatelami.

Rosja wykorzystała ponad 150.000 kont na Twiterze w trakcie kampanii dotyczącej Brexitu (referendum 23 czerwca 2016).

Większość tweetów głosowała za „LEAVE”

Najwięcej tweetów było w dniu referendum i nazajutrz.

BwSK
T.Łukaszewski

Texas Lone Star
@SouthLoneStar

Follow

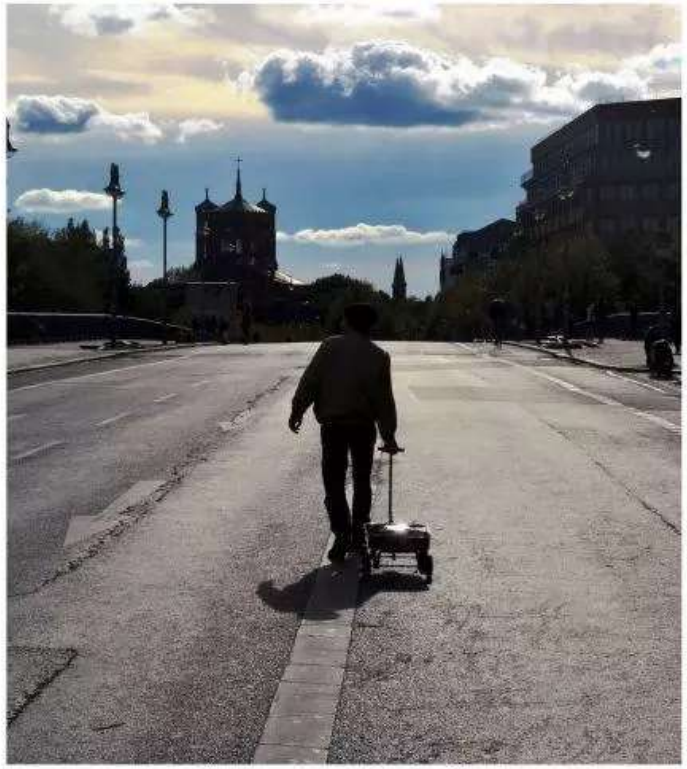
Muslim woman pays no mind to the terror attack, casually walks by a dying man while checking phone
#PrayForLondon #Westminster #BanIslam

RETWEETS 1,648 LIKES 1,871

15.12.2024

Media społecznościowe
Manipulacja obywatelami

Google Maps łatwo zmanipulować. Simon Weckert umieścił na niewielkim ręcznym wózku **99 smartfonów** i postanowił przejść się z takim ładunkiem wzdłuż mostu Schillinga w Berlinie



Efekt Streisand

Media społecznościowe
Efekt Streisand

Najlepiej smakuje zakazany owoc. Ta zasada sprawdza się w bardzo różnorodnych dziedzinach życia. Dotyczy także informacji. Jeśli chcemy coś koniecznie ukryć, możemy przez to wywołać w ludziach ciekawość do poznania tego, a wówczas efekt, jaki osiągniemy, może być zupełnie odwrotny do zamierzonego. W 2003 r. przekonała się o tym amerykańska piosenkarka i aktorka Barbra Streisand.

Ludzie bardziej pragną tego,
na co im się nie pozwala.
Zdjęcie domu Streisand stało
się popularne tylko dlatego, że
z nim walczono.

Facebook
a
Cambridge Analytica

Media społecznościowe
Facebook a C.A.

O tym, jak dane z Facebooka może ukraść firma a potem sprzedać je politykowi.

Polityk będzie wiedział o Tobie wszystko i wyśle Tobie spreparowaną propagandę, żebyś go wybrał.

Media społecznościowe
Facebook a C.A.

- C.A. zapłaciła 320 tys. Amerykańskim wyborcom od 2 do 5 dolarów, za rozwiązanie w Internecie testu osobowości i poglądów politycznych. Aplikacja wymagała zalogowania z Facebooka.
- Aplikacja zbierała również inne dane – co użytkownik polubił i inne osobiste informacje z Facebooka
- Aplikacja zbierała dane znajomych osób biorących udział w teście – łącznie około 50 mln. ludzi.
- Dane były analizowane przez algorytmy – na podstawie polubień skatalogowano schematy psychologiczne osób, m.in. preferencję polityczną
- Przygotowano spersonalizowaną kampanię polityczną

Media społecznościowe
Facebook a C.A.

Kryzys wybuchł w weekend (jak to kryzysy w social media), w niedzielę 18 marca 2018, kiedy to **Christopher Wylie**, 28 latek opisał dla Guardiana, jak to związana z doradcą Donalda Trumpa firma C.A. wykorzystuje nielegalnie zdobyte informacje do wpływania na amerykańskich wyborców

Media społecznościowe
Facebook a C.A.

Christopher Wylie

W liście, który ujawnił Wylie, jest informacja o tym, że prawnicy Facebooka przyznali w 2016 roku, że C.A. pozyskiwała dane nielegalnie.

Prawnicy prosili o usunięcie tych danych. Facebook wiedział więc o wycieku, ale niewiele z tym zrobił. Aplikacja, która pomagała pozyskać dane użytkowników, została wprawdzie przez FB zablokowana, ale jak twierdzi Wylie, FB nawet nie wie, czy pozyskane nielegalnie dane zostały skasowane

Media społecznościowe
Facebook a C.A.

W ciągu kilku tygodni kurs Facebooka spadł o kilkanaście procent

Szef ds. bezpieczeństwa Facebooka chce odejść z firmy

W sieci popularność zyskał hasztag *#DeleteFacebook*

Mark Zuckerberg wyraził żal, przeprosił i zapowiedział spore zmiany w bezpieczeństwie swojego serwisu. Portal wyjaśnia, że już w 2015 roku zmienił politykę prywatności. Wcześniej aplikacje takie jak ta, którą stworzyła firma C.A., miały dostęp do danych osób, które aplikację zainstalowały oraz do danych znajomych. W tej chwili takie pozyskiwanie informacji nie jest już możliwe.

Media społecznościowe
Michal Kosinski

Aby było to wszystko możliwe potrzebne są dane i **sposób** ich analizy.

Ten sposób wynalazł kilka lat wcześniej polski naukowiec **Michal Kosiński** pracujący na uniwersytecie Stanford Graduate School of Business

Media społecznościowe
Michal Kosinski

U podstaw badań legł model tzw. Wielkiej Piątki, zwany modelem OCEAN, znany od dawna w psychologii model osobowości: **neurotyczność, ekstrawersja, otwartość na doświadczenie, ugodowość i sumienność.**

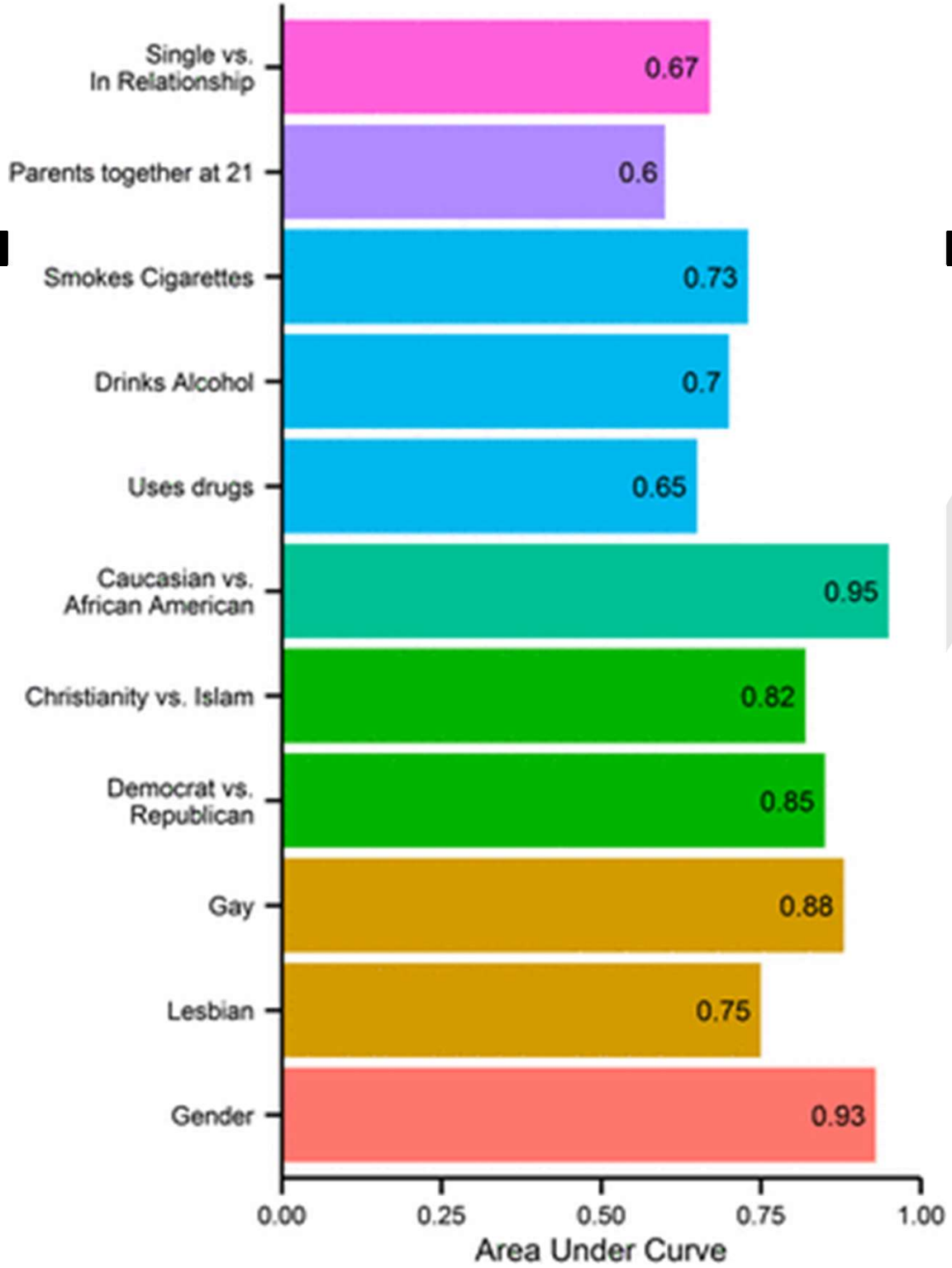
Kosinski zbadał, jak zachowanie użytkowników sieci, zapisane na stronach, na które wchodzą i na ich profilach na Facebooku, odnoszą się do ich osobowości.

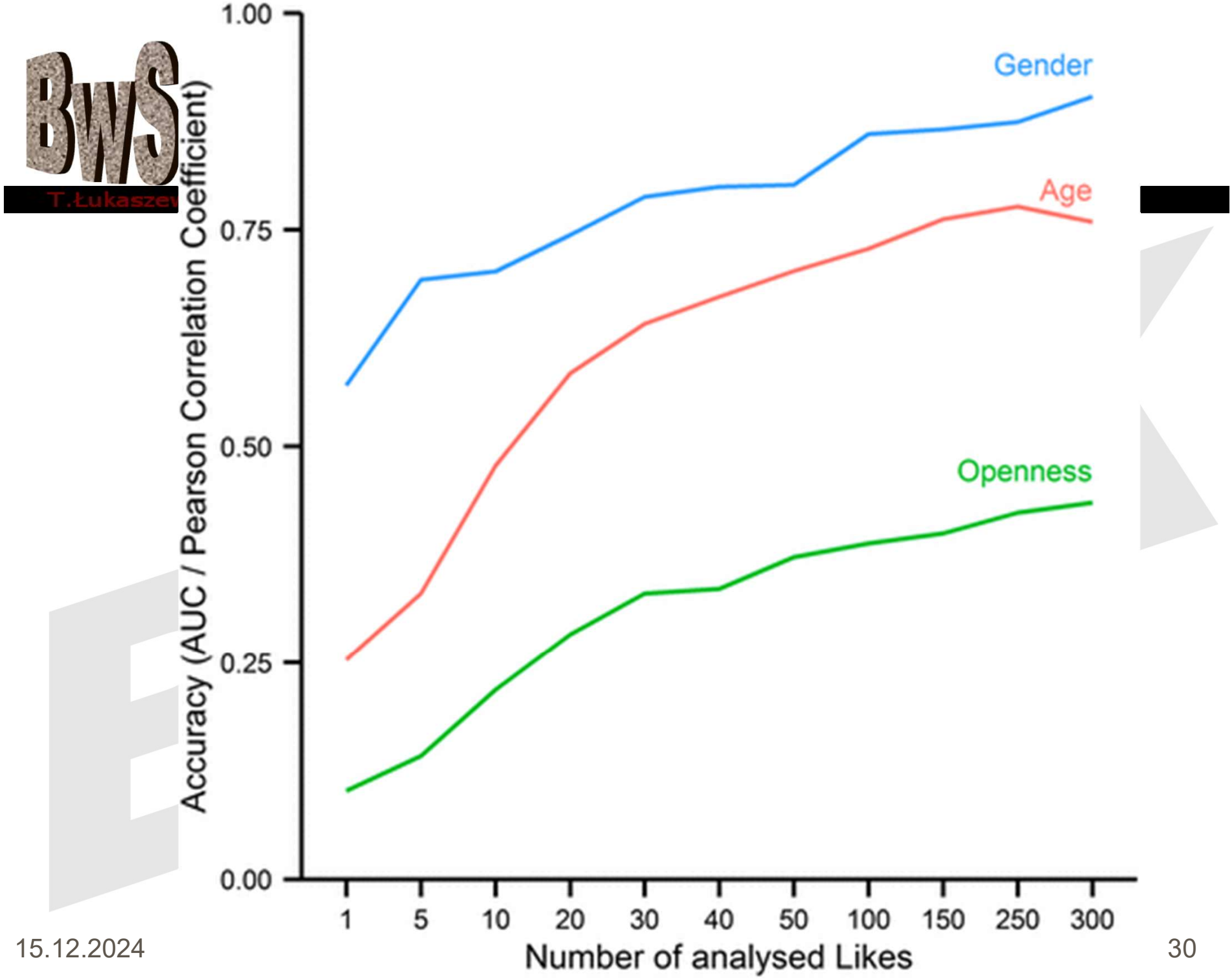
Skąd wziął dane?

Media społecznościowe
Michal Kosinski

W jego badaniach wzięły udział dziesiątki tysięcy osób, w jednym z nich nawet 330tys. Dobrowolnie, za cenę możliwości wzięcia udziału w teście osobowości, badani zgodzili się na to, by aplikacja dostarczająca im rozrywki **miała dostęp do historii ich działalności na Facebooku.**

Kosiński zebrane dane przepuścił przez algorytmy, które wykazały, że polubienia na Facebooku (same polubienia, "**lajki**", bez dokopywania się do skrzynki wiadomości, treści postów, statusów czy zawartości zdjęć!) **mogą zostać wykorzystane do precyzyjnego określenia całej gamy bardzo osobistych cech każdego użytkownika Facebooka. A także jego poglądów politycznych**.


Single vs. In Relationship
0.67
Parents together at 21
0.6
Smokes Cigarettes
0.73
Drinks Alcohol
0.7
Uses drugs
0.65
Caucasian vs. African American
0.95
Christianity vs. Islam
0.82
Democrat vs. Republican
0.85
Gay
0.88
Lesbian
0.75
Gender
0.93
0.00
0.25
0.50
0.75
1.00
Area Under Curve


1.00
0.75
0.50
0.25
0.00
Accuracy (AUC / Pearson Correlation Coefficient)
Gender
Age
Openness
1
5
10
20
30
40
50
100
150
250
300
Number of analysed Likes

Media społecznościowe
Michal Kosinski

W ciągu kilkunastu lat w sieci setki milionów ludzi chcąc nie chcąc ujawniły i upubliczniły swoje **przekonania**, **poglądy** i **pragnienia**. Naukowiec, który dysponuje taką bazą danych, nie jest już zwykłym naukowcem. Ma do dyspozycji taką wiedzę, że w świecie nauki jest bogiem.

Teraz do Kosinskiego dzwonią firmy i ludzie, proponując mu pracę. Wszystko dlatego, że jego odkrycie może się przysłużyć nie tylko zdobyciu wiedzy, ale także **pieniędzy** i **władzy**.

Media społecznościowe
Michal Kosinski

Wszystko wskazuje, że algorytm oparty na danych z Facebooka wie o nas wiele więcej niż Rodzina, znajomi, przyjaciele.

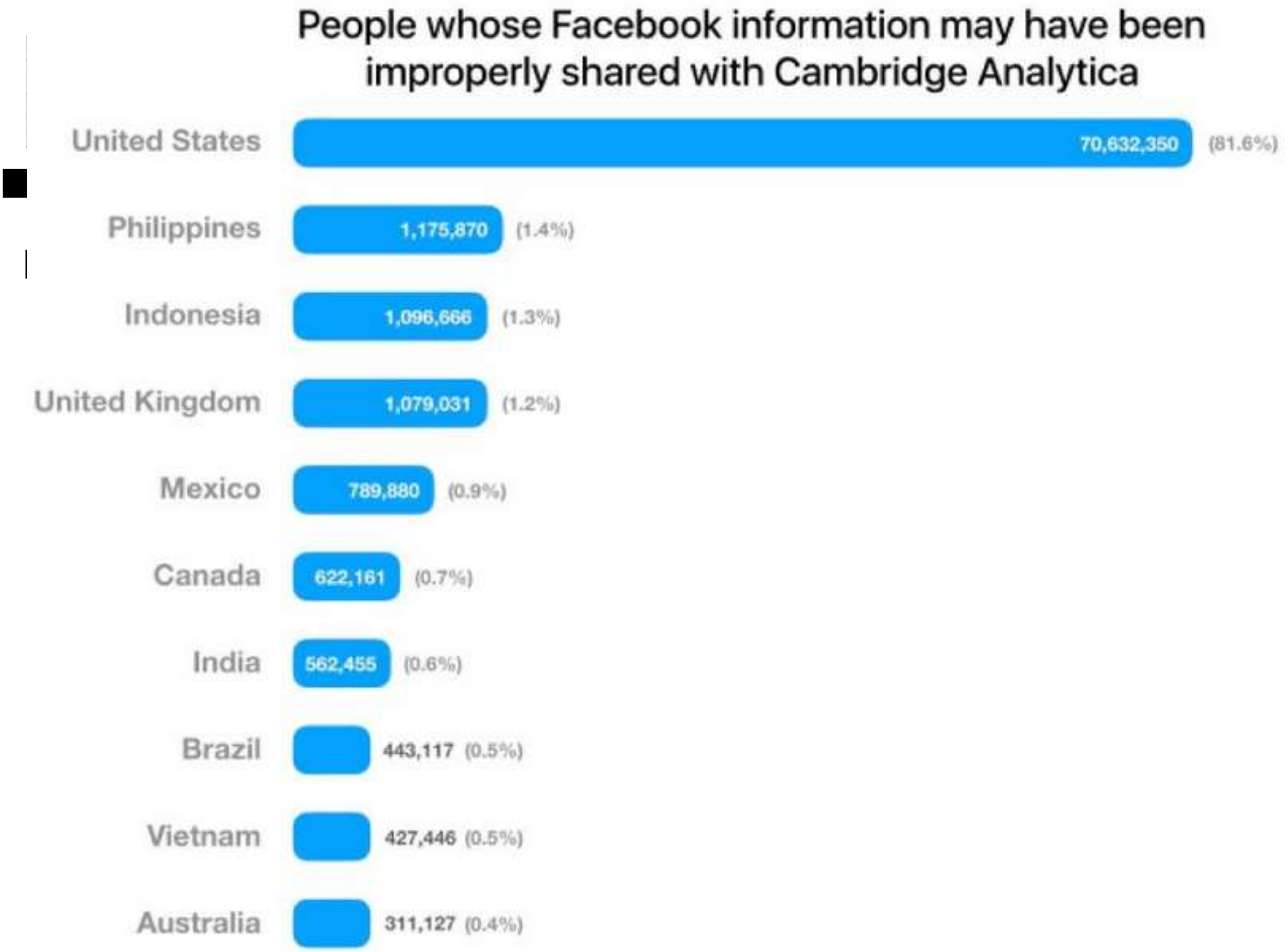
Nie trzeba nas znać. Wystarczą nasze cyfrowe ślady.

Media społecznościowe
Facebook

Facebooka problemy cd. (5.04.2018)

Facebook przyznaje, że w ręce CA wpadły dane nie 50 mln kont ale 87 mln

Zuckerberg łapie każdą możliwą okazję, by załagodzić sytuację – zniknie możliwość pozyskania dodatkowych danych przez reklamodawców


People whose Facebook information may have been improperly shared with Cambridge Analytica
United States
70,632,350
(81.6%)
Philippines
1,175,870
(1.4%)
Indonesia
1,096,666
(1.3%)
United Kingdom
1,079,031
(1.2%)
Mexico
789,880
(0.9%)
Canada
622,161
(0.7%)
India
562,455
(0.6%)
Brazil
443,117
(0.5%)
Vietnam
427,446
(0.5%)
Australia
311,127
(0.4%)

Media społecznościowe
Facebook 2018

Snowden uważa, że Facebook jest jedną wielką **machiną inwigilacyjną**, która działa pod przykrywką mediów społecznościowych.

"Przedsiębiorstwa zarabiające pieniądze przez zbieranie i handel prywatnymi danymi zostały kiedyś określone jako "przedsiębiorstwa inwigilujące". Przemianowanie ich na "media społecznościowe" było najbardziej udanym oszustwem od czasu nazwania Departamentu Wojny, Departamentem Obrony"

Podsumowanie

„Bóg przebacza i zapomina, ale Internet NIGDY”

Viviane Reding, europejska komisarz ds. sprawiedliwości.

Media Społecznościowe - zarządzanie kryzysem

Media społecznościowe
Zarządzanie kryzysem

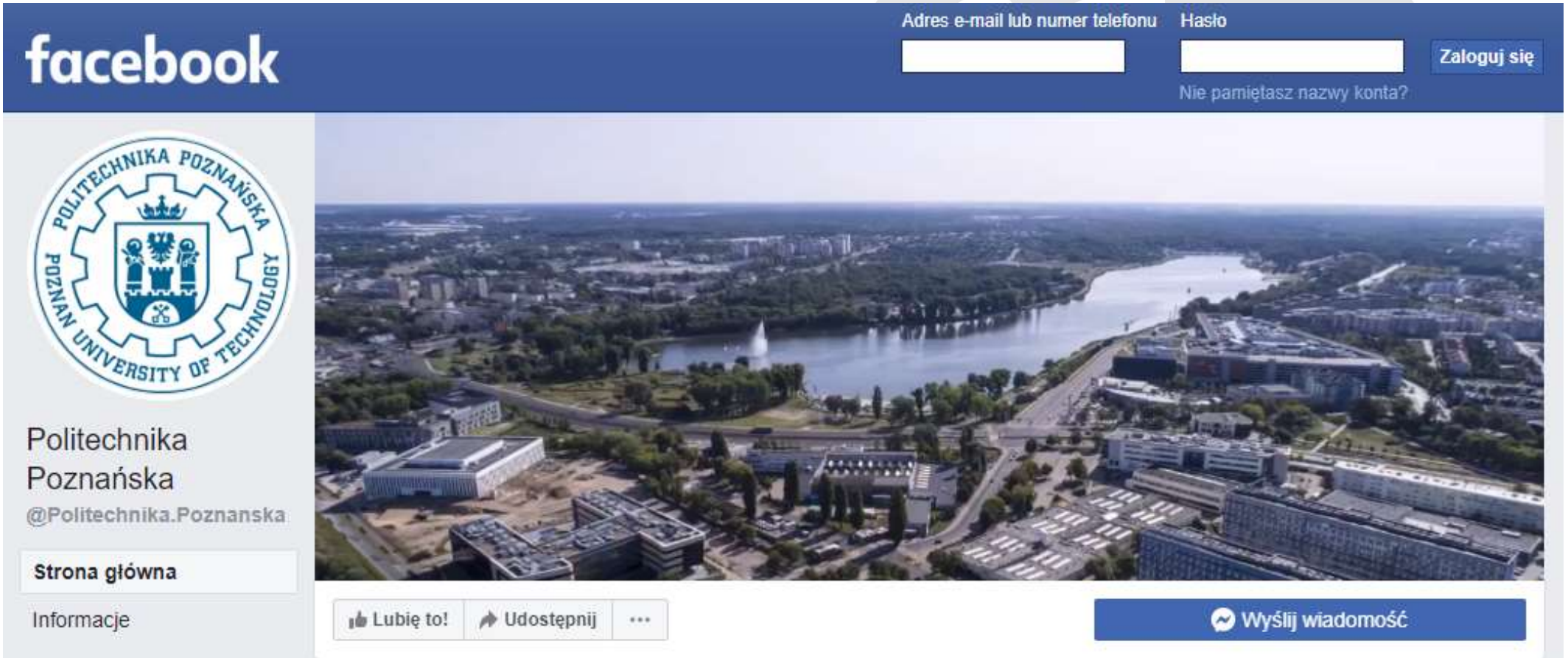
Zarządzanie kryzysem w social media, Monika Czaplicka, Helion 2014

Media społecznościowe
Zarządzanie kryzysem

T.Łukaszewski

Obecność marek w **social media** staje się niezbędna i oczywista.

Dziś uważa się, że każdy dobry **produkt** powinien mieć swój **fanpage**



Media społecznościowe
Zarządzanie kryzysem

Ale „nie każdy może i powinien robić internety”.

- Brak odpowiednich **umiejętności** i niewłaściwy dla grupy docelowej **dobór kanałów** komunikacji to najczęstsze powody powstawania **kryzysów** generowanych przez markę

- Ponadto, **niezadowolony** klient może dotrzeć do tysięcy osób ze swoją skargą. Szybko, tanio i skutecznie

Media społecznościowe
Zarządzanie kryzysem

Dlatego, bardziej niż kiedykolwiek wcześniej, warto znać i rozumieć zasady **postępowania w razie kryzysu w social media** oraz umiejętnego zarządzania nim.

Prędzej czy później **każda firma zetknie się z taką sytuacją**.

Zatem powinniśmy poznać

- Teorię
- Zaistniałe kryzysy

Media społecznościowe
Zarządzanie kryzysem

Kryzys – w łacinie oznacza **punkt zwrotny**, sytuację decyzyjną; w zarządzaniu oznacza stan w rozwoju **zagrażający** podstawowym funkcjom organizacji, zagrażający jej misji; w PR kryzys to sytuacja, której występują **gwałtowne** i **nieprzewidywalne** wydarzenia, skutkujące **niekontrolowanymi** reakcjami.

Media społecznościowe
Zarządzanie kryzysem

Kryzys ma określone **cechy** - nieprzewidywalność, działanie pod presją czasu, zagrożenie dla organizacji, nasilenie częstotliwości występowania niekorzystnych zdarzeń, konieczność podejmowania natychmiastowych działań

Media społecznościowe
Zarządzanie kryzysem

Kryzys

- Pogarsza wizerunek firmy
- A nawet zagraża firmie

BwSK

Media społecznościowe
Zarządzanie kryzysem

Kryzys w social mediach jest zdarzeniem, które **zaistniało** w social mediach bądź zostało przez nie **wzmocnione**, skutkiem czego pojawiły się liczne **negatywne** publikacje w mediach mainstreamowych, zmiany w procesie biznesowym albo duża **strata** finansowa lub wizerunkowa

Rysunek 2.1. Przykładowy proces powstawania kryzysu

Media społecznościowe
Zarządzanie kryzysem

Przyczyny kryzysów:

- **Rozwiązania ad hoc** bez strategii, bez przemyślanych działań, bez kierowania się zasadami etyki i sztuki marketingu społecznościowego
- **Brak współpracy** różnych działów firmy z komórką medium społecznościowego
- **Byle jak, byle na fejsie**, bez znajomości specyfiki użytkowników danego medium
- **Brak monitoringu mediów** - to, że Cię tam nie ma, nie znaczy, że się o Tobie nie pisze
- **Brak przepływu wiedzy** między marką, agencją i społecznością

Media społecznościowe
Zarządzanie kryzysem

Przyczyny kryzysów cd.:

- **Kiepska obsługa petentów**
- **Brak indywidualnego traktowania klientów przez agencje**, używanie oklepanych formułek
- Strategia to cel i metody sprawdzania jego realizacji. Koncentrując się na **jednej metodzie** łatwo można zgubić cel i jest to też świetne pole do nadużyć i wybuchu kryzysu
- **Niespełnienie obietnic**, bo biznes to oferowanie (obietnica) rozwiązań problemów

Media społecznościowe
Zarządzanie kryzysem

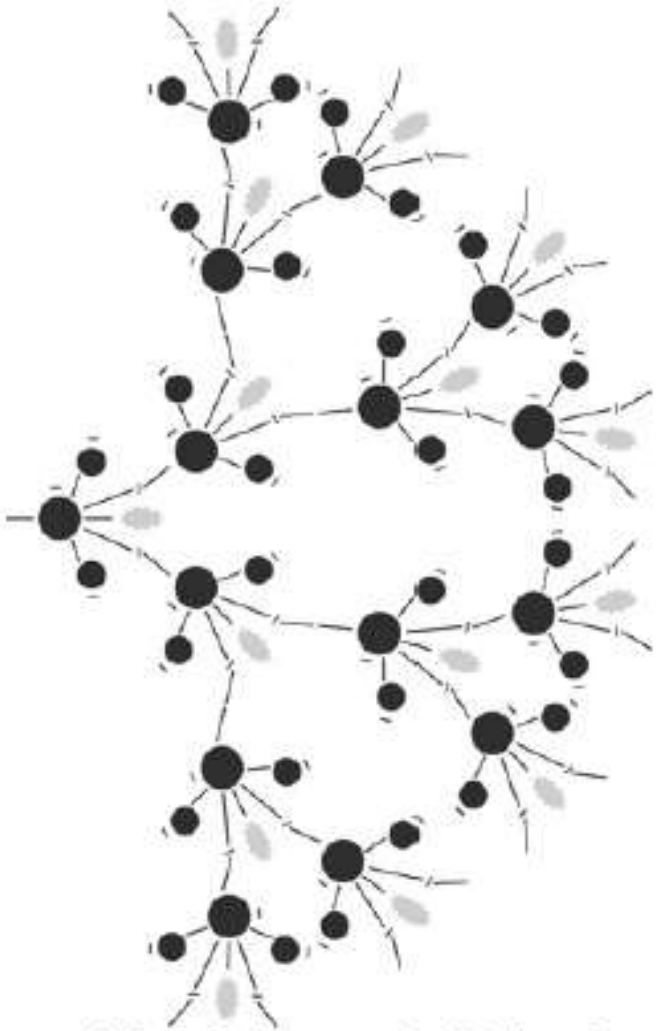
Dlaczego akurat w **weekendy**:

- Social media nigdy nie śpią. Sobota to dzień, kiedy ludzie mają czas, którego brakuje w tygodniu, np. na hejtowanie marki.

- A firma przez weekend nie pracuje. Nawet, jeżeli opieka nad kanałem komunikacji odbywa się w sobotę i niedzielę, zebranie sztabu kryzysowego czy wystosowanie odpowiedniego oświadczenia jest w weekend znacznie utrudnione.

Media społecznościowe
Zarządzanie kryzysem

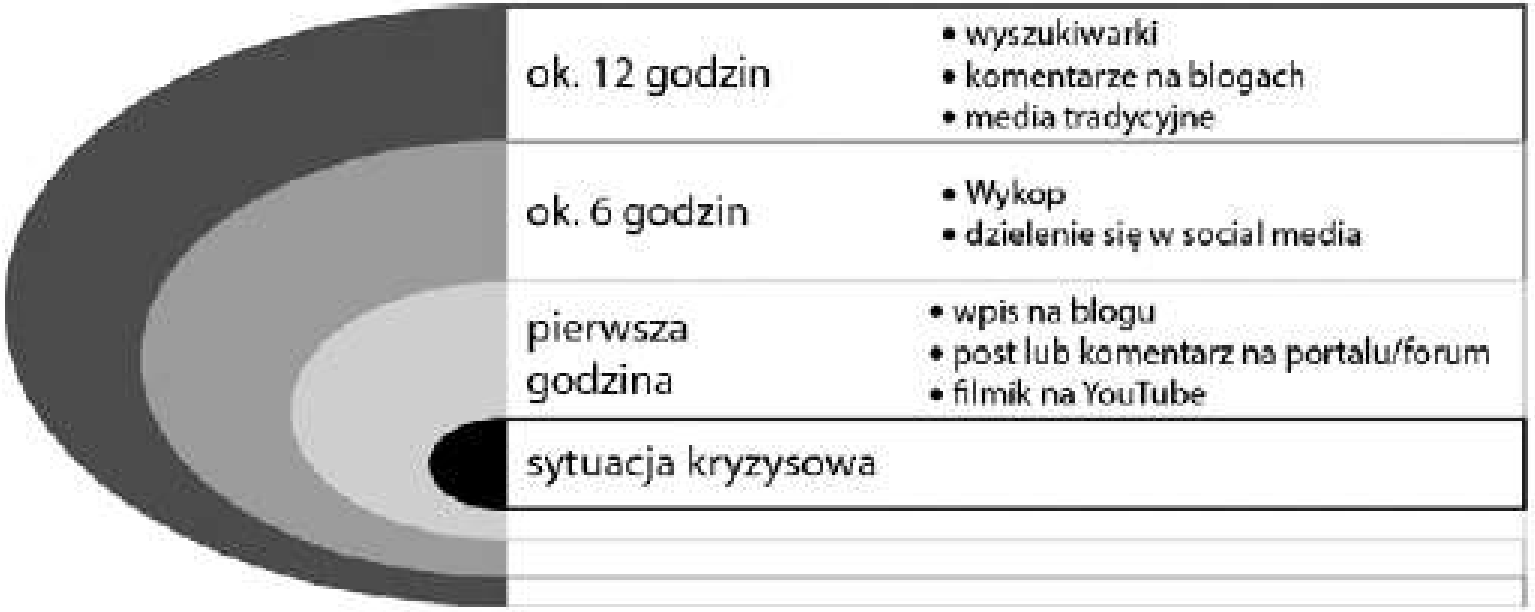
Przebieg kryzysu



Rysunek 2.3. Schemat reakcji łańcuchowej

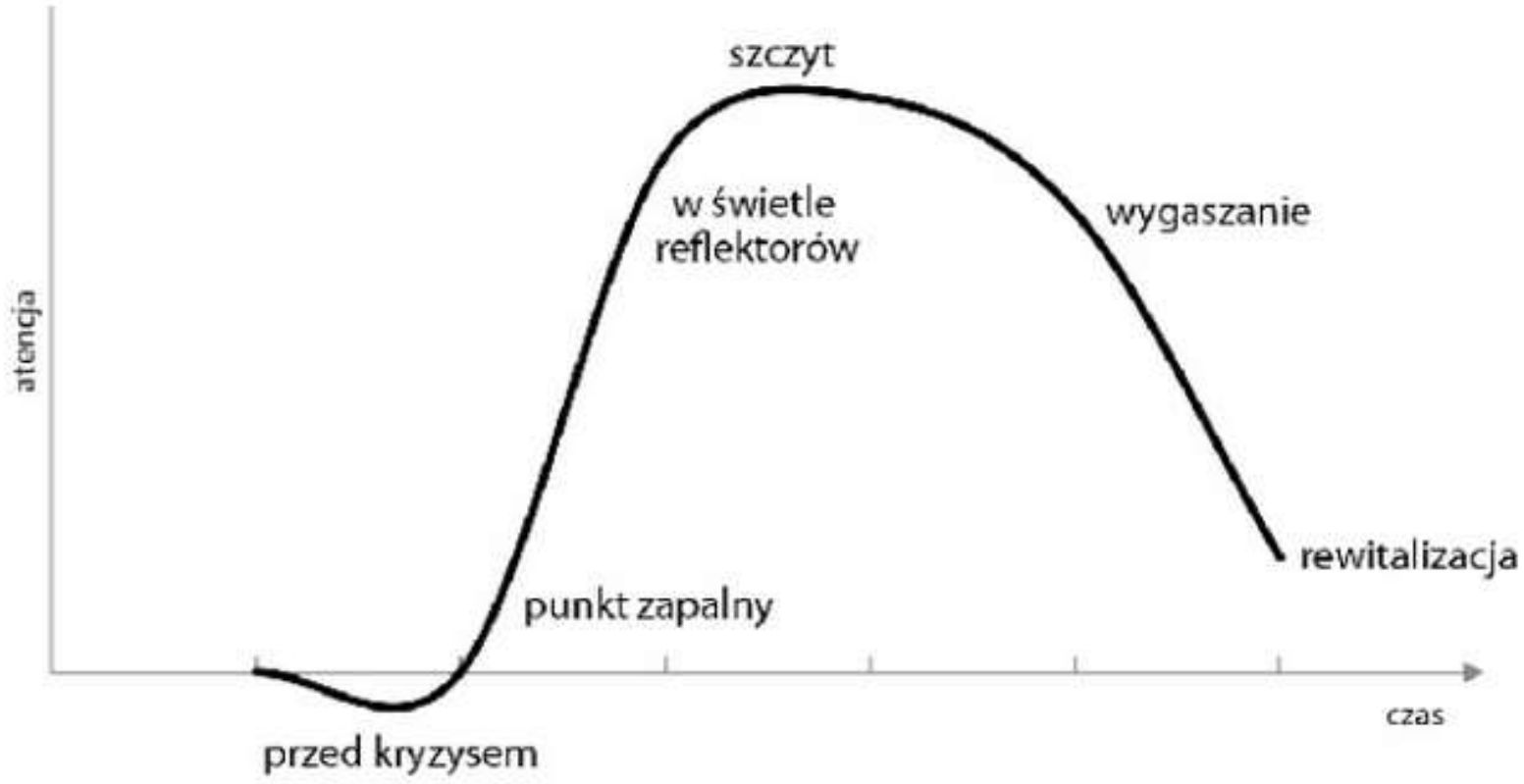
Media społecznościowe
Zarządzanie kryzysem

Przebieg kryzysu



Rysunek 2.4. Orientacyjny schemat rozprzestrzeniania się informacji kryzysowej w social media

Przebieg kryzysu



Rysunek 2.5. Przebieg kryzysu z kluczowymi punktami

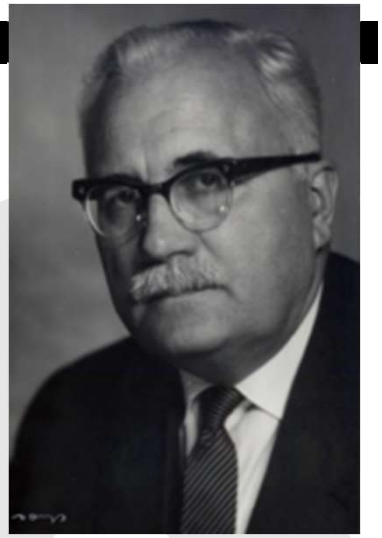
Media społecznościowe
Zarządzanie kryzysem

8 błędów w kryzysie

- **Chowanie głowy w piasek**
- **Działanie tylko z nożem na gardle**
- **Najlepszą obroną jest atak**
- **Przekupstwo**
- **Minimum wysiłku**
- **Twoja reputacja/wielkość/wiarygodność Cię chroni**
- **Masz rację**
- **Prawda musi być po mojej stronie**

Media społecznościowe
Zarządzanie kryzysem

Jak reagować na kryzys w social media



Panowanie nad **SŁOWAMI** to panowanie i nad **myślą**, i nad swoim **działaniem**, i nad **stosunkami** z ludźmi.

Witold Doroszewski (1899-1976)

Media społecznościowe
Zarządzanie kryzysem

Pierwsze 24h:

- Przedstaw swoją wersję wydarzeń
- Pogódź się z tym, że nie będziesz mieć wszystkich informacji
- Wyraź swoje wątpliwości
- Dowiedz się, o co chodzi i co się stało
- Wyraź swoją empatię
- Poproś o pomoc
- Nie panikuj, ale też nie unikaj emocji
- Pomóż klientom zrozumieć problem i jego skutki
- Zbieraj poparcie
- Słuchaj
- Pamiętaj, że ludzie zwykle stają po stronie ofiary

Media społecznościowe
Zarządzanie kryzysem

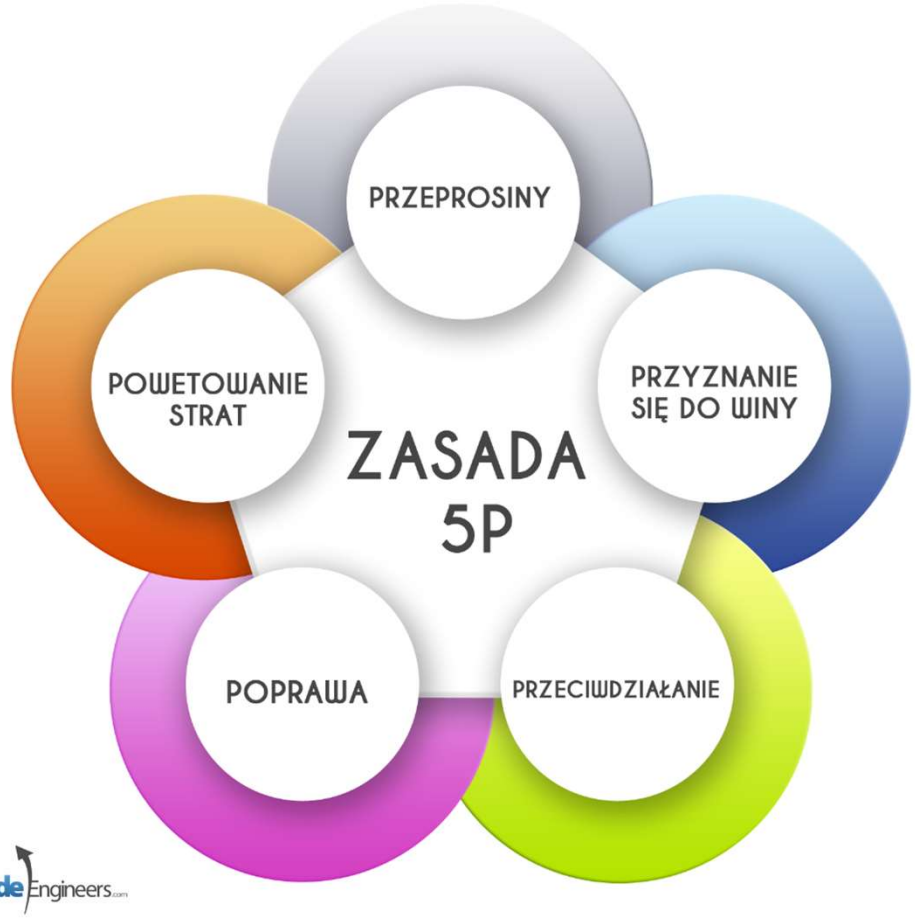
8 (+1) faktów o kryzysach:

- Atakują w najmniej spodziewanym momencie.
- Krótko trwające sytuacjami, których skutki ciągną się bardzo długo.
- Kryzys, który pozostawia się bez odpowiedzi, rośnie i zwykle osiąga większe rozmiary niż w przypadku udzielenia stosownej odpowiedzi.
- Kryzysy same się nie rozwiązują.
- Kryzysy skutkują negatywnymi emocjami, które na długo pozostają w świadomości klienta.
- Informacje w czasie kryzysu zmieniają się szybko i często klienci czują się oszukani, zdezorientowani i źle poinformowani.
- Jeśli się przeżyło kryzys, to nie znaczy, że nie może on się powtórzyć.
- Kryzysowi nie da się przeciwdziałać, ale można się nań przygotować.
- **Dobrze zarządzony kryzys to ogromna szansa dla marki.**

Media społecznościowe
Zarządzanie kryzysem

Zasada 5P

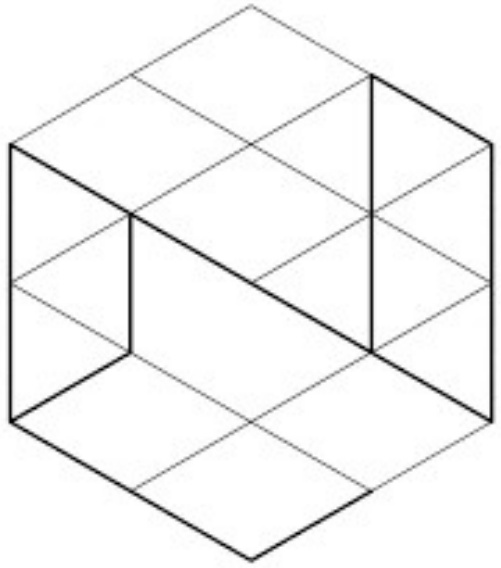
- Przeproś
- Przyznaj się do błędu
- Przeciwdziałaj
- Popraw się
- Powetuj



Media społecznościowe
Zarządzanie kryzysem

Nie zawsze trudna sytuacja jest kryzysem

Czasem są to problemy komunikacyjne, czy też sprawy do załatwienia, krótko mówiąc – **„zagwozdki”**



Media społecznościowe
Zarządzanie kryzysem

Jak zatrzymać problem na poziomie zagwozdki?

3 zasady działania:

- Szybciej niż mądrzej
- Transparentna polityka firmy
- Ekstrawertyczna osobowość osoby prowadzącej fanpage

Media społecznościowe
Zarządzanie kryzysem

Zagwozdka - Negatywne komentarze

- Nie kasuj negatywnych komentarzy
- Odpowiadaj wkurzonym klientom
- Przeproś
- Reaguj natychmiast
- Wykorzystaj lojalną społeczność do tego, by stanęli w twojej obronie

Media społecznościowe
Zarządzanie kryzysem

Zagwozdka - Wkurzony klient

- Dowiedz się dokładnie, co się stało, ale później już **nie wracaj do sprawy**
- **Nie próbuj wpłynąć na emocje klienta**
- **Nie emocjonuj się**
- **Nie zwalaj winy** na czynniki zewnętrzne czy na inne osoby
- **Nie usprawiedliwiaj się**
- **Nie rezygnuj z przeproszenia**

Media społecznościowe
Zarządzanie kryzysem

Lepiej **przeciwdziałać** niż naprawiać:

- Określ zagrożenia i opracuj pomysły jak ich uniknąć
- Zrozum, czego chcą klienci i spełniaj ich pragnienia
- Buduj więź ze społecznością
- **Przygotuj się na kryzys**

Media społecznościowe
Zarządzanie kryzysem

Play

Play

PLAY
JAKUBIE, TWÓJ
NUMER JEST JUŻ W PLAY
PRZEPRASZAMY,
ŻE MUSIAŁEŚ CZEKAĆ
RZECZNIK
PLAY

Media społecznościowe
Zarządzanie kryzysem

Heinz

BwS

T.Łukasz

Heinz

Heinz Poland

No, dobra... Wiemy, że niektórzy z Was tylko na to czekali a więc... Powszechnie wiadomo, że słonie nie obsługują Photoshopa, ale Wy tak, czego już dowiedliście! ;) Zapraszamy Was, zatem do naszego małego, kreatywnego konkursu. Wystarczy wejść do aplikacji „Stwórz swojego słonia" widocznej pod cover photo na naszym profilu i dać się ponieść ułańskiej fantazji ;) Macie do wyboru – skomentować „wzburzone słonie" albo zrobić swoją własną wersję tej poetyckiej kreacji ;). Do wygrania: tak, tak - a jakże! Słoń oczywiście! Wprawdzie pluszowy, ale za to duuuży. No i jeszcze zapas ketchupu, by na długo inspirował Waszą kreatywność :) To jak? Wchodzicie w to?

Album: Zdjęcia na osi czasu

Udostępnione dla: Publiczne

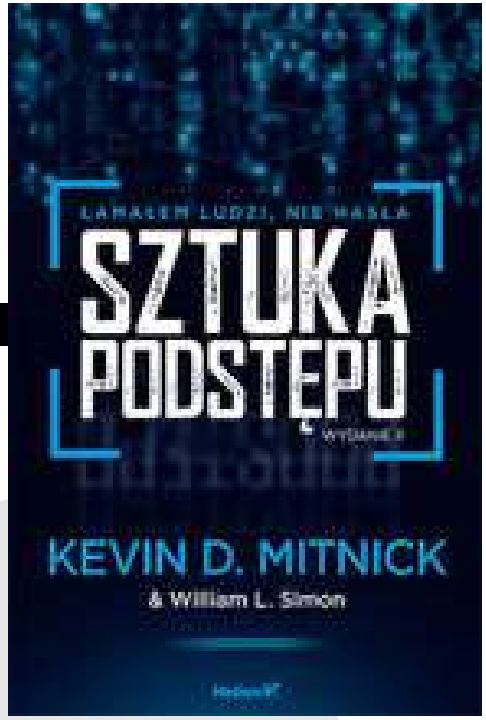
Pokaż większe

Pobierz

Zgłoś / Usuń znacznik

Socjotechnika

Wprowadzenie



Motto (1):

W obecnych czasach, kiedy tak dużo uwagi poświęca się bezpieczeństwu, wydaje ogromne kwoty na ochronę sieci komputerowych i danych, powinniśmy zdać sobie sprawę z tego, jak łatwo oszukać ludzi „z wewnątrz” i obejść wszelkie możliwe zabezpieczenia technologiczne

Sztuka podstępu, Kevin Mitnick, Wiliam Simon, Helion 2017

Wprowadzenie

Motto (2):

Skuteczną obronę przed atakami typu socjotechnika może zapewnić wyłącznie dobra znajomość socjotechnik

Socjotechnika. Sztuka zdobywania władzy nad umysłami
Christopher Hadnagy, Helion, 2020

Wprowadzenie

Socjotechnika (**inżynieria społeczna**) w kontekście bezpieczeństwa zaczęła się od Kevina Mitnicka

Obecnie ma zastosowanie w dziedzinach:

- bezpieczeństwo
- administracja
- edukacja
- psychologia
- wojskowość
- i inne

BwSK

Wprowadzenie

Popularność socjotechniki wynika z 2 powodów

- **niskie koszty**
- **minimalne ryzyko**

Jest to najłatwiejszy sposób ataku

Wprowadzenie
Definicja

(Christoper Hadnagy) – **manipulacja ludźmi**

- Działanie wpływające na inną osobę w celu nakłonienia jej do podjęcia działania, które może być **niezgodne z osobistym interesem tej osoby**
- Socjotechnika **nie zawsze jest szkodliwa**

Socjotechnika czyli sztuka zdobywania władzy nad umysłami
Christopher Hadnagy, Helion, 2020

Wprowadzenie
Sposób manipulacji

Sposób manipulacji

- Celem każdego socjotechnika jest sprawienie, aby jego cel **podjął decyzję nie myśląc**, gdyż im dłużej myślisz, tym więcej masz szans na zauważenie manipulacji.
- **Emocje** !!! – gdy nasze emocje zostaną wzbudzone, zaczynamy myśleć mniej racjonalnie a im mniej racjonalnie myślimy, tym szybciej podejmujemy decyzje w oparciu o same emocje.

Wprowadzenie

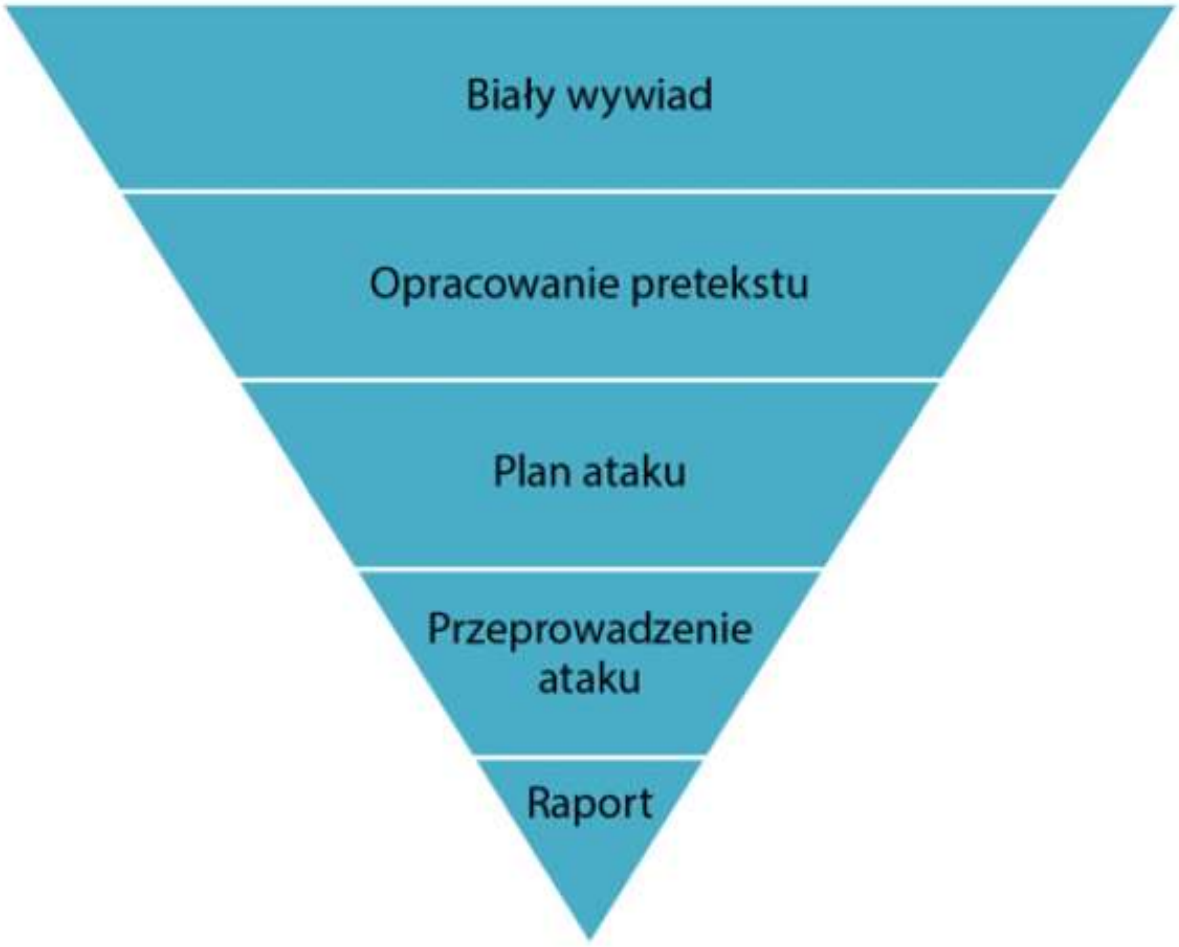
Szkodliwa socjotechnika wykorzystuje m.in. **podszywanie** (phishing)

Wyróżniono pewne podkategorie phishingu:

- SMS phishing
- Voice phishing
- Email phishing

Wprowadzenie

Piramida socjotechniki



Socjotechnika okiem psychologa

Socjotechnika okiem psychologa

Socjotechnika to manipulacja?

Wg. psychologa to spłycenie problemu

Trzeba przyjrzeć się jeszcze temu, **co dzieje się po stronie ofiary**

Socjotechnika okiem psychologa
Zaskakująca odpowiedź

THE H@CK SUMMIT

Pierwszy Nigeryjski Książę...

Pierwszy udokumentowany przypadek zastosowania mechanizmu, na którym opiera się przekręt 419 miał miejsce w latach:

1.) Na przełomie XVII i XIX wieku listownie.

2.) Lata 70te XX wieku, niedługo po powstaniu Arpanetu umożliwiającego.

3.) Pod koniec XX wieku, gdy powstaje Yahoo oraz Google.

4.) 2004, rozwój internetu, indeks Google przekroczył 6 miliardów elementów.

THE H@CK SUMMIT

BwSK

T.Łukaszewski

Socjotechnika okiem psychologa

Wniosek

Socjotechnika okiem psychologa

Skoncentrujmy się zatem na ofiarach

Socjotechnika okiem psychologa
Skoncentrujmy się zatem na ofiarach

Omawiane mechanizmy

A. Widzimy … mózgiem a nie oczami

A.1 mózg szuka podobieństwa/**kwestionowanie to dodatkowe operacje**

A.2 **emocje przeszkadzają byciu racjonalnym**

B. Szybkie podejmowanie decyzji – heurystyczne

BwSK

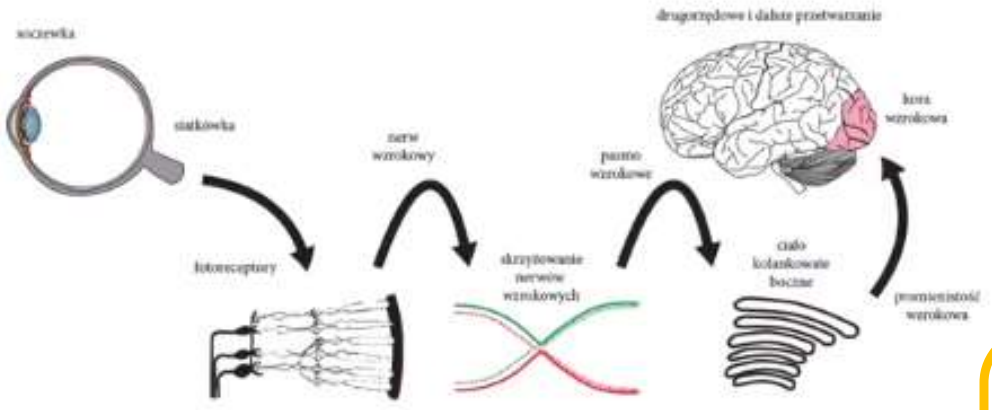
T.Łukaszewski

Socjotechnika okiem psychologa

A. Widzimy … mózgiem a nie oczami

THE H@CK SUMMIT

Dekodowanie informacji



Oko rejestruje światło odbite od przedmiotów.

Mózg dekoduje, tworzy obraz i rozpoznaje.

Mózg decyduje o tym co widzi.

Mózg szuka podobieństw.

Mózg posługuje się wartościami „prawdziwymi”.

Zaprzeczenie to dodatkowa operacja.

THE H@CK SUMMIT

Socjotechnika okiem psychologa

A.1: mózg szuka podobieństw

T.Łukaszewski

THE H@CK SUMMIT

Dekodowanie informacji

Text Message
Friday 9:52 AM

Hello mate, your FEDEX package with tracking code GB-6412-GH83 is waiting for you to set delivery preferences: c4dmc.info/sKenKPAAaLg

Mózg najpierw widzi podobieństwa, a dopiero potem próbuje je zakwestionować.

THE H@CK SUMMIT

Socjotechnika okiem psychologa
A.1: mózg szuka podobieństw

Preferujemy informacje, które wydają się nam podobne !!!

Kwestionowanie wymaga dodatkowych operacji !!!

Należy uświadamiać użytkowników o przekrętach: budując „w głowach” użytkowników wizualizację przekrętów, użytkownik będzie miał „w głowie” bazę danych nie tylko o prawdziwych ale też o fałszywych treściach i **będzie mógł odkryć „fałsz” bez kosztownych, dodatkowych operacji kwestionowania**

Socjotechnika okiem psychologa

A.2: najpierw emocje potem racjonalność

THE H@CK SUMMIT

Czy ludzie potrafią reagować racjonalnie?

Robert Zajonc, psycholog Polskiego pochodzenia (1923 – 2008).

1980 – seria eksperymentów udowadnia, że mózg najpierw analizuje emocje (*w prostych sytuacjach).

Istotny mechanizm ewolucyjny: dobry = podejdź, zły = uciekaj.

THE H@CK SUMMIT

Socjotechnika okiem psychologa

A.2: redukcja hormonów wymaga czasu

THE H@CK SUMMIT

Emocje, czyli hormony we krwi

Przeżywane emocje są związane z hormonami.

Kortyzol, Oksytocyna, Melatonina, hormony Tarczycy, Adrenalina, Endomorfiny.

Nasz nastrój, to inaczej mówiąc wysokie stężenie danego hormonu we krwi. Wpływa on na umiejętności poznawcze, podejmowanie decyzji, skłonności do ryzyka.

Tego się nie da tak po prostu wyłączyć!

THE H@CK SUMMIT

Socjotechnika okiem psychologa

A.2: a emocje wywołamy „jednym zdaniem”

T.Łukaszewski

THE H@CK SUMMIT

Emocje na OLX

Czemu to tak dobrze działa?

Email został usunięty

Witam, jestem zainteresowana zakupem, mam kilka pytań

Twoja odpowiedź

oczywiście. Słucham?

Email został usunięty

Jak długo były noszone?

Czy są jakieś ślady użytkowania ?

Przepraszam, nadal aktualne?

Twoja odpowiedź

Buty miałam dosłownie dwa razy na ściance, zrobiłam może z 6 drog na panelu. Nie mają prawie żadnych śladów użytkowania, nawet guma na kantach jest ostra, jak od nowości. Miałam pęknięty niedawno duży palec i niestety trudno mi dopasować teraz buty. A marka świetna, bo kiedyś miałam już jej buty

Email został usunięty

Rozumiem, no to mnie wszystko pasuje i cena jest bardzo dobra, szczęście że oferta jest nowa i ja pierwsza zauważyłam :)

Chciałabym zapytać czy możliwa jest wysyłka przez olx ?

Zapłacę koszty wysyłki

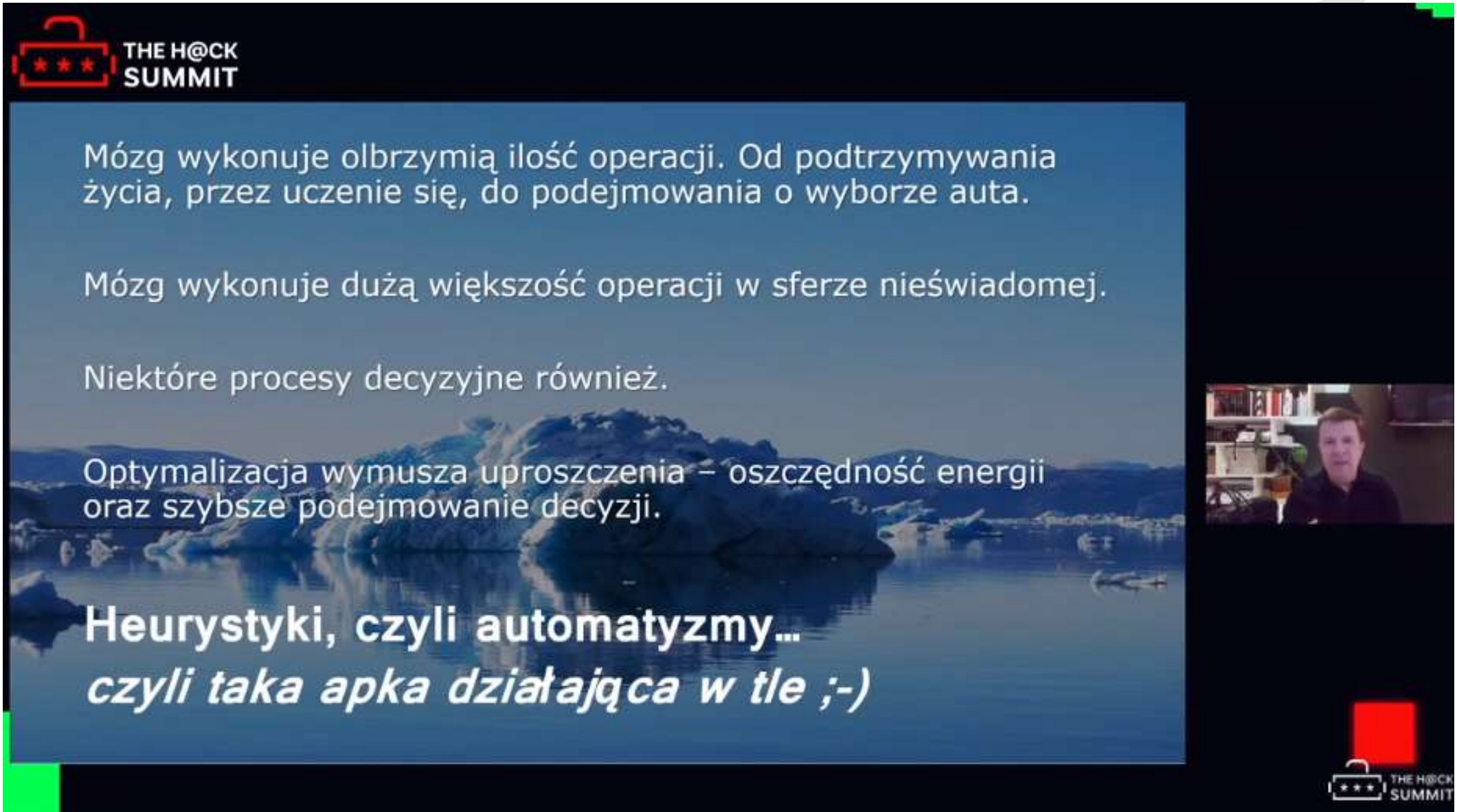
THE H@CK SUMMIT

BwSK

T.Łukaszewski

Socjotechnika okiem psychologa

B: Podejmowanie decyzji - heurystyczne



Socjotechnika okiem psychologa
B: Podejmowanie decyzji - heurystyczne

- **Tempo życia** każe nam odejmować decyzje **szybko/heurystycznie**
- Ponadto, określony **bodziec** może uruchomić taką **heurystykę** bez naszej wiedzy i podejmowane decyzje będą błędne.

Zasady wywierania wpływu na ludzi

- Robert Cialdini
- Christoper Hadnagy

Socjotechnika okiem psychologa
B: Podejmowanie decyzji - heurystyczne

Zasady wywierania wpływu na ludzi

- Wzajemność
- Ustępowanie
- Zaangażowanie
- Zobowiązanie
- Niedobór
- Autorytet

BwSK

Socjotechnika okiem psychologa
Wzajemność

- Ludzie zwykle czują się zobowiązani **odwdzięczyć się** za prezenty, przysługi, darmowe próbki i tym podobne dobra
- **Nakłonienie ludzi do oddania więcej niż otrzymali !!!**

Socjotechnika okiem psychologa
Ustępowanie

Uzyskanie zgody na mniejszą prośbę po uprzednim sprzeciwie wobec początkowej większej prośby

A. Prosimy o wsparcie schronisk dla zwierząt – 250$

B. Chętnie pomogę, ale to za dużo

A. Rozumiemy, to może 25$?

Socjotechnika okiem psychologa
Zaangażowanie i konsekwencja

T.Łukaszewski

Kiedy dokonamy wyboru uruchamia się **mechanizm bycia konsekwentnym** zgodnie z tym w co już się **zaangażowaliśmy**

A. Czy mogę prosić o niewielką przysługę
B. OK

A. Czy mógłbym jeszcze prosić o …

Socjotechnika okiem psychologa
Zobowiązanie

Wynika z norm społecznych i związanych z nimi oczekiwań.

Zobowiązaniem jest przytrzymanie drzwi komuś kto niesie duży ciężar

(wpuszczenie go bez weryfikacji !!!)

Socjotechnika okiem psychologa
Niedobór

Niedobór określonych dóbr sprawia, że ich wartość wzrasta.

A. Prosimy o wpuszczenie do gabinetu szefa by zoptymalizować jego komputer
B. Nie ma na ten temat żadnej notatki

A. Ale szef do nas dzwonił, powiedział, że teraz wyjeżdża i prosi o naprawę podczas nieobecności. W następnym miesiącu jak wróci mamy wszystkie terminy niedostępne. Proszę tylko o podpis, że dzisiaj nie mogłem naprawić sprzętu.

Socjotechnika okiem psychologa
Autorytet

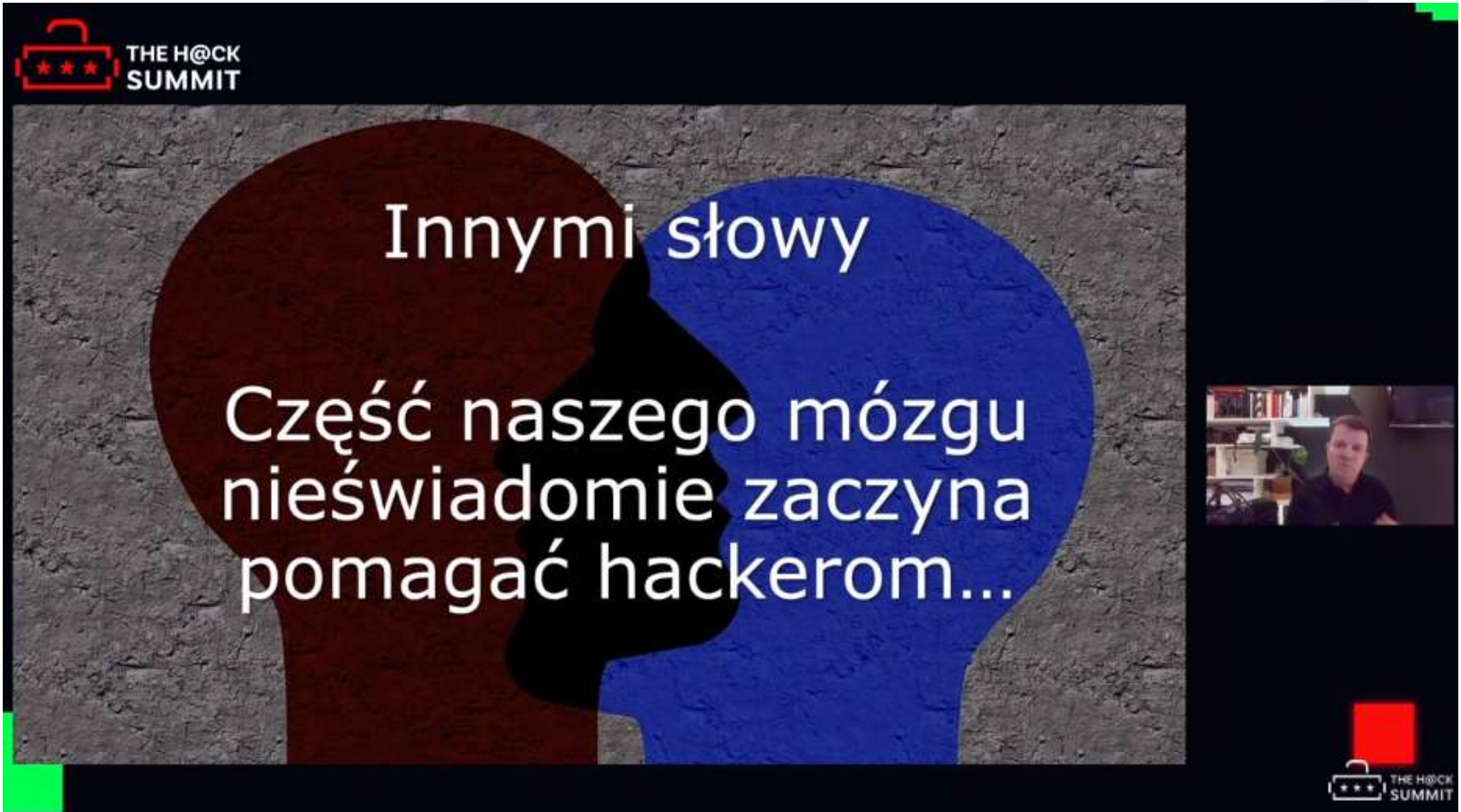
Kiedy osoba mająca istotny autorytet coś mówi lub robi, ludzie zwykle traktują to bardzo poważnie

Jak zostać wpuszczonym przez ochronę – powołać się na spreparowanego SMSa z ponagleniem przyjścia od Dyrektora.

BwSK

T.Łukaszewski

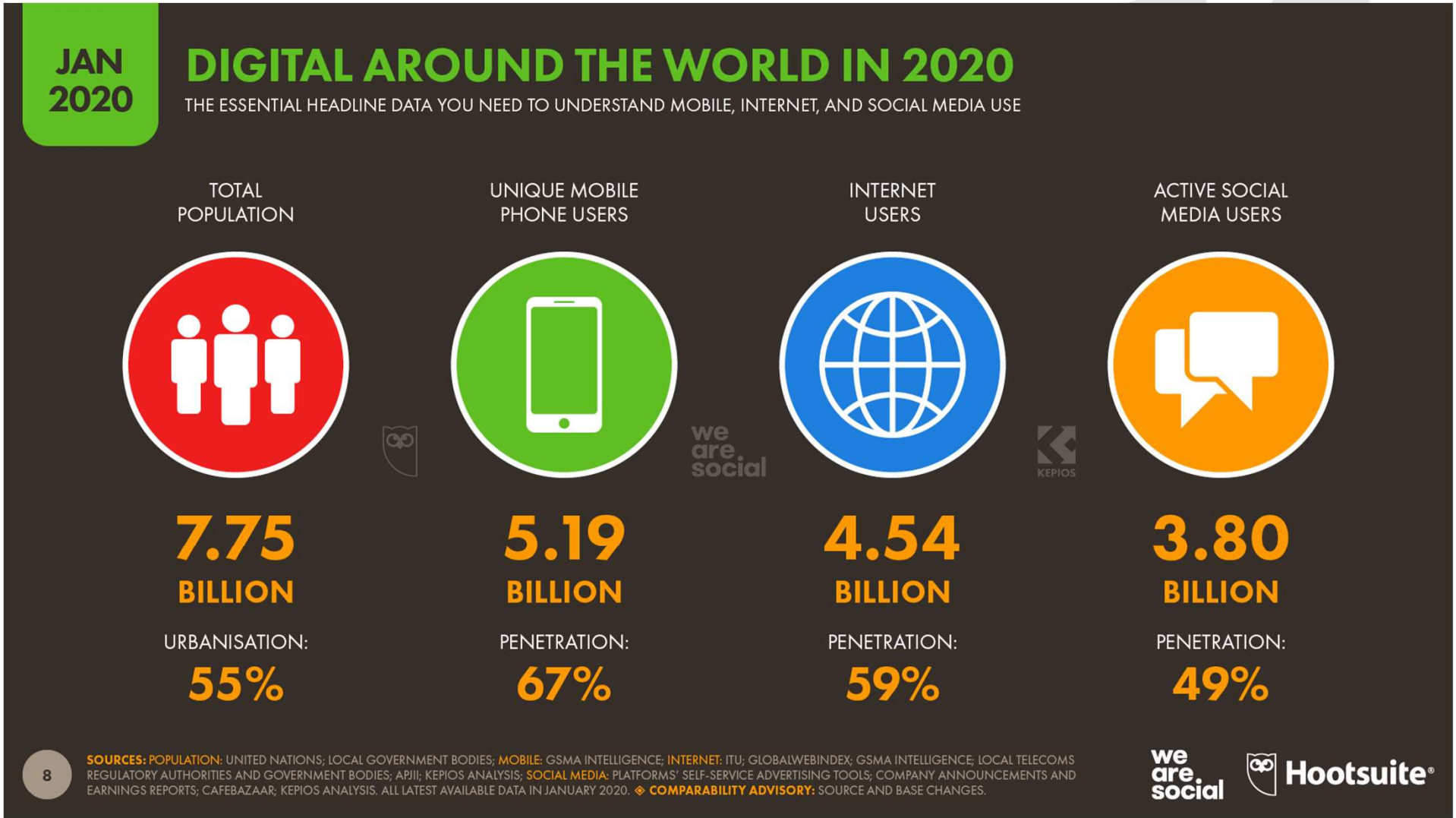
Socjotechnika okiem psychologa
Podsumowanie !!!



Biały wywiad

Biały wywiad

Biały wywiad (Open Source Intelligence - OSINT)



Biały wywiad

Przypadek dyrektora FBI Jamesa Comeya (2017)

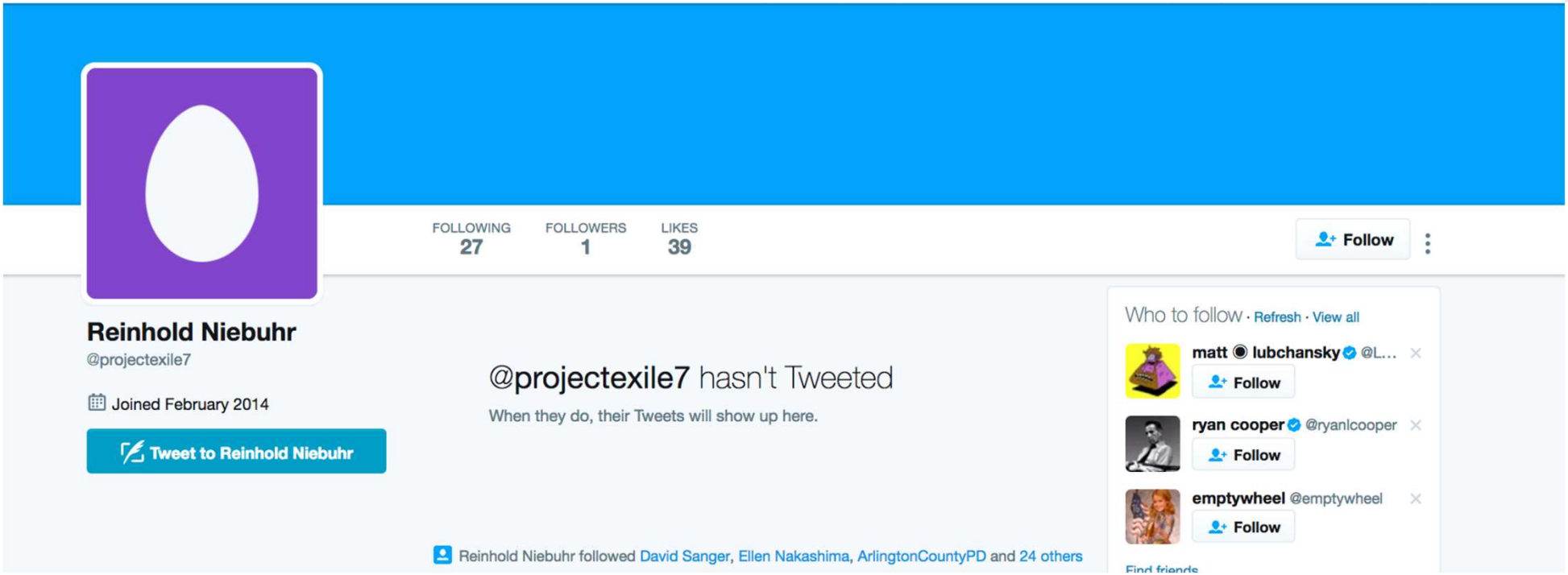
Poszukiwanie kont na portalach społecznościowych

Biały wywiad

Przypadek dyrektora FBI Jamesa Comeya (2017)

Poszukiwanie kont na portalach społecznościowych

Historia opisana na stronie: https://gizmodo.com/this-is-almost-certainly-james-comey-s-twitter-account-1793843641



BwSK

T.Łukaszewski

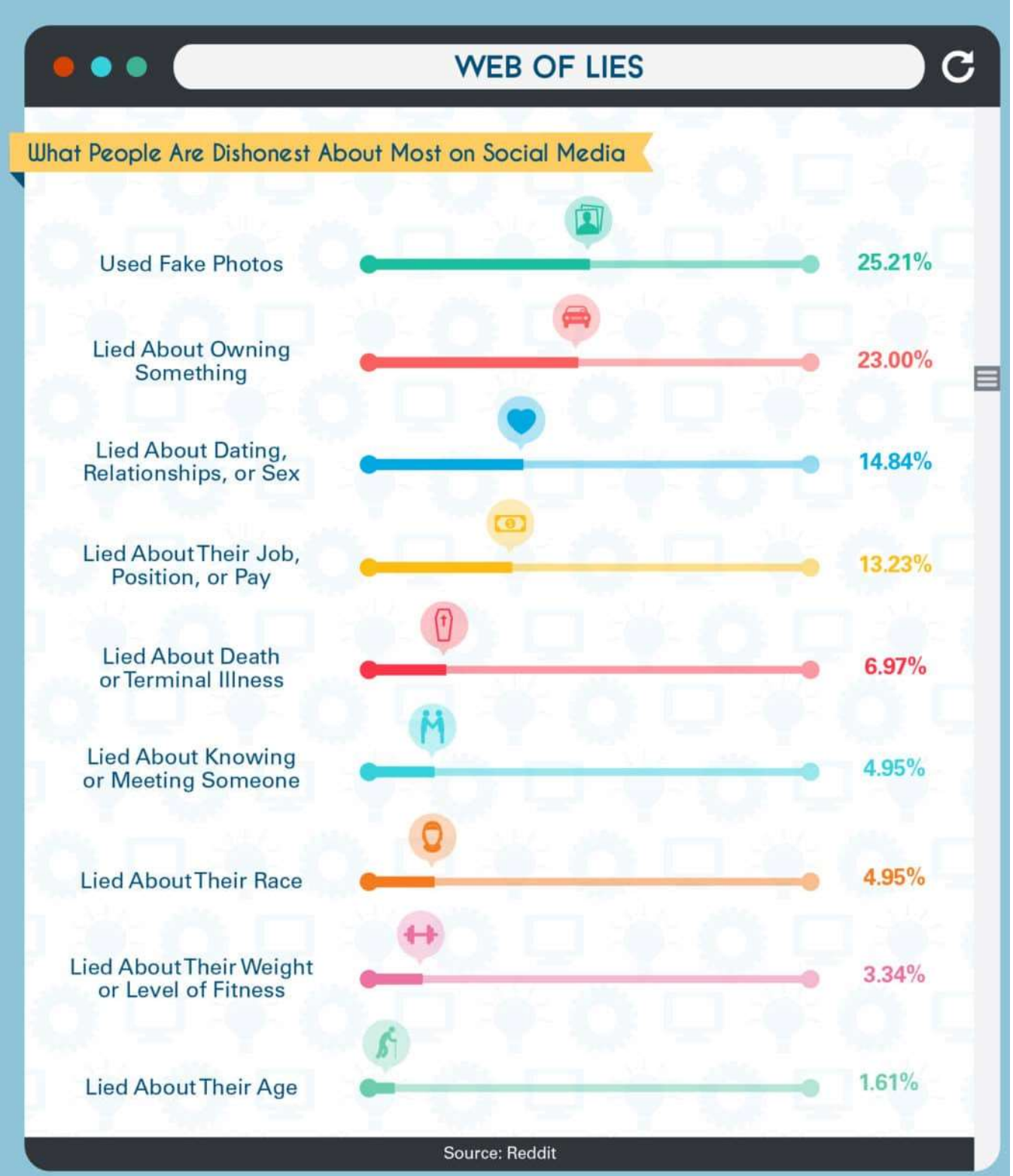
Ludzie

w sieci

tworzą

fałszywy

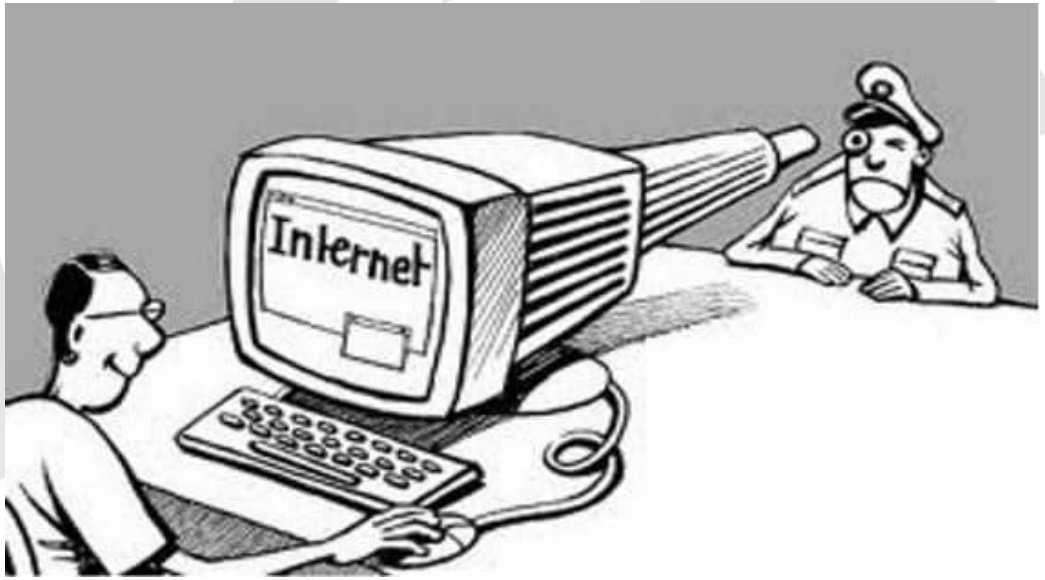
wizerunek



21.01.2025

Biały wywiad

d0xing – zakładanie teczki zawierającej informacje o życiu osobistym wybranego celu: google, kamerki, współdzielone katalogi, metadane



https://www.vpnshazam.com/2018/02/08/hamful-effects-doxing-protect/

Biały wywiad

Biały wywiad jest nie tylko **techniczny**

Biały wywiad to także **obserwacja i improwizacja**

Biały wywiad

Biały wywiad to także **obserwacja i improwizacja**

Atak phishingowy przeciwko prawniczce zajmującej wysokie stanowisko w dużej korporacji. Cel zajmował się przepisami obowiązującymi w stanie Massachussets. Niedawno wprowadzono zmiany systemu podatkowego – wysłanie e-maila (ze szkodliwym załącznikiem) dotyczący problemu.

Atak nieudany – Massachussetts jest wspólnotą!

Pretekst

Biały wywiad
Opracowanie pretekstu
Plan ataku
Przeprowadzenie ataku
Raport

Pretekst

Pretekst

Pretekst to prezentowanie się jako ktoś inny w celu uzyskania informacji o charakterze prywatnym. To coś więcej niż kłamstwo i często polega na stworzeniu całkowicie nowej tożsamości i wykorzystaniu jej w celu zdobycia określonej informacji.

Pretekst

Pretekst

Tworzenie nowej tożsamości może zostać wykryte jeżeli rozmowa zahaczy o szczegóły, których nie zna „agresor”

Komunikacja

Komunikacja

Motto:

- Aby skutecznie się komunikować, musimy zrozumieć, że każdy z nas **inaczej** postrzega świat, i użyć tej wiedzy jako podstawy do komunikacji z innymi.

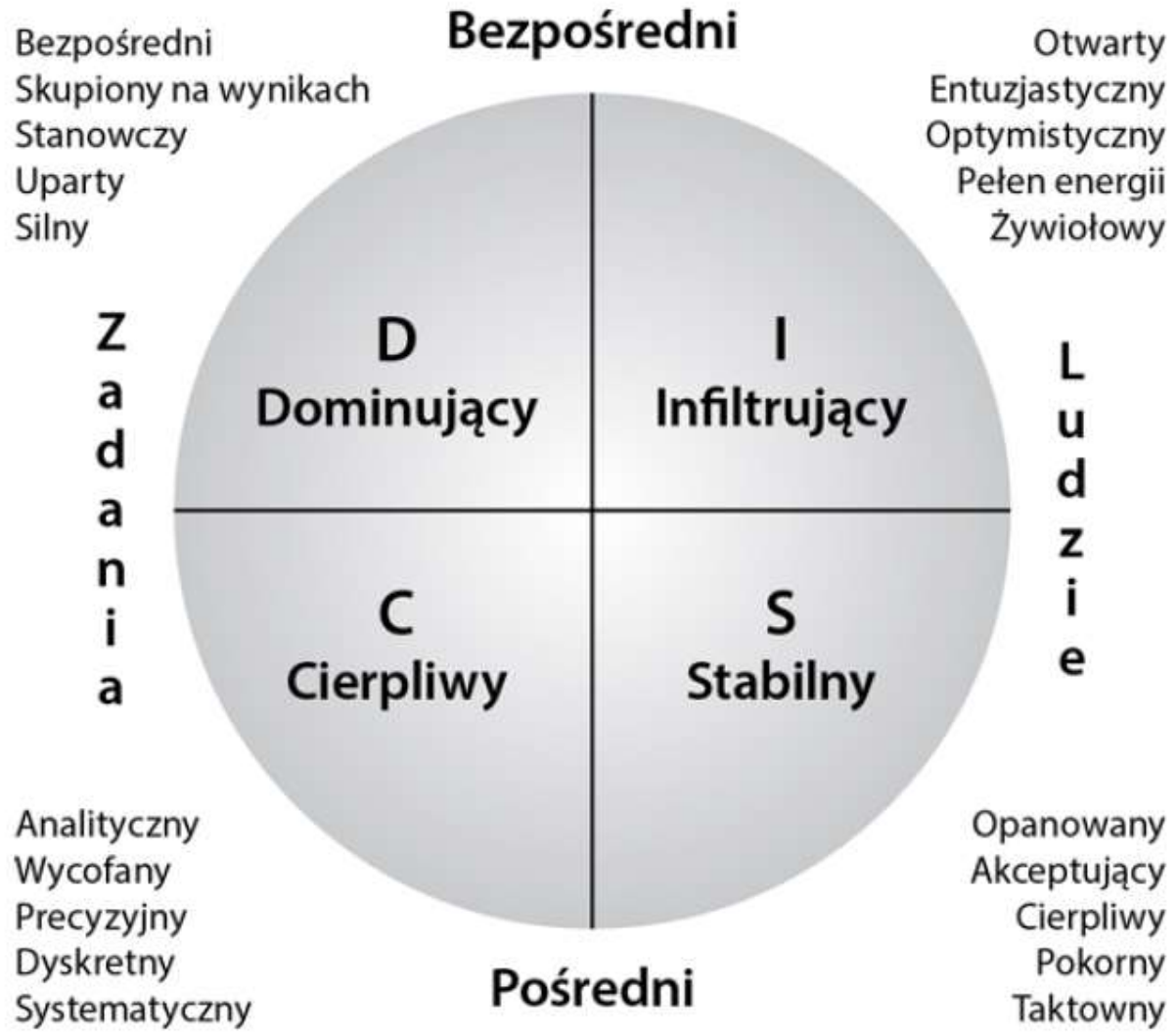
(Tony Robbins)

Komunikacja

Zastanów się, czego Człowiek, z którym się komunikujesz, może od Ciebie chcieć, aby poczuć się **komfortowo i bezpiecznie**!

Komunikacja

DISC – style komunikacji a osobowość



Komunikacja

DISC – style komunikacji

- Punktem wyjścia jest ustalenie, czy druga osoba preferuje styl **bezpośredni** czy też **pośredni**

Komunikacja

Komunikator typu *D*

Jeżeli zamierzasz komunikować się z pozycji siły:

- Mów bezpośrednio i stanowczo.
- Ustal jasne granice.
- Mów krótko i do rzeczy.
- Odpowiedz na pytanie: *Co?*.

Jeżeli planujesz wykorzystać mniej autorytarny pretekst:

- Skup się na pytaniu: *Co?*, nie: *Jak?*.
- Przedstaw kilka opcji, ale podkreśl, że najważniejszy jest wynik.
- Skup się na logicznej argumentacji.
- Zgadzaj się z faktami, nie z osobą.

Komunikacja

Komunikator typu *I*

Jeżeli zamierzasz komunikować się z pozycji siły:

- Zachowuj się spokojnie i przyjaźnie.
- Pozwól rozmówcy mówić jak najwięcej.
- Spróbuj przekształcić pomysły rozmówcy w działania.
- Odpowiedz na pytanie: *Kto?*.

Jeżeli planujesz wykorzystać mniej autorytarny pretekst:

- Podkreślaj rzeczy nowe i wyjątkowe.
- Wyciągaj informacje, ale dziel się też swoimi.
- Nie dominuj w rozmowie.
- Powołuj się na „ekspertów" i opinie z życia wzięte.

Komunikacja

Komunikator typu S

Jeżeli zamierzasz komunikować się z pozycji siły:

- Mów w sposób systematyczny i obiektywny.
- Zachowuj się spokojnie i przyjaźnie.
- Mów spójnie i odpowiedz na pytanie: *Dlaczego?*.
- Jasno wyraź, czego oczekujesz.

Jeżeli planujesz wykorzystać mniej autorytarny pretekst:

- Zachowaj cierpliwość.
- Zadawaj pytania: *Jak?*.
- Skupiaj się na zespole.

Komunikacja

Komunikator typu C

Jeżeli zamierzasz komunikować się z pozycji siły:

- Mów szczegółowo.
- Rób wrażenie osoby, na której można polegać.
- Daj do zrozumienia, że akceptujesz rozmówcę.
- Odpowiedz na pytanie: *Jak?*.

Jeżeli planujesz wykorzystać mniej autorytarny pretekst:

- Powołuj się na dane i statystyki.
- Przedstawiaj fakty i logiczne argumenty.
- Podkreślaj wiarygodność.

Komunikacja

DISC – podsumowanie

- Znajdź **pretekst**
- Skup się na tym, co Twoi rozmówcy **chcą usłyszeć**, nie na tym co chcesz powiedzieć – spraw, aby inni ludzie po spotkaniu z Tobą czuli się lepiej

- Ale na komunikację mogą wpłynąć **negatywnie** takie czynniki jak: choroba, stres, przepracowanie

Podsumowanie

Podsumowanie

Jak to zrobić skutecznie

- Osoba, na którą skutecznie wpłynęliśmy, powinna odczuwać, że sama chce zrobić to, co leży w naszym interesie, co dodatkowo wzmacnia jej zaangażowanie

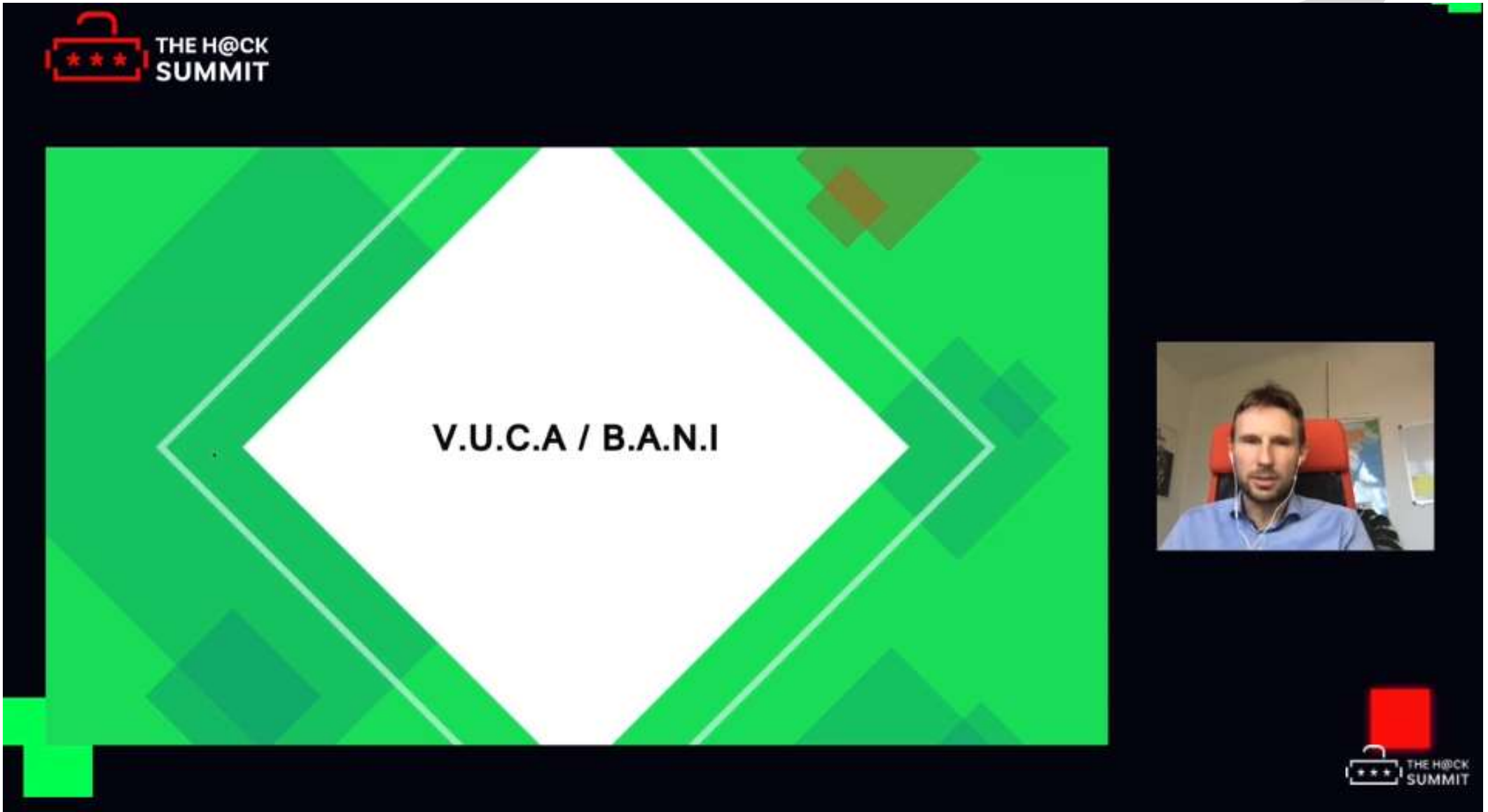
Nowe koncepcje

- Antykruchość

BwSK

Antykruchość

Antykruchość
Obecna rzeczywistość



Antykruchość
Opis rzeczywistości/świata

THE H@CK SUMMIT

VUCA (1987 r.)
- zmienny (volatile)
- niepewny (uncertain)
- złożony (complex)
- niejednoznaczny (ambiguous)

B.A.N.I. (2020 r.)
- kruchy (brittle)
- niespokojny (anxious)
- nieliniowy (nonlinear)
- niezrozumiały (incomprehensive)

THE H@CK SUMMIT

Planowanie strategiczne ???

10 lat – nie

5 lat – nie

1 rok ???

BwSK

BWSK

T.Łukaszewski

Antykruchość
Czynniki powodujące zmiany

THE H@CK SUMMIT

Nowe wyzwania związane z dynamicznymi zmianami otoczenia zewnętrznego:	globalizacja;	zmiany kulturowe i socjologiczne;	dynamika zmian;
niestabilna sytuacja gospodarcza;	wzrost znaczenia technologii;	ciągłe zmiany technologiczne;	IT jako jedna z najważniejszych funkcji usługowych w organizacji;
ewolucja IT (Information Technology) na BT (Business Technology);	wzrost znaczenia dla szeroko rozumianego bezpieczeństwa w biznesie;	wzrost zagrożeń związanych z bezpieczeństwem;	nowe wymogi prawne związane z bezpieczeństwem.

THE H@CK SUMMIT

THE H@CK SUMMIT

BwSK
T.Łukaszewski

WORLD ECONOMIC FORUM

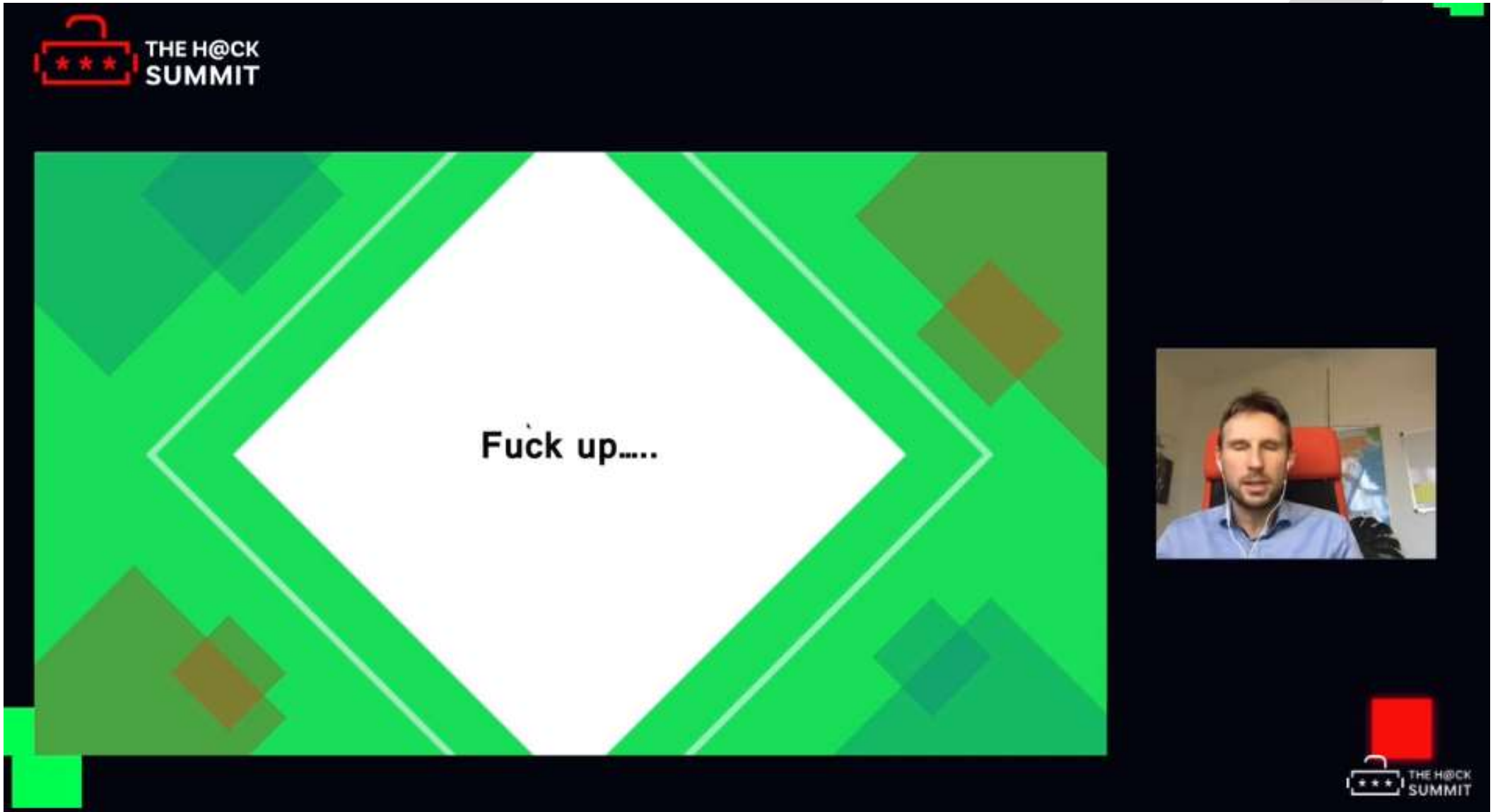
Top 10 skills of 2025

Source: Future of Jobs Report 2020, World Economic Forum.

BwSK

T.Łukaszewski

Antykruchość
wpadki z przeszłości



Antykruchość
elektrownia jądrowa Ohio – atak na OT

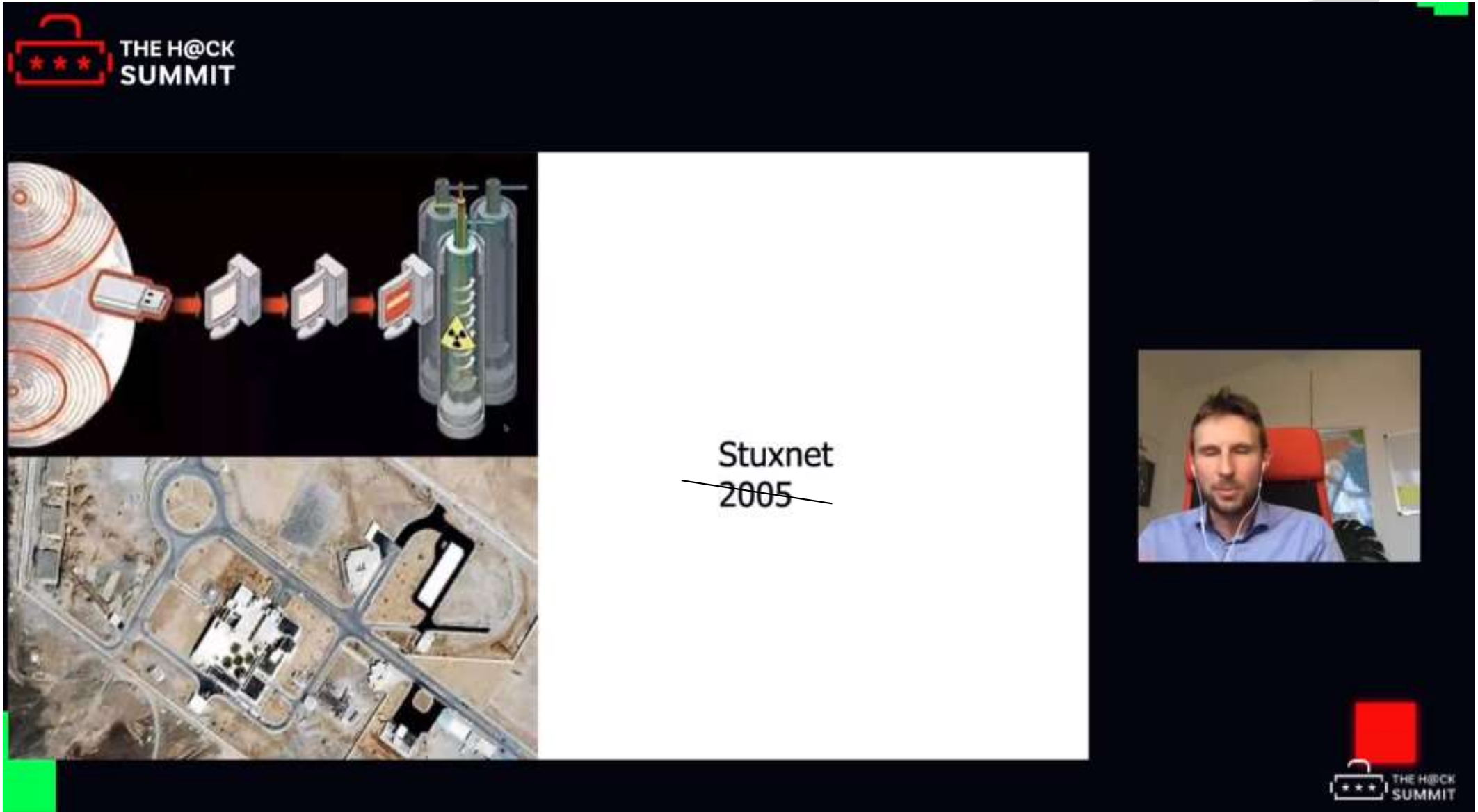
THE H@CK SUMMIT

```
C:\>netstat -a -p udp 100

Active Connections

  Proto  Local Address          Foreign Address
  UDP    FSIBM310:epmap         *:*
  UDP    FSIBM310:microsoft-ds  *:*
  UDP    FSIBM310:1032          *:*
  UDP    FSIBM310:ms-sql-m      *:*
  UDP    FSIBM310:1591          *:*
  UDP    FSIBM310:44354         *:*
  UDP    FSIBM310:netbios-ns    *:*
  UDP    FSIBM310:netbios-dgn   *:*
  UDP    FSIBM310:isakmp        *:*
  UDP    FSIBM310:4914          *:*
```

Slammer
2003

Antykruchość

oczyszczanie uranu w Iranie – atak na OT



BwSK

T.Łukaszewski

Antykruchość

port przeładunkowy – łańcuchy dostaw

THE H@CK SUMMIT

Port of Tianjin
2015

THE H@CK SUMMIT

BwSK

T.Łukaszewski

Antykruchość

incydent na Ukrainie – uderza w świat

BwSK

T.Łukaszewski

Antykruchość
podatność rozwiązań scentralizowanych

THE H@CK SUMMIT

CD PROJEKT

solarwinds

Colonial Pipeline Company

Ostatnie incydenty

Exchange

Marriott

Kaseya

THE H@CK SUMMIT

Antykruchość
dobre praktyki

THE H@CK SUMMIT

Lotnictwo i inne rozwiązania safety / security

Antykruchość
1. działanie – całościowo i elastycznie

THE H@CK SUMMIT

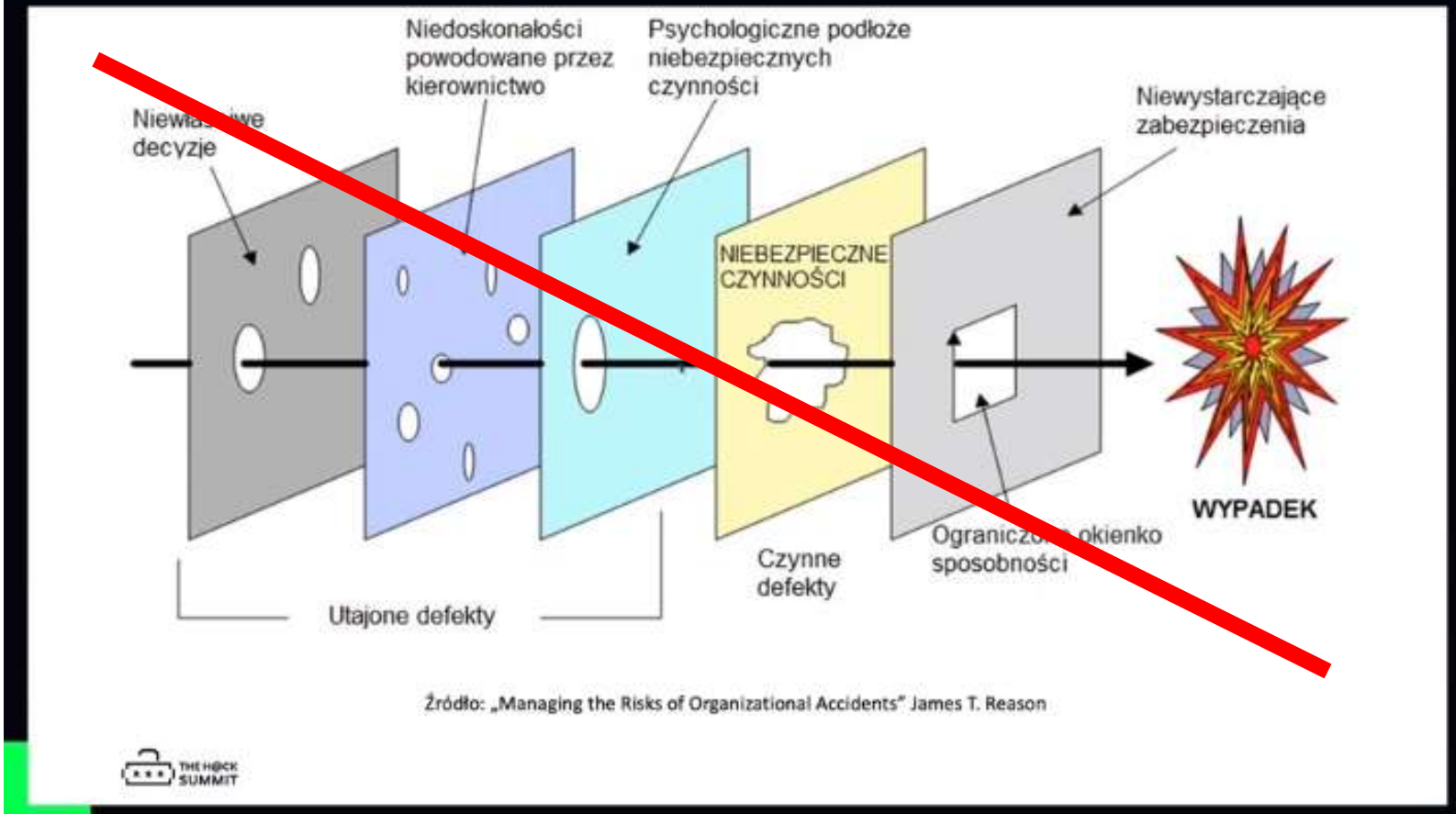
BwSK

T.Łukaszewski

Antykruchość

2. zabezpieczanie – systemowo (nie liniowo)

THE H@CK SUMMIT



THE H@CK SUMMIT

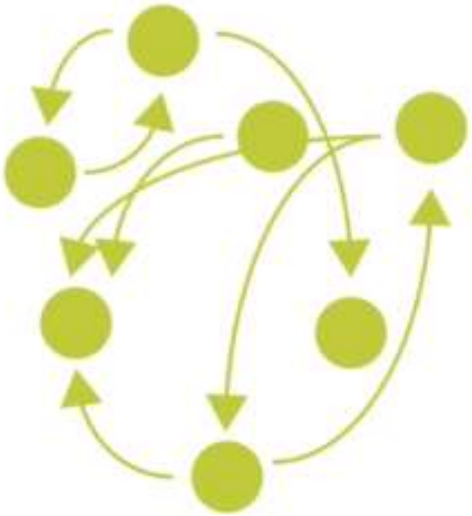
Antykruchość

2. zabezpieczanie – systemowo (nie liniowo)

THE H@CK SUMMIT

Traditional thinking

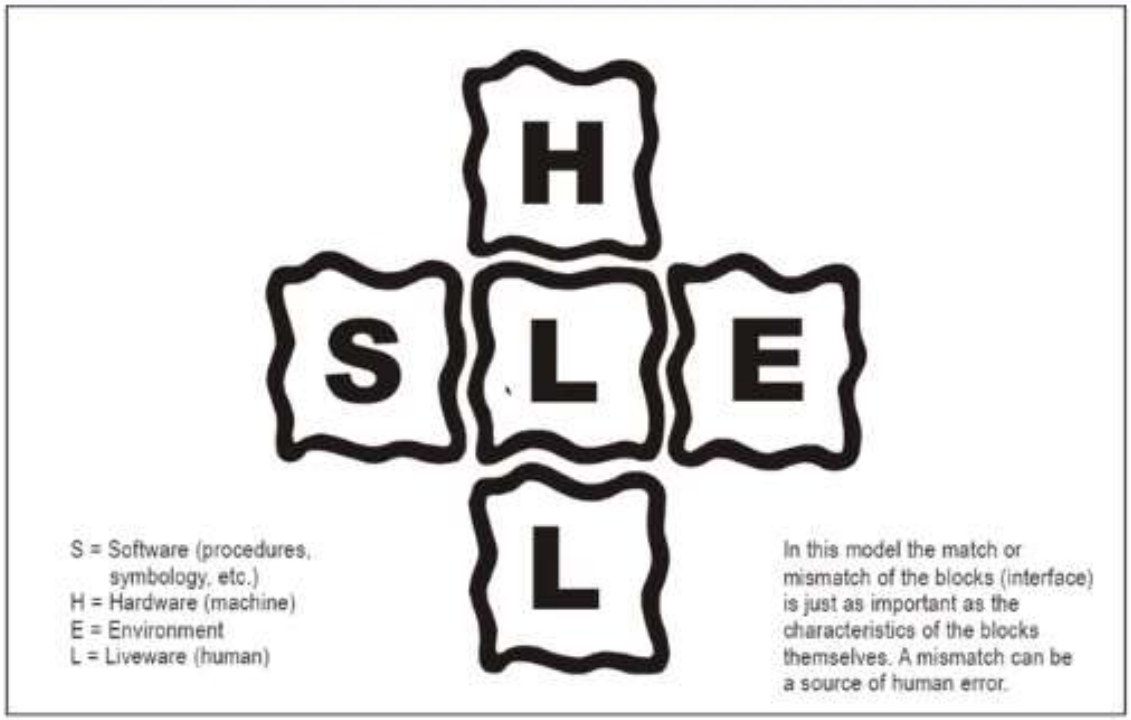
Systems thinking



THE H@CK SUMMIT

Antykruchość
3. uwzględnienie czynnika ludzkiego !!!

THE H@CK SUMMIT

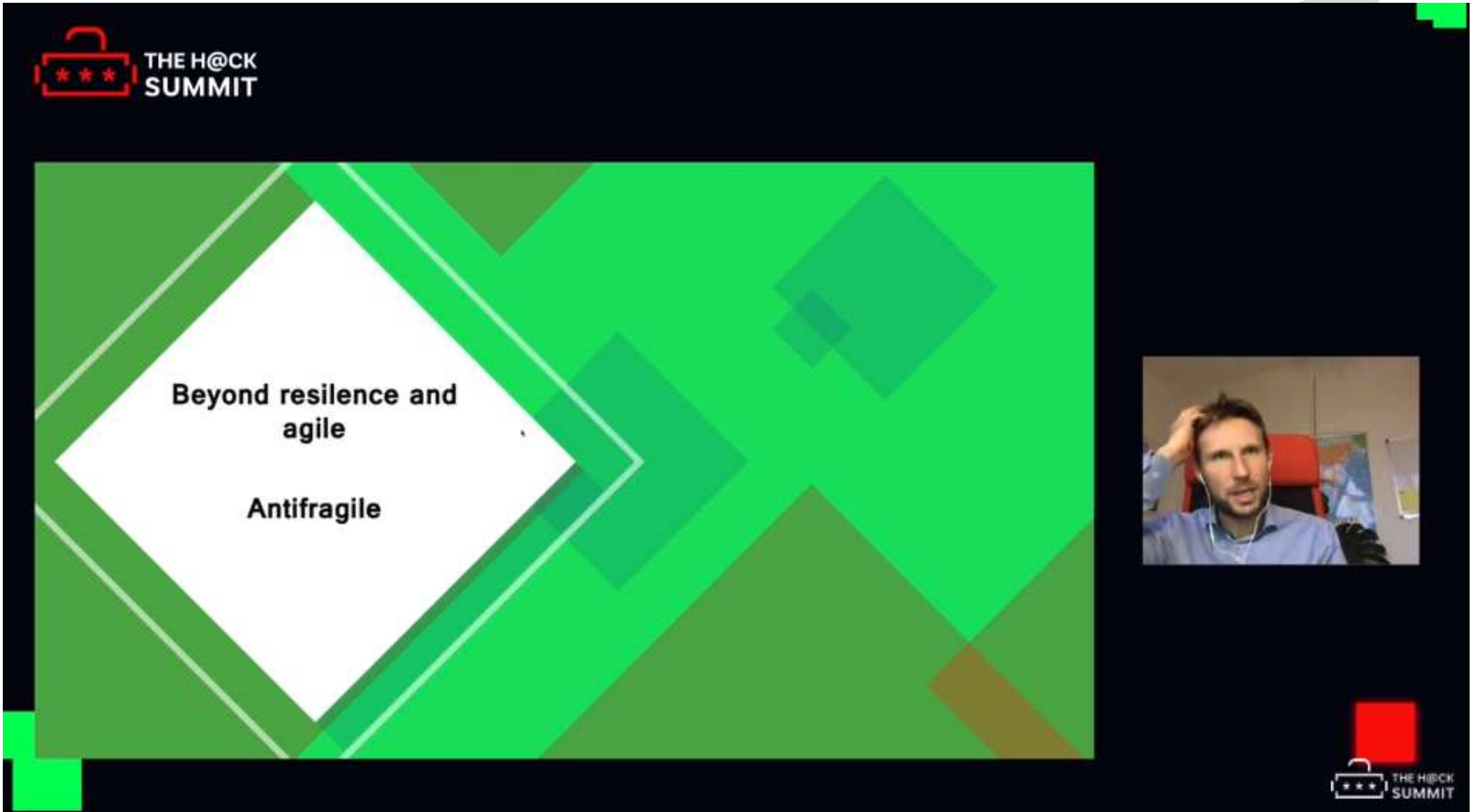


Źródło: ICAO – Doc 9859

THE H@CK SUMMIT

Antykruchość

Antykruchość



BwSK

T.Łukaszewski

Antykruchość
od nieprzewidzialnego (czarne łabędzie)

THE H@CK SUMMIT

THE H@CK SUMMIT

THE H@CK SUMMIT

BWSK

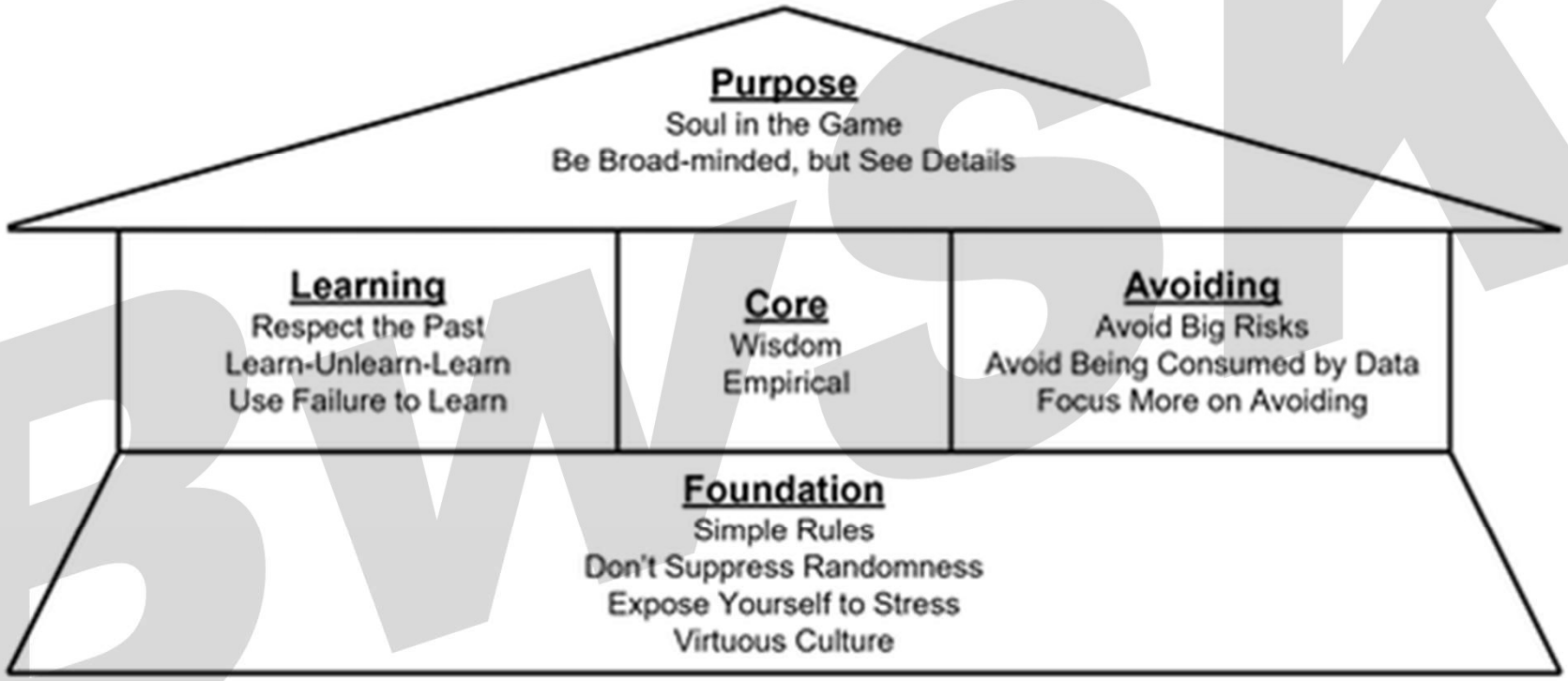
T.Łukaszewski

Antykruchość
do akceptacji małych błędów

	Kruche (Fragile)	Odporne (Robust)	Antykruche (Antifragile)
Mitologia grecka	Miecz Demoklesa, głaz Tantala	Feniks	Hydra
Biznes / Finanse	Przemysł / Zadłużenie	Small business Kapitał	Rzemiosło Kapitał wysokiego ryzyka
Regulacje	Przepisy	Zasady	Cnoty
Reputacja	Papież, polityk, menadżer w korporacji, akademicki naukowiec	Pracownik poczty, kierowca ciężarówki, konduktor	Artysta, pisarz
Literatura	Książka	E-book / E-czytnik	Przekaz ustny
Myśliciele	Platon. Arystoteles, Awerroes	Pierwsi stoicy, Witgenstein, Popper	Stoicy rzymscy, Nietzsche, Hegel, Jaspers
Epoka	Nowoczesność	Europa średniowieczna	Antyk
Relacje międzyludzkie	Przyjaźń	Powinowactwo	Atrakcyjność, urok
Sposób myślenia	Teoria	Fenomenologia	Heurystyki i triki praktyczne
Stosunek do błędów	Nienawidzi i unika	Błędy to tylko informacja	Kocha błędy (dopóki są niewielkie)
Ludzkie ciało / choroba / zdrowie	Łagodzenie, atrofia, starzenie się sarkopenia	„Mitrydateza", powrót do zdrowia	„Hormeza", hipertforia

Na podstawie: „Antykruchość. O rzeczach, którym służą wstrząsy"; N. N. Taleb.

Antykruchość
elementy zarządzania



The Antifragility Institute (Si Alhir, Sebastian Burgemejster, Piotr Welenc) © 2021.
Version 1.0 September 2021